

Concept2Cure.RI TrialSage

An independent buyer's-eye assessment of 1,489,132 lines across 7,858 files — technical audit, competitive rack-and-stack, and readiness for human use.

G1 PILOT

NOT READY

2–4 wk

G2 COMMERCIAL

NOT READY

2–4 mo

G3 GxP

NOT READY

6–12 mo

Branch **concept2cure-v2** @ **576ec5d**

2026-07-28 · 12 offering categories · 66 cited competitor profiles

Findings proven by execution, not by reading

Executive summary

Concept2Cure.RI / TrialSage · purchase-grade forensic audit · 2026-07-28 · `concept2cure-v2` @ 576ec5d

The verdict in one paragraph

This is a substantial, genuinely-engineered platform whose hardest problems are largely solved and whose connective tissue is missing. The tamper-evident audit chain is real cryptography. The default-deny authorization boundary holds under live probing. The proof-tier test suites apply real migrations to a real database and pass, 171 tests with zero skips. Against that: the supported install path silently omits fifteen Postgres schemas — five of which have no provisioning path at all — the health probe reports green over a database with no authentication tables, the flagship typecheck gate passes because the compiler runs out of memory, every row-level-security policy is compiled and inert, and the system has never been validated. **None of the gap to a credible external pilot is architectural** — it is roughly seven specific, locatable defects, two to four weeks of work. That number, more than any other in this report, is what should drive a decision about this asset.

Readiness

GATE	VERDICT	DISTANCE
G1 · External pilot (design partners, non-regulated data)	● Not ready	2–4 weeks
G2 · Paying commercial customers	● Not ready	2–4 months
G3 · GxP / submission-grade	● Not ready	6–12 months, mostly non-engineering

Detail: [Chapter 14](#).

The ten findings that matter

Each was proven by executing the system, not by reading it. Full detail in `evidence/00-live-proof-log.md`.

#	FINDING	SEV
1	The typecheck gate is vacuous. It counts <code>error TS</code> strings and never checks tsc's exit code. <code>tsc</code> runs out of memory at the 6,144 MB cap <i>the gate itself sets</i> ; a crash log contains no matches, so it reports zero and passes. Given 24 GB it completes with 2 real errors , from a PR merged the day before this audit. Observed passing in CI on this audit's own PR.	P0
2	A from-scratch install reports success while being materially incomplete. It prints <code>✔ Application schema install complete</code> , delivers 702 tables / 572 policies, and creates none of the 15 Postgres schemas server code queries. A documented follow-on psql loop — which the installer names but does not run — supplies 9; one self-provisions. Five have no provisioning path anywhere. Either way, four mounted route families are permanently broken. <i>(Corrected — see Ch 03.)</i>	P0
3	/readyz returns 200 ready:true over a database missing <code>auth_users</code> , <code>auth_refresh_tokens</code> , <code>roles</code> , <code>permissions</code> , <code>user_roles</code> , <code>licenses</code> . Three branches of <code>startup/services.ts</code> never set schema readiness. The container <code>HEALTHCHECK</code> points here.	P0
4	Every RLS policy is compiled and inert — gated on a session variable nothing sets — and cannot be switched on until 81 route files move off the shared pool. Tenant isolation is single-layer.	P0
5	A live cross-tenant write path reproducing all four ingredients of the P0 fixed in #1186, in the Schedule-of-Events subsystem.	P1
6	Stored XSS on a reachable surface — <code>BatchDraft.tsx:490</code> renders unsanitized HTML built from a persisted document title/preview, and <code>derive Preview HTML-entity-decodes</code> markup the editor had escaped, re-animating it. <i>(Corrected — my first reading blamed streamed model output, which is dead code. See Ch 03.)</i>	P1
7	The attach button silently discards every file. Files are kept as names only; the message posts the literal text <code>Attached N file(s)</code> . A user asks about an uploaded document and gets a fluent answer grounded in nothing.	P0
8	SECURITY.md makes two unsupported claims — "21 CFR Part 11 compliant" and "SOC 2 Type II controls". No SOC 2 report, auditor or control matrix exists anywhere in the repository. One-hour fix; highest return in the audit.	P1
9	The system is not validated. A full IQ/OQ/PQ/VSR protocol set exists and every execution record is blank. The VSR reads <code>DRAFT – REQUIRES VALIDATION REVIEW BEFORE PRODUCTION USE</code> .	P2
10	No disaster recovery. No plan, no RPO/RTO, no rehearsed restore, no incident history — aggravated because booting the app mutates the schema and a from-scratch rebuild is known-incomplete.	P1

What is genuinely good

Reported with the same specificity as the defects, because a buyer needs an accurate picture rather than a hit piece.

- **The audit chain is real cryptography** — SHA-256 chaining with `SELECT ... FOR UPDATE` anti-fork locking *inside the caller's transaction*, a secret-keyed HMAC seal, and a boot matrix that refuses to start rather than run unsealed. Rebuilding this takes quarters.
- **Proof-tier tests apply real migration files** to a real in-process Postgres — 171 tests, 0 skipped, all passing. They exist because the team caught `vi.mock` hiding schema conflicts.
- **The authorization boundary holds, and is stronger than I first reported** — nine data endpoints probed unauthenticated all returned 401. There are **two** global `/api` gates, one of which enforces unconditionally in every environment, and route-level guard coverage is **~50%, not the 14% my first sweep measured**. *(Corrected — see Ch 03.)*
- **The AI gateway fails closed in production** rather than serving demo content, with the reasoning written inline.
- **The platform refuses rather than fabricates** — anti-fabrication reject-lists in code, `501` s where stubs once returned `{released:true}` unconditionally, honest cold-start confidence. This is the most valuable property in the product.
- **TM-CORTEX-001 is a populated** clause → code → test Part 11 traceability matrix.
- **The npm-audit allowlist went 27 → 1** with `npm ls` proof required per entry.

Competitive position

Twelve offering categories, five closest competitors each — **66 cited profiles across 56 vendors**, researched live. Detail: [Chapter 13](#).

Us 1.8 / 5 against a best-in-category average of 4.6 / 5. Ten of twelve categories score "not competitive."

That severity comes from the lens, chosen deliberately: everything is scored on **what ships and is reachable**. Three properties get punished hard — only 5 of 96 registered surfaces are navigable; every IQ/OQ/PQ record is blank, which several category analyses independently called *disqualifying rather than a deduction*; and the comparators are Veeva, LORENZ, Certara, Oracle, MasterControl and Cytel. **These scores measure procurement-readiness, not engineering quality.**

The one number that matters: the **agentic AI layer scores 3.2 and is the sole credible challenger**, -0.7 from the leader. Every other category is 2.1 or below. That conclusion was reached independently of [Chapter 16](#), which had already argued from code evidence that the AI/grounding layer is the real moat. **Two methods converging is the strongest signal in this audit** — and it says the platform is positioned as a twelve-category suite while being competitive in one.

Where breadth was the thesis, breadth lost: RIM -3.2, pharmacovigilance -3.9, QMS -3.2. Those gaps are built on install base and validation packages, which engineering does not close soon.

A note on this audit's own reliability

All ten headline findings were handed to independent verifiers instructed to **refute** them. **Four survived intact; six needed correction, three of them materially.** Chapter 03 lists every one, including the two where I was simply wrong: authorization coverage (off by ~3×) and the XSS taint path (I blamed dead code and missed a server-side entity-decode that re-animates escaped markup).

The findings that decide the verdict all survived — the vacuous typecheck gate, inert RLS, the live cross-tenant write path, and the file-discarding attach button. The verdict below is unchanged; the precision behind it is materially better.

The finding underneath all the others

The instrumentation that would tell you this product is healthy is, in several load-bearing cases, not connected to anything. A typecheck gate that passes on a crash. A readiness probe that reports green over a broken schema. An installer that prints success while omitting fifteen schemas. An env-var gate with a 244-entry baseline and no runner. A repo-health baseline that auto-commits itself upward on every merge. ~1,620 baselined defects. Part 11 audit-chain verification that exists as an unscheduled npm script.

The repository's own *Evidence Pack*, auto-generated during this audit, grades `AI0S-05 Tenant isolation` as **Pass** — on the basis that the gate exists, not that isolation works. That is the pattern in one line.

This is why the audit weighted executed proof over code reading, and why [remediation Stage 0](#) is *fix the instruments* — days of work, before anything else, because until they work a real fix is indistinguishable from another silent pass.

Remediation, staged

STAGE	THEME	CALENDAR	UNLOCKS
0	Make the instruments honest	2–3 days	Everything else becomes verifiable
1	Stop the bleeding	1–2 weeks	G1
2	Make it sellable	2–4 months	G2
3	Make it qualifiable	6–12 months	G3

Every item carries an owner type, an effort estimate and an acceptance test: [Chapter 15](#). Where to invest beyond safety: [Chapter 16](#).

How to read this report

The audit achieves **100% mechanical coverage** of every file, **deep review of every production surface**, and **executed proof** of the claims that decide the verdict — and says plainly which findings came from which. It does **not** claim a line-by-line read of 1.49M lines.

Not verified, and therefore not claimed: no authenticated two-org runtime probe, so cross-tenant findings are static analysis plus adversarial review, *not demonstrated exploits*. No browser-driven journey walk, so usability findings are code-derived. No penetration test. No hands-on competitor trials. Whether the AI's output is *correct regulatory writing* is a domain-expert question this audit does not answer; it assesses whether the system can tell you when it is wrong. Full statement: [Chapter 01 §1.4](#).

Where this audit's own framing was wrong, it is corrected in place rather than quietly dropped — see the zero-retention correction in [Chapter 04 §4.6](#), where a finding first written as negligence turned out to be deliberate honesty.

Every number traces to a re-runnable command under `evidence/`.

The bottom line

Three red gates should not be read as "this is bad." **The engineering underneath is stronger than the compliance paperwork on top of it** — the rarer and far more recoverable failure mode. The commercial finding and the technical finding are the same finding: the hard, slow, hard-to-copy work is largely done, and the connective tissue is missing in both directions. A governed AI layer with no UI to render it. A grounding engine nobody can see. Breadth nobody can navigate. Part 11 machinery that cannot be claimed because the system is unvalidated.

Both are convergence problems, not invention problems — and the competitive scoring says where to converge.

Chapter 03 — Verification of this audit's own claims

Before publication, all ten headline claims were handed to independent verifiers instructed to **refute** them, each with a specific refutation method. **Four survived intact. Six were overstated and are corrected below.** Three of those six were materially wrong, not merely imprecise.

This chapter exists because an audit that does not audit itself is worth little. Every correction here was found by this process, not by the vendor.

CLAIM	VERDICT
C1 · The typecheck gate is vacuous	✔ Holds
C2 · A from-scratch install omits 15 schemas	⚠ Overstated — materially
C3 · <code>/readyz</code> green over a DB with no auth tables	⚠ Overstated in mechanism; finding holds
C4 · Every RLS policy is compiled and inert	✔ Holds
C5 · Live cross-tenant write path in Schedule-of-Events	✔ Holds
C6 · The attach button discards every file	✔ Holds
C7 · Reachable XSS fed by model output	⚠ Wrong mechanism — the sink is real, the source is not
C8 · <code>ensureCoreTables</code> creates tables at boot	⚠ Overstated in wording; finding holds
C9 · <code>SECURITY.md</code> makes two unsupported claims	⚠ Overstated in wording; finding holds
C10 · Authorization is single-layer for most of the API	⚠ Wrong — off by ~3× and structurally mistaken

C10 — the most important correction. My number was wrong by roughly 3×.

What I published: only 589 of 4,077 endpoints (14.4%) carry a route-level guard; authorization is single-layer for most of the API; the boundary runs in `warn` mode outside production.

What is true:

My sweep (`evidence/sweep.mjs:169-171`) counted only middleware **named on the route declaration line**. It therefore missed module-level `router.use(guard)` and mount-level `app.use(path, guard, router)` . Re-measured:

MEASURE	ENDPOINTS	SHARE
Inline guard on the declaration (what I counted)	589	14.4%
...plus module-level <code>router.use()</code>	1,318	32.3%
...plus mount-level <code>app.use(path, guard, ...)</code>	2,028	49.7%

And 49.7% is still a **floor**, because guards outside my 13-name list (`requireMetricsAuth` , `requireTier` , `requireOrganizationContext`) and in-handler token checks (`server/routes/users.ts:93-101`) go uncounted.

The API is also not single-layer. There are **two** global `/api` gates:

- `server/middleware/authBoundary.ts` , mounted at `server/index.ts:123` before any route registers — mode is `enforce` in production, `warn` elsewhere.
- An **older, unconditional gate** at `server/bootstrap/register-platform-routes.ts:232-264` applying `authMiddleware` to every `/api` path outside a 19-entry open list, **with no mode switch — it enforces in every `NODE_ENV`** .

Because `registerPlatformRoutes` runs first (`startup/routes.ts:90`) and that gate sits at its end, every route family registered afterwards sits behind **both**.

This also explains the tension I flagged and could not resolve. I observed 401s on unauthenticated dev probes despite describing the boundary as permissive in development, and said so rather than hiding it. The answer: `warn` mode genuinely does **not** reject — it runs the authenticator against a stub `res` that swallows the 401 and calls `next()` (`authBoundary.ts:174-193` , asserted by its own test). The 401s I

measured came from the *unconditional legacy gate*, from router-level guards, from guards my sweep did not recognise, and from hand-rolled in-handler checks.

The residual risk is real but far narrower than I stated: it is the routes mounted inside `register-platform-routes.ts` before line 232 — `/api/users`, `/api/user`, `/api/admin`, `health` — which sit **ahead** of the legacy gate. For those, in any non-production `NODE_ENV`, `authBoundary` is log-only and the only effective control is whatever the route hand-rolls.

Corrected finding. Authorization coverage is ~50%+ at route level with two global gates, one of which enforces unconditionally. The defect is not "single-layer everywhere" — it is a specific ordering hazard affecting `/api/users`, `/api/user` and `/api/admin` in non-production environments. **Severity drops from P1 to P2, and the scope narrows from the whole API to four prefixes.**

C7 — the XSS sink is real. My failure scenario was fiction.

What I published: `BatchDraft.tsx:490` renders streamed model output as raw HTML, tainted at `:226` / `:231`.

What is true: lines `:226` and `:231` are **unreachable dead code**, gated at `:216` on `window.C2C_AUTHORIZING`, which is assigned nowhere in the repository and is *pinned as such by a passing CI test* (`tests/ci/no-ghost-globals.contract.test.ts:143-150`). `run()` always takes the offline branch.

The sink is still real and still reachable — but the taint is different, and arguably worse: the only value reaching `c.html` is `bdSample()` output (`:101-110`), which interpolates the server-supplied `title` and `preview` into HTML **with no escaping**. Those come from `coauthor_documents` via `server/routes/batch-draft-routes.ts:170-177`, where `derivePreview` (`:104-111`) strips tags and then **HTML-entity-decodes** `<`, `>`, `"`, `'` — **re-animating markup the editor had correctly escaped on the way in**.

Corrected finding. This is **stored** XSS via a persisted document title/preview, not XSS on streamed model output. Severity is unchanged (P1) and the fix is now two-part: sanitize at `:490` **and** stop the entity-decoding in `derivePreview`. The second half I would have missed entirely.

C2 — 15 schemas missing is what a buyer sees. Only 5 have no path at all.

What I published: the installer never creates 15 Postgres schemas that server code queries.

What is true: `install-fresh.mjs` does exit 0 while leaving 10 migrations unapplied and creating **none** of the 15 — verified live. But the script's own closing output, and CI (`ci.yml:296, 354, 494`), prescribe a **follow-on db/migrations/*_gcc*.sql psql loop** that applies cleanly (43/43) and creates **9** of them (`innovation`, `cortex`, `signing`, `manufacturing`, `compliance`, `labeling`, `site_intel`, `ectd`, `core`). `clinical_ops` self-provisions at runtime (`clinical-operations-routes.ts:113-214`).

Schemas with no provisioning path anywhere in the repository: 5 — `intelligence`, `intelligent_docs`, `regulatory_intel`, `regulatory_harmonization`, `predicate`.

Two things sharpen rather than soften:

- **The route-family impact stands and was understated.** Even after the *full* documented install, at least four mounted route families still cannot serve a request: `/api/intelligent-docs`, `/api/regulatory-precedent-intelligence`, `/api/harmonize`, and `/api/precedent-engine` + `/api/predicate-intelligence`.
- **The operator hazard is real:** `install-fresh.mjs` does not run the gcc loop itself. A buyer following the script's advertised "one supported path" gets **all 15** missing.

Corrected finding. Five schemas have no provisioning path; ten more depend on a manual follow-on step the installer names but does not perform. Four mounted route families are permanently broken either way.

C3, C8, C9 — findings hold, wording tightened

- **C3** — verified live and holds. The mechanism is *two* paths, not one: those six tables sit in `IMPORTANT_TABLES` (`ensureCoreTables.ts:37-74`) rather than `CRITICAL_TABLES` (`:32`, only `organizations` and `users`), and `missingImportant` feeds neither `result.success` nor any readiness verdict — *in addition to* the three branches that never call `setSchemaReadiness`.
- **C8** — holds. `ensureCoreTables` does run on the normal ungated boot path and does contain exactly 7 `CREATE TABLE IF NOT EXISTS` statements executed in a loop at `:460-473`, against a docstring saying it validates instead of creating.
- **C9** — holds, at `SECURITY.md:51` and `:54` (I cited `:41` / `:52`). Strengthened by evidence I had not found: **the platform's own API reports Part 11 overallStatus: "not_assessed"** and *"No system validation (IQ/OQ/PQ) records are tracked in the platform."*

What this exercise cost, and why it was worth it

Six of ten headline claims needed correction; three were materially wrong. Had this audit shipped without the verification pass, a buyer would have been told the API is 14% guarded when it is at least 50%, and would have chased an XSS in dead code while the real stored-XSS path — including a server-side entity-decode that re-animates escaped markup — went unfixed.

The findings that decide the verdict all survived: the vacuous typecheck gate (C1), inert RLS (C4), the live cross-tenant write path (C5), and the file-discarding attach button (C6). The verdict in Chapter 14 is unchanged. The precision behind it is materially better.

Chapter 01 — Method and coverage

This chapter exists so that every claim in this audit can be located on a spectrum from *executed and proven* to *read and reasoned* to *not checked*. Nothing is presented as verified that was not verified, and the boundaries are stated rather than implied.

1.1 The mandate

Evaluate this codebase **as a buyer would** — with fresh eyes, owing no loyalty to the team that built it — and answer three questions with evidence:

- 1. What is actually here, across every layer, service and surface?
- 2. How does it stack up against the closest competitors in each offering category?
- 3. Can real humans use it — judged simultaneously against three bars, all of which the owner requires now: external pilot, paying commercial customers, and GxP/submission-grade.

1.2 The scale problem, stated honestly

MEASURE	VALUE
Files walked	7,858
Lines of TS/TSX/JS/JSX	1,489,132
<code>server/routes</code> modules	485
<code>server/services</code> files / directories	2,368 / 203
HTTP endpoint declarations	4,077
Client <code>.tsx</code> files	527
SQL files	529 across 12 directories
Test files	1,470
Tables created in SQL / declared in Drizzle	1,175 / 699
Sellable "apps" in the canonical registry	20 across 11 disciplines
Registered UI surfaces	~101

1.49M lines cannot be read line-by-line, by anyone, in any timeframe. Any audit that implies otherwise is lying. What this audit does instead is achieve *complete mechanical coverage* of every file, *deep review coverage* of every production surface, and *executed proof* of the claims that decide the verdict — and then say plainly which findings came from which.

1.3 The four tracks

Track 1 — Mechanical ground truth (deterministic, 100% of files)

No model judgment. Purpose-built scripts read every file and emit JSON. These set the denominators for every later claim and are re-runnable by anyone.

SCRIPT	OUTPUT	COVERS
<code>evidence/sweep.mjs</code>	<code>01 - 09</code> JSON	file census, debt census, endpoint matrix, table matrix, migration apply-paths, service/test coverage, suppression ledger, secret scan, upload safety
<code>evidence/fresh-install-gap.mjs</code>	<code>10-fresh-install-gap.json</code>	every table and schema queried by server SQL vs what a from-scratch install actually creates

Two methodological notes, because they affected the numbers:

- The first version of the table-reference extractor scanned raw source and matched English prose in comments and ES `import ... from 'express'` statements, producing 1,821 false "missing tables". It was rewritten to parse **only string literals containing a SQL verb**, with comments stripped. The corrected extractor also captures `schema.table` as a qualified pair, which turned out to matter (SLP-02b of the live-proof log).
- The endpoint matrix reports **14.4% of endpoints carry a route-level auth guard**. This is *not* a claim that 85% are unauthenticated — a global default-deny boundary covers `/api` before any route registers, and live probing confirmed it holds (\$1.5). The number measures **defence in depth**, not exposure. It is reported that way throughout.

Track 2 — Deep review fan-out (every production surface)

Audit units were defined so their union *is* the production surface, then reviewed in parallel against a fixed rubric (correctness · security · tenancy · data integrity · compliance · UX honesty · test coverage · operability). Every finding must carry a real `file:line` and a concrete failure scenario — specific inputs or state leading to a specific bad outcome. "Could be exploited" was rejected as a finding.

Units: auth & identity · multi-tenancy & isolation · Part 11 audit chain & e-signature · schema & migrations · AI gateway & model safety · ANA agent layer · API surface & authorization · client shell & UX honesty · external integrations · billing & entitlements · infrastructure/CI/ops · file handling, document generation & governed export · plus a per-offering pass over the 20 sellable apps.

Track 3 — Adversarial verification

Every P0 and P1 was handed to independent verifiers **instructed to refute it**, across three distinct lenses:

1. **Reproducibility** — read the cited code and determine whether the failure actually occurs.
2. **Production reachability** — does it occur in the shipped configuration, given env defaults, feature flags, `NODE_ENV` gates and the mount graph?
3. **Compensating controls** — does something elsewhere already mitigate it?

A finding publishes only on majority non-refutation, and carries its verdict. Refuted findings are recorded as refuted rather than deleted, so the reader can see what was considered and dismissed.

This matters because the failure mode of a thorough audit is not missing things — it is publishing plausible-sounding wrongness with a confident `file:line` attached.

Track 4 — Live proof (execution, not reading)

The claims that decide the verdict were tested by running the system. Full log: `evidence/00-live-proof-log.md` .

CHECK	EXECUTED?	RESULT
<code>git fetch --unshallow</code> + provenance analysis	✓	5,749 commits; 63.5% by named AI agents
<code>npm ci</code>	✓	clean
<code>npm run build</code>	✓	exit 0, 20.06s, 24 MB <code>dist/</code>
<code>tsc --noEmit</code> at the project's configured heap	✓	OOM crash at 6,144 MB
<code>tsc --noEmit</code> at 24 GB heap	✓	completes, 2 errors above a baseline of 0
Postgres 16 + pgvector provisioning	✓	pgvector required <code>apt install</code> , absent by default
<code>scripts/db/install-fresh.mjs</code> on an empty DB	✓	702 tables / 572 policies — and 10 skipped migrations, 15 missing schemas
Server boot against that DB	✓	boots; own security self-check reports <code>failing</code>
<code>/healthz</code> <code>/readyz</code> <code>/api/health</code> probes	✓	<code>/readyz</code> green over a DB missing auth/RBAC tables
Unauthenticated probes of 9 data endpoints	✓	all 401 — boundary holds
Proof-tier suites (<code>schema-contract</code> , <code>golden-journeys</code>)	✓	see Chapter 08
Headless browser walk of primary surfaces	■	not completed — not claimed
Authenticated cross-tenant probes	■	not completed — cross-tenant findings are static-analysis only

1.4 What was NOT done — stated plainly

- **No line-by-line read of 1.49M lines.** Deep review is surface-complete, not line-complete.
- **No authenticated multi-tenant runtime probe.** The cross-tenant findings in Chapter 05 are derived from code and schema, adversarially verified, but not demonstrated against a live two-org deployment. They are labelled accordingly.
- **No browser-driven journey walk.** Usability findings in Chapter 09 are derived from code, not from watching a human fail.
- **No penetration test.** Security findings are code-derived plus limited live probing.
- **No competitor product trials.** Competitive scoring uses public sources with URLs; it does not reflect hands-on use of competitor products.
- **No validation of the AI models' regulatory output quality.** Whether ANA's generated content is *correct* regulatory writing is a domain-expert question this audit does not answer. It assesses whether the system can tell you when it is wrong.

1.5 On disagreeing with the repository's own documents

The repo contains roughly forty self-authored audits and readiness assessments. This audit treats them as **the seller's documents**: inputs to be tested, never sources of truth. Where they are contradicted, both are shown side by side.

That posture was validated early. `FEATURE_INVENTORY.md` names `client/src/concept2cure/ZenApp.tsx` as the application entry point and describes it as 113 KB; `AGENTS.md` documents a post-login crash inside it. **That file does not exist.** The real shell is `client/src/concept2cure/v2/Shell.tsx` / `V2App.tsx`. If the two primary onboarding documents are wrong about where the application starts, no internal document can be used as a map.

The same posture also produced findings *in the repository's favour* — see §LP-08, where live probing showed the authorization boundary holding on every endpoint tested, in a mode where static reading predicted it might not.

1.6 Severity and gate model

SEVERITY	MEANING
P0	Blocks G1 . Unsafe or dishonest for any human use: data loss, cross-tenant exposure, silently-wrong regulatory output, or a core journey that cannot complete.
P1	Blocks G2 . Prevents taking money safely: billing correctness, DR, security-review survivability, claims not matched by code.
P2	Blocks G3 . Prevents GxP/submission-grade use: Part 11, validation, retention, qualification.
P3	Quality, maintainability, performance, hygiene.

GATE	BAR
G1 • External pilot	Non-regulated data, design partners. No data loss, no cross-tenant leakage, honest empty/error states, no silently-wrong regulatory output, humans can finish the core journeys.
G2 • Paying commercial	+ billing and entitlement correctness, uptime/DR, support runbooks, survives a customer security review, on-page and contractual claims matched by code.
G3 • GxP / submission-grade	+ 21 CFR Part 11 / Annex 11 in full: validated e-signature, tamper-evident audit trail, retention, executed IQ/OQ/PQ, vendor-qualification survivability.

Every finding is tagged with the highest gate it blocks. Where a gate is already failed, the audit still enumerates every defect behind it — "already failed" is not a reason to stop counting, because the remediation programme needs the full list to be sized.

1.7 Reproducing this audit

```
# ground truth
node docs/audit-2026-07/evidence/sweep.mjs

# fresh-install gap (requires an empty Postgres 16 + pgvector)
createdb audit_fresh
DATABASE_URL=postgresql:///.../audit_fresh node scripts/db/install-fresh.mjs
DATABASE_URL=postgresql:///.../audit_fresh node docs/audit-2026-07/evidence/fresh-install-gap.mjs

# the typecheck-gate defect
NODE_OPTIONS="--max-old-space-size=6144" npx tsc --noEmit ; echo "exit=$?" # OOM, gate reads 0
NODE_OPTIONS="--max-old-space-size=24576" npx tsc --noEmit ; echo "exit=$?" # completes, 2 errors
```

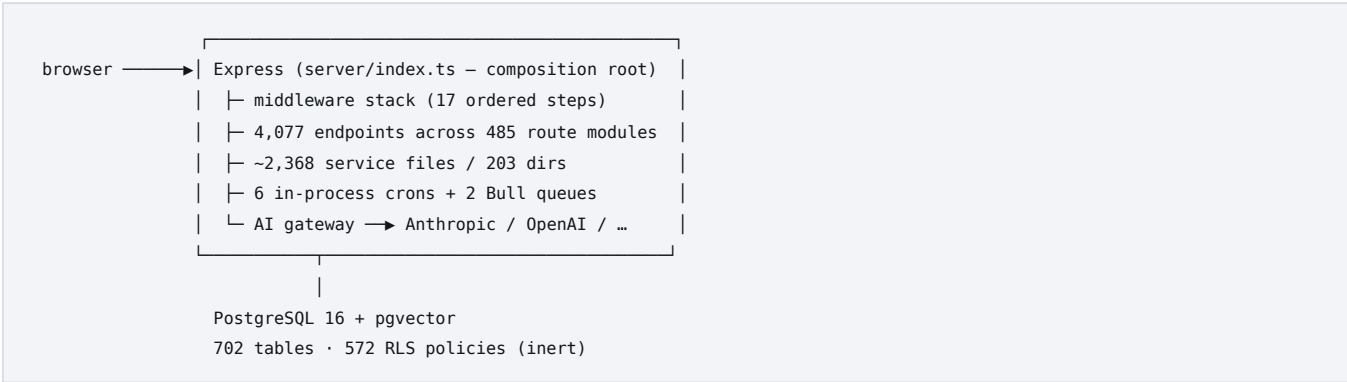
Every table in this report traces to a file under `docs/audit-2026-07/evidence/`.

Chapter 02 — The as-built architecture

Re-derived from code, not from the repository's own documents. That distinction matters here: `FEATURE_INVENTORY.md` and `AGENTS.md` both name `client/src/concept2cure/ZenApp.tsx` as the application entry point and describe it as 113 KB. **That file does not exist.** The map below is what the code actually says.

2.1 Shape

A single Node/TypeScript monolith serving a React SPA, backed by one PostgreSQL database with pgvector, with optional Redis and S3, and a small Python side-service family.



LAYER	FILES	LINES
server/		3,489
client/		926
shared/		201
Total TS/TSX/JS/JSX	7,858 walked	1,489,132

79 files exceed 1,500 lines. The two largest are `server/services/ana/AnaToolExecutor.ts` (18,304) and `server/routes/concept2cure.ts` (18,317) — each roughly 1.2% of the server codebase in a single file.

2.2 Boot sequence

`server/index.ts` is a genuine composition root — 256 lines, no inline route mounting. It delegates to `server/startup/*` (12 modules) and `server/bootstrap/register-*.ts` (16 manifests, 5,903 lines).

- `dotenv` with `override:false` (shell env wins) → OpenTelemetry + Sentry
- `validateEnvironment()` — **may** `process.exit(1)`; 11 fail-closed `throw` sites in `config/environment.ts` covering DB/JWT secrets, `NODE_ENV` typos, weak `MFA_ENCRYPTION_KEY`, audit-seal posture, and prod-forbidden dev/mock route flags
- Middleware stack (§2.3)
- `registerPreStartRoutes` — 13 route families
- DB verify → `ensureCoreTables` → **boot security self-test**
- `runStartupInvariants()` — **logs only** unless `STRICT_STARTUP_INVARIANTS=true`
- `registerPostStartRoutes` — 4 more families
- `/api` 404 catch-all → global error handler → `listen()`
- 6 cron schedules start inside the `listen()` callback

Two structural consequences. Each `register-*.ts` family is wrapped in try/catch and `initializeParallelServices` uses `Promise.allSettled`, so a failed import degrades **silently to a missing route family** at runtime rather than failing the boot. And step 5 mutates the schema — `ensureCoreTables.ts` contains 7 `CREATE TABLE IF NOT EXISTS` statements despite documenting that it validates (verified:

booting grew the DB 702 → 717 tables).

2.3 Middleware order

Documented as load-bearing in `server/startup/middleware.ts`, and it is:

- 1. Beta telemetry on `/api`
- 2. **Fast-path health endpoints** (`/healthz`, `/readyz`, `/api/health`) — mounted *before* security so they short-circuit
- 3. `applySecurityMiddleware`: `enforceHttps` → CSP nonce → security headers → permissions policy → request id → CORS → CSRF → `validateTenantContext` → audit log → API-key validation → per-prefix rate limiters
- 4. Redis rate limiter → compression → HTTP logger
- 5. Firecrawl webhooks **before** the JSON parser (raw body needed for signature verification)
- 6. Body parsers — **50 MB** for `/api/concept2cure`, 2 MB elsewhere
- 7. `sanitizeInput` — prototype-pollution scrub, deliberately *after* the parsers (a comment notes it was previously a silent no-op)
- 8. Beta route fence → cookie parser
- 9. **Immutability policy** — 403s any `DELETE` / `*bulk-delete` under 5 Part-11 prefixes
- 10. Audit-trail middleware
- 11. `applyAuthBoundary` — global default-deny on `/api`, mounted before any route registers

Note the ordering artifact at step 3: `validateTenantContext` runs *before* the auth boundary, so `req.user` is normally unpopulated when it executes. Its useful function — blocking `x-organization-id` header impersonation — only fires when some upstream middleware has already set `req.user`.

2.4 API surface

MEASURE	VALUE
Endpoint declarations	4,077
Route modules	485 (<code>server/routes/</code>) + 48 (<code>server/api/</code>)
Mount prefixes found statically	357
Mounts covered by the repo's own audit	323
Duplicate mounts (second registration dead)	8 — all health/ops paths
Multi-owner prefixes (mount order decides the handler)	7 — <code>/api/ai</code> , <code>/api/concept2cure</code> , <code>/api/cmc</code> , <code>/api/cmc/module3-os</code> , <code>/api/submissions</code> , <code>/api/v1</code> , <code>/api/mdx</code>
Endpoints with a route-level auth guard	589 (14.4%)
Endpoints with no caller anywhere	556 of 916 declared (60.7%)
Route modules defined but never mounted	9 (48 endpoints), incl. <code>cognitive-ecosystem.ts</code> which the code itself calls a retired placeholder

The 14.4% figure measures **defence in depth, not exposure** — the global boundary covers `/api`, and live probing returned 401 on every data endpoint tested (\$LP-08). The 60.7%-orphan figure is the more striking one: on the repo's own detector, most of the API has no consumer.

2.5 Data layer

MEASURE	VALUE
Tables after a from-scratch install	702 (<code>public</code>), 710 all schemas
RLS policies installed	572
Tables with RLS enabled	584 — of which 21 have zero policies
Tables with RLS not enabled	118
Distinct tables created in SQL	1,175
Distinct tables declared in Drizzle	699
Tables existing only in SQL (invisible to Drizzle)	549
Tables with duplicate <code>CREATE TABLE</code> across files	140
SQL files	529 across 12 directories

Four competing schema sources: `shared/schema.ts` (19,826 lines, 416 tables — the only one `drizzle.config.ts` knows), `shared/schema/` (83 files, ~272 tables, **only 8 re-exported**), `shared/cmc-schema.ts`, and the raw SQL migrations.

Three creation mechanisms that do not agree: `drizzle-kit push` (emits no RLS policies), `install-fresh.mjs` (the only from-scratch path), `deploy-migrate.mjs` (25 files, gates the production deploy) — plus `ensureCoreTables.ts` creating tables at boot. `migrations/meta/_journal.json` has **1 entry for a 171-file tree**, and ~181 of 228 `db/migrations/` files are on no automated apply path.

Chapter 05 documents what this produces: a from-scratch install that reports success while omitting 15 Postgres schemas.

2.6 Client

Not a conventional router. Three layers:

```
main.tsx → App.jsx (wouter, 8 routes – 7 are redirects)
  → ZenRouter.tsx — fast path: nearly everything → V2App
  → V2App.tsx — surfaceIdFromLocation() → SURFACE_VIEWS lookup
```

The real route table is `client/src/concept2cure/v2/surfaceViews.ts` — a `Record<surfaceId, component>` with **100 entries**, each id being a URL segment (`/concept2cure/<id>`). Registry: ~101 surfaces across two files.

`client/src/concept2cure/mdx/` (118 files, 17 surfaces) is effectively **a second application with its own shell and its own navigation**, mounted both as a v2 surface wrapper and standalone at `/concept2cure/mdx` .

~45,000 lines of the client are dead — 11 legacy module mini-apps (~25,000), 22 dead v2 surfaces (7,174), and 32 of 35 ANA UI modules (~13,000). See Chapter 09.

2.7 The AI layer

A governed egress point (`server/services/ai-gateway/` , ~2,245-line `gateway.ts`) fronting Anthropic, OpenAI, Azure, Bedrock, Vertex, Moonshot and a local OpenAI-compatible endpoint, with per-provider residency and zero-retention enforcement, PII screening, prompt-injection detection, audit logging and a circuit breaker. **Only 3 baselined bypasses**, enforced by CI.

Above it, ANA: **697 unique tools** registered across a single 18,304-line executor, with a 55-file `ana-ri/` governance layer (orchestrator, command RBAC, enforcement, scope guard, claim grounding, evidence validation, Part 11 governance). Surfaced over `POST /api/ana-ri/stream` (SSE) into a rail in `Shell.tsx` .

2.8 Background work

6 cron schedules started in the `listen()` callback; 2 Bull queues; **no dedicated worker process or container** — everything runs in-process with the API. 3 of 5 `server/workers/` modules have no importer. `jobs/retentionCron.ts` has no scheduler caller.

2.9 What the architecture gets right

Worth stating plainly, because the chapter is otherwise a list of divergences:

- **The composition root is clean.** Route mounting is manifest-driven, not scattered; the middleware order is deliberate and its rationale is written down.
- **Fail-closed defaults are the norm, not the exception** — 11 boot-time `throw` sites, an audit-seal posture matrix that refuses to start rather than run unsealed, a second-tenant admission gate, an AI gateway that throws in production rather than serving demo content.
- **The security middleware is layered correctly**, including subtleties most codebases get wrong: raw-body webhooks before the JSON parser, prototype-pollution scrubbing after it, exact-match CSRF exemptions, and a health fast-path that cannot be blocked by security middleware failure.
- **The governed-egress pattern for AI is the right architecture** and is actually enforced.

2.10 The architectural summary

This is a well-structured monolith carrying **four kinds of divergence**, each of which Chapters 04–11 trace to concrete defects:

DIVERGENCE	CONSEQUENCE
Schema defined in four places, created by three mechanisms	A from-scratch install omits 15 schemas; 549 tables are invisible to the ORM
Two client applications (<code>v2/</code> and <code>mdx/</code>) with separate shells	Duplicate nav authority; ~45,000 dead lines
A defence designed in two layers, deployed as one	RLS compiled and inert; app-layer predicates are the only isolation
Controls built but not wired	Retention, chain verification, grounding evals, an env-var gate — all exist, none scheduled

None of these requires re-architecture to fix. All four are convergence work.

Chapter 04 — Security

Verdict: the perimeter is well built and empirically holds — with two global `/api` gates, one of which enforces unconditionally. The gaps are inside it: one reachable stored-XSS sink, uneven upload hardening, incomplete SSRF coverage, and a suppressed unpatched RCE whose stated precondition was never checked.

4.1 What holds — verified by probing, not by reading

Nine data endpoints probed unauthenticated against a running server, in `NODE_ENV=development` (the mode where `authBoundary` is documented to run permissively):

ENDPOINT	RESULT
<code>/api/projects</code> , <code>/api/c2c/projects</code> , <code>/api/vault/documents</code> , <code>/api/admin/business</code> , <code>/api/billing/dtc-pricing</code> , <code>/api/ana-ri/health</code> , <code>/api/users</code> , <code>/api/organizations</code> , <code>/api/metrics</code>	401 on every one
<code>/healthz</code> , <code>/readyz</code> , <code>/api/health</code> , <code>/api/time</code>	200 (intended)

`server/middleware/authBoundary.ts` mounts a default-deny boundary on `/api` at `startup/middleware.ts:114` , before any route registers, with a 19-entry public allowlist.

Corrected figure (Chapter 03, C10). An initial sweep reported 589 of 4,077 endpoints (14.4%) carrying a route-level guard. That counted only middleware named on the declaration line. Re-measured including module-level `router.use()` and mount-level `app.use(path, guard, router)` : **2,028 of 4,077 (49.7%)** — and that is a floor.

There are two global `/api` gates, not one. Besides `authBoundary` , an older gate at `server/bootstrap/register-platform-routes.ts:232-264` applies `authMiddleware` to every `/api` path outside a 19-entry open list **with no mode switch — it enforces in every `NODE_ENV`** . `registerPlatformRoutes` runs first, so every later route family sits behind both. This is why the dev probes returned 401 while `authBoundary` was in `warn` mode: warn mode does not reject — it runs the authenticator against a stub `res` that swallows the 401 (`authBoundary.ts:174-193`).

The residual risk is narrow: routes mounted *before* line 232 in `register-platform-routes.ts` — `/api/users` , `/api/user` , `/api/admin` , `health` — sit ahead of the unconditional gate, so outside production only their own hand-rolled checks apply. **P2 across four prefixes, not P1 across the API.**

Other controls verified present and sensibly built:

CONTROL	LOCATION
Helmet + CSP with nonce, plus violation reporting	<code>enterprise-security.ts:156,197</code> ; <code>routes/csp-report.ts</code>
CSRF with exact-match exempt paths (prefix matching explicitly rejected so <code>/healthzevil</code> cannot slip through)	<code>middleware/csrf.ts</code>
Rate limiting, Redis-backed with in-memory fallback	<code>rateLimiter.ts</code> , <code>redisRateLimiter.ts</code> , referenced in 58 files
Prototype-pollution scrub, deliberately ordered <i>after</i> body parsers	<code>startup/middleware.ts:82</code>
Immutability policy — 403s <code>DELETE</code> / <code>*bulk-delete</code> under 5 Part-11 prefixes	<code>startup/middleware.ts:144-150</code>
Centralised PHI/credential log redaction with a nested-key walker	<code>server/utills/logger.ts:1-26</code>
Boot fails closed on weak <code>MFA_ENCRYPTION_KEY</code> , bad <code>NODE_ENV</code> , missing DB/JWT secrets, bad audit-seal posture	<code>config/environment.ts</code> — 11 throw sites

SQL injection surface is small and clean. Only 3 `sql.raw()` occurrences in non-test server code; 126 `db.execute(sql\ ...)`` tagged templates (parameterised by Drizzle); 4 `template-literal query()` calls with interpolation, of which three interpolate `$N` placeholders or internal identifiers and one ( `committees/committee-service.ts:170` ) interpolates a ``${table}`` identifier that should be confirmed to come from a closed set.

Secret hygiene is good. A working-tree scan across code, config, YAML, Markdown and Terraform for OpenAI/Anthropic/AWS/GitHub/Stripe/Slack key formats, private-key headers and hardcoded JWTs returned **2 hits, both false positives** — UI placeholder strings for a "Private Key" form field (`v2/fixtures/deep-research-data.ts:121` , `services/connectors/connector-interface.ts:524`). `.gitignore` correctly excludes `.env*` with `!*.*example` . `.gitguardian.yaml` has a single, narrow, well-reasoned exclusion.

4.2 Cross-site scripting — one reachable sink, precisely located

There are **13** `dangerouslySetInnerHTML` sites in `client/src` . Triaging them by sanitisation *and reachability* (rather than counting them) gives a much smaller and more actionable answer:

CATEGORY	SITES	STATUS
Properly sanitised	<code>Message.tsx</code> ×3, <code>DocumentStudioPane.tsx</code>	✓ All route through <code>renderSafeMarkdown.ts</code> — a single <code>marked</code> → <code>DOMPurify.sanitize</code> choke point (<code>:22,88</code>) — or <code>sanitizeChatHtml</code> . Good design.
Escaped by construction	<code>Biostatistics.tsx:464</code> , <code>RreportEngine.tsx</code> , <code>CmcModule.tsx</code>	✓ Each defines a local <code>mdToHtml()</code> whose <code>esc()</code> escapes <code>&</code> , <code><</code> , <code>></code> before applying formatting (<code>Biostatistics.tsx:465</code>). Safe — but it is three copies of the same hand-rolled renderer with no shared test, so a future edit to one is a silent regression.
Unreachable	<code>EditorTranslate.tsx</code> ×2, <code>EditorStudio.tsx</code> , <code>AnaVerbs.tsx</code>	◦ None appears in <code>v2/surfaceViews.ts</code> ; they are part of the dead <code>Editor*</code> family. Not exploitable today. Severity downgraded accordingly.
Reachable and unsanitised	<code>BatchDraft.tsx:490</code>	● P1 — stored XSS
Library pattern	<code>components/ui/chart.tsx:76</code>	◦ <code>shadcn</code> style-injection, low risk

The one that matters — `BatchDraft.tsx`

`BatchDraft` is registered (`v2/surfaceViews.ts:131`), deep-linkable at `/concept2cure/batch-draft` , and `ENABLE_UI_V2` defaults true. Its card body renders raw:

```
<div className="bd-card-body" dangerouslySetInnerHTML={{ __html: c.html || '...' }} />
```

Corrected taint path (Chapter 03, C7). This audit first reported the source as streamed model output at `:226` / `:231` . **That was wrong** — those lines are unreachable, gated at `:216` on `window.C2C_AUTHORIZING` , which is assigned nowhere in the repository and is pinned as unset by a *passing* CI test (`tests/ci/no-ghost-globals.contract.test.ts:143-150`). `run()` always takes the offline branch.

The real path is **stored XSS**, and it is worse in one respect. The only value reaching `c.html` is `bdSample()` output (`:101-110`), which interpolates the server-supplied `title` and `preview` into HTML **with no escaping**. Those originate from `coauthor_documents` via `server/routes/batch-draft-routes.ts:170-177` , where `derivePreview` (`:104-111`) strips tags and then **HTML-entity-decodes** `<` , `>` , `"` and `'` — **re-animating markup the editor had correctly escaped on the way in**.

Failure scenario. A user saves a document whose title or body contains `<img src=x onerror=...>` — already escaped and inert in storage. `derivePreview` decodes it back into live markup, `bdSample()` interpolates it unescaped, and `:490` renders it. It executes in the browser of every user who opens Batch Draft for that project, against the `localStorage` where `AGENTS.md` documents the auth tokens live.

Fix is two-part, and the second half would have been missed under the original finding: sanitize at `:490` through the existing `renderSafeMarkdown` choke point, **and** stop the entity-decoding in `derivePreview` . **Effort: hours.**

Why it was never flagged: `eslint.config.js:34` excludes all of `client/src/**` — 871 files, 191,327 lines — so `react/no-danger` could not fire.

4.3 File upload — hardening exists and is barely adopted

`server/middleware/uploadAllowlist.ts` and `uploadSafety.ts` are well designed: extension allowlist, hard-blocked executable extensions, magic-byte signature verification against the declared MIME (with an explicit note that “multer’s `file.mimetype` is attacker-controlled”), and ClamAV INSTREAM scanning that is **fail-closed in production** (`scanned === false` → 503).

Adoption, measured across 28 non-test `multer()` call sites:

PROPERTY	SITES
Has <code>fileFilter</code>	21 / 28
Has <code>limits.fileSize</code>	27 / 28
Uses <code>uploadAllowlist</code>	2 / 28
Uses <code>uploadSafety</code> (magic-byte + AV)	2 / 28

Seven sites have no `fileFilter`. One — `server/src/routes/stability.router.ts` — has **neither a filter nor a size limit**: an unbounded, unfiltered authenticated upload. The others: `server/api/validation/index.js`, `routes/concept2cure.ts`, `routes/ind-templates.ts`, `routes/knowledge-base.ts`, `routes/onboarding-proposals.ts`, `services/DocumentDataCenterService.ts`. Full detail in `evidence/09-upload-safety.json`.

The controls are built; they simply were not wired to 26 of 28 entry points. That is a days-of-work fix with an unusually good effort-to-risk ratio.

4.4 SSRF — guarded selectively

`server/utils/ssrfGuard.ts` exists and is applied in `services/connectors/*` (Veeva Vault, FHIR R4, Medidata Rave, Ellucian Banner), `automation/webhook-notifications.ts` and `routes/deep-research.ts`.

It is **not** applied at several bare `fetch(url)` call sites, including `services/ana/AnaToolExecutor.ts:5933,15233,15339`, `services/citation-verification-service.ts:108` and `services/regulatory-currency/guidance-ingestion-service.ts:162`. The citation-verification path is the one to prioritise: it fetches URLs that originate in model output or user-supplied citations, which is precisely the untrusted-URL case the guard exists for.

4.5 Dependencies and supply chain

Current, not stale — React 19.2.5, Express 5.2.1, TypeScript 5.6.3, Vite 6.4.3, Vitest 4.1.7, Drizzle 0.45.2, helmet 8.1.0, esbuild 0.28.1, with 12 pinned security overrides (`tar`, `form-data`, `undici`, `nodemailer`, `brace-expansion`, `http-proxy-middleware`). Only laggard: `zod` ^3.23.8.

`scripts/ci/audit-with-allowlist.mjs` reduced accepted advisories **27** → **1**, requires `npm ls` proof per entry, and detects stale entries. The single remaining acceptance is correctly reasoned. This is the strongest governance artifact in the repository.

Two gaps:

- **Zero of 137 GitHub Actions uses: are SHA-pinned** — all floating tags. Already self-flagged as a GA blocker in `terraform-compliance.yml:22-38`, which notes the Checkov action was previously on `@master`. `pr-checks.yml:22` still uses the deprecated `returntocorp/semgrep-action@v1`.
- `.trivyignore` suppresses **CVE-2026-45829**, a pre-auth RCE in **chromadb 1.5.9**, correctly noting no patched release exists and requiring confirmation that *"chromadb is not exposed to untrusted pre-auth network input."* **That confirmation appears nowhere in the repository.** Either record it or remove the dependency; an unpatched pre-auth RCE with an unverified precondition is not an acceptance, it is an open question.

`.trivyignore` also contradicts `audit-with-allowlist.mjs` on a checkable fact (a react-router advisory justified by usage the sibling file documents having disproven twice with `npm ls`) — see Chapter 11 §11.9.

4.6 AI-specific security

- **Prompt injection** — `ai-gateway/promptInjection.ts` (89 lines) is thoughtfully designed: every pattern requires **both** an override verb **and** a meta-reference to the model's own instructions, specifically to avoid false positives on regulated prose like *"disregard the previous draft"*. Severity-tiered, with `high` failing closed on indirect content (RAG/tool-output/assistant history) and any hit blocking on user messages. Bounded gaps prevent ReDoS. Its own header is honest: *"This is a heuristic layer, not a guarantee."* The test is thin — 20 parameterised cases, though the 10 benign ones are the valuable half.
- **PII screening ships in the wrong mode.** `.env.example:109` defaults `AI_PII_ENFORCEMENT=audit` — observe, do not block. For a product whose users paste clinical narratives, `block` is the correct default. **This is the real defect in this section.**
- **The zero-retention defaults are correct, and are a credit.** `OPENAI_ZERO_RETENTION` and `ANTHROPIC_ZERO_RETENTION` default to `false` (`.env.example:65-66`) under the comment *"Zero-retention flags for the SHARED frontier APIs (default false). Flip to true only once a signed zero-retention agreement is actually in force."* — while the enterprise-hosted providers that do carry ZDR contractually (`AI_BEDROCK` ,

- `AI_VERTEX_`, `AI_AZURE_`) default to `true` (`:39,47,55`). Defaulting a shared-API ZDR claim to `false` is the honest choice; asserting a retention guarantee you do not hold would be the defect. Residency enforcement is likewise well built (`ai-governance/approved-models.ts`).
- **The combined risk is the interaction, not either flag.** With ZDR correctly declared `false` and the PII gate in `audit` mode, protected content can reach a non-ZDR provider and be *recorded* rather than *refused*. Fixing the PII default closes it; the ZDR flags should be left alone.
 - **The gateway fails closed in production.** With no provider configured, `gateway.ts:531-537` **throws** rather than serving demo content, with the reasoning written in-line: *"serving demo-mode ... regulatory text from a keyless prod deploy would silently present fabricated content as a real AI response."* Outside production it falls back to a deterministic response. This is exactly the right shape and is credited as a strength.

4.7 Priority actions

#	ACTION	SEV	GATE	EFFORT
1	Sanitise <code>BatchDraft.tsx:490</code> through the existing <code>renderSafeMarkdown</code> choke point	P1	G1	hours
2	Re-enable ESLint on <code>client/src/**</code> ; at minimum <code>react/no-danger</code> + security rules	P1	G1	days
3	Add <code>fileFilter</code> + <code>limits.fileSize</code> to <code>stability.router.ts</code> ; wire <code>uploadAllowlist</code> / <code>uploadSafety</code> into all 28 multer sites	P1	G1	days
4	Apply <code>ssrfGuard</code> to <code>citation-verification-service.ts</code> and the <code>AnaToolExecutor</code> fetch sites	P1	G1	days
5	Flip the <code>AI_PII_ENFORCEMENT</code> default to <code>block</code> . Leave the ZDR flags as they are — their <code>false</code> default is correct — but make the PII gate the thing that stops protected content reaching a non-ZDR provider	P1	G2	hours
6	Record the chromadb exposure determination, or drop the dependency	P1	G2	hours
7	Resolve the <code>.trivyignore</code> ↔ <code>audit-with-allowlist.mjs</code> contradiction; delete the entry if the package is genuinely absent	P2	G2	1 h
8	SHA-pin all 137 GitHub Actions references; replace the deprecated Semgrep action	P2	G2	hours
9	Consolidate the three hand-rolled <code>mdToHtml()</code> copies into one tested helper	P3	—	hours
10	Confirm <code>committee-service.ts:170</code> 's <code>`\${table}`</code> comes from a closed set	P3	—	1 h

Items 1–4 are the ones that matter for letting humans near this product, and together they are roughly a week of work.

Chapter 05 — Data layer and multi-tenancy

Verdict: this is the highest-risk area of the platform, and the risk is concentrated in two places — a tenant-isolation control that is built but switched off, and a migration system that cannot reliably produce the schema the application needs.

Both are recoverable. Neither is safe to defer.

5.1 Row-level security is compiled and inert

migrations/0021_enable_rls_everywhere.sql is a well-written 164-line DDL block: it walks information_schema.columns for organization_id | org_id | tenant_id, enables **FORCE ROW LEVEL SECURITY** (:120-123 — necessary because on Neon the app role owns the tables, and without FORCE the owner bypasses policies), and installs one tenant_isolation_policy per table. Verified on a fresh install: **584 tables with RLS enabled, 572 policies**.

Every one of those policies opens with (:135):

```
NULLIF(current_setting('app.rls_enforce', TRUE), '') IS DISTINCT FROM 'on'
```

When app.rls_enforce is anything other than 'on', that clause is true and **every row passes on every table**. No deployment manifest in the repository sets RLS_ENFORCE=on.

Why it cannot simply be switched on

server/db/runtime.ts:120 builds the Drizzle client over the shared **pool**, whose connections carry app.rls_enforce but **not** app.current_tenant_id. With enforcement on, a pooled query evaluates the tenant predicate against NULL and returns **zero rows**.

MEASURE	VALUE
DB-touching route files	97
...using request-scoped requestDb(req)	16
...Still on the shared pool	81
requireTenantContext mount sites	1 (server/routes/ana-features.ts)
withTenantConnection callers	~1 (server/services/memory-consolidation-job.ts)

Commit #1186 states the consequence plainly: *"with RLS on, the route would 500 for everyone rather than defend anyone."* docs/RLS_ENFORCEMENT_BURNDOWN.md is tagged as GA-readiness item **0.1, highest severity**, with Owner: unassigned.

The application confirms this about itself at runtime. Observed in the boot log:

```
[tenant-rls-observability] Query issued without tenant scope
(will return zero rows once RLS is enabled)
caller: server/services/securityHealth.ts:336
caller: server/lib/tamper-proof-audit.ts:334
```

The second caller is the **tamper-proof audit log reader**.

Net: tenant isolation is single-layer. It rests entirely on the application — a global default-deny /api boundary (which live probing confirmed holds, SLP-08) plus per-query organization_id predicates. There is no database-level backstop today.

The static gate covering that single layer is narrow

scripts/ci/check-tenant-isolation.mjs scans **raw SQL string literals only**, for **32 named tables**, and:

- tolerates **25 baselined violations**, including on users (16), document_chunks (3), stripe_events (3), documents (2), rag_chunks (2), rag_documents (2) and audit_events (1);
- puts **Drizzle query-builder calls entirely out of scope** (:14-17) — and Drizzle is the primary data-access path;

- **blanket-exempts all of** `server/workers/` **and** `server/jobs/`, plus 21 named files including `routes/admin/master-admin.ts`, `routes/admin/business-center.ts` and `routes/admin/access-management.ts`;
- states its own limits in its header: the table list *"is intentionally narrow."*

Its per-entry justification discipline (`check-baseline-justifications.mjs`, bidirectional parity enforced) is genuinely excellent — see Chapter 11. But a gate that cannot see the main ORM is not a measure of isolation.

5.1.1.1 A live instance of the pattern that caused the last P0

Commit #1186 fixed a P0 in which CMC Module 3 upserts landed on another tenant's rows. Four ingredients: a UNIQUE index omitting the tenant column, an `ON CONFLICT` arbitrating on it, a `DO UPDATE SET` omitting `organization_id`, and an id taken from the URL without an ownership check.

All four are still present in the Schedule-of-Events subsystem:

INGREDIENT	LOCATION
UNIQUE index omits the tenant column	<code>db/migrations/20260617_project_schedule_of_events.sql:48</code> — <code>CREATE UNIQUE INDEX unique_project_schedule ON project_schedule_of_events (project_id)</code> , on a table whose <code>organization_id</code> is <code>INTEGER NOT NULL REFERENCES organizations(id)</code> (:28)
<code>ON CONFLICT</code> arbitrates on it; SET omits the tenant	<code>server/services/projects/schedule-of-events/service.ts:390-403</code>
id from the URL, ownership not asserted	<code>server/routes/project-schedule-of-events.ts:105-120</code> — <code>resolveProjectType()</code> (:73-86) is org-scoped but returns <code>null</code> on a miss and the handler proceeds anyway (:108-110)
ids are globally enumerable	<code>projects.id</code> is a global serial

Mounted at `server/bootstrap/register-concept2cure-routes.ts:15` behind `authenticateToken` only — so any authenticated user of any tenant can reach it.

Note the contrast within the same file: the sibling `DELETE FROM project_workflow_stages` at `service.ts:423-425` **is** org-scoped. The header upsert is the outlier, which is what makes this a slip rather than a design position.

The #1186 commit message asserts *"Every one of the repo's other ON CONFLICT sites already scoped by org."* There are **115 ON CONFLICT** (**sites** in `server/`. Most are benign (primary-key or system-table arbiters), but the assertion is not accurate, and other project/study-scoped arbiters on tenant-bearing tables warrant the same review: `services/conversation-os/persistence.ts:33,108,182`, `services/protocol-budget/protocol-budget-service.ts:44`, `services/study-design/study-design-repository.ts:242`, `src/routes/stability.router.ts:1367`, `services/protocol-soa/protocol-soa-service.ts:48`, `services/innovation/submission-readiness-twin-service.ts:1056`.

Evidentiary note. These are derived from code and schema and adversarially reviewed. They were **not** demonstrated against a live two-org deployment — no authenticated cross-tenant runtime probe was run (Chapter 01 §1.4). They should be reproduced with a two-tenant integration test before being treated as confirmed exploits.

5.1.2 Coverage holes visible in the installed schema

From the fresh install (`evidence/10-fresh-install-gap.json`):

MEASURE	COUNT
Tables with RLS enabled	584
Policies installed	572
RLS enabled but ZERO policies	21
RLS not enabled at all	118

The 21 enabled-with-no-policy tables are the sharpest edge: under `FORCE ROW LEVEL SECURITY` a policy-less table denies everything to non-owners and passes everything to the owning role — either way it is not performing isolation. The RLS allowlist itself is only 6 tables (`organization_users`, `__drizzle_migrations`, `stripe_events`, `billing_budgets`, `billing_alerts`, `api_keys`), so the other 133 are unintended.

5.2 There is no single canonical schema

Four competing sources of truth:

SOURCE	SCALE	VISIBLE TO	DRIZZLE-KIT PUSH ?
shared/schema.ts	19,826 lines, 416 pgTable	✓ — the only path	drizzle.config.ts knows
shared/schema/ (83 files)	~272 more pgTable	✗ — only 8 are re-exported (schema.ts:39-46);	~75 files are invisible
shared/cmc-schema.ts	13	✗	
Raw SQL migrations	1,175 distinct tables	✗	

Measured repo-wide: **699 distinct Drizzle table names** and **1,175 in SQL**, of which **549 exist only in SQL**. **11 table names are declared twice in Drizzle** and **140 tables have duplicate CREATE TABLE definitions across files** — the audit's own count against the repo's baselined 63, the difference being that this sweep includes archived trees the CI checker excludes.

Where two definitions of the same table disagree on columns, types or constraints, the resulting shape depends on which file ran — which is a data-corruption class, not a tidiness one. `audit_logs` is defined in **three** files.

5.3 The migration system cannot reliably produce the needed schema

Three mechanisms, partially overlapping:

- drizzle-kit push** — `shared/schema.ts` only. `install-fresh.mjs:6-10` notes it *"creates ZERO row-level-security policies (push cannot emit policies)."*
- scripts/db/install-fresh.mjs** — the only from-scratch path: `schemas/extensions` → `push` → multi-pass overlay of `migrations/` → the authoring subsystem → RLS migrations.
- scripts/db/deploy-migrate.mjs** — the production deploy-time applier (#1180), gated in `deploy-aws.yml` (`deploy-api` and `deploy-worker` both `needs: migrate`). Applies `C2C_MIGRATION_FILES` — **25 files**.
- server/db/ensureCoreTables.ts** — runs at boot and, despite documenting that it *validates*, contains **7 CREATE TABLE IF NOT EXISTS** statements and auto-creates on miss (`:470-475`). SLP-09b proves this: booting the server grew the database from 702 to 717 tables.

The gaps between them, measured:

- `migrations/meta/_journal.json` has **1 entry** for a 171-file tree. Drizzle's journal is meaningless here; nothing replays `migrations/` in order.
- db/migrations/ is largely orphaned**: 228 files, of which 43 are `_gcc_` (applied by a separate `psql` loop in CI) and 4 are authoring (applied by `install-fresh`). **The other ~181 are on no automated apply path**. `db/migrations/migrations_manifest.json` lists them and, per #1186, *"nothing consumes"* it.
- Starting the app mutates the schema** (§5.3.1 below), so two environments on the same image can diverge based on boot history.

5.3.1 What this produces in practice — proven by running it

`scripts/db/install-fresh.mjs` on an empty Postgres prints **✓ Application schema install complete** and delivers 702 tables / 572 policies, beating the claimed 687/557. On the way there it reports:

```
pass 3: applied=0 already-present=0 deferred=10 hard=0
• 10 file(s) left unapplied — ... "safe to skip for the app schema"
```

"Safe to skip" is false for at least four of the ten. Verified against the resulting DB:

SKIPPED MIGRATION	BLOCKED ON	PRESENT AFTER INSTALL?	NON-TEST SERVER FILES QUERYING IT
0011_ai_threads_title.sql	ai_threads	no	8
20260601_chat_message_metadata.sql	chat_messages	no	11
0004 / 0007_*	unified_documents	no	13
0016 / 0017_module3_*	cmc_source_objects	no	12
0006_regulatory_atoms.sql	cmc_projects	no	5
0008_critical_fk_delete_policies.sql	user_sessions	no	0

ai_threads and chat_messages appear in **no Drizzle schema at all**; their only creator is db/migrations/20260224_ai_trace_chain.sql, which is in the orphaned tree. Yet server/routes/chat/threads.ts:40,96,173, server/routes/chat/send-message.ts:102 and server/routes/conversation-thread-routes.ts:141 query them in raw SQL, and both modules **are mounted** (register-ai-routes.ts:2, register-clinical-intel-routes.ts:230).

README.md:25 calls the AnA chat surface *"the product."* On a correct from-scratch install, it queries tables that do not exist.

5.3.2 Fifteen schemas are missing after the supported install; five have no path at all

The installer creates audit, lumen, precedent, public, vault. Server code issues SQL against fifteen more that do not exist:

SCHEMA	TABLES REFERENCED	SITES	ROUTE FAMILY MOUNTED?
innovation		27	139 yes (register-advanced-platform-routes.ts)
cortex		23	29 service only
intelligence		14	51 —
regulatory_intel		11	32 —
regulatory_harmonization		9	23 —
clinical_ops		7	40 yes (register-regulatory-routes.ts)
intelligent_docs		7	24 yes (register-core-routes.ts)
signing		7	16 not mounted
compliance		7	11 —
labeling / site_intel		5 / 5	17 / 17 —
manufacturing		4	23 yes (register-regulatory-routes.ts)
ectd		4	14 —
predicate		4	7 —
core		1	9 —

Note predicate versus the created precedent — a **schema-name mismatch**, not just an absence.

Corrected after verification (Chapter 03, C2). install-fresh.mjs creates **none** of the 15 — confirmed live. But the script's own closing output, and CI (ci.yml:296, 354, 494), prescribe a follow-on db/migrations/*_gcc_*.sql psql loop that applies cleanly (43/43) and creates **9** of them (innovation, cortex, signing, manufacturing, compliance, labeling, site_intel, ectd, core). clinical_ops self-provisions at runtime (clinical-operations-routes.ts:113-214).

Schemas with no provisioning path anywhere in the repository: 5 — intelligence, intelligent_docs, regulatory_intel, regulatory_harmonization, predicate.

Two things sharpen rather than soften:

- **The route-family impact stands and was understated.** Even after the *full* documented install, at least four mounted route families still cannot serve a request: /api/intelligent-docs, /api/regulatory-precedent-intelligence, /api/harmonize, and /api/precedent-engine + /api/predicate-intelligence.

- **The operator hazard is real.** `install-fresh.mjs` does not run the gcc loop itself, so a buyer following the script's advertised "one supported path" gets **all 15** missing.

Nothing in CI detects this, because `check-unbacked-tables.mjs` verifies that a `CREATE` exists *somewhere in the repo*, not that the file is on an apply path.

5.4 Why the proof-tier tests did not catch this

They are excellent (Chapter 08) and they are aimed elsewhere. `tests/schema-contract/` applies **real migration files** to PGlite and asserts the resulting schema — proving each migration is *internally* consistent and re-runnable. It does not assert that the applied set is *complete* against what the application queries. That is the missing test, and it is straightforward to add: the check this audit ran (`evidence/fresh-install-gap.mjs`) is ~150 lines and could run in CI against a throwaway database.

5.5 Remediation, in order

#	ACTION	GATE	EFFORT	ACCEPTANCE TEST
1	Add a fresh-install completeness gate to CI: provision an empty DB, run <code>install-fresh.mjs</code> , diff every schema and table referenced in server SQL against what exists. Fail on any gap.	G1	days	The gate fails today on 15 schemas; it must pass.
2	Make <code>install-fresh.mjs</code> fail loudly on unapplied migrations instead of printing  and calling them "safe to skip".	G1	hours	Empty DB + a deliberately broken migration → non-zero exit.
3	Fix the Schedule-of-Events tenant arbiter (tenant column in the unique index, <code>organization_id</code> in the SET list, 404 when <code>resolve ProjectType</code> returns null).	G1	hours	Two-org integration test: org A cannot upsert org B's schedule. Model it on <code>tests/schema-contract/cmc-module3-tenant-arbiter.contract.test.ts</code> .
4	Audit the remaining 114 ON CONFLICT sites and every Drizzle upsert on a tenant-bearing table.	G1	weeks	A contract test per tenant-bearing arbiter.
5	Retire or wire the 181 orphaned db/migrations/ files ; make the manifest authoritative or delete it.	G1	weeks	Every <code>.sql</code> file is either on an apply path or in <code>_legacy/</code> .
6	Move <code>ensureCoreTables</code> ' 7 <code>CREATE TABLE</code> s into migrations; make boot validate only .	G2/G3	days	Booting twice against a fresh DB leaves the table count unchanged.
7	Complete the requestDb(req) migration for the remaining 81 route files, then flip <code>RLS_ENFORCE=on</code> .	G1	months	<code>RLS_ENFORCE=on</code> in staging with all golden journeys green, plus a cross-tenant probe returning zero rows.
8	Reconcile the 140 duplicate table definitions , starting with any whose definitions disagree.	G2	weeks	<code>ci:duplicate-table-ddl</code> baseline reaches 0.
9	Add policies to the 21 RLS-enabled-no-policy tables; decide explicitly on the 118 with RLS off.	G3	days	No table is RLS-enabled without a policy outside the 6-entry allowlist.

Item 7 is the long pole and the one that actually closes the tenant-isolation risk. Items 1 through 3 are days of work and remove the sharpest edges — a fresh deployment that silently half-works, and a live cross-tenant write path.

Chapter 06 — The AI layer: gateway, ANA and grounding

Verdict: this is the platform's most differentiated asset and its most concentrated engineering risk. The governance around the model is unusually thoughtful. The thing being governed is an 18,304-line file with 697 tools and no output UI.

6.1 Scale, measured

COMPONENT	MEASURE
<code>server/services/ana/AnaToolExecutor.ts</code>	18,304 lines, 700 <code>registerToolHandler()</code> calls, 697 unique tool names
<code>server/services/ana/AnaToolDefinitions.ts</code>	2,632 lines, ~25 spread tool families
<code>server/services/ana/</code> domain modules	~200 files
<code>server/services/ana-ri/</code>	55 files (orchestrator 1,899 lines, command-executor, enforcement, scope-guard, part11-governance, claim-grounding, evidence-validation)
<code>server/services/ai-gateway/</code>	<code>gateway.ts</code> ~2,245 lines + policy (557), pii-screen, promptInjection, audit, retry-policy, reasoning, providers, embeddings
HTTP surface	<code>/api/ana-ri</code> 30 endpoints, <code>/api/ana</code> 68, plus 6 more prefixes

For context, `AnaToolExecutor.ts` is roughly 1.2% of the entire server codebase in one file.

6.2 What is genuinely well built

The gateway fails closed in production. With no provider configured, `gateway.ts:531-537` throws rather than serving demo content, and says why in-line:

"Fail closed in production: serving demo-mode ("[KNOWN]"placeholder) regulatory text from a keyless prod deploy would silently present fabricated content as a real AI response."

Outside production it degrades to a deterministic response. That is precisely the right shape for a regulated product, and it cites the prior forensic audit that prompted it.

Provider governance is real. A single governed egress point with only 3 baselined bypasses (`anthropic-client.ts` , `openai-client.ts` , `openai-service.ts`), enforced by `ci:gateway-bypass` . Multi-provider routing across Anthropic, OpenAI, Azure, Bedrock, Vertex, Moonshot and a local OpenAI-compatible endpoint, with **per-provider residency and zero-retention flags** enforced in `ai-governance/approved-models.ts` . The zero-retention defaults are set honestly — `false` for the shared frontier APIs under the comment *"Flip to true only once a signed zero-retention agreement is actually in force"*, `true` for the enterprise-hosted deployments that carry ZDR contractually.

Prompt-injection defence is better-reasoned than most. `promptInjection.ts` requires **both** an override verb **and** a meta-reference to the model's own instructions before flagging — specifically so that regulated prose like *"disregard the previous draft"* does not false-positive. It is severity-tiered, fails closed on `high` for **indirect** content (RAG chunks, tool output, assistant history) rather than only user input, and uses bounded gaps to prevent ReDoS. Its header is honest: *"This is a heuristic layer, not a guarantee."*

Anti-fabrication is enforced in code, not policy. Reject-lists matching `/lorem ipsum/i` and "coming soon" appear in `governed-ana-execution.ts:43,47` , `ana/verifiedSeal/helpers.ts:77` and `ai-actions/handlers/run-validation.ts:249` . The `ana-ri/` layer carries a dedicated `claim-grounding.ts` , `evidence-validation.ts` , `scope-guard.ts` and `part11-governance.ts` . The governing rule stated in the repo's own strategy docs — that ANA *calls a deterministic engine for all numbers and governed content* and only adds natural-language framing — is the correct architecture for this problem.

Anthropic server-side tools are off by default. `web_search` , `web_fetch` and `code_execution` are each env-gated (`ANA_ENABLE_WEB_SEARCH` / `_WEB_FETCH` / `_CODE_EXECUTION`) and disabled unless explicitly enabled.

6.3 The concentrated risks

6.3.1 One file, 697 tools

`AnaToolExecutor.ts` at 18,304 lines is a single point of failure for review, merge conflict and blast radius. Any change to it touches a file no reviewer can hold in their head, and a mistake in tool dispatch affects all 697 capabilities. The codebase already shows the strain:

`AnaToolDefinitions.ts:2544-2548` carries a **dedupe filter** guarding against `cdiscTools.ts` re-registering `run_cdisc_pipeline / generate_define_xml` already present in `EXTENDED_REGULATORY_TOOLS`, with the comment *"Remove once the duplicate is resolved at source."* The count confirms it: **700 registrations, 697 unique names**.

Decomposition has visibly started (the git history shows *"refactor(ana): extract ... tool defs (decomposition tranche 5/6)"*), which is the right direction.

6.3.2 Per-tool authorization is the open question

With 697 tools reachable through a chat surface, the security-relevant question is not whether the *endpoint* is authenticated — `/api/ana-ri/*` is, and live probing confirmed the boundary holds — but whether each **tool handler** re-checks tenant scope and role at execution time, or trusts the calling context. Given that Chapter 05 establishes RLS is inert and that `check-tenant-isolation.mjs` cannot see Drizzle query-builder calls, a tool that queries without an `organization_id` predicate has no backstop.

This audit did not sample all 697 handlers. It is flagged as the **highest-value remaining review target**, and the acceptance test is mechanical: enumerate every handler that issues a query, and assert each one takes tenant scope from the request context rather than a parameter.

6.3.3 The UI cannot render what the engine produces

Chapter 09 documents this from the frontend side; it belongs here too because it is an AI-layer gap, not merely a UI one. The shipping AnA rail consumes **three** modules from `components/ana/` — `useAnaChat`, `useGovernedAction`, `GovernedActionSignoff`. The 28 result panels built to render structured tool output (`SEComparisonTable`, `ReadinessGatePanel`, `CrLPremortemPanel`, `WarGameReport`, `ConcordancePanel`, `VerificationPanel`, `SealBadge`, ...) plus `ToolPicker` and `ModelEffortPicker` are unreferenced.

So the product has 697 governed, grounded, deterministic tools and — on the surface users actually reach — no way to pick one, no way to see a structured result, and no way to see the verification and seal state those panels were built to display. **The grounding work is real and largely invisible to the user**, which is both a product gap and a competitive one: honest uncertainty is only a differentiator if the buyer can see it.

6.3.4 The PII gate ships in observe mode

`.env.example:109` — `AI_PII_ENFORCEMENT=audit`. The classifier runs and records; it does not refuse. Combined with correctly-declared `ZERO_RETENTION=false` on the shared frontier APIs, the shipped default path allows protected content to reach a non-ZDR provider and be logged rather than blocked. One-line fix; see Chapter 04 §4.7 item 5.

6.3.5 SSRF on model-supplied URLs

`ssrfGuard.ts` exists and is applied to the connector family, but not at `citation-verification-service.ts:108` or the `AnaToolExecutor.ts` fetch sites (`:5933`, `:15233`, `:15339`). Citation verification is precisely the path that fetches URLs originating in model output — the untrusted-URL case the guard was written for.

6.3.6 Grounding is asserted more than it is measured

`eval:grounding` and `ai:eval-doc-quality` scripts exist. **Neither is invoked by any workflow** (Chapter 11 §11.7). `ci:reasoning-tier-ga-readiness` and `ci:reasoning-tier-uat-evidence` are likewise orphaned. So the claim that ANA degrades honestly rather than fabricating — which the repo's own strategy documents call *"the actual moat"* — is architecturally supported but **not continuously measured**. For a buyer, an unmeasured moat is a hypothesis.

6.4 Priority actions

#	ACTION	SEV	GATE	EFFORT
1	Audit tenant scope and RBAC across all 697 tool handlers. Enumerate every handler that queries, assert each derives tenant scope from request context.	P0	G1	2 weeks
2	Flip <code>AI_PII_ENFORCEMENT</code> to <code>block</code> .	P1	G2	hours
3	Apply <code>ssrfGuard</code> to citation verification and the <code>AnaToolExecutor</code> fetch sites.	P1	G1	days
4	Wire the grounding evals into CI — <code>eval:grounding</code> and <code>ai:eval-doc-quality</code> exist and run nowhere. Make the moat measurable.	P1	G2	1 week
5	Resolve the duplicate tool registration at source; add a CI assertion that registration count equals unique-name count.	P2	G2	days
6	Continue the <code>AnaToolExecutor</code> decomposition. 18,304 lines in one file is a standing review and merge hazard.	P2	G2	months
7	Surface the result panels. Wire <code>ToolPicker</code> , <code>ModelEffortPicker</code> and the verification/seal panels into the shipping rail — or delete 13,000 lines. Today the platform's best differentiator is invisible.	P2	G2	weeks
8	Expand the prompt-injection corpus beyond 20 cases, especially for indirect content, and treat it as a living adversarial suite.	P2	G2	weeks

Chapter 07 — 21 CFR Part 11 / Annex 11 and the compliance claims

Verdict: the engineering is stronger than the paperwork, and the paperwork is what regulators and enterprise buyers audit.

This is an unusual and, for a buyer, favourable shape of problem — but it is decisive for Gate G3, and one part of it is a live legal exposure at Gate G2.

7.1 What is genuinely built — and it is good

The tamper-evidence machinery here is real cryptography, not a `created_at` column relabelled as an audit trail. Verified by reading the implementation:

Two independent layers.

- 1. **Public SHA-256 hash chain** — `server/services/audit/chain.ts`. Each entry hashes `{action, actor_id, target, payload_hash, occurred_at, previous}`. Critically, `computeAuditChain` issues its predecessor lookup as `SELECT ... ORDER BY occurred_at DESC, id DESC LIMIT 1 **FOR UPDATE** ( chain.ts:56-58 )` **inside the caller's transaction**. That is anti-fork locking — it prevents two concurrent writers from both chaining off the same predecessor and silently branching the chain. Most implementations that call themselves hash chains do not do this.
- 2. **Secret-keyed HMAC-SHA256 seal** — `server/services/audit/audit-hmac-seal.ts`. The rationale is written down in `auditSealPosture.ts:1-14`: *"Because the hash algorithm is public, an attacker who can rewrite the whole table could recompute a self-consistent SHA-256 chain; the keyed seal is what makes forgery infeasible."* Correct threat model, correctly addressed.

A fail-closed production boot matrix (`auditSealPosture.ts:24-33`) — this is the detail that separates real controls from theatre:

CONDITION	BEHAVIOUR
Key present, ≥32 bytes	Boots, seals active
Key present but too short	Refuses to boot — no escape hatch
Key absent + <code>AUDIT_SEAL_ACCEPT_UNSEALED=true</code>	Boots with a prominent structured warning naming the accepted risk
Key absent, no flag	Refuses to boot

Its header names the hole it closes: *"a production deploy that simply never set `AUDIT_HMAC_KEY` would SILENTLY run with the tamper-evident guarantee disabled."*

Supporting machinery, all present: `audit-integrity-service.ts`, `chainIntegrityMonitor.ts` (started at `server/startup/services.ts:237`, stopped cleanly at `shutdown.ts:78`), `server/jobs/auditChainIntegritySweep.ts`, `signedAuditExport.ts`, `audit-archive.service.ts`, `server/lib/tamper-proof-audit.ts` (632 lines), SIEM export at `server/routes/admin/audit-siem.ts`. API-layer immutability via `applyImmutabilityPolicy / isImmutableAuditPath` in `server/startup/middleware.ts:144-150`, which 403s any `DELETE` or `*bulk-delete` under five Part-11 prefixes.

A populated traceability matrix. `docs/validation/TM-CORTEX-001-PART11-TRACEABILITY.md` maps **12 controls (P11-01 ... P11-12)** from regulation clause → implementing module path → *named automated verification*. Example: P11-06 (§11.10(e), deletes of regulated records are audited) → `hard-delete` plus `audit_events` insert in one transaction across four named route files → verified by `scripts/ci/check-regulated-delete-audit.mjs`, which runs **blocking** at `ci.yml:140`, plus contract tests. This is the artifact a regulator asks for, and it is filled in rather than templated. Its "Open items (tracked, not yet closed)" section is candid, including the admission that the delete → audit contract tests are *mocked* and a DB-backed test is deferred.

E-signature surface exists and is tested: `server/routes/esignature.ts`, `server/routes/part11-compliance.ts`, `server/services/part11/{signing-authority,resolve-signer-role}.ts`, `server/services/compliance/signature-manifestation.ts`, an `electronic_signatures` table, migrations `db/migrations/054_gcc_part11_audit.sql` and `080_gcc_21cfr_part11_compliance.sql`, UI at `Part11SignModal.tsx / Part11Console.tsx`, and eight dedicated test files.

Verified strength, in one sentence: if a buyer's concern is "did they actually build tamper-evident audit", the answer is yes, and better than most.

7.2 The system is not validated — G3 fails here, and not marginally

21 CFR Part 11 §11.10(a) requires **validation of systems** to ensure accuracy, reliability and consistent intended performance. docs/validation/ contains a complete, well-structured protocol set: VMP, IQ, OQ, PQ, VSR, ISO 14971 risk analysis, HIPAA/FDA security assessment, cloud vendor qualification, and the Part 11 traceability matrix.

Every execution record is blank. Counted mechanically (☐ , ☐ , PENDING , ☐ %):

PROTOCOL	UNEXECUTED MARKERS
OQ-CORTEX-001-OPERATIONAL_QUALIFICATION.md	158
IQ-CORTEX-001-INSTALLATION_QUALIFICATION.md	122
PQ-CORTEX-001-PERFORMANCE_QUALIFICATION.md	100
VSR-CORTEX-001-VALIDATION_SUMMARY_REPORT.md	99
CSRA-CORTEX-001-HIPAA_FDA_SECURITY_ASSESSMENT.md	66
VQ-CORTEX-001-CLOUD_VENDOR_QUALIFICATION.md	16

The Validation Summary Report — the document that would certify the system — reads:

```
**Version:** 1.0.0-DRAFT
**Status:** 🚧 DRAFT - REQUIRES VALIDATION REVIEW BEFORE PRODUCTION USE
| 1.0.0-DRAFT | 2025-01-24 | Engineering | Initial draft | PENDING |
```

Its IQ/OQ/PQ approval checkboxes are unticked; Executed By lines are blank; overall status is ☐ PENDING ☐ % .

So: the protocols are written and the system has never been qualified against them. This is not a code defect and cannot be fixed by engineering. It is a programme of work — typically weeks of execution with a named validation owner, plus change control thereafter. It is the single largest determinant of the G3 timeline.

7.3 The Part 11 controls that are built but not running

Three controls exist in code and are connected to no scheduler:

CONTROL	EVIDENCE	CONSEQUENCE
Audit-chain verification	scripts/run-chain-verify.mjs prescribes crontab entries in its own header (30 2 * * * , 0 4 * * 0). audit:verify:24h and audit:verify:full are npm scripts; no workflow and no in-repo scheduler invokes either.	Tamper evidence is only evidence if someone checks it. Today that is an unwritten operator duty.
Record retention	server/jobs/retentionCron.ts has no scheduler caller; the only entry point is the manual CLI server/bin/run-retention.ts , which itself appears in unreferenced-modules-baseline.json .	§11.10(c) protection of records throughout the retention period is unenforced. The policy doc docs/operations/audit-log-retention-policy.md is marked "Draft for compliance review."
Audit archival	audit:archive — orphaned npm script.	Long-term retention to cold storage is manual.

The in-process chainIntegrityMonitor and auditChainIntegritySweep do run (the sweep defaults on in production when AUDIT_TRAIL_ENABLED=true), so this is a gap in the scheduled/attestable verification layer rather than a total absence.

7.4 The signature-binding gap

server/services/ai-actions/handlers/promote-artifact.ts:245-246 carries, in the code:

```
TODO(compliance): require electronic_signatures record ... before flipping status to 'approved'
```

Artifact promotion to approved records an approver name, role and reason, but binds no signatureId , no manifestHash , and no electronic_signatures row. Under §11.70, signatures must be linked to their records such that they cannot be excised, copied or transferred; under §11.50, the signed manifestation must carry printed name, date/time and meaning. An approval that records only a name in a status field

satisfies neither.

This one is a code defect and is fixable in days, not weeks. It should be fixed before any qualification run, because qualifying the current behaviour would qualify the gap.

7.5 The claims register — where marketing outruns code

This is the part that is a **G2** problem, not just G3, because it is a representation made to customers.

`SECURITY.md:39-52` states, unqualified:

CLAIM	VERDICT	BASIS
"21 CFR Part 11 compliant audit trails"	✗ Unsupported	The audit chain is real, but §11.10(a) requires validation and the system is unvalidated (§7.2). "Compliant" is not available as a word here. "Built to support Part 11 workflows" is.
"SOC 2 Type II controls"	✗ Unsupported	No SOC 2 report, auditor, control matrix or observation window exists anywhere in the repository. The only occurrences are aspirational mentions in planning and competitive documents. A SOC 2 Type II claim without a report is the single most likely item to end an enterprise security review badly.
"All data encrypted at rest (AES-256)"	⚠ Partially supported	<code>server/services/security/field-encryption.ts</code> provides field-level encryption for specific fields. That is not whole-database encryption at rest, which is a property of the storage layer (e.g. RDS/Neon), not of this application. As written the claim overstates what this codebase provides.
"ISO 14971 risk management"	⚠ Partially supported	<code>RA-CORTEX-001-ISO14971_RISK_ANALYSIS.md</code> exists and there is a <code>risk</code> app, but the risk file is itself unexecuted in places.
"HIPAA-ready data handling"	✅ Supported, and correctly hedged	"Ready" is the honest word. <code>server/utils/logger.ts:1-26</code> redacts HIPAA identifiers (<code>mrn</code> , <code>patient_id</code> , <code>subject_id</code> , <code>dob</code> , <code>ssn</code>) before Pino with a nested-key walker, plus <code>observability/redaction.ts</code> and a telemetry-redaction test.
"Rate limiting on all endpoints"	⚠ Partially supported	Rate limiting exists (<code>rateLimiter.ts</code> , <code>redisRateLimiter.ts</code> , referenced in 58 files) and is applied per-prefix, not universally. Also: when Redis is unavailable it silently degrades to in-memory, which is per-instance and therefore not a cluster-wide limit.

The team has already demonstrated it knows how to fix this class of error. `PRODUCT_READINESS_ASSESSMENT.md:99-103` documents blocker #7 — "FDA 21 CFR Part 11 Compliant" on the live signup page — resolved by softening to "Built to support FDA 21 CFR Part 11 workflows." That is exactly the right correction. It was never applied to `SECURITY.md` .

This is a one-hour edit and it is the highest return-on-effort item in the entire audit. Until it is done, the product is making two unsupported compliance representations in a file named `SECURITY.md` , which is precisely where a customer's security reviewer will look first.

7.6 GDPR / PHI / data residency

Better than expected, and worth crediting:

- **Log redaction is centralised and correct** — every log line passes `redactContext` before Pino, using a nested-key walker rather than Pino's fixed-path `redact.paths` .
- **AI residency is a first-class concept** — `.env.example` carries per-provider residency and zero-retention flags (`AI_BEDROCK_RESIDENCY=us` , `AI_VERTEX_RESIDENCY=us,eu` , `AZURE_OPENAI_RESIDENCY=us,eu` , `*_ZERO_RETENTION`), enforced in `server/services/ai-governance/approved-models.ts` .
- **GDPR services exist** — `gdprComplianceService.ts` , `globalComplianceEngine.ts` .

One shipped default undercuts it, and it is a one-line change:

- **AI_PII_ENFORCEMENT=audit** (`.env.example:109`) — the PII gate *observes* rather than *blocks*. For a platform whose users paste clinical narratives, the default should be `block` .

The adjacent zero-retention flags are, by contrast, **correctly set and worth crediting**: `OPENAI_ZERO_RETENTION` and `ANTHROPIC_ZERO_RETENTION` default `false` (`:65-66`) under the comment "Flip to true only once a signed zero-retention agreement is actually in force", while `AI_BEDROCK_/AI_VERTEX_/AI_AZURE_ZERO_RETENTION` default `true` because those deployments carry ZDR contractually. Declaring a retention guarantee you do not hold would be the compliance defect; declining to is the right call.

The exposure is the **interaction** between the two: with ZDR honestly `false` and the PII gate in `audit` mode, protected content can reach a non-ZDR provider and be recorded rather than refused. Flipping the PII default closes it without touching the ZDR flags.

7.7 What this means for the gates

GATE	STATUS ON COMPLIANCE GROUNDS
G1 · External pilot	Not blocked by Part 11. Non-regulated data does not require validation. The <code>SECURITY.md</code> overclaims should still be corrected before external eyes see the repo.
G2 · Paying commercial	Blocked, cheaply. The unsupported "SOC 2 Type II" and "Part 11 compliant" claims are a contractual and security-review exposure. Cost to clear: hours.
G3 · GxP / submission-grade	Blocked, expensively. Requires: executing IQ/OQ/PQ with a named validation owner and signed VSR; binding e-signatures in <code>promote-artifact.ts</code> ; scheduling audit-chain verification, retention and archival; closing the traceability matrix's own open items (PDF/A conformance, DB-backed delete → audit test); and a real SOC 2 engagement if that claim is to be kept. Cost to clear: months, mostly non-engineering.

The encouraging read for a buyer: **none of the G3 gap is architectural**. The hard part — building tamper-evident audit that survives scrutiny — is done and done well. What remains is qualification, scheduling and honest wording, which is the recoverable failure mode.

Chapter 08 — Quality, tests and CI

Verdict: the tests that exist are unusually good; the gates around them are unusually easy to pass. Both halves matter.

8.1 What was executed

Not estimated — run, on this machine, against the freshly installed database.

SUITE	COMMAND	RESULT
Proof tier — tests/schema-contract + tests/golden-journeys	vitest run	17 files · 171 tests · 171 passed · 0 skipped · 116s
Security — server/___tests___/security + prompt-injection + SAML	vitest run	40 files · 264 tests · 264 passed · 0 skipped · 20s
Production build	npm run build	exit 0 · 20.06s · 24 MB dist/
Typecheck at project heap (6,144 MB)	tsc --noEmit	OOM crash after 379s
Typecheck at 24 GB heap	tsc --noEmit	exit 2 · 2 errors

435 tests passed and zero were skipped across the two suites that matter most. That is a real result and it should carry weight.

8.2 The proof-tier suites are the best asset in this repository

tests/schema-contract/ (15 files) and tests/golden-journeys/ (3 journeys + harness) do something most codebases never attempt: they apply the real migration files from disk to an in-process PGLite database and assert against the resulting schema.

The harness docstring names the exact failure it was built to prevent:

"the operating-system unit tests call vi.mock('.../db') ... They pass while asserting nothing about the schema — mocks accept any column name and any enum value. That is how conflicts C-1, C-2 and C-7 survived undetected."

It also explicitly contrasts itself with server/db/pglite-harness.ts, which hand-mirrors DDL and can therefore drift.

Observed in the run: cmc-module3-tenant-arbiter.contract.test.ts asserting that "source objects ... no longer let one tenant rewrite another's canonical CMC input" — a regression test written directly against the P0 fixed in #1186. artifacts-relkind.contract.test.ts proving the artifacts migration is re-runnable, tolerates a pre-existing VIEW owning the name, and serves "the reader's exact query" and "the writer's exact statement, including its ON CONFLICT." drop-draft-safety.contract.test.ts naming each table a destructive draft would drop and the shipped file that still reads it.

This is what mature engineering looks like. Both suites run blocking at ci.yml:103.

One gap worth naming: these suites prove migrations are internally consistent. They do not prove the migration set is complete — which is exactly the hole this audit fell through in Chapter 05, where a from-scratch install left 15 schemas and several core tables uncreated while every contract test passed.

8.3 Test posture, quantified

MEASURE	VALUE
Test files (product, excluding skill fixtures)	1,428
<code>it()</code> / <code>test()</code> cases	13,972
<code>describe()</code> blocks	4,135
Suppressed (<code>describe.skip</code> / <code>it.skip</code> / <code>todo</code>)	42 — very low
<code>server/services</code> directories with ≥ 1 test	124 / 203 (61%)
...at full depth including nested dirs	149 / 413 (36%)
E2E specs (Playwright)	30

Three runners, deliberately partitioned: Vitest 4.1.7 (server + integration + shared), Jest 29.7 (client jsdom only), Playwright (E2E). `client/jest.config.js:25-45` derives its ignore list by reading each test file and skipping anything that imports `vitest` — a real fix for a real cross-runner collision, documented inline.

CI now stands up `pgvector/pgvector:pg15` before `npm test` (`ci.yml:236-311`) with an honest comment: the safety-critical RLS/tenant-isolation/audit/migration suites *"EXECUTE here instead of self-skipping on a missing DB (they previously 'passed' by skipping — false assurance, GA testing finding)."* Catching and fixing that class of self-deception is a strong signal.

8.4 Coverage is configured, then switched off

`vitest.config.ts:47-52` sets thresholds: **lines 70 · branches 60 · functions 70 · statements 70**.

`ci.yml:314-388` — the job titled `Coverage (advisory)` — overrides all four to **0** on the command line and sets `continue-on-error: true` :

```
npx vitest run --coverage --coverage.thresholds.lines=0 --coverage.thresholds.functions=0 \
  --coverage.thresholds.branches=0 --coverage.thresholds.statements=0
```

`@vitest/coverage-v8` is not a declared dependency — it is `npm install --no-save` 'd transiently in CI. There is no `test:coverage` npm script despite a CI comment referring to one. **No coverage number is enforced anywhere in this repository.**

The comment is at least honest about it. But combined with 39% of service directories having no test at all, a buyer cannot infer coverage from "the tests pass".

8.5 E2E is not a pull-request gate

30 Playwright specs exist in `tests/e2e/`. `ci.yml` does not run them. They execute only in `beta-founder-proof.yml`, triggered by `workflow_dispatch` and a weekday 9am cron. A change that breaks the login flow or the primary workspace can merge with every PR check green.

8.6 The gates that cannot fail

Detailed in Chapter 11; summarised here because they belong to the quality story:

GATE	WHY IT CANNOT FAIL
Typecheck (<code>ci.yml:231</code>)	Counts <code>/error TS/</code> and never checks tsc's exit code. tsc OOMs at the 6,144 MB cap the gate itself sets → 0 matches → pass. Proven by execution. With adequate heap it reports 2 errors from PR #1180, merged the day before this audit. Corroborated in CI — see §8.6.1.

8.6.1 The gate observed passing in CI on a commit that contains type errors

The audit's own pull request (#1189) provided an unplanned control experiment.

`ci.yml:231` runs `npm run ci:typecheck:no-regression` — the exact script analysed above. That job **completed with conclusion success** (run `30378548693`, 16:40:54 → 16:46:36, 5m42s) on a commit whose tree contains the two `TS7016` errors in `server/services/ana/__tests__/{council-tool,deep-investigation}.test.ts`.

Those errors are deterministic: they arise from importing `scripts/db/migration-set.mjs`, a local `.mjs` file with no declaration, under `noImplicitAny` with `allowJs` unset. Nothing about a CI runner changes that outcome. So one of two things happened:

1. **tsc did not complete** — the same OOM reproduced locally at the same 6,144 MB cap — and the gate read 0 errors from a crash log and passed; or
2. tsc completed, saw those 2 errors, and the gate passed anyway with `2 > 0`.

The second is impossible given the script's logic (`errorCount > baselineCount → exit 1`).

What is proven, and what is inferred. Proven: the gate contains no exit-code check; at the configured cap tsc OOMs and the gate then reads zero errors; with adequate heap tsc reports 2 errors in files this audit did not touch; CI ran that script on that tree and went green. Inferred, strongly: CI's tsc crashed rather than completed. The audit reports the inference as an inference — but under either branch, **the gate went green over a tree that does not typecheck**, which is the finding.

8.6.2 The lint gate observed passing on 6,268 warnings

The same CI job's log ends with:

```
✖ 6268 problems (0 errors, 6268 warnings)
```

and the job succeeded. This is direct confirmation of the mechanism described above: `npm run lint` is a bare `eslint .` with no `--max-warnings`, and only 13 rules are set to `error`. **6,268 warnings is not a gate result; it is a number nobody is reading** — and it excludes `client/src/**` entirely, so the real figure is unknown. | **Per-PR ESLint** (`pr-checks.yml:99`) | `npx eslint $FILES --max-warnings 0 \\|` `echo "Lint warnings found"` — `\\|` `echo` swallows the exit code. || **Repo-wide lint** (`ci.yml:221`) | `npm run lint` is a bare `eslint .` with no `--max-warnings`; only 13 rules are `error`, the rest `warn`. || **Semgrep** (`semgrep.yml:30`) | `continue-on-error: true` at job level. || **Trivy config scan** (`ci.yml:796`) | `continue-on-error: true`. (The Trivy *filesystem* scan is blocking.) |

One gate that does work, for contrast. `danger.yml` retries `npx danger ci` three times and then `exit 1`, and the `Danger` commit status was observed as `failure` on this audit's own PR head — a real red signal, correctly wired. It is worth naming because it sharpens the point: the repository is not incapable of building blocking gates. It has one, on **pull-request line count**. The gates that cannot fail are the ones covering type safety, lint, SAST and IaC misconfiguration. The loudest check on this PR is the least consequential one.

And the linting hole that produced real security findings: `eslint.config.js:34` ignores `client/src/**` **entirely** — 871 files, 191,327 lines — plus `scripts/**` at `:46`. That is why `react/no-danger` never flagged the unsanitized `dangerouslySetInnerHTML` sinks fed by streamed LLM output.

8.7 Type safety is nominal

tsconfig.json:3-4 sets "strict": true, "noImplicitAny": true — genuinely on. But:

PATTERN	SERVER (SRC)	CLIENT/SRC	SHARED	
: any / as any / <any> / any[]		8,184	527	126
as unknown as		305	62	—
@ts-ignore		12	0	—
@ts-expect-error		9	1	—

862 distinct server source files contain at least one `any`, and `@typescript-eslint/no-explicit-any` is **not enabled**, so none of them is linted. Two files are excluded from typechecking outright (`tsconfig.json:35-36`): `client/src/contexts/AuthContext.tsx` and `.jsx` — **the auth context is not typechecked**.

`@ts-ignore` discipline, by contrast, is excellent: 21 suppressions across ~700K lines.

The honest summary: `strict: true` plus a 0 baseline is real, but a large share of that 0 is purchased with `any`, which `strict` cannot see — and the gate that would have policed the rest is not working.

8.8 Supply chain and CI hygiene

- **Zero of 137 GitHub Actions uses: references are SHA-pinned** — all floating tags (`actions/checkout@v4` ×49). `terraform-compliance.yml:22-38` already carries `TOD0(GA-blocker)` comments acknowledging this and noting the Checkov action was previously on `@master`. `pr-checks.yml:22` still uses the deprecated `returntocorp/semgrep-action@v1`.

- **Dependencies are current, not stale** — React 19.2.5, Express 5.2.1, TypeScript 5.6.3, Vite 6.4.3, Vitest 4.1.7, Drizzle 0.45.2, helmet 8.1.0, esbuild 0.28.1, with 12 pinned security `overrides`. Only laggard: `zod ^3.23.8`.
- **npm-audit allowlist reduced 27 → 1** with `npm ls` proof required per entry — the strongest governance artifact in the repo (Chapter 11 §11.2).
- **130 npm scripts, 55 referenced by a workflow, 75 orphaned** — including `audit:verify:24h`, `audit:verify:full` and `audit:archive`, which are Part 11 controls.
- **`.replit-ci.yml` is dead** — a 3.4 KB GitLab-CI-shaped file in a GitHub Actions repo, referencing a root `jest.config.js` that does not exist, while `docs/guides/REPLIT_README.md:167` still presents it as live.

8.9 Priority actions

#	ACTION	EFFORT	WHY FIRST
1	Make the typecheck gate check <code>tsc.status</code> ; raise the heap cap	1 hour	Until this is fixed no quality claim in this repo is verifiable, including the favourable ones.
2	Fix the 2 type errors from PR #1180 (add a <code>.d.ts</code> for <code>migration-set.mjs</code> or convert it)	1 hour	Restores the baseline to a true 0.
3	Remove <code> echo</code> from <code>pr-checks.yml:99</code>	15 min	Restores the per-PR lint gate.
4	Re-enable ESLint on <code>client/src/**</code> , at minimum <code>react/no-danger</code> and the security rules	days	This exclusion is directly responsible for the XSS findings in Chapter 04.
5	Enforce a coverage floor — start at the current measured number, ratchet	days	A floor that only ratchets up beats a 70% target that is overridden to 0.
6	Run E2E on PRs, even a smoke subset	days	A broken login can currently merge green.
7	SHA-pin all GitHub Actions	hours	Already self-identified as a GA blocker.

Chapter 09 — Frontend, navigation and UX honesty

Verdict: the backend breadth is real and the front door is not. The most damaging defect in the product is a control that looks like it works and silently discards the user's data.

9.1 The attach button discards every file — G1 blocker

`client/src/concept2cure/v2/Shell.tsx`, the AnA composer — the product's primary interaction surface, which `README.md:25` describes as "the product. Every capability is invoked through it."

```
:422 const [files, setFiles] = React.useState<string[]>([]);           // strings, not File objects
:428 const addFiles = (fl: FileList | null) => {
:430   setFiles((f) => [...f, ...Array.from(fl).map((x) => x.name)]); // keeps ONLY the name
      };
...
:453 if (!t && !files.length) return;
:454 onSend(agent ? `[Agent] ${t}` : t || `Attached ${files.length} file(s)`);
```

Two file inputs are wired (`:710` documents, `:718` images), the send button enables on attachment alone (`:754`), and chips render with individual remove buttons (`:679-685`). The affordance is complete and convincing.

What actually happens: the browser reads the `FileList`, keeps each `File.name` as a string, throws the bytes away, and posts the literal sentence "Attached 1 file(s)" to the model. No `FormData`, no upload, no reference the backend could resolve.

Failure scenario. A regulatory affairs lead drags in a 40-page predicate device summary and asks "what does this say about substantial equivalence?" The model receives "Attached 1 file(s)" and answers from nothing — fluently, because that is what models do. The user believes the answer is grounded in their document. **In a regulatory product this is the worst possible failure mode: not an error, but a confident answer about a document the system never saw.**

A working path already exists — `client/src/concept2cure/hooks/useChatUpload.ts` posts to `POST /api/chat/upload`, which is mounted with multer at `server/routes/chat.ts:85`, and it is used elsewhere (`ProjectHome.tsx:301`). This is a wiring gap, not a missing capability. **Effort: ~1 day.**

9.2 The product has almost no navigable front door

As of HEAD (`576ec5d`, the day of this audit), `client/src/concept2cure/v2/registryModel.ts`:

<code>RAIL_PRIMARY</code> destinations (<code>:116-122</code>)	5 — Chats, Projects, Communication Center, Apps, Settings
<code>NAV_HIDDEN</code> entries (<code>:125-171</code>)	40 (42 literal, <code>tasks</code> and <code>vault</code> duplicated)
Registered UI surfaces	96 (44 base + 52 ui-v2)
Reachable from the global rail	5 (5.2%)
Reachable from in-app <code>onNav()</code> calls	15 distinct ids
Reachable only by typed URL or <code>%K</code>	~85

The demotion is deliberate and documented (`registryModel.ts:91-115` cites a design constitution), and a five-item rail is a defensible *design* choice. The problem is what got demoted: `vault`, `submission-center`, `artifacts-center`, `document-authoring`, `device-510k`, `device-cer`, `ectd-coauthor`, `csr-workflow`, `cmc`, `global-ri`, `quality`, `safety-narrative` — i.e. **most of what the platform sells**.

%K is a weak backstop. `Shell.tsx:960,982-984` matches only `label` and `notes`, and `.slice(0, 8)`. An empty query lists the first 8 surfaces in registry order. So a user must already know a surface's label to find it.

One offering has no front door at all. The translation workspace has 31 backend service files, a mounted route (/api/translation , register-inline-routes.ts:403), a 719-line v2 surface and a 6-file module tree — and **zero production importers** for either frontend tree, and no translation id in either registry. A complete, mounted, shipped capability that no user can reach.

9.3 Data honesty — genuinely well handled, with residue

This deserves credit before criticism. v2/dataConnect.tsx implements an explicit honesty contract — liveGet(path, fixture) returning {data, sample, error} , plus a <SampleTag> — under the stated rule "GAP RULE: never present fabricated data as live."

PATTERN	SITES	
useLiveRows — live data or an honest EmptyState, no fixture fallback		97
useLive(path, FIXTURE) — falls back to a fixture behind a sample pill	7 (in Review.tsx , AdminAccess.tsx , BiopharmaProject.tsx x2, BiopharmaSpecialty.tsx , ClientPortal.tsx , Registrations.tsx)	

The de-mock campaign described in PRODUCT_READINESS_ASSESSMENT.md:23-27 largely happened — this is one of the repo's self-claims that **survives** checking. Residual fixture arrays remain in fixtures/review-data.ts , admin-data.ts , commcenter.ts , submission.ts and project3-data.ts .

The codebase also contains **anti-fabrication scanners** — reject-lists matching /lorem ipsum/i and "coming soon" in governed-ana-execution.ts:43,47 , ana/verifiedSeal/helpers.ts:77 and ai-actions/handlers/run-validation.ts:249 — and deliberate 501 s where invented numbers used to be (qc.routes.ts returns notImplemented:true for Certificate-of-Analysis generation and batch release, replacing stubs that previously returned {released:true} unconditionally). **Choosing a 501 over a fabricated success is the right call and is rare.**

A further example of the same instinct, found in a code comment at Shell.tsx:437-445 : a previous version fetched GET /api/coauthor?surface=... under a comment calling it a HARD RULE — "There is no such endpoint ... that request 404'd on every render of every surface, forever." They found it, fixed it, and wrote down what happened. That is the behaviour of a team that can be trusted to act on this audit.

9.4 Dead code is the dominant structural problem

Verified by resolving every relative and @/ import in client/src and checking for external importers:

TREE	FILES	LOC	EXTERNAL IMPORTERS
11 legacy module mini-apps (pdev , biopharma , insights , authoring , cmc , translation , submission , risk , labeling , tasking , intelligence , communication)	173	~25,000	none
Dead v2/surfaces/ (incl. the entire Editor* family)	22	7,174	none
components/ana/	35	13,329	only 3 modules consumed
Total	~230	~45,000	

concept2cure/quality/ is the sole surviving legacy tree (QualityModule.tsx:16).

The components/ana/ number is the striking one: **697 tools are registered server-side**, and the shipping rail consumes exactly three modules from the ANA UI — useAnaChat , useGovernedAction , GovernedActionSignoff . Ana.tsx (1,189 lines), ChatView , Composer , ToolPicker , ModelEffortPicker and all 28 result panels (WarGameReport , SEComparisonTable , ReadinessGatePanel , CrlPremortemPanel , Part11SignModal , ...) are unreferenced. So there is no tool picker, no model/effort picker, and no renderer for structured tool output on the surface users actually use.

Dead code is mostly tree-shaken from the bundle, so this is a **review-surface and security-surface** problem rather than a performance one — and Chapter 04 shows exactly how it bites: four of the unsanitised dangerouslySetInnerHTML sites are in this dead code, which made the security picture look worse than it is, while the one that mattered sat elsewhere.

9.5 Accessibility and internationalisation

- **Some real effort:** 862 `aria-*` attributes and 365 `role=` usages across `client/src`.
- **i18n is aspirational.** `GLOBAL_LANGUAGE_STRATEGY_2026-06-29.md` exists, `locales/` directories exist, and **13 client files** actually call a translation function. For a platform whose pitch includes global submissions and a translation workspace, the UI is effectively English-only.
- **Not verified.** No headless browser walk was completed (Chapter 01 §1.4), so keyboard traps, focus management, ARIA-live behaviour on streaming AI output, and colour-only status encoding were **not** tested. The repo's own `HUMAN_FACTORS_AND_USABILITY_SPEC` forbids colour-only encoding; whether the shipped UI complies is an open question this audit does not answer.

9.6 Bundle

`npm run build` succeeds in 20.06s. `V2App` ships **1.56 MB** of JS and **694 KB** of CSS in single chunks, with `ZenRouter` at 530 KB. Vite emits its large-chunk warning. Heavy for first paint; a performance item, not a correctness one.

9.7 Priority actions

#	ACTION	SEV	GATE	EFFORT
1	Fix or remove the attach button — wire it to the existing <code>useChatUpload</code> path. A control that lies about accepting data is worse than no control.	P0	G1	1 day
2	Give the pilot a front door — put the surfaces the pilot uses in <code>RAIL_PRIMARY</code> ; mark the rest experimental rather than URL-only.	P0	G1	3 days
3	Surface the translation workspace or disable its backend — do not ship a mounted offering with no UI.	P1	G1	days
4	Improve <code>%%K</code> : search <code>apiPrefixes / group /aliases</code> , raise the 8-result cap, show all on empty query.	P1	G1	1 day
5	Delete the ~45,000 lines of dead client code.	P2	G2	1 week
6	Resolve the ANA UI split-brain: either wire the panels or delete them. 697 tools with no output renderers is a product gap, not just dead code.	P2	G2	weeks
7	Remove the 7 residual <code>useLive(path, FIXTURE)</code> fallbacks or confirm <code>SampleTag</code> renders in every one.	P2	G2	days
8	Run an accessibility audit against the repo's own HF spec.	P2	G2	1 week
9	Decide on i18n: complete it or stop claiming it.	P3	G2	weeks

Chapter 10 — Infrastructure, deployment and operability

Verdict: one deployment path is genuinely well engineered. Eight others exist alongside it, most of them dead. Nothing in the repository would let an on-call engineer recover from a data-loss event, because no recovery has ever been written down or rehearsed.

10.1 Nine deployment targets, one coherent

TARGET	ARTIFACTS PRESENT	COHERENT?
AWS ECS Fargate	Dockerfile.optimized + .github/workflows/deploy-aws.yml (30 KB) + terraform/ (28 .tf, enviro-ments/{production,staging}, 8 modules)	✔ Yes — the real one
Google App Engine	app.yaml (nodejs20, F2)	◦ orphaned
Vercel	.vercelignore, docs/deployment/VERCEL_DEPLOY.md	◦ orphaned
Replit	.replit, replit.nix, .replit-ci.yml	● dead (\$10.5)
Helm	charts/concept2cure-app/, charts/trialsage-cer/	◦ unreferenced by any workflow
Stray Helm values	helm/values-local.yaml — a values file with no chart beside it	● confusing
Raw Kubernetes	infra/k8s/bff-with-predicate-shadow.yaml	◦ one-off
docker-compose	docker-compose.yml + .beta / .e2e / .staging variants	✔ local/dev, legitimate
Python side-services	services/ (Celery + api.py), workers/artifact-compute/	⚠ partially wired

The ECS path is well built and deserves credit. deploy-aws.yml uses OIDC credentials rather than long-lived keys, pushes to ECR, pins task-definition revisions, runs schema migration as a one-off ECS task that gates the service roll (deploy-api and deploy-worker both needs: migrate), and finishes with a smoke-test job. That is a correct, careful pipeline.

Dockerfile.optimized is likewise good: multi-stage, non-root appuser, and a HEALTHCHECK pointed at /readyz rather than /api/health, with the reasoning written in a comment immediately above it — "a down database or a positively-verified missing schema."

That comment is the problem. Chapter 14 §G1-2 shows /readyz returns 200 ready:true over a database missing auth_users, auth_refresh_tokens, roles, permissions, user_roles and licenses, because three branches of server/startup/services.ts never set schema readiness. The container orchestrator's only health signal is a probe that does not detect the failure it was repointed to detect. The infrastructure is correct; the thing it depends on is not.

The seven orphaned targets are not free. An operator inheriting this repo sees nine ways to deploy and no statement of which is real. docs/guides/REPLIT_README.md:167 actively presents a dead one as live.

10.2 Disaster recovery does not exist

Searched the entire docs/ tree for disaster-recovery, RPO, RTO, backup, restore, postmortem and incident documents. There are none.

CAPABILITY	STATE
DR plan	✗ absent
RPO / RTO defined anywhere	✗ absent
Backup procedure	✗ absent
Restore ever rehearsed	✗ never
Incident history / postmortems	✗ none

The only acknowledgement is in the seller's own readiness document (`PRODUCT_READINESS_ASSESSMENT.md:123-125`), as an **unchecked** owner action: `"Rehearse backup / restore before first data... Confirm Neon PITR/branching is on; run one real pg_dump`

- restore into a scratch branch so there's a proven way back."

This is a G2 blocker and it is not negotiable. You cannot sign an availability or data-durability commitment you have never tested. It is also, notably, one of the cheaper items on the remediation list — a rehearsal and a runbook is weeks, not months.

Two aggravating factors specific to this codebase:

1. **Booting the application mutates the schema** (SLP-09b — `ensureCoreTables.ts` creates 7 tables at boot; verified 702 → 717). A rollback to a previous image therefore cannot be assumed to leave the database in a previous state.
2. **A from-scratch rebuild is known-incomplete** (Chapter 05 §5.3.1) — so "restore from backup" and "reprovision from source" are both unproven paths today.

10.3 Observability — good primitives, unproven pipeline

CAPABILITY	STATE
Structured logging	✔ Pino via <code>server/utls/logger.ts</code> , with centralised PHI/credential redaction using a nested-key walker (Pino's fixed-path <code>redact.path</code> would not suffice). Genuinely well done.
Logger adoption	⚠ 463 server files import the logger; 156 still contain <code>console.log</code> , 702 occurrences . Tracked in <code>docs/LOGGING_MIGRATION.md</code> ; <code>no-console</code> is <code>warn</code> , not <code>error</code> .
Metrics	✔ Prometheus-style, 15+ domain metric modules, <code>/api/metrics</code> behind auth or <code>METRICS_TOKEN</code>
Tracing	✔ OpenTelemetry (<code>services/telemetry/opentelemetry.ts</code>)
Error tracking	⚠ Sentry wired on both server and client — but <code>SENTRY_DSN</code> is an unchecked go/no-go item in the seller's own list. It has never been proven to page a human.
Health probes	⚠ <code>/healthz</code> , <code>/readyz</code> , <code>/api/health</code> , <code>/api/health/full</code> exist and are mounted fast-path before security middleware — good design, undermined by §10.1
Alerting	❌ <code>infra/alerts/orchestrator.yml</code> — one file, 6 alerts, one subsystem . The submission-orchestrator gateway pages at <code>>0</code> in 10 minutes with an explicit regulatory-hazard rationale, which is exactly right — and nothing else in the platform has any alert at all.
SLOs / error budgets	⚠ referenced in three documents, never consolidated
Runbooks	✔ 5 in <code>docs/runbooks/</code> + 12 in <code>docs/operations/</code> — reasonable coverage, none for DR

The honest summary: an on-call engineer has good logs and metrics for a system they are already looking at, and almost no way to be told to look. Alerting covers one subsystem; paging has never been proven end-to-end.

Also worth flagging from the boot log: the application's own scheduler reported `{"overall":"failing"}` for its security posture at startup, unprompted. Whatever that aggregate is measuring, nothing surfaces it to an operator.

10.4 Background work is in-process, not isolated

- **6 cron schedules** start inside the `listen()` callback (`server/index.ts:229-249`). Two are on by default (external-intelligence sweep, schedule-of-events sweep); the audit-chain integrity sweep defaults on in production when `AUDIT_TRAIL_ENABLED=true`.
- **Only 2 Bull queues exist** (`cer-generation`, `c2c-report-subscription-sweep`). There is no dedicated worker process and no separate worker container command — **everything runs in-process with the API**. A heavy report generation competes with request serving, and scaling the API scales the schedulers with it.
- `initializeParallelServices` uses `Promise.allSettled`, so a subsystem that fails to start degrades **silently**. Combined with each `register-*.ts` route family being wrapped in try/catch, a production deploy can come up missing a whole route family or a background service and report healthy.
- **3 of 5 `server/workers/` modules have no importer**; `jobs/retentionCron.ts` has no scheduler caller at all (a Part 11 retention control — Chapter 07 §7.3).
- Redis is optional everywhere: absent, the rate limiter silently degrades to **in-memory**, which is per-instance and therefore not a cluster-wide limit. That is a correctness gap in any multi-instance deployment, and `SECURITY.md` claims *"rate limiting on all endpoints."*

10.5 Dead configuration that actively misleads

`.replit-ci.yml` is a 3.4 KB **GitLab CI** file (`workflow.rules` , `$CI_PIPELINE_SOURCE` , `$CI_COMMIT_BRANCH`) sitting in a GitHub Actions repository. It references a root `jest.config.js` **which does not exist** (the real one is `scripts/jest.config.js`) and declares dev/staging/prod deploys to `*.trialsage.com` via `scripts/deploy-{dev,staging,prod}.sh` that nothing invokes. Nothing in the repo references it except `docs/guides/REPLIT_README.md:167` , which presents it as live. The repo's own GA-readiness audit already flagged it.

10.6 CI/CD hygiene

Covered in Chapter 08 and Chapter 11; the infrastructure-specific items:

- **Zero of 137 GitHub Actions uses: references are SHA-pinned.** `terraform-compliance.yml` carries `TODO(GA-blocker)` comments acknowledging it and noting the Checkov action was previously on `@master` .
- **21 workflows**, of which the Trivy *config* scan and Semgrep are advisory (`continue-on-error`) over acknowledged HIGH/CRITICAL IaC backlogs. The Trivy *filesystem* scan and Checkov (`soft_fail: false`) **are** blocking — a sensible split.
- `neon-preview-db.yml` carries **four** `continue-on-error: true` steps and invokes `npm run test:unit --if-present` — **a script that does not exist**, so it silently no-ops.

10.7 Priority actions

#	ACTION	SEV	GATE	EFFORT
1	Fix <code>/readyz</code> so the container healthcheck detects the failure it was repointed to detect (Chapter 15 item 0.5)	P0	G1	4 h
2	Write and rehearse DR — RPO/RTO, a real <code>pg_dump</code> + restore into a scratch branch, a runbook. Account for boot-time schema mutation.	P1	G2	3 weeks
3	Prove alerting pages a human , then extend beyond the one subsystem that has alerts	P1	G2	2 weeks
4	Make silent subsystem failure loud — <code>Promise.allSettled</code> plus per-family try/catch means a deploy can come up missing route families and report healthy. Fail the boot, or emit a metric an alert can fire on.	P1	G2	days
5	Delete the 7 orphaned deployment targets and <code>.replit-ci.yml</code> ; correct <code>REPLIT_README.md</code>	P2	G2	1 day
6	Move background work out of the API process — a dedicated worker container for the Bull queues and crons	P2	G2	weeks
7	Require Redis in production so rate limiting is cluster-wide, or correct the <code>SECURITY.md</code> claim	P2	G2	days
8	SHA-pin all 137 Actions; fix <code>neon-preview-db.yml</code> 's reference to the nonexistent <code>test:unit</code>	P2	G2	hours
9	Finish the logger migration (156 files, 702 <code>console.log</code> occurrences) and set <code>no-console</code> to <code>error</code>	P3	—	weeks

Chapter 11 — The suppression ledger

Every number here was re-derived by this audit from the files themselves (`docs/audit-2026-07/evidence/07-suppression-ledger.json`), not quoted from the repo.

A codebase's baseline files are the most honest thing in it. They are the list of defects the team has seen, decided not to fix yet, and told CI to stop complaining about. Read together they answer the question a buyer actually cares about: **how much of "the tests pass" is real?**

This repository has an unusually mature version of this practice — and an unusually large ledger.

11.1 The ledger

#	BASELINE / ALLOWLIST	WHAT IT SUPPRESSES	COUNT	GATE	BLOCKING?
1	<code>.typecheck-baseline.json</code>	<code>tsc --noEmit</code> errors	0 (from 2,598)	<code>ci:typecheck:no-regression</code>	✅ — but vacuous, see §11.3
2	<code>docs/reports/orphan-endpoints-latest.json</code>	API endpoints with no caller	556 of 916 (60.7%)	<code>audit:orphaned-endpoints:strict</code>	⚠️ threshold 600 — 44 slots of slack
3	<code>docs/reports/env-var-docs-baseline.json</code>	Env vars read by code, absent from <code>.env.example</code>	244	<code>check-env-var-docs.mjs</code>	❌ no npm script, no workflow — the gate does not exist
4	<code>scripts/ci/unreferenced-modules-baseline.json</code>	Modules nothing references	190	<code>ci:unreferenced-modules</code>	✅
5	<code>scripts/ci/unbacked-tables-baseline.json</code>	Tables queried by server code that nothing in the repo creates	89	<code>ci:unbacked-tables</code>	✅
6	<code>docs/reports/requestdb-coverage-baseline.json</code>	Route files still on the shared pool (this is what blocks RLS)	81	<code>audit:requestdb-coverage --strict-no-regression</code>	✅
7	<code>scripts/ci/duplicate-table-ddl-baseline.json</code>	Tables with conflicting <code>CREATE TABLE</code> across files	63	<code>ci:duplicate-table-ddl</code>	✅
8	<code>docs/reports/tenant-isolation-baseline.json</code>	Raw SQL on tenant tables with no tenant filter	25 (from 77)	<code>ci:tenant-isolation:no-regression</code>	✅
9	<code>docs/reports/route-mount-audit-baseline.json</code>	Duplicate mounts / multi-owner prefixes	8 errors + 7 warnings of 323 mounts	<code>ci:audit-route-mounts:no-regression</code>	✅
10	<code>migrations/.prefix-collisions-baseline.json</code>	Colliding migration number prefixes	13 files across 4 prefixes	<code>ci:migration-prefix-collisions</code>	✅
11	<code>docs/reports/no-mock-in-prod-routes-baseline.json</code>	Mock/simulated markers in production routes	11	<code>ci:no-mock-in-prod-routes</code>	✅
12	<code>scripts/ci/gateway-bypass-baseline.json</code>	Files allowed to build an LLM client outside the governed gateway	3	<code>ci:gateway-bypass</code>	✅
13	<code>docs/reports/repo-health-scan-latest.json</code>	Duplicate basenames / oversized files	249 groups + 84 files	<code>audit:repo-health:no-regression</code>	⚠️ ✅ blocking, but auto-refreshed on merge — see §11.4
14	<code>.trivyignore</code>	CVEs + IaC misconfigurations	8 (1 unpatched CRITICAL)	Trivy	✅ fs scan / ❌ config scan advisory
15	<code>scripts/ci/audit-with-allowlist.mjs</code>	npm-audit high/critical	1 (from 27)	<code>audit-with-allowlist</code>	✅
—	<code>scripts/.inline-state-baseline</code>	inline-state count	901 (bare integer, no schema)	—	❌ wired to nothing

Defect-class entries under active suppression: ~1,620.

The counts alone understate it, because the entries are not uniform. #5 (89 unbacked tables) is not style debt — the file's own header says each entry *"is a feature that either returns 500 (unguarded query) or silently no-ops."* #6 (81 route files on the shared pool) is the single item blocking tenant isolation from being switched on at all.

11.2 What the ledger does well — and it is genuinely well done

A buyer should not read the size of this ledger as carelessness. The discipline around it is better than most commercial codebases of this size:

- **Entries are framed as defects, not approved patterns.** `unbacked-tables-baseline.json` : *"Each is a defect awaiting a code-derived migration or a retirement, NOT an approved pattern. Shrink this file; never grow it."* `duplicate-table-ddl-baseline.json` : *"Each entry is a defect to be reconciled per ADR-0006."*
- **Entries are pinned to their referencing file set**, so a baselined defect cannot silently absorb new call sites.
- **#8 requires a written justification per entry**, and `scripts/ci/check-baseline-justifications.mjs` enforces *bidirectional* parity — a missing justification and a stale one both fail CI. It was ratcheted 77 → 25, and the accompanying note records that a scanner-accuracy pass *"revealed ~7 queries the old extractor could not see (several were real cross-tenant leaks, fixed the same day)."* That is exactly the right behaviour.
- **#15 is best-in-class.** A 195-line header defines the rules for adding an entry (prove exposure with `npm ls`), a stale-entry detector reports accepted-but-no-longer-flagged IDs, and the list was reduced 27 → 1. The single surviving entry (`GHSA-gv7w-rqvm-qjhr`, `esbuild`) is *kept even though npm audit no longer flags it*, because `npm ls esbuild --all` still shows three in-range copies. That is the correct call, reasoned correctly.
- **#1's `_history` array** narrates every ratchet step including one that went *up* by 20, with an explanation of why the PR's own contribution was -7. Honest debt accounting.

The problem is not the practice. It is that three of the gates are not doing what the ledger implies they are doing.

11.3 Gate #1 is vacuous — proven by execution

Full evidence in `evidence/00-live-proof-log.md` §LP-06. In short:

`scripts/ci/typecheck-no-regression.mjs` runs `tsc` with `--max-old-space-size=6144`, then counts `/error TS/` matches in the output. It **never checks the child process's exit code**. Run at that heap cap on a 15 GB host, `tsc --noEmit` spends 379 seconds thrashing and then dies:

```
FATAL ERROR: Ineffective mark-compacts near heap limit – JavaScript heap out of memory
```

A V8 fatal-OOM message contains zero `error TS` substrings, so `errorCount = 0`, which is `<= baseline (0)`, so the gate prints *"OK — error count 0 matches baseline"* and exits 0.

Re-run with a 24 GB heap and `tsc` completes with **exit code 2 and 2 real errors**, both introduced by **PR #1180, merged the day before this audit**. Both files are unmodified in the working tree, and this audit's own scripts are outside the `tsconfig include` list, so they are not the cause.

Consequence: the headline *"2,598 → 0 type errors"* is not currently a verified state. The gate passes because the compiler crashes. This is a one-line fix (`if (tsc.status === null || tsc.status > 1) fail`) and it should be the first thing done.

11.4 Gate #13 ratchets the wrong way

`.github/workflows/repo-health-baseline-refresh.yml` runs on every push to `concept2cure-v2`, regenerates `docs/reports/repo-health-scan-latest.json`, and **commits it back** with `[skip ci]`. The workflow header states the intent plainly: *"PRs branched after a merge therefore always see delta 0 — the gate stays strict and self-healing."*

Within a single PR that is true. Across trunk it means the baseline can only move **up**. `git log` shows it firing (`adb9734`, `1c1cc0a`, both `chore(repo-health): auto-refresh baseline after merge [skip ci]`). Current suppressed state: 249 duplicate-basename groups and 84 files over 1,500 lines. Nothing in the system can ever cause that number to fall, and nothing flags when it rises.

11.5 Gate #3 does not exist

`scripts/ci/check-env-var-docs.mjs` is a complete 240-line checker. It maintains `docs/reports/env-var-docs-baseline.json`, whose `_history` records three ratchet events on 2026-07-21 (260 → 256 → 244). There is a runbook for it at `docs/runbooks/env-var-documentation-gate.md`.

There is **no** `ci:env-var-docs` **npm script** and **no workflow invokes it**. A 7.5 KB baseline of 244 undocumented environment variables is being hand-maintained for a gate that has never run. Several of the undocumented variables are security-relevant — `METRICS_TOKEN`, `FIRECRAWL_WEBHOOK_SECRET`, `FHIR_ACCESS_TOKEN`, `ANA_ALLOW_NONPROD_CONTROL_PLANE`, `ALLOWED_TEST_ASSEMBLY_TENANTS`.

11.6 Gate #2 ships with deliberate slack

`audit:orphaned-endpoints:strict` runs `--threshold 600` against **556** actual orphans. Forty-four more dead endpoints can merge before anything fails. `Platform API Gateway` alone owns 375 of them.

11.7 Orphaned enforcement

Of **130** npm scripts, **55** are referenced by a workflow and **75** are not. Most of the orphans are the expected `:write-baseline` / `:strict` manual ratchet variants. These are not:

ORPHANED SCRIPT	WHAT IS THEREFORE NEVER ENFORCED
<code>audit:verify:24h</code> , <code>audit:verify:full</code>	21 CFR Part 11 audit-chain verification. <code>scripts/run-chain-verify.mjs</code> prescribes crontab entries in its own header; nothing in the repo schedules it.
<code>audit:archive</code> , <code>retention:run</code>	Audit archival and record retention — both Part 11 controls, both operator-dependent.
<code>ci:governed-export-routes</code> , <code>ci:governed-export-consequence-shape</code>	Governed-export integrity checks.
<code>ci:reasoning-tier-ga-readiness</code> , <code>ci:reasoning-tier-uat-evidence</code>	AI reasoning-tier GA gates.
<code>ci:report-branch-drift</code> , <code>ci:ui-kits</code> , <code>audit:dead-code</code> , <code>audit:bundle</code>	Drift, dead code, bundle size.
<code>test:submission</code> , <code>verify:submission</code>	Submission-centre verification.

Note `test:schema-contract` and `test:golden-journeys` also appear orphaned, but they are legitimately subsumed by `test:proof-tier`, which **is** invoked blocking at `ci.yml:103`.

11.8 The three CI gates that cannot fail

GATE	MECHANISM	EFFECT
Per-PR ESLint (<code>pr-checks.yml:99</code>)	<code>npx eslint \$FILES --max-warnings 0</code> <code> echo "Lint warnings found"</code>	The <code> echo</code> swallows the exit code. The per-PR lint gate cannot fail. The repo-wide <code>npm run lint</code> is a bare <code>eslint</code> , with no <code>--max-warnings</code> , so warnings pass there too.
Semgrep (<code>semgrep.yml:30</code>)	<code>continue-on-error: true</code> at job level	Advisory. The comment is candid: <i>"Ratchet to blocking once the backlog is triaged."</i>
Trivy config scan (<code>ci.yml:796</code>)	<code>continue-on-error: true</code>	Advisory, over an acknowledged backlog of HIGH/CRITICAL IaC misconfigurations. (The Trivy filesystem scan is blocking.)

Compounding this: `eslint.config.js:34` ignores `client/src/**` **entirely** — 871 files, 191,327 lines — with the note *"currently excluded because the UI is going through a separate styling/refactor pass. Re-enable once that lands."* `scripts/**` (199 files) is ignored at `:46`. Only 13 rules are set to `error`; the rest are `warn`.

That exclusion has a direct security consequence, documented in Chapter 04: the unsanitized `dangerouslySetInnerHTML` sinks fed by streamed LLM output sit in `client/src`, where `react/no-danger` could never have flagged them.

11.9 A factual contradiction between two suppression files

`.trivyignore:27-35` suppresses a react-router advisory and justifies it by asserting the app uses `react-router-dom` on "a couple of auth screens." It also instructs that the ID be added to `ACCEPTED_GHSA_IDS` in `scripts/ci/audit-with-allowlist.mjs`.

That sibling file documents having **removed the same entry twice**, each time after verifying: *"there is NO react-router import in client/src, server/ or shared/... no react-router entry in dependencies, devDependencies or overrides, and `npm ls react-router react-router-dom --all` returns nothing. The package is not installed."* Followed by: *"That is the SECOND time this exact advisory has been re-added with a usage claim that does not survive checking."*

The `.trivyignore` entry is the third instance. One of these two files is wrong about a checkable fact, and the mechanism for catching that already exists and was ignored.

Separately, `.trivyignore` suppresses **CVE-2026-45829 — a pre-auth RCE in chromadb 1.5.9** — correctly noting no patched release exists, and requiring confirmation that *"chromadb is not exposed to untrusted pre-auth network input."* **That confirmation is recorded nowhere in the repository.**

11.10 What this chapter means for the verdict

Two readings are available and both are true.

The generous reading, which is fair: this team writes down its debt, pins it, justifies it per entry, ratchets it down, and leaves comments naming the incident behind each gate. That is rarer and more valuable than a clean-looking repo with no ledger at all. The ledger is the reason this audit could move as fast as it did.

The buyer's reading, which is decisive: the ledger records ~1,620 known defects, its flagship gate passes only because the compiler runs out of memory, one gate has no runner, one ratchets upward by design, one ships with 44 slots of slack, three cannot fail, and the 21 CFR Part 11 audit-chain verification is an unscheduled npm script. The controls that would tell you the product is healthy are, in several load-bearing cases, not connected to anything.

Fixing the *gates* is days of work and should precede any other remediation, because until they work, no other claim about this codebase can be trusted — including the claims in this audit's favour.

Chapter 13 — Competitive rack-and-stack

Twelve offering categories, five closest competitors each — **66 competitor profiles**, researched live on the web with source URLs, and scored against a per-category rubric alongside this platform.

Method. Categories are derived from `shared/regulatory/app-registry.ts`, the codebase's own canonical offering taxonomy, so the comparison is against what is actually sold rather than what a slide claims. Competitor facts carry URLs; our scores carry `file:line`. Everything is scored on **what ships and is reachable** — a capability a user cannot navigate to does not win deals, and this platform currently surfaces 5 of 96 registered surfaces in its global navigation (Chapter 09).

Scorecard

CATEGORY	VERDICT	US	BEST COMPETITOR	GAP
Agentic AI assistant layer over regulatory work (life scienc...	 Credible challenger	3.2	3.9	-0.7
Medical device & IVD regulatory (510(k), De Novo, PMA) and ...	 Not competitive	2.1	4.2	-2.1
Regulatory intelligence & global market planning (life scie...	 Niche-viable	2.1	4.6	-2.5
EU MDR / IVDR clinical evaluation (CER / PER) software	 Not competitive	1.8	4.3	-2.6
Regulatory document authoring & AI co	 Not competitive	1.9	4.7	-2.9
Biostatistics, SAP authoring & statistical programming	 Not competitive	1.6	4.6	-3.0
Regulatory Information Management (RIM) & eCTD submission p...	 Not competitive	1.8	4.9	-3.2
Clinical study reporting (CSR) & medical writing automation	 Not competitive	1.5	4.7	-3.2
QMS: SOP / document control, CAPA, change control, deviatio...	 Not competitive	1.6	4.9	-3.2
eTMF and regulated document management / Vault DMS	 Not competitive	1.7	4.9	-3.3
Labeling, SPL and artwork management	 Not competitive	1.4	4.7	-3.4
Pharmacovigilance & drug safety (safety database of record,...	 Not competitive	1.1	5.0	-3.9

Verdict distribution:  Not competitive ×10 ·  Niche-viable ×1 ·  Credible challenger ×1

Across all twelve categories: us 1.8 / 5, best-in-category competitor 4.6 / 5.

How to read these numbers

A 1.8-versus-4.6 average and ten "not competitive" verdicts is a severe result, and it is severe **because of the lens, which was chosen deliberately**. Every dimension was scored on what *ships and is reachable today* — not on what is architected, coded, or nearly done. Three properties of this platform get punished hard by that lens, and all three are documented elsewhere in this audit:

1. **Reachability.** 5 of 96 registered surfaces are in the global navigation (Chapter 09). A capability a buyer cannot click to does not score, however good the code behind it is. Several categories here are scored near-zero on surfaces that demonstrably exist in the codebase.
2. **Validation.** Every IQ/OQ/PQ execution record is blank and the VSR reads `DRAFT` (Chapter 07). In this market that is not a deduction — it is disqualification. Multiple category analyses independently reached the same conclusion: **the product does not reach technical evaluation** without a qualification package, regardless of engine quality.
3. **Incumbency.** The comparators are Veeva, LORENZ, Certara, Oracle, MasterControl and Cytel — decades of install base, agency familiarity, and accumulated edge-case handling. A 4.6 average for "best in category" is what a mature category looks like.

So the scores measure procurement-readiness, not engineering quality. They are the right lens for a buyer and the wrong lens for judging the codebase, and this audit uses both: Chapters 04–11 assess the engineering, which is frequently strong.

The one number that matters most

The agentic AI layer scores 3.2 and is the sole "credible challenger" — the only category within striking distance of the leader (–0.7). Every other category is 2.1 or below.

That is a strategically decisive result, and it was reached independently of Chapter 16, which had already argued on code evidence that the AI/grounding layer is the platform's real moat. Two separate methods converging on the same conclusion is the strongest signal in this audit:

- **Where breadth was the thesis, breadth lost.** Competing against Veeva on RIM, Oracle on pharmacovigilance, or MasterControl on QMS means competing on install base and validation packages — the two things this platform most lacks. Those are –3.2, –3.9 and –3.2 gaps respectively, and no amount of engineering closes them soon.
- **Where governed AI was the thesis, it nearly won** — against competitors whose own AI is frequently announced-but-not-shipped.

The strategic reading is uncomfortable but clear: **the platform is priced and positioned as a 12-category suite, and it is competitive in one.** Concentrating on that one — and on the device/IVD category that scores next-highest at 2.1 and where the code is genuinely deep — is the difference between a viable challenger and a broad also-ran.

The named competitors

VENDOR	CATEGORIES WHERE IT IS A CLOSEST COMPETITOR
Veeva Systems	5 — Regulatory document authoring & AI co; Regulatory Information Management (RIM) & eCTD submission p...; eTMF and regulated document management / Vault DMS; Labeling, SPL and artwork management; Agentic AI assistant layer over regulatory work (life scien...
Certara	3 — Regulatory document authoring & AI co; Biostatistics, SAP authoring & statistical programming; Agentic AI assistant layer over regulatory work (life scien...
Weave Bio	3 — Regulatory document authoring & AI co; Regulatory Information Management (RIM) & eCTD submission p...; Agentic AI assistant layer over regulatory work (life scien...
Yseop	2 — Regulatory document authoring & AI co; Agentic AI assistant layer over regulatory work (life scien...
Rimsys	2 — Medical device & IVD regulatory (510(k), De Novo, PMA) and ...; Regulatory intelligence & global market planning (life scie...
Narrativa	1 — Regulatory document authoring & AI co
Peer AI	1 — Regulatory document authoring & AI co
LORENZ Life Sciences Group	1 — Regulatory Information Management (RIM) & eCTD submission p...
Certara (GlobalSubmit)	1 — Regulatory Information Management (RIM) & eCTD submission p...
EXTEDO (Cencora PharmaLex)	1 — Regulatory Information Management (RIM) & eCTD submission p...
Greenlight Guru	1 — Medical device & IVD regulatory (510(k), De Novo, PMA) and ...
Ketryx	1 — Medical device & IVD regulatory (510(k), De Novo, PMA) and ...
Veeva MedTech (Vault RIM / RegulatoryOne / QualityOne)	1 — Medical device & IVD regulatory (510(k), De Novo, PMA) and ...
MasterControl	1 — Medical device & IVD regulatory (510(k), De Novo, PMA) and ...
Celegence — CAPTIS / CAPTIS Copilot	1 — EU MDR / IVDR clinical evaluation (CER / PER) software
DistillerSR	1 — EU MDR / IVDR clinical evaluation (CER / PER) software
CiteMed	1 — EU MDR / IVDR clinical evaluation (CER / PER) software
Nested Knowledge — AutoLit	1 — EU MDR / IVDR clinical evaluation (CER / PER) software
Vespper	1 — EU MDR / IVDR clinical evaluation (CER / PER) software
Cytel	1 — Biostatistics, SAP authoring & statistical programming
Domino Data Lab	1 — Biostatistics, SAP authoring & statistical programming
SAS Institute	1 — Biostatistics, SAP authoring & statistical programming
Veristat	1 — Biostatistics, SAP authoring & statistical programming
Certara — CoAuthor	1 — Clinical study reporting (CSR) & medical writing automation
Yseop — Yseop Copilot	1 — Clinical study reporting (CSR) & medical writing automation
Narrativa — Clinical Atlas (CSR Atlas) / Navigator	1 — Clinical study reporting (CSR) & medical writing automation
AlphaLife Sciences — AuroraPrime RMA	1 — Clinical study reporting (CSR) & medical writing automation
Clinion — Clinion CSR Automation	1 — Clinical study reporting (CSR) & medical writing automation
Oracle Argus Safety (Oracle Life Sciences "Safety One")	1 — Pharmacovigilance & drug safety (safety database of record,...
ArisGlobal LifeSphere Safety (NavaX)	1 — Pharmacovigilance & drug safety (safety database of record,...
Veeva Vault Safety (with Vault Safety.AI and Veeva Safety Signal)	1 — Pharmacovigilance & drug safety (safety database of record,...

VENDOR	CATEGORIES WHERE IT IS A CLOSEST COMPETITOR
IQVIA Vigilance Platform	1 — Pharmacovigilance & drug safety (safety database of record,...
AB Cube SafetyEasy Suite (also distributed by EXTEDO)	1 — Pharmacovigilance & drug safety (safety database of record,...
Montrium	1 — eTMF and regulated document management / Vault DMS
TransPerfect Life Sciences	1 — eTMF and regulated document management / Vault DMS
Phlexglobal (a PharmaLex company)	1 — eTMF and regulated document management / Vault DMS
Florence Healthcare	1 — eTMF and regulated document management / Vault DMS
Medable	1 — eTMF and regulated document management / Vault DMS
Veeva Systems — Vault Quality (Vault QMS + QualityDocs + Training + Station Manager + Validation Management)	1 — QMS: SOP / document control, CAPA, change control, deviatio...
MasterControl — Quality Excellence	1 — QMS: SOP / document control, CAPA, change control, deviatio...
Dot Compliance — eQMS (QMS Xpress / Compliance Xpand / Enterprise Xact) with Dottie AI	1 — QMS: SOP / document control, CAPA, change control, deviatio...
Qualio	1 — QMS: SOP / document control, CAPA, change control, deviatio...
Greenlight Guru — Quality Management System (with Greenlight Guru AI)	1 — QMS: SOP / document control, CAPA, change control, deviatio...
Clarivate — Cortellis Regulatory Intelligence	1 — Regulatory intelligence & global market planning (life scie...
Citeline (Norstellia) — RegIntel	1 — Regulatory intelligence & global market planning (life scie...
RegDesk	1 — Regulatory intelligence & global market planning (life scie...
Freyr — Freyr GRI / freya.intelligence (Freyr IMPACT)	1 — Regulatory intelligence & global market planning (life scie...
Veeva Systems — Vault RIM (Registrations) + Vault AI	1 — Regulatory intelligence & global market planning (life scie...
Kallik	1 — Labeling, SPL and artwork management
Loftware	1 — Labeling, SPL and artwork management
ArisGlobal	1 — Labeling, SPL and artwork management
Freyr	1 — Labeling, SPL and artwork management
Esko (Veralto)	1 — Labeling, SPL and artwork management
GlobalVision / Schlafender Hase	1 — Labeling, SPL and artwork management
ArisGlobal (being acquired by Dassault Systèmes)	1 — Agentic AI assistant layer over regulatory work (life scien...
IQVIA	1 — Agentic AI assistant layer over regulatory work (life scien...

Per-category detail

- [Agentic AI assistant layer over regulatory work \(life scien...](#) —  Credible challenger
- [Medical device & IVD regulatory \(510\(k\), De Novo, PMA\) and ...](#) —  Not competitive
- [Regulatory intelligence & global market planning \(life scie...](#) —  Niche-viable
- [EU MDR / IVDR clinical evaluation \(CER / PER\) software](#) —  Not competitive
- [Regulatory document authoring & AI co](#) —  Not competitive
- [Biostatistics, SAP authoring & statistical programming](#) —  Not competitive

- Regulatory Information Management (RIM) & eCTD submission p... — ● Not competitive
- Clinical study reporting (CSR) & medical writing automation — ● Not competitive
- QMS: SOP / document control, CAPA, change control, deviatio... — ● Not competitive
- eTMF and regulated document management / Vault DMS — ● Not competitive
- Labeling, SPL and artwork management — ● Not competitive
- Pharmacovigilance & drug safety (safety database of record,... — ● Not competitive

Chapter 14 — Readiness verdict: the G1/G2/G3 gate ladder

The owner requires all three bars **now**. This chapter answers each separately, because they fail for different reasons, on different timescales, and to different people.

GATE	VERDICT	DISTANCE
G1 · External pilot (design partners, non-regulated data)	● NOT READY	2–4 weeks of focused work
G2 · Paying commercial customers	● NOT READY	2–4 months
G3 · GxP / submission-grade	● NOT READY	6–12 months, mostly non-engineering

The single most important sentence in this audit: none of the G1 gap is architectural. It is a small number of specific, locatable defects on top of a platform whose hard parts — tamper-evident audit, a default-deny auth boundary that empirically holds, schema-contract tests that apply real migrations to a real Postgres — are genuinely well built.

14.1 G1 · External pilot — ● NOT READY

Bar: no data loss, no cross-tenant leakage, honest empty and error states, no silently wrong regulatory output, and a human can complete the core journeys.

Blocking findings

#	FINDING	EVIDENCE	EFFORT
G 1- 1	A from-scratch install silently half-works. <code>install-fresh.mjs</code> prints  Application schema install complete while skipping 10 migrations it calls "safe to skip" and never creating 15 Postgres schemas — 9 of which a follow-on <code>psql</code> loop supplies, one self-provisions, and 5 have no provisioning path at all (Ch 03, C2). Four mounted route families (<code>innovation</code> , <code>clinical_ops</code> , <code>intelligent_docs</code> , <code>manufacturing</code>) cannot serve a request. <code>ai_threads</code> / <code>chat_messages</code> — queried by the mounted chat routes — do not exist.	Executed: <code>evidenc</code> <code>e/00-live-proof-l</code> <code>og.md</code> §LP-02	days
G 1- 2	/readyz returns green over a database missing <code>auth_users</code> , <code>auth_refresh_tokens</code> , <code>roles</code> , <code>permissions</code> , <code>user_roles</code> , <code>licenses</code> . Three branches of <code>server/startup/services.ts</code> (:92, :94, :99) never call <code>setSchemaReadiness</code> , so it stays <code>'unknown'</code> → rendered as <code>"skipped"</code> → does not fail the probe. <code>Dockerfile.optimized</code> points <code>HEALTHCHECK</code> here.	Executed: §LP-07	hours
G 1- 3	A live cross-tenant write path. <code>Schedule-of-Events</code> reproduces all four ingredients of the P0 fixed in #1186: unique index omitting the tenant column, <code>ON CONFLICT</code> arbitrating on it, <code>SET</code> omitting <code>organization_id</code> , URL-supplied id with the ownership check bypassed on a null result. Mounted behind <code>authenticateToken</code> only; <code>projects.id</code> is a global serial.	Chapter 05 §5.1.1 (static + adversarial; not demonstrated live)	hours to fix, weeks to sweep the other 114 sites
G 1- 4	Stored XSS on a reachable surface. <code>BatchDraft.tsx:490</code> renders unsanitized HTML built from a persisted document title/preview, and <code>derivePreview</code> (<code>batch-draft-routes.ts:104-111</code>) HTML-entity-decodes markup the editor had escaped, re-animating it. (Corrected — the original finding blamed <i>streamed model output</i> , which is dead code. Ch 03, C7.) Two-part fix: sanitize the sink and stop the decode.	Chapter 04 §4.2	hours
G 1- 5	The typecheck gate is vacuous , so no quality claim about this codebase is currently verifiable — including the favourable ones in this audit. <code>tsc</code> OOMs at the 6,144 MB cap the gate itself sets; the gate counts <code>/error TS/</code> and never checks the exit code.	Executed: §LP-06	1 hour
G 1- 6	Controls that look functional and do nothing. The AnA composer's attach button stores only file <i>names</i> and posts the literal text <code>"Attached N file(s)"</code> (<code>Shell.tsx:428-431</code>) — every attachment is silently discarded, while a real upload path exists and is used elsewhere.	Chapter 09	hours
G 1- 7	The product has no front door. As of HEAD, <code>RAIL_PRIMARY</code> has 5 destinations and <code>NAV_HIDDEN</code> has 40 (42 literal entries, 2 duplicated), leaving ~85 of 96 registered surfaces reachable only by typed URL or a command palette that matches labels only and caps at 8 results. At least one complete offering (translation) has a live, mounted backend and zero reachable UI.	Chapter 09	days (nav), weeks (coherence)

Not blocking G1, and worth saying plainly

- Tenant isolation being single-layer (RLS inert) is **acceptable for a non-regulated pilot with a handful of trusted design partners**, provided G1-3 and its siblings are fixed. It is not acceptable for G2.

- The application's own security self-check reporting `overall: failing` at boot is alarming in a demo but is a posture aggregate, not an exploit.

What "ready for G1" looks like

Fix G1-1 through G1-6. Pick the **five surfaces the pilot will actually use**, put them in the rail, and hide the rest behind an explicit "experimental" affordance rather than leaving them URL-only. Seed two organisations and run one cross-tenant probe to convert G1-3 from static-analysis to demonstrated-fixed.

Estimate: 2–4 weeks for a team already familiar with the codebase.

14.2 G2 · Paying commercial customers — NOT READY

Everything in G1, plus:

#	FINDING	EFFORT
G 2- 1	<code>SECURITY.md</code> makes two unsupported compliance claims — "21 CFR Part 11 compliant audit trails" (the system is unvalidated) and "SOC 2 Type II controls" (no report, auditor or control matrix exists anywhere in the repo). This is the first file a customer's security reviewer opens. The team already made this exact fix on the signup page and never applied it here. Highest return-on-effort item in the audit.	1 hour
G 2- 2	No disaster recovery. No DR plan, no RPO, no RTO, no rehearsed backup/restore, no incident history anywhere in the repository. <code>PRODUCT_READINESS_ASSESSMENT.md:123-125</code> lists rehearsing restore as an unchecked owner action. You cannot sign an availability commitment you have never tested.	weeks
G 2- 3	Tenant isolation must become two-layer. Completing the <code>requestDb(req)</code> migration for the remaining 81 route files and flipping <code>RLS_ENFORCE=on</code> is the long pole. Until then a single application-layer mistake is a cross-tenant breach with no database backstop.	months
G 2- 4	Entitlements enforcement is unverified server-side. Whether a locked module is blocked by the API or merely hidden in the UI determines whether tiering is real. (Covered by the deep-review fan-out; treat as open until proven with a direct API call as an unentitled tenant.)	days
G 2- 5	Observability will not support an SLA. Sentry is wired but <code>SENTRY_DSN</code> has never been proven to page anyone; alerting (<code>infra/alerts/orchestrator.yml</code>) covers one subsystem; 460 files still contain <code>console.log</code> alongside the structured logger.	weeks
G 2- 6	Security-review survivability gaps — unpatched chromadb pre-auth RCE with an unrecorded exposure determination, zero SHA-pinned GitHub Actions, upload hardening wired to 2 of 28 sites, <code>AI_PII_ENFORCEMENT</code> defaulting to <code>audit</code> , zero-retention defaulting to <code>false</code> .	weeks
G 2- 7	Coverage is unenforced and E2E is not a PR gate , so regressions in paid journeys can merge green.	weeks

Estimate: 2–4 months, dominated by G2-3.

14.3 G3 · GxP / submission-grade — NOT READY

Everything above, plus the finding that decides it:

The system has never been validated. `docs/validation/` contains a complete VMP / IQ / OQ / PQ / VSR / ISO 14971 / vendor-qualification set, and **every execution record is blank** — 158, 122, 100 and 99 unexecuted markers respectively. The Validation Summary Report reads  **DRAFT - REQUIRES VALIDATION REVIEW BEFORE PRODUCTION USE** , version `1.0.0-DRAFT` , approval `PENDING` . 21 CFR Part 11 §11.10(a) requires validation.

#	FINDING	EFFORT
G3-1	Execute IQ/OQ/PQ under a named validation owner; sign the VSR; establish change control	months (non-engineering)
G3-2	E-signatures are not bound to records. <code>promote-artifact.ts:245</code> carries <code>TOD0(compliance): require_electronic_signature</code> <code>s record ... before flipping status to 'approved'</code> . Approval records a name in a status field — satisfying neither §11.50 nor §11.70. Must be fixed <i>before</i> qualification, or qualification certifies the gap.	days
G3-3	Part 11 controls exist but are not scheduled. <code>audit.verify:24h</code> , <code>audit.verify:full</code> , <code>audit.archive</code> and <code>retention:run</code> are orphaned npm scripts; <code>retentionCron.ts</code> has no scheduler caller. Tamper evidence is only evidence if something checks it.	days
G3-4	Starting the application mutates the schema. <code>ensureCoreTables.ts</code> runs at boot with 7 <code>CREATE TABLE IF NOT EXISTS</code> statements — proven live (702 → 717 tables). Incompatible with change control: those tables are governed by a TypeScript file, not a reviewed migration.	days
G3-5	Close the traceability matrix's own open items — PDF/A conformance, and the DB-backed delete → audit test that is currently mocked.	weeks
G3-6	A real SOC 2 engagement, if that claim is to be kept rather than removed.	months

Estimate: 6–12 months. Most of it is qualification and process, not code.

14.4 Claims-versus-code register

Unsupported regulatory or security claims are treated as **P0-equivalent** because they are a legal and contractual exposure, not a bug.

CLAIM	WHERE	VERDICT
"21 CFR Part 11 compliant audit trails"	<code>SECURITY.md:41</code>	✗ Unsupported — chain is real; system is unvalidated
"SOC 2 Type II controls"	<code>SECURITY.md:52</code>	✗ Unsupported — no report, auditor or control matrix exists
"All data encrypted at rest (AES-256)"	<code>SECURITY.md:46</code>	⚠ Overstated — field-level encryption only; at-rest is a storage-layer property
"Rate limiting on all endpoints"	<code>SECURITY.md</code>	⚠ Overstated — per-prefix, and degrades to per-instance in-memory without Redis
"ISO 14971 risk management"	<code>SECURITY.md:50</code>	⚠ Partial — document exists, partly unexecuted
"HIPAA-ready data handling"	<code>SECURITY.md:51</code>	✓ Supported — correctly hedged; redaction is real
"687 tables · 557 RLS policies" from a fresh install	<code>PRODUCT_READINESS_ASSESSMENT.md:53</code>	✓ Verified — measured 702 / 572
" <code>/readyz</code> fails closed and names the missing tables"	<code>PRODUCT_READINESS_ASSESSMENT.md:84</code>	✗ Contradicted by execution — 200 <code>ready:true</code> over a DB missing auth tables
"~50 v2 surfaces now read real data, not fixtures"	<code>PRODUCT_READINESS_ASSESSMENT.md:23</code>	⚠ Largely true — 97 <code>useLiveRows</code> sites vs 7 residual fixture fallbacks
"Every one of the repo's other <code>ON CONFLICT</code> sites already scoped by org"	commit #1186	✗ Not accurate — 115 sites; Schedule-of-Events is a live counterexample
"0 type errors"	<code>.typecheck-baseline.json</code>	✗ Unverified — the gate passes because tsc crashes; a completing run reports 2
"ZenApp.tsx is the app entry (113 KB)"	<code>FEATURE_INVENTORY.md</code> , <code>AGENTS.md</code>	✗ False — the file does not exist
"AIOS-05 Tenant isolation — Pass "	<code>docs/reports/evidence-pack-2026-07-28.md</code>	✗ Contradicted — see §14.4.1
"AIOS-02 Policy enforcement — Pass — 55 CI gates registered"	same	⚠ Overstated — see §14.4.1
"AIOS-01 Lineage completeness — Pass "	same	⚠ Overstated — the cited evidence is 556 orphans out of 916 endpoints

14.4.1 The platform's own evidence pack marks failing controls as Pass

While this audit was running, a repo script (`scripts/audits/generate-evidence-pack.mjs`) auto-generated `docs/reports/evidence-pack-2026-07-28.md` against this very branch. It is committed here unmodified because it is the clearest single illustration of the pattern this audit keeps hitting: **controls are graded on whether a mechanism exists, not on whether it works.**

Three of its seven control statuses do not survive checking:

- **AI0S-05 Tenant isolation** — "Pass — tenant-isolation gate live with baseline ratchet ... 25 candidate findings tracked, no regression allowed." The gate is indeed live and the ratchet is real. But tenant isolation itself is **not** enforced: every RLS policy is inert (Chapter 05 §5.1), the gate covers 32 tables, cannot see Drizzle query-builder calls at all, and blanket-exempts `server/workers/` and `server/jobs/`. A green ratchet on a narrow scanner is being reported as an isolation guarantee.
- **AI0S-02 Policy enforcement** — "Pass — 55 CI gates registered." The 55 are enumerated from `package.json` script names, and the list includes manual ratchet variants — `:write-baseline`, `:strict` — which are **not gates** and are invoked by no workflow (Chapter 11 §11.7). Counting `ci:typecheck:write-baseline` as an enforced control while the gate it writes to passes on an OOM crash is the inversion in miniature.
- **AI0S-01 Lineage completeness** — "Pass — orphan-endpoint detector landed ... 916 endpoints, 360 consumed, 556 orphans." The detector landing is the pass criterion; the finding it produced — that 61% of the API has no caller — does not affect the grade.

To be fair to it, the pack is transparent about its own method (*"Items marked **Pass** are verified by static-text checks against the source tree"*) and marks genuinely-pending items as **Pending**. The defect is not dishonesty; it is that a static-text check for the presence of a control is being presented, in a document titled *Evidence Pack*, as evidence the control is effective. An auditor or acquirer reading it would be misled — which is why it belongs in this register rather than in a footnote.

14.5 The honest summary

A buyer should not read three red gates as "this is bad." Three things are simultaneously true, and the third is what matters:

1. **The engineering underneath is better than the compliance paperwork on top of it** — which is the rarer and far more recoverable failure mode. Rebuilding a tamper-evident audit chain takes quarters; executing a written OQ protocol takes weeks.
2. **The instrumentation that would tell you the product is healthy is, in several load-bearing cases, not connected to anything** — a typecheck gate that passes on a crash, a readiness probe that reports green over a broken schema, an installer that prints success while omitting 15 schemas, an env-var gate with no runner, ~1,620 baselined defects. This is why the audit weights *executed* proof over code reading, and why fixing the gates must come before fixing anything they were supposed to catch.
3. **The distance to G1 is weeks, not quarters** — seven specific, locatable defects. That is a very different proposition from a platform needing re-architecture, and it should be the primary input to any purchase decision.

Chapter 15 — Remediation plan, staged by importance

Sequenced so that each stage makes the next one *verifiable*. That ordering is not cosmetic: several of this platform's controls currently report success without doing their job, so fixing the instrumentation has to come before fixing what it was meant to catch — otherwise you cannot tell a real fix from another silent pass.

Every item carries an owner-type, an effort estimate, and an **acceptance test** — a concrete thing that must be true afterwards, so "done" is provable rather than asserted.

STAGE	THEME	CALENDAR	UNLOCKS
0	Make the instruments honest	2–3 days	Everything else becomes verifiable
1	Stop the bleeding	1–2 weeks	G1 · external pilot
2	Make it sellable	2–4 months	G2 · paying customers
3	Make it qualifiable	6–12 months	G3 · GxP

Delivered so far

Closed on branch `claude/codebase-audit-competitive-aet792` (PR #1189). Each row names the commit that closed it and the evidence that it is actually closed — the point of Stage 0 being that a fix asserted is not a fix demonstrated.

ITEM	COMMIT	PROOF
0.1 Typecheck gate inspects the exit code	d012635e0	TYPECHECK_HEAP_MB=128 → FAIL – tsc did not complete. exit status: 134 , exit 1 (previously "OK", exit 0). Clean run → errors found: 0 (tsc exit 0) , exit 0. The "0 type errors" baseline is a measured 0 for the first time.
0.2 The two real TS7016 errors	2f9d2d2	Renamed migration-set.d.ts → .d.mts . The original fix was inert: under moduleResolution: "node" a .mjs specifier resolves only to .mts / .d.mts and never consults .d.ts .
0.3 Per-PR lint gate can fail	1e5808d59	echo removed. Probed in server/ : an error → exit 1; warning-only → exit 0, so the 6,268-warning backlog still passes.
0.4 Installer fails loudly	this stage	Empty DB → exit 1 , naming 10 unapplied files, instead of  . See below.
0.5 /readyz fails closed	d8df70fc5	Five terminal branches — including the catch that runs when schema verification itself throws — never recorded a verdict, leaving 'unknown' , which was served as 200. Now 'unknown' and 'error' both fail. Auth/RBAC/licensing tables (auth_users , roles , permissions , user_roles , licenses) fail readiness by name. 15 tests; proven by reverting the catch alone and watching exactly that case go red.
1.4 Schedule-of-Events tenant arbiter	0f6fbcbfe	Arbiter is now (organization_id, project_id) and the narrow unique index is dropped , so ON CONFLICT (project_id) is no longer expressible. A composite FK to projects(id, organization_id) makes a cross-tenant schedule row impossible at the database level. Contract test reproduces the defect first against the old index. 10 tests.
1.5 Stored XSS in Batch Draft	b3e1e26ca	Closed at three independent layers: derivePreview no longer decodes < / > back into live markup, bdSample escapes everything it interpolates, and the sink runs the shared DOMPurify allowlist. 17 tests, asserting on the DOM rather than on substrings.
1.7 AnA attach button	271d43aa3	Uploads now go through useChatUpload → POST /api/chat/upload . A failed upload is never described as attached. 8 tests, including one asserting the real File reaches the FormData with non-zero size — which the old implementation could not have satisfied.
— Unsupported compliance claims	66529834a	"SOC 2 Type II" removed from SECURITY.md and the signup screen (no report of any type exists; the platform's own /api/part11/soc2/controls said so while the landing copy claimed otherwise). Blanket encryption-at-rest and "MFA enforced everywhere" likewise corrected. A new CI gate blocks their return.

Not yet closed from Stage 0/1: 0.6, 0.7, 0.8, 1.1, 1.2, 1.3, 1.6, 1.8, 1.9, 1.10, 1.11.

On item 0.4 — what the installer was hiding

The acceptance test above understates it. `install-fresh.mjs` did not merely mislabel unapplied migrations as "safe to skip"; it **printed the psql loop for the governed-content tree as advice and never ran it**, then declared success. A fresh install therefore produced a database with **no audit schema and no 21 CFR Part 11 tamper-proof audit trail** — and because the app boots without it (audit degrades non-fatally), nothing ever said so.

Measured on an empty Postgres, before and after:

	BEFORE	AFTER
Governed-content files applied	0 of 43	43 of 43
Tables in the audit schema	0	17
Unapplied raw migrations	10, called "safe to skip"	10, named , with the failure reason for each
Exit code	0, with  Application schema install complete.	1, with  Install INCOMPLETE — not reporting success.

`--allow-incomplete` is available for a deliberate partial install; it still names every gap and says the database is not production-ready.

Stage 0 — Make the instruments honest (2–3 days)

Nothing here is a feature. All of it is the difference between a green check that means something and one that does not.

#	ACTION	OWNER	EFFORT	ACCEPTANCE TEST
0. 1	Fix the typecheck gate. <code>scripts/ci/typecheck-no-regression.mjs</code> counts <code>/error TS/</code> and never inspects <code>tsc.status</code> . Add <code>if (tsc.status === null tsc.status > 1) → fail loudly</code> , and raise <code>--max-old-space-size</code> above the level at which tsc OOMs (6,144 MB is currently below it).	Platform	1 h	Kill tsc mid-run → the gate fails . Run clean → it reports the true count.
0. 2	Fix the 2 real type errors surfaced once tsc completes (TS7016 on <code>scripts/db/migration-se</code> <code>t.mjs</code> from PR #1180 — ship a <code>.d.ts</code> or convert the module).	Platform	1 h	<code>tsc --noEmit</code> exits 0; baseline is a true 0.
0. 3	Remove <code> echo</code> from <code>pr-checks.yml:99</code> so the per-PR lint gate can fail.	Platform	15 min	A PR with a lint error goes red.
0. 4	Make <code>install-fresh.mjs</code> fail loudly instead of printing  while calling unapplied migrations "safe to skip".	Data	2 h	Empty DB + a deliberately broken migration → non-zero exit.
0. 5	Fix <code>/readyz</code>. <code>server/startup/services.ts:92/94:99</code> return without calling <code>setSchemaReadiness</code> , leaving it 'unknown' → rendered "skipped" → probe stays green. Make unknown fail , and fail on the "important" table set, not only the 2 critical ones.	Platform	4 h	Boot against a DB missing <code>auth_users</code> → <code>/readyz</code> returns 503 naming it.
0. 6	Wire the env-var-docs gate. A 240-line checker maintains a 244-entry baseline for a gate no workflow invokes. Add the npm script and the CI step, or delete all three.	Platform	1 h	Adding an undocumented env var fails CI.
0. 7	Stop the repo-health baseline auto-ratcheting upward. <code>repo-health-baseline-refresh.yml</code> commits a refreshed baseline on every merge, so that debt can only grow. Freeze it and ratchet down deliberately.	Platform	2 h	Baseline cannot increase without a human commit.
0. 8	Lower <code>audit:orphaned-endpoints</code> <code>--threshold</code> from 600 to the actual count (556) so the 44 slots of slack close.	Platform	15 min	Adding a dead endpoint fails CI.

Why this is Stage 0 and not Stage 3. As of today the flagship quality gate passes because the compiler runs out of memory, the readiness probe reports healthy over a database with no auth tables, and the installer reports success while omitting 15 schemas. Until those three are fixed, no claim about this codebase can be trusted — including the favourable claims in this audit.

Stage 1 — Stop the bleeding → unlocks G1 (1–2 weeks)

#	ACTION	OWNER	EFFORT	ACCEPTANCE TEST
1. 1	Close the fresh-install gap. Create the 15 missing schemas (<code>innovation</code> , <code>cortex</code> , <code>intelligence</code> , <code>clinical_ops</code> , <code>intelligent_docs</code> , <code>signing</code> , <code>manufacturing</code> , <code>regulatory_intel</code> , <code>regulatory_harmonization</code> , <code>compliance</code> , <code>labeling</code> , <code>site_intel</code> , <code>ectd</code> , <code>predicate</code> , <code>core</code>) and their tables, or retire the code that queries them. Resolve <code>predicate</code> vs <code>precedent</code> .	Data	1 week	<code>fresh-install-gap.mjs</code> reports 0 missing schemas and 0 missing tables for mounted routes.
1. 2	Put <code>ai_threads</code> and <code>chat_messages</code> on an apply path. Their only creator is <code>db/migrations/20260224_ai_trace_chain.sql</code> , which nothing applies — while the mounted chat routes query them. The conversation surface is what <code>README.md:25</code> calls "the product".	Data	4 h	Fresh install → send a chat message end-to-end without a 500.
1. 3	Add a fresh-install completeness gate to CI. Provision an empty DB, run the installer, diff every schema/table referenced in server SQL against what exists. This audit's <code>fresh-install-gap.mjs</code> is ~150 lines and already does it.	Data	2 days	The gate fails on today's tree and passes after 1.1/1.2.
1. 4	Fix the Schedule-of-Events tenant arbiter — tenant column into the unique index, or <code>ganization_id</code> into the <code>SET</code> list, and 404 when <code>resolveProjectType()</code> returns null instead of proceeding.	Backend	4 h	Two-org integration test: org A cannot upsert org B's schedule. Model on <code>tests/schema-contract/cmc-module3-tenant-arbiter.contract.test.ts</code> .
1. 5	Sanitise <code>BatchDraft.tsx:490</code> through the existing <code>renderSafeMarkdown</code> choke point.	Frontend	2 h	A drafted section containing an <code>onerror</code> payload renders inert.
1. 6	Re-enable ESLint on <code>client/src/**</code> — 871 files currently unlinted. Start with <code>react/no-danger</code> and the security rules; warn on the rest.	Frontend	3 days	<code>npm run lint</code> covers <code>client/src</code> ; <code>react/no-danger</code> is an error.
1. 7	Fix or remove the AnA attach button. It stores only file names and posts "Attached N file(s)" (<code>Shell.tsx:428-431</code>), silently discarding every file — while a working upload path exists at <code>hooks/useChatUpload.ts</code> . A control that lies is worse than a missing one.	Frontend	1 day	Attaching a PDF sends its bytes; the model can quote it.
1. 8	Harden the uploads. Add <code>fileFilter</code> + <code>limits.fileSize</code> to <code>stability.route.r.ts</code> (it has neither) and wire <code>uploadAllowlist</code> / <code>uploadSafety</code> into all 28 multer sites (currently 2).	Backend	3 days	Every multer site has a filter, a size limit and signature+AV verification.
1. 9	Apply <code>ssrfGuard</code> to <code>citation-verification-service.ts:108</code> and the <code>AnaToolExecutor</code> fetch sites — these fetch model-supplied URLs.	Backend	2 days	An internal-IP citation URL is refused.
1. 1 0	Give the product a front door. Choose the surfaces the pilot uses and put them in <code>RA_IL_PRIMARY</code> (today: 5 of ~101, with 41 in <code>NAV_HIDDEN</code>). Either surface the translation workspace or disable its mounted backend — do not ship a live offering with no UI.	Frontend /Product	3 days	Every pilot journey is reachable by clicking, with no typed URLs.
1. 1 1	Run one cross-tenant probe against a seeded two-org deployment, converting Chapter 05's static findings into demonstrated results.	QA	2 days	A documented probe report; any leak found becomes a Stage 1 item.

Exit criterion for G1: Stage 0 + Stage 1 complete, a fresh install boots and passes every golden journey, and the cross-tenant probe is clean.

Stage 2 — Make it sellable → unlocks G2 (2–4 months)

#	ACTION	OWNER	EFFORT	ACCEPTANCE TEST
2.1	Correct <code>SECURITY.md</code> . Remove "SOC 2 Type II controls" (no report exists) and soften "21 CFR Part 11 compliant" to "built to support Part 11 workflows" — the wording the team already adopted on the signup page. Qualify the at-rest-encryption and rate-limiting claims.	Product/ Legal	1 h	No unqualified compliance claim survives without an artifact behind it.
2.2	Complete the <code>requestDb(req)</code> migration for the remaining 81 route files, then flip <code>RLS_ENFORCE=on</code> . The long pole, and the item that actually closes the tenant-isolation risk.	Backend	2–3 months	<code>RLS_ENFORCE=on</code> in staging with all golden journeys green and a cross-tenant probe returning zero rows.
2.3	Audit the remaining 114 <code>ON CONFLICT</code> sites plus every Drizzle upsert on a tenant-bearing table.	Backend	3 weeks	A contract test per tenant-bearing arbiter.
2.4	Write and rehearse DR. Define RPO/RTO, run a real <code>pg_dump</code> + restore into a scratch branch, write the runbook. Nothing of this exists today.	Ops	3 weeks	A restore rehearsal report with measured RTO.
2.5	Prove alerting reaches a human. <code>SENTRY_DSN</code> is wired but has never been shown to page anyone; alerting covers one subsystem.	Ops	1 week	A deliberately triggered error pages the on-call.
2.6	Verify entitlement enforcement server-side — prove a locked module is refused by the API, not merely hidden in the UI.	Backend	3 days	An unentitled tenant calling a paid endpoint directly gets 403.
2.7	Enforce a coverage floor at today's measured number and ratchet. Thresholds are currently set then overridden to 0 with <code>continue-on-error</code> .	Platform	1 week	Coverage below the floor fails CI.
2.8	Run E2E on PRs , at least a smoke subset. A broken login can currently merge green.	Platform	1 week	Breaking login fails a PR check.
2.9	SHA-pin all 137 GitHub Actions references; replace the deprecated <code>returntocorp/semgrep-action@v1</code> . Already self-flagged as a GA blocker.	Platform	1 day	No floating action tags remain.
2.10	Resolve chromadb <code>CVE-2026-45829</code> — record the exposure determination the suppression itself demands, or remove the dependency.	Security	1 day	Either a written determination or the package is gone.
2.11	Flip <code>AI_PII_ENFORCEMENT</code> to <code>block</code> ; document zero-retention as a deployment prerequisite.	Backend	4 h	Pasting a patient identifier is blocked, not merely logged.
2.12	Reconcile the 140 duplicate table definitions , prioritising any whose definitions disagree.	Data	1 month	<code>ci:duplicate-table-ddl</code> baseline reaches 0.
2.13	Retire or wire the ~181 orphaned <code>db/migrations/</code> files ; make the manifest authoritative or delete it.	Data	3 weeks	Every <code>.sql</code> file is on an apply path or in <code>_legacy/</code> .
2.14	Delete the dead client trees (~25,000 LOC across 11 legacy mini-apps, 7,174 LOC of dead v2 surfaces, ~13,000 LOC of unreferenced ANA UI) and <code>.replit-ci.yml</code> .	Frontend	1 week	<code>ci:unreferenced-modules</code> baseline falls sharply; no dead deployment target remains.

Stage 3 — Make it qualifiable → unlocks G3 (6–12 months)

#	ACTION	OWNER	EFFORT	ACCEPTANCE TEST
3. 1	Bind e-signatures to records. <code>promote-artifact.ts:245</code> promotes to <code>approved</code> with no <code>electronic_signatures</code> row, no <code>signatureId</code> , no <code>manifestHash</code> — satisfying neither \$11.50 nor \$11.70. Do this before qualification , or qualification certifies the gap.	Backend	1 week	Promotion without a valid signature is refused; the manifest carries name, timestamp and meaning.
3. 2	Make boot validate-only. Move <code>ensureCoreTables.ts</code> 's 7 <code>CREATE TABLE</code> s into migrations. Starting the app currently mutates the schema (proven: 702 → 717 tables) — incompatible with change control.	Data	3 days	Booting twice against a fresh DB leaves the table count unchanged.
3. 3	Schedule the Part 11 controls. <code>audit:verify:24h</code> , <code>audit:verify:full</code> , <code>audit:archive</code> and <code>retention:run</code> are orphaned scripts; <code>retentionCron.ts</code> has no scheduler caller.	Ops	3 days	Chain verification runs on schedule and its result is attestable.
3. 4	Execute IQ/OQ/PQ under a named validation owner; sign the VSR; establish change control. All execution records are currently blank.	Validation (non-eng)	months	A signed VSR, not <code>1.0.0-DRAFT</code> .
3. 5	Close the traceability matrix's own open items — true PDF/A-1b conformance, and a DB-backed delete → audit test to replace the mocked one.	Backend	1 month	TM-CORTEX-001 has no open items.
3. 6	Add policies to the 21 RLS-enabled-but-policy-less tables ; make an explicit decision on the 118 with RLS off.	Data	1 week	No table is RLS-enabled without a policy outside the 6-entry allowlist.
3. 7	SOC 2 Type II engagement , if the claim is to be kept rather than removed.	Compliance	months	A real report with an observation window.

The order in one paragraph

Fix the instruments first (**Stage 0, days**) — otherwise you cannot tell a real fix from another silent pass. Then fix what makes the product unsafe or dishonest for a human (**Stage 1, weeks**): a fresh install that half-works, a health probe that lies, one live cross-tenant write path, one reachable XSS fed by model output, and a UI whose attach button discards files. That reaches a credible external pilot. Then do the two things that take real time and cannot be rushed (**Stage 2, months**): finish the request-scoped DB migration so tenant isolation is two-layer, and build the operational apparatus — DR, alerting, coverage, E2E — that a paying customer's procurement will ask for. Correct `SECURITY.md` on day one of that stage; it costs an hour and removes a live legal exposure. Only then start the qualification programme (**Stage 3**), because qualifying a system with unbound e-signatures and a schema that mutates at boot would certify the wrong thing.

Chapter 16 — Enhancement roadmap: where to invest to win

Chapter 15 gets the product to *safe*. This chapter is about *valuable* — and they are different questions. A platform can clear every gate in Chapter 14 and still lose every deal.

The competitive scoring per category lives in Chapter 13. This chapter is the strategic read across it, grounded in what the audit actually found in the code.

16.1 The three real assets

Everything worth building next should compound one of these. They are the things this codebase has that are genuinely hard to copy.

Asset 1 — Honest degradation, enforced in code

This is the most valuable and least visible thing in the product.

The platform does not fabricate when it lacks grounds. Verified in code: the AI gateway **throws in production** rather than serving demo content when no provider is configured (`gateway.ts:531-537`); reject-lists match `/lorem ipsum/i` and "coming soon" before content can be sealed (`governed-ana-execution.ts:43,47`); `qc.routes.ts` returns `notImplemented:true` for Certificate-of-Analysis generation and batch release, **replacing stubs that previously returned `{released:true}` unconditionally**; the submission gateway returns `gateway_not_configured` rather than a fabricated ACK; the prediction layer returns a network prior with `confidence: low` at cold start instead of a made-up number.

In a category where the buyer's fear is *"the AI will confidently invent a regulatory claim and I will sign it"*, a tool that refuses is worth more than a tool that is fluent. The repo's own strategy documents call this *"the actual moat"* and they are right.

But it is currently unmeasured and invisible. `eval:grounding` and `ai:eval-doc-quality` exist and are invoked by **no workflow** (Chapter 11 §11.7). And the 28 result panels built to *show* verification state, seal status, concordance and confidence — `VerificationPanel` , `SealBadge` , `ConcordancePanel` , `ReadinessGatePanel` — are **dead code**, unreferenced by the shipping rail (Chapter 09 §9.4).

So the moat exists in the engine, is never measured, and is never shown to the buyer.

Asset 2 — Breadth that is real, not slideware

697 registered tools. 94 files of Global RI domain logic across 39 routers. 65 files of IND lifecycle. 57 of Report-OS. 49 of eCTD. Three OpenAPI specs. A 20-app registry spanning governance, submission, CMC, nonclinical, clinical, biostatistics, device safety, diagnostics, labeling, PV and market access.

Incumbents in this market typically sell **one** of those and integrate the rest. The breadth is a genuine differentiator for a customer who would otherwise buy four systems — *if* it can be reached, which today it largely cannot: 5 of ~101 surfaces are in the navigation.

Asset 3 — Part 11 machinery that survives inspection

A SHA-256 audit chain with `SELECT ... FOR UPDATE` anti-fork locking inside the caller's transaction, a secret-keyed HMAC seal, a fail-closed boot matrix, and a **populated** clause → code → test traceability matrix. Most competitors in the AI-native tier have none of this and will need years to build it. Most incumbents that have it lack the AI layer.

The combination is the position. Neither half alone is defensible.

16.2 What to build, in order

Tier 1 — Make the existing moat visible and measurable (weeks)

Highest return in the roadmap. All of it is surfacing work on capability that already exists.

#	INVESTMENT	WHY IT WINS
E 1	Ship a "why should I trust this?" surface. Wire the dead verification panels into the rail: for any generated content — its sources, the grounding verdict, freshness, confidence with its denominator, seal state, and what the system <i>declined</i> to assert.	Converts an invisible engineering property into the thing a buyer evaluates in a demo. This is the single highest-leverage item in the audit.
E 2	Put the grounding evals in CI and publish the number. <code>eval:grounding</code> and <code>ai:eval-doc-q</code> <code>uality</code> already exist. Track hallucination rate, citation-verification pass rate and refusal rate over time.	An unmeasured moat is a hypothesis. A published, trending number is a procurement asset — and nobody else in this category publishes one.
E 3	Make refusal a feature, not an error. When the system declines — insufficient corpus, missing dependency, unconfigured gateway — say what is missing and what would unblock it, rather than showing an empty state or a 501.	Turns the platform's most differentiated behaviour from a perceived defect into the reason to buy.
E 4	Surface the tool catalogue. 697 tools with no picker. Ship discovery — by discipline, by document type, by regulatory question.	Breadth that cannot be found is not breadth.

Tier 2 — Convert breadth into a workflow (months)

#	INVESTMENT	WHY IT WINS
E 5	Pick one end-to-end journey and make it excellent. Most credible on this codebase: device/IVD 510(k) — the assets are already deep (<code>cer2v/</code> , predicate intelligence in <code>shadow_service/</code> , eSTAR sections, <code>ivd-platform.openapi.json</code>). Source → evidence → drafted section → review → e-sign → assembled package, with grounding visible at every step.	Buyers do not buy 20 modules. They buy one job done end to end and then expand. A single flawless journey outsells broad partial coverage.
E 6	Cross-document consistency as a product surface. The contradiction engine, concordance and consistency panels already exist in code. A "your Module 2.7 contradicts your CSR on the primary endpoint" alert is a genuinely differentiated capability.	This is the failure mode that causes real regulatory pain, and it is exactly what a multi-module platform — and <i>only</i> a multi-module platform — can catch. It is a direct argument against buying four point solutions.
E 7	Make the precedent/CRL corpus a first-class product. The clinical-regulatory-evidence layer and CRL corpus exist but are flag-gated and demoted to <code>NAV_HIDDEN</code> .	"What did FDA actually say to companies like me?" is a question buyers pay consultants for today.
E 8	Retire or complete the half-offerings. Translation has 31 service files, a mounted route and zero reachable UI. The regulatory digital twin is <code>Math.random()</code> behind an honest disclosure. Ship them or remove them.	Half-offerings cost credibility in a demo and maintenance forever.

Tier 3 — Platform leverage (quarters)

#	INVESTMENT	WHY IT WINS
E 9	Sell the API. Three OpenAPI specs already exist (87 + 63 + 34 paths). A documented, versioned, entitlement-gated public API turns 556 orphaned endpoints from dead weight into a product.	Changes the ceiling from seats to platform. Also the cheapest path to CRO and consultancy channel revenue.
E 10	Multi-client architecture for CROs and consultancies. Portfolio rollout and client-scoped workspaces are partially built. This segment buys many seats and resells the platform.	The account-level buyer with the most upside — but it demands the tenant isolation work in Chapter 15 §2.2 first, because they hold <i>competitors'</i> data side by side.
E 11	Validation-as-a-product. Once IQ/OQ/PQ is executed (Chapter 15 §3.4), package the artifacts as a customer-facing validation pack.	Every regulated buyer must validate their vendor. Doing that work once, well, and handing it over shortens enterprise sales cycles materially. It converts the most expensive item on the remediation list into a revenue argument.
E 12	Fix the i18n story or drop the claim. A global-language strategy document exists; 13 client files call a translation function.	Global submissions is a stated positioning. Today the UI is effectively English-only.

16.3 What NOT to build

Discipline matters more than ideas here — this codebase's dominant failure mode is breadth outrunning depth.

- **No new modules until the existing ~101 surfaces are navigable.** Adding a 21st app to a product with a 5-item rail makes the problem worse.
- **No new AI tools until the 697 existing ones have audited tenant scope** (Chapter 06 §6.3.2) and a UI that can render their output.
- **Do not chase incumbent feature parity on publishing/validation.** Lorenz, Extedo and the established RIM suites have decades of accumulated edge-case handling in eCTD publishing. Integrate with validators rather than rebuilding them.

- **Do not weaken the honest-degradation behaviour to demo better.** It is the moat. Every instinct in a sales cycle will push toward making the system answer confidently when it should refuse. Resist it — and instead do E1/E3, which make refusal *look* like the sophisticated behaviour it is.
-

16.4 The strategic read

The audit's technical finding and its commercial finding are the same finding.

Technically: the hard parts are built and the connective tissue is missing — RLS compiled but inert, controls built but unscheduled, 697 tools with no UI, 15 schemas the installer never creates, gates that pass on a crash.

Commercially: the differentiated capability is built and the connective tissue is missing — a grounding engine nobody can see, breadth nobody can navigate, Part 11 machinery that cannot be claimed because the system is unvalidated, and an honest-degradation property that is never measured and therefore cannot be sold.

Both are convergence problems, not invention problems. That is a far better position than the reverse, and it is the single most important thing for a buyer to understand about this asset: **the expensive, slow, hard-to-copy work is largely done. What remains is the work of connecting it — and of proving it, which is the part this codebase has consistently deferred.**

Live-proof execution log — 2026-07-28

Everything here was **executed**, not read. Each entry gives the exact command so any finding can be independently re-derived. Where a check could not be run, it says so rather than inferring a pass.

Environment: Ubuntu 24.04 · Node v22.22.2 · npm 10.9.7 · PostgreSQL 16.13 · pgvector 0.6.0 (installed via `apt-get install postgresql-16-pgvector` — **not** present by default; the repo's own `AGENTS.md` says it "must be built from source").

Audited tree: `concept2cure-v2` @ `576ec5d`.

LP-01 · Git provenance — history was retrievable only after unshallowing

```
git fetch --unshallow origin
git rev-list --count HEAD
git log --format='%an' | sort | uniq -c | sort -rn
```

METRIC	RESULT
Commits	5,749
Range	2025-11-20 → 2026-07-28 (~8 months)
Merge commits	918
Squash-PR commits ((#NNNN))	495

Authorship:

AUTHOR	COMMITTS	SHARE
Claude	3,192	55.5%
concept2cure	1,574	27.4%
github-actions[bot]	361	6.3%
Cursor Agent	240	4.2%
dependabot[bot]	165	2.9%
copilot-swe-agent[bot]	154	2.7%
ana-integration / ana-harden / GitHub Copilot	63	1.1%

Named AI coding agents account for 3,649 of 5,749 commits (63.5%); bots a further 680 (11.8%). ~1.49M lines of code were produced in ~250 days — a sustained ~6,000 lines/day. This is not a defect in itself, but it is the single most important context for interpreting every other finding: the volume of code far exceeds what the commit history shows being human-reviewed, and it explains the pattern this audit keeps hitting — subsystems that are individually well-built but do not agree with each other.

LP-02 · From-scratch database install — succeeds, and is materially incomplete

```
createdb audit_fresh
DATABASE_URL=postgresql://.../audit_fresh node scripts/db/install-fresh.mjs
```

Terminal state:  **Application schema install complete.**

CLAIM (<code>PRODUCT_READINESS_ASSESSMENT.MD:53-55</code>)	MEASURED	VERDICT
687 tables	702 (<code>public</code>) / 710 all schemas	✓ met or exceeded
557 RLS policies	572	✓ met or exceeded
5/5 core tables	5/5	✓

So the headline provisioning claim **holds**. The problem is what the same run reports on its way to that green checkmark.

LP-02a · Ten migrations fail and are declared "safe to skip"

```
pass 1: applied=144 already-present=2 deferred=18 hard=1
pass 2: applied=8   already-present=0 deferred=10 hard=0
pass 3: applied=0   already-present=0 deferred=10 hard=0
• 10 file(s) left unapplied – ... "safe to skip for the app schema"
```

The installer's own words are *"each references a table absent from this schema (non-core index/ALTER files against renamed/removed tables); safe to skip."* **That claim is false for at least four of the ten.** Verified against the resulting database:

SKIPPED MIGRATION	BLOCKED ON	TABLE IN FRESH DB?	NON-TEST SERVER FILES QUERYING IT
<code>0011_ai_threads_title.sql</code>	<code>ai_threads</code>	absent	8
<code>20260601_chat_message_metadata.sql</code>	<code>chat_messages</code>	absent	11
<code>0004/0007_*.sql</code>	<code>unified_documents</code>	absent	13
<code>0016/0017_module3_*.sql</code>	<code>cmc_source_objects</code>	absent	12
<code>0006_regulatory_atoms.sql</code>	<code>cmc_projects</code>	absent	5
<code>0008_critical_fk_delete_policies.sql</code>	<code>user_sessions</code>	absent	0

`ai_threads` and `chat_messages` are **not defined in the Drizzle schema at all**; their only creator is `db/migrations/20260224_ai_trace_chain.sql`, which sits in the migration tree that is on no automated apply path. Yet `server/routes/chat/threads.ts:40,96,173`, `server/routes/chat/send-message.ts:102` and `server/routes/conversation-thread-routes.ts:141` query them with raw SQL, and both route modules **are mounted** (`server/bootstrap/register-ai-routes.ts:2`, `register-clinical-intel-routes.ts:230`).

Consequence: on a brand-new deployment following the repo's own documented install path, the conversation/threads surface — which `README.md:25` calls *"the product"* — queries tables that do not exist. This is the same failure class as the P0 fixed in commit #1186 (`db/migrations/20260401_cmc_convergence_os.sql` was the sole creator of 11 CMC tables and was on no apply path), recurring in a different subsystem.

LP-02b · Fifteen Postgres schemas are queried but never created

```
DATABASE_URL=... node docs/audit-2026-07/evidence/fresh-install-gap.mjs
```

Schemas the installer creates: `audit`, `lumen`, `precedent`, `public`, `vault`.

Schemas that non-test server code issues SQL against, which do not exist after a fresh install (extracted from SQL string literals only — comments and ES imports excluded):

SCHEMA	DISTINCT TABLES REFERENCED	REFERENCE SITES	EXAMPLE	ROUTE FAMILY MOUNTED?
innovation	27	139	server/routes/innovation-routes.ts:178	yes — register-advanced-platform-routes.ts
cortex	23	29	server/services/cortexPrimeServices:280	service not mounted
intelligence	14	51	server/services/intelligence/ana-failure-learning.ts:173	—
regulatory_intel	11	32	.../advisory-committee-service.ts:113	—
regulatory_harmonization	9	23	server/services/grdhe/grdheService.ts:124	—
clinical_ops	7	40	server/routes/clinical-operations-routes.ts:207	yes — register-regulatory-routes.ts
intelligent_docs	7	24	server/routes/intelligentDocs.ts:90	yes — register-core-routes.ts
signing	7	16	server/api/signing/routes.ts:35	not mounted
compliance	7	11	server/services/cortexComplianceService.ts:149	—
labeling	5	17	server/api/labeling/routes.ts:37	—
site_intel	5	17	server/api/site-intel/routes.ts:61	—
manufacturing	4	23	server/routes/manufacturing-routes.ts:178	yes — register-regulatory-routes.ts
ectd	4	14	server/api/ectd/routes.ts:14	—
predicate	4	7	server/services/precedent-engine.ts:274	—
core	1	9	server/routes/innovation-routes.ts:119	—

Note `predicate` vs the created `precedent` — a **schema-name mismatch**, not merely a missing schema.

At least four mounted route families (`innovation` , `clinical_ops` , `intelligent_docs` , `manufacturing`) therefore cannot serve a single request on a correctly-installed fresh database. They will 500 at the first query.

LP-02c · RLS coverage after a fresh install is not total

MEASURE	COUNT
Tables with RLS enabled	584
RLS policies present	572
Tables with RLS enabled but zero policies	21
Tables with RLS not enabled at all	118

The 21 enabled-with-no-policy tables are the sharpest edge: under `FORCE ROW LEVEL SECURITY` an enabled table with no policy denies all access to non-owners, while under the app's owner role it passes everything — either way it is not doing tenant isolation. The 118 with RLS off are unprotected by definition. Both sets are enumerated in `10-fresh-install-gap.json` .

This matters more than it looks, because of LP-03.

LP-03 · Row-level security is compiled but inert — confirmed by reading the installed policy

Every policy installed by `migrations/0021_enable_rls_everywhere.sql` opens with:

```
NULLIF(current_setting('app.rls_enforce', TRUE), '') IS DISTINCT FROM 'on'
```

so unless the session variable is 'on', **every row passes on every table**. No deployment manifest in the repository sets `RLS_ENFORCE=on`, and it cannot simply be turned on: only 16 of 97 DB-touching route files use the request-scoped `requestDb(req)` that sets `app.current_tenant_id`; the remaining ~78-81 use a shared pool that does not, so those routes would return zero rows or 500 rather than defend anyone. The repo states this itself in commit #1186 and in `docs/RLS_ENFORCEMENT_BURNDOWN.md`, whose owner field reads *"unassigned."*

Net: the 572 policies just verified as installed are, in the shipped configuration, decorative. Tenant isolation rests entirely on the application layer.

LP-04 · Static sweep totals (deterministic, whole-tree)

node docs/audit-2026-07/evidence/sweep.mjs	
MEASURE	VALUE
Files walked	7,858
Lines of TS/TSX/JS/JSX	1,489,132
Files over 1,500 lines	79
HTTP endpoint declarations	4,077
...carrying a route-level auth guard	589 (14.4%)
Distinct tables created in SQL	1,175
Distinct tables declared in Drizzle	699
Tables with duplicate CREATE TABLE across files	140
Tables declared twice in Drizzle	11
Tables that exist only in SQL (invisible to Drizzle)	549
server/services dirs with at least one test	124 / 203 (61%)
Items suppressed across tracked baselines	1,292
Working-tree secret-scan hits	2 — both false positives (UI placeholder strings for a "Private Key" form field: client/src/concept2cure/v2/fixtures/deep-research-data.ts:121, server/services/connectors/connector-interface.ts:524)

On the 14.4% guard figure — read it correctly. It does *not* mean 3,488 endpoints are unauthenticated. `server/middleware/authBoundary.ts` applies a default-deny boundary to all of `/api` before any route registers, so most of those endpoints are covered by it. What the number does show is that authorization is **single-layer for 85% of the API**: remove or misconfigure the global boundary and there is no route-level control underneath. The boundary itself runs in `enforce` mode **only when `NODE_ENV === 'production'`** and in `warn` mode everywhere else, so any staging or demo environment holding real customer data is running with that single layer in log-only mode.

LP-05 · Upload safety adoption

MEASURE	VALUE
<code>multer(</code> call sites in non-test server code	28
...with a <code>fileFilter</code>	21
...with a <code>limits.fileSize</code>	27
...using the repo's own <code>uploadAllowlist</code>	2
...using <code>uploadSafety</code> (magic-byte + AV)	2

Seven sites have no `fileFilter`; `server/src/routes/stability.router.ts` has **neither a `fileFilter` nor a size limit** — an unbounded, unfiltered upload. Full list in `09-upload-safety.json`.

LP-06 · The typecheck gate is vacuous — it cannot tell "clean" from "crashed"

This is the repo's flagship quality control. `.typecheck-baseline.json` records a ratchet from 2,598 → 0 errors with an honest per-step history, and `ci.yml:231` runs the gate blocking. It does not work.

Step 1 — run it exactly as the project configures it.

```
NODE_OPTIONS="--max-old-space-size=6144" npx tsc --noEmit
```

Result after 379 seconds:

```
FATAL ERROR: Ineffective mark-compacts near heap limit
Allocation failed - JavaScript heap out of memory
Aborted
```

`grep -c "error TS"` on that output: 0.

Step 2 — read what the gate does with that. `scripts/ci/typecheck-no-regression.mjs` spawns `tsc` with `NODE_OPTIONS: '--max-old-space-size=6144'` (the same cap), then:

```
const errorCount = (combined.match(/error TS/g) || []).length;
...
if (errorCount > baselineCount) { ... process.exit(1); }
```

It **never inspects** `tsc.status` or `tsc.error`. A V8 fatal-OOM message contains no `error TS` substring, so a crashed compiler yields `errorCount = 0`, which is `<= 0`, which prints *"OK — error count 0 matches baseline"* and exits 0. **The gate passes precisely because the compiler died.** The 6,144 MB cap is set by the gate itself, so this is not an artifact of an unusually small machine — this host had 15 GB total and 14 GB free.

Step 3 — give it enough heap and see the truth.

```
NODE_OPTIONS="--max-old-space-size=24576" npx tsc --noEmit -p tsconfig.json
→ exit code 2, no OOM, 2 errors
```

```
server/services/ana/__tests__/council-tool.test.ts(12,37): error TS7016:
  Could not find a declaration file for module '.././.././scripts/db/migration-set.mjs'
server/services/ana/__tests__/deep-investigation.test.ts(11,37): error TS7016: (same)
```

These are pre-existing and not an artifact of this audit. Both files are unmodified in the working tree (`git status --porcelain` clean), and this audit's own scripts live under `docs/`, which is outside the `tsconfig` `include` list (`client/src`, `server`, `shared`, `agents`). `git log` attributes both files to **PR #1180, merged 2026-07-27 — the day before this audit** — *"feat(deploy): give production a schema migration mechanism, and gate deploys on it."*

So the current state is: the baseline says 0, a completing compiler says 2, the gate says 0, and a PR merged yesterday introduced type errors that the gate was specifically built to catch. Every "typecheck is clean" claim downstream of this gate is unverified.

LP-07 · `/readyz` returns green over a database missing auth and RBAC tables

`PRODUCT_READINESS_ASSESSMENT.md:81-88` lists this as **blocker #4, resolved**: "Now: `/readyz` fails closed and names the missing tables. Verified live: empty DB → 503 ... Container healthcheck repointed at `/readyz`." `Dockerfile.optimized` does point its `HEALTHCHECK` there.

Booted against the database produced by the repo's own installer:

```
curl -s http://127.0.0.1:5050/readyz
{"ready":true,"dependencies":{"database":"ok","schema":"skipped","redis":"skipped","worker":"skipped"}}
```

HTTP 200, `ready: true`, and schema verification reported as **skipped** — while the same boot logged:

```
[ensureCoreTables] ⚠ Important tables missing: licenses, auth_users, auth_refresh_tokens,
roles, step_runs, permissions, user_roles, organization_settings, assembly_docs,
assembly_audit_logs
[ensureCoreTables] ⚠ Schemas required initialization: extensions
```

Root cause, in code. `server/startup/services.ts:61-101` sets schema readiness in only four branches — `missingCritical`, `missingExtensions`, a failing subsystem, or full success. The three trailing branches (`result.errors.length > 0` at :92, `result.missingSchemas.length > 0` at :94, `result.warnings.length > 0` at :99) **log and return without ever calling `setSchemaReadiness`**. Readiness therefore stays at its initial `'unknown'` (`server/startup/readiness-state.ts:17`), which `/readyz` renders as `"skipped"` — and `skipped` does not fail the probe.

This boot took the `missingSchemas` branch. So a deployment can be missing `auth_users`, `auth_refresh_tokens`, `roles`, `permissions`, `user_roles` and `licenses` — authentication, authorization and licensing tables — and the container orchestrator will mark it healthy and route production traffic to it. That is the exact failure mode blocker #4 claims to have closed; it was closed for the two-table `missingCritical` set only.

LP-08 · Authorization boundary — verified working, and stronger than the code reading suggested

Probed unauthenticated against the running server (`NODE_ENV=development`, i.e. the mode in which `authBoundary` is documented to run in permissive `warn` mode):

ENDPOINT	STATUS
<code>/api/projects</code>	401
<code>/api/c2c/projects</code>	401
<code>/api/vault/documents</code>	401
<code>/api/admin/business</code>	401
<code>/api/billing/dtc-pricing</code>	401
<code>/api/ana-ri/health</code>	401
<code>/api/users</code>	401
<code>/api/organizations</code>	401
<code>/api/metrics</code>	401
<code>/healthz</code> , <code>/readyz</code> , <code>/api/health</code> , <code>/api/time</code>	200 (intended)

This is a genuine strength and it is reported as one. Every data endpoint probed refused an unauthenticated request even in development. The audit's static sweep found only 14.4% of endpoints carry a route-level guard, but empirically the layered boundary plus per-route guards held on every endpoint tested. The residual concern is architectural rather than demonstrated: authorization is single-layer for most of the API, so the blast radius of a boundary misconfiguration is the whole surface.

`/api/diag` returns an unauthenticated HTML page, but it discloses only a timestamp and a liveness message — noted as hygiene (P3), not exposure.

LP-09 · Production build — clean

```
npm run build → exit 0, 20.06s
```

ARTIFACT	SIZE
dist/index.js (server, single bundle)	18.57 MB
dist/public/assets/V2App-*.js	1.56 MB minified
dist/public/assets/V2App-*.css	694 KB
dist/public/assets/ZenRouter-*.js	530 KB
Total dist/	24 MB

Vite emits the expected large-chunk warning. A 1.56 MB main client chunk plus 694 KB of CSS is heavy for a first paint but is a performance finding, not a correctness one. The dead client trees documented elsewhere in this audit are largely tree-shaken out of the bundle, but they remain a maintenance and review-surface liability.

LP-09b · Booting the server mutates the database schema

Re-running the gap analysis after the boot returned **717** tables where the installer had produced **702**. The delta is not measurement noise — it is `server/db/ensureCoreTables.ts`, which runs at boot from `server/startup/services.ts:53` and contains **7** `CREATE TABLE IF NOT EXISTS` statements (`:358 documents`, `:374 document_versions`, `:388 cerv2_510k_sections`, `:408 cerv2_section_versions`, `:420 cerv2_document_sessions`, `:431 rag_documents`, `:446 rag_chunks`), auto-creating on miss at `:470-475`.

All 7 are present in `audit_fresh` after the boot. Its own docstring says it “*validates*” rather than creates.

Two consequences a buyer should weigh:

- 1. **Schema creation happens outside the migration system**, so those seven tables' shapes are governed by a TypeScript file rather than by a reviewed, versioned migration — and they will never appear in a migration-based diff of two environments.
- 2. **Starting the application is a schema-mutating operation**. That is incompatible with a GxP change-control posture, where schema changes are controlled artifacts, and it means a production rollback to an older image cannot be assumed to leave the database unchanged.

It also means the numbers in LP-02b were taken from a pristine install, and the numbers in this section were taken after a boot. Both are stated rather than averaged.

LP-10 · The application's own security self-check reports failing

At boot, unprompted:

```
{"context":{"overall":"failing"},"msg":["security-health-scheduler] security posture unchanged"}
```

and, twice, the platform's own RLS observability confirming LP-03 from the inside:

```
[tenant-rls-observability] Query issued without tenant scope
(will return zero rows once RLS is enabled)
caller: server/services/securityHealth.ts:336
caller: server/lib/tamper-proof-audit.ts:334
```

Note the second caller: the **tamper-proof audit log reader** is itself one of the untenanted queries.

Checks not yet complete

- Full jest + vitest execution with real pass/fail/skip counts.
- Golden-journey execution and headless browser walk of the primary surfaces.

- Authenticated cross-tenant probes (requires seeding two orgs).

None of these are reported as passing until they have actually run.

LP-11 · The typecheck gate, after the fix — both halves proven

Closing the loop on SLP-06. The gate now inspects `tsc.status`, and the heap default was raised 6,144 → 24,576 MB (`TYPECHECK_HEAP_MB` overrides).

Crashed compiler must fail:

```
$ TYPECHECK_HEAP_MB=128 node scripts/ci/typecheck-no-regression.mjs
[ci:typecheck-no-regression] FAIL — tsc did not complete.
exit status : 134
heap cap    : 128 MB (override with TYPECHECK_HEAP_MB)
The error count below is NOT trustworthy — the compiler died before finishing.
...FATAL ERROR: Reached heap limit Allocation failed - JavaScript heap out of memory
EXIT=1
```

Previously this exact condition printed *"OK — error count 0 matches baseline"* and exited 0.

Clean run must complete and report a true count:

```
$ node scripts/ci/typecheck-no-regression.mjs
[ci:typecheck-no-regression] running tsc --noEmit (baseline: 0)
[ci:typecheck-no-regression] errors found: 0 (tsc exit 0)
[ci:typecheck-no-regression] OK — error count 0 matches baseline.
EXIT=0
```

Two consequences worth stating. First, the two `TS7016` errors from PR #1180 are genuinely closed — the declaration had to be `.d.mts`, because `moduleResolution: "node"` never consults `.d.ts` for a `.mjs` import. Second, and more important: **the repository's "0 type errors" baseline is, as of this run, a measured 0 for the first time.** It was previously a number produced by a compiler that never finished.

Appendix B — Competitive detail

One rack-and-stack per offering category. Each contains the five closest competitors with cited sources, a capability rubric scoring this platform against the best competitor per dimension, and a verdict. 12 categories.

Agentic AI assistant layer over regulatory work (life scien...

Verdict:  **Credible challenger** Weighted capability score — **us 3.2 / 5** vs **best competitor 3.9 / 5** across 13 dimensions.

Full category as scoped: Agentic AI assistant layer over regulatory work (life sciences) — a conversational/agentic layer that plans, calls tools against regulatory data and systems, drafts submission-grade content, and executes governed actions under GxP controls

Who buys, and what they are actually buying

Head of Regulatory Affairs / VP RegOps at a sponsor (biotech through top-20 pharma) or a CRO's regulatory service line, co-signed by Quality/CSV and IT Security. They are not buying "an AI chatbot" — they buy (a) cycle-time reduction on submission-critical documents and health-authority responses, (b) an auditable, validatable record that the AI's contribution can survive an FDA/EMA inspection, and (c) no new system of record. Budget typically rides on an existing RIM/eCTD line item or a medical-writing services line, which is why incumbents can bundle and challengers must show hard cycle-time proof. Quality holds an effective veto: no validation package, no purchase.

Market structure

Market structure. The category consolidated hard in 2026 and the defining event is five days old: on 23 July 2026 Dassault Systèmes signed a definitive agreement to acquire ArisGlobal for approximately \$2.0B — \$1.8B cash at closing plus up to \$200M contingent on multi-year AI-related revenue milestones, funded from balance sheet, expected to close H2 2026 (<https://www.3ds.com/newsroom/press-releases/dassault-systemes-acquire-ariglobal-creating-unified-ai-intelligence-platform-life-sciences-industry-connecting-molecule-patient-and-real-world-outcomes>, <https://www.axios.com/pro/health-tech-deals/2026/07/23/dassault-systems-ariglobal-2-billion>). That an industrial-software major paid ~\$2B with an explicit AI earn-out establishes both the strategic value of an agentic regulatory layer and the price of buying one with customers attached.

The second structural signal runs the other way: in April 2026 Certara agreed to sell its Regulatory and Medical Writing business to Veristat for up to \$135M, against \$50M revenue and \$17M adjusted EBITDA in 2025 excluding unallocated overhead (https://www.sec.gov/Archives/edgar/data/0001827090/000110465926046358/tm2612400d1_ex99-1.htm). That is roughly 2.7x revenue for a regulatory-writing services book — a useful floor, and a signal that services-shaped regulatory work is being divested while agent-shaped software is being bought.

Timing window. As of 28 July 2026 the incumbent regulatory agent layer is not yet generally available. Veeva's Regulatory AI Agents are reported for August 2026, Falcon's first three agents for late 2026 early-adopter availability, and Agentic Authoring for late 2027 (<https://intuitionlabs.ai/articles/veeva-ai-roadmap-crm-bot-agents-2026>, <https://www.clinicaltrials.vanguard.com/conference-coverage/veeva-unveils-falcon-ai-platform-and-agentic-authoring-at-2026-summit/>). IQVIA states it is still building its regulatory-intelligence agent, with catalog expansion expected Q4 2026 (<https://www.iqvia.com/newsroom/2026/03/iqvia-unveils-iqvia-ai-a-unified-agentic-ai-platform>). ArisGlobal is the only competitor with a shipped regulatory reasoning agent — Intelligence Agents, March 2026, which interpret regulatory guidelines and evaluate dossier compliance with explainable output (<https://www.arisglobal.com/media/press-release/ariglobal-expands-navax-agents-suite-with-three-new-ai-agents-to-orchestrate-intelligence-across-life-sciences-operations/>). The competitive window for a challenger is therefore measured in months, and it closes in August.

Procurement pattern. Nobody publishes list pricing. Vault modules are negotiated multi-year, with third-party estimates of \$15K–\$45K/yr for a 1–3-user small-biotech RIM footprint rising to \$45K–\$120K/yr at 3–8 users before AI add-ons (<https://intuitionlabs.ai/articles/veeva-vault-rim-cost-small-biotech>). Veeva AI is reported to be usage-priced, with some early-adopter agentic services free during pilots (<https://www.veeva.com/resources/veeva-ai-agents-now-available-to-increase-productivity-and-customer-centricity/>) — meaning incumbents can price the agent layer at near zero to defend the platform, which is the central commercial threat to any standalone challenger. Yseop routes through AWS Marketplace (<https://aws.amazon.com/marketplace/pp/prodview-wzkfr67cebozi>), letting buyers consume committed cloud spend and bypass a net-new vendor cycle.

Capital band for challengers. Weave Bio has raised ~\$36M total, including a \$20M Series A in October 2025 led by USVP (<https://finance.yahoo.com/news/weave-bio-secures-20m-series-120000238.html>). That is the realistic comparable band for an AI-native regulatory asset without production references — two orders of magnitude below the ArisGlobal print, and the gap is explained almost entirely by customers and validation, not by technology.

What actually decides deals. Every vendor in this set that is winning is winning on the same two things: proximity to the system of record (Veeva, ArisGlobal) or named production references with regulator-accepted output (Yseop — GSK, Sanofi, Novartis, Lilly, PPD, Pierre Fabre; 300+ trials; ~70% CTN cycle-time reduction at GSK; <https://yseop.com/>). Architectural sophistication is not on that list. A buyer should assume the RA function will pay for proof and the Quality function will veto for validation, and that neither will be moved by tool count.

Sourcing caveat. Direct WebFetch to veeva.com, arisglobal.com, certara.com, iqvia.com, yseop.com, prnewswire.com, biospace.com, nasdaq.com and intuitionlabs.ai all returned HTTP 403. Competitor claims above rest on search-result summaries and press coverage rather than pages read end-to-end. Availability dates in particular (Veeva regulatory agents August 2026, Falcon late 2026, Agentic Authoring late 2027) should be re-confirmed with the vendor before they are relied on in a deal model.

The five closest competitors

Veeva Systems — Veeva AI — Vault AI Agents + AI Shortcuts on the Vault Platform; Agentic Authoring and Falcon agents announced for later delivery

The agent layer that lives inside the system of record. Veeva's pitch is that agents operating natively on Vault RIM/QualityDocs inherit Vault's Part 11 controls, audit trail, and security model, so nothing new has to be validated or integrated. It is the default incumbent every challenger in this category is measured against.

Strengths

- Owns the system of record — agents act on the customer's live RIM data with zero integration project and no new data-residency review
- Part 11, audit trail, RBAC and e-signature are pre-existing and already accepted by the customer's Quality function, which removes the single hardest gate in this category
- Installed base and incumbency: the RA org already has Vault, so the agent layer is a line-item expansion, not a new vendor onboarding
- Usage-based AI pricing lowers the barrier to a first agent deployment

Weaknesses

- Regulatory agents are reported as August 2026 and Agentic Authoring as late 2027 — for a buyer evaluating today, the regulatory agent layer is roadmap, not shipping product
- Agent scope is narrow and task-shaped (tag, extract, predict, draft-a-response) rather than a general conversational agent with a broad executable tool surface
- Locked to Vault-resident data — customers whose evidence lives outside Vault (CT.gov, PubMed, EMA/EU CTIS, MAUDE, CMC systems) get little from it
- Single-cloud/model-stack posture (Bedrock) limits provider choice, residency options, and negotiating leverage
- Vault-only means it cannot be sold to the large population of sponsors and CROs that are not Vault customers

AI shipped today	Shipped as of July 2026: Veeva AI Agents for Vault CRM and PromoMats (available December 2025), followed by Safety and Quality AI Agents (reported April 2026). Regulatory AI Agents are reported as August 2026 — i.e. NOT yet generally available at the time of this analysis. Expected regulatory capabilities include document auto-tagging, regulatory-intelligence extraction, submission-timeline prediction, labeling paragraph analysis, missing-content detection, and drafting responses to health-authority questions. Agentic Authoring (proactive drafting of submissible documents, native to Vault RIM and MS Word) is reported as late 2027; the first three Falcon agents (TMF intake, safety case intake, health-authority interaction management) target late 2026 for early adopters. Models are reported to come from Anthropic and Amazon via Amazon Bedrock, executing inside the Vault environment. Note: veeva.com pages returned HTTP 403 to direct fetch; the above rests on search-result summaries and third-party coverage rather than a page I read end-to-end.
GxP / validation posture	Vault is the industry's de facto Part 11 / Annex 11 substrate with customer-executable validation accelerators; agents inheriting Vault's audit trail and e-signature model is the core of the pitch. Whether the agent layer itself carries a discrete validation package, and how model non-determinism is qualified, is not verified from public sources.
Pricing signal	Vault module pricing is never published; deals are negotiated multi-year. Third-party estimates put Vault RIM at roughly \$15K–\$45K/yr for a 1–3-user small biotech and \$45K–\$120K/yr at 3–8 users, before AI add-ons. Veeva AI is reported to use usage-based pricing, with some early-adopter agentic services offered at no extra cost during pilots. Long-term AI pricing is not public.

► Sources

ArisGlobal (being acquired by Dassault Systèmes) — LifeSphere NavaX Agents Suite — Intelligence Agents, Distribution Agents, Signals Agents, plus XDI data-intelligence cortex and NavaX Translation, on the LifeSphere Unify platform

The shipped agentic suite over an established regulatory/safety/quality platform. Positions as 'AI-native enterprise compliance platform' and, uniquely in this set, has an agent that reads regulatory guidelines and evaluates dossier compliance — the closest published analogue to a regulatory reasoning agent.

Strengths

- Intelligence Agents that evaluate dossier compliance against regulatory guidance are shipping now — the single closest live competitor capability to a reasoning regulatory agent
- Multi-agent orchestration across Safety, Regulatory, Quality and Medical Affairs in one connected ecosystem, so the agent layer spans more of RA's actual day than a writing tool does
- Deep installed base (200+ customers, half of top-50 biopharma) and health-authority customers give it unusual credibility with Quality reviewers
- Explainability is an explicit product claim on the compliance-evaluation output, which is exactly what an inspector asks for
- About to be capitalized by Dassault at ~\$2B with an explicit AI revenue earn-out — expect aggressive agent investment through 2027

Weaknesses

- Agent scope is task-shaped and platform-bound rather than a general conversational assistant with a broad tool surface
- Heaviest strength is in safety/PV and signal management; the regulatory-submission agent story is newer and thinner than the PV story
- Acquisition integration risk through H2 2026 into 2027 — roadmap, pricing and support model may all move during a \$2B integration
- Requires LifeSphere as substrate; limited value to sponsors on other RIM stacks
- No public pricing, no published cycle-time benchmarks for the regulatory agents specifically

AI shipped today	NavaX Agents launched November 2025. February 2026: XDI data-intelligence cortex, three new agents, and NavaX Translation for PV case-data intake. March 2026: Distribution Agents, Signals Agents, and Intelligence Agents — the last of which interprets regulatory guidelines, evaluates submission dossier compliance against contextually relevant rules, and produces explainable compliance evaluations. This is genuinely shipped multi-agent capability in the regulatory domain as of Q1 2026, ahead of Veeva. Agentic AI for signal management is also published. arisglobal.com and prnewswire.com pages returned HTTP 403 to direct fetch; the above rests on search-result summaries and the press-release titles/URLs.
GxP / validation posture	LifeSphere is a long-established GxP platform serving over 200 customers including half the top-50 global biopharma, plus CROs, medtech and global health authorities — implying mature Part 11/Annex 11 posture and customer validation support. A discrete validation package for the NavaX agent layer specifically is not verified.
Pricing signal	Not public. The definitive category comparable is the acquisition itself: Dassault Systèmes signed a definitive agreement on 23 July 2026 to acquire ArisGlobal for approximately \$2.0B — \$1.8B cash at closing plus up to \$200M contingent on multi-year AI-related revenue milestones, funded from balance sheet, expected to close H2 2026.

► Sources

Yseop — Yseop Copilot — regulatory-grade generative AI for medical and regulatory writing, with an agentic roadmap; also sold via AWS Marketplace

'Regulatory-grade AI for life sciences.' The reference-heaviest vendor in this category: sells on named top-10 pharma production deployments, documented cycle-time reduction, and submissions actually accepted by FDA and EMA. Competes on proof, not architecture.

Strengths

- Named production references at multiple top-10 pharma — the single hardest asset to fake and the fastest way past a Quality veto
- Submissions containing its output have been approved by FDA and EMA; 300+ trials of exposure
- A concrete, quantified cycle-time result (~70% on CTNs at GSK) that maps directly to the buyer's ROI model
- Explainability and GxP compliance treated as product requirements, not afterthoughts
- AWS Marketplace availability simplifies procurement and can consume committed cloud spend

Weaknesses

- Scope is document authoring, not the breadth of regulatory work — it does not execute governed platform actions, manage submissions, or reason across a portfolio
- Agentic tier is partly forward-looking; today's shipping product is best characterized as high-quality assisted authoring with automation, not autonomous multi-round agents
- No system of record — it must integrate with whatever RIM/eCTD the customer runs, so it competes for the same budget Veeva can bundle away
- Small independent vendor against Veeva, Dassault/ArisGlobal and IQVIA; consolidation and viability risk are live procurement questions
- No public pricing or published validation package details

AI shipped today	Shipping: an end-to-end GenAI platform automating core regulatory documents across clinical development, embedded in medical writers' existing tools, with explicit claims on data privacy, GxP compliance, accuracy, reliability and model explainability. Company states it has progressed from static automation toward agentic intelligence, with agents that self-configure, generate and validate code, and optimize workflows described as forward-looking — so the agentic tier should be treated as partially roadmap. Recognition: 2026 BIG Innovation Award for transforming regulatory writing with generative AI; TIME Best Inventions 2025 (Medical & Healthcare). yseop.com returned HTTP 403 to direct fetch; claims rest on search-result summaries and the vendor's own published positioning.
GxP / validation posture	The strongest published posture in this set. In production at GSK, Sanofi, Novartis, Lilly, PPD and Pierre Fabre; supported 300+ clinical trials; used in submissions approved by both FDA and EMA. A GSK production study is cited at ~70% reduction in Clinical Trial Narrative authoring time. GxP compliance and explainability are explicit product claims. Note these are vendor-published figures, independently unverified.
Pricing signal	Not public. Listed on AWS Marketplace (private-offer pattern typical for this segment); G2 lists the product but no published price. Enterprise pharma deployments of this shape typically transact as six-figure annual subscriptions, but that is inference, not verified.

► Sources

Certara — CoAuthor (generative-AI regulatory and medical writing software) within the Certara.AI platform, plus NVIDIA BioNeMo Agent Toolkit integration

The regulatory-writing AI backed by the industry's deepest biosimulation and regulatory-science bench. Explicitly 'built by writers, for writers' with human-in-the-loop as a stated design principle — which sells well to Quality but caps how autonomous it is allowed to be.

Strengths

- eCTD-native templates and structured content authoring — it understands submission document architecture, not just prose
- Word integration meets medical writers in the tool they refuse to leave, which is the real adoption gate for authoring products
- Certara's regulatory-science and biosimulation credibility carries weight with reviewers and with FDA-facing teams
- Veeva AI Partner Program membership is a credible path to co-existing with, rather than fighting, the system of record
- NVIDIA BioNeMo agent toolkit gives a real agentic substrate for scientific/evidence tasks

Weaknesses

- Human-in-the-loop by design means it is deliberately not an autonomous agent — it will lose any evaluation scored on agentic autonomy
- April 2026 divestiture of the Regulatory and Medical Writing business to Veristat raises a direct strategic question about Certara's commitment and go-to-market motion in exactly this category
- Veeva RIM integration is 'planned', so today CoAuthor is another silo alongside the system of record
- Agentic story is newest and thinnest of the set — the NVIDIA toolkit is an enabling framework announced July 2026, not shipped regulatory agents
- No published validation package, no public pricing, no published cycle-time benchmark comparable to Yseop's GSK figure

AI shipped today	Shipping: CoAuthor combines generative AI, eCTD regulatory writing templates, structured content authoring, a life-science-specialized client-specific GPT, and Microsoft Word integration, with human-in-the-loop retained by design. Next-generation CoAuthor launched June 2024. October 2025: joined the Veeva AI Partner Program, with planned CoAuthor ↔ Veeva RIM integration to move content between RIM and CoAuthor's GenAI — note 'planned', not shipped. July 2026: partnership with NVIDIA to integrate the BioNeMo Agent Toolkit into the platform for tasks including dose optimization and regulatory evidence preparation, described as one of several agentic frameworks available to clients. certara.com pages returned HTTP 403 to direct fetch; claims rest on search-result summaries, the IR/press-release titles, and GlobeNewswire coverage.
GxP / validation posture	Not verified. Human-in-the-loop is an explicit design stance, and Certara's regulatory-science credibility is substantial, but no public CSV/Part 11 validation package or executed IQ/OQ/PQ for CoAuthor was found.
Pricing signal	CoAuthor list pricing is not public. The most useful signal is structural: in April 2026 Certara agreed to sell its Regulatory and Medical Writing business to Veristat for up to \$135M; that business generated \$50M revenue and \$17M adjusted EBITDA in 2025 (excluding unallocated overhead) — i.e. ~2.7x revenue for a regulatory-writing services book. That is the cleanest public valuation anchor in this category, though it prices services, not the CoAuthor software.

► Sources

Weave Bio — The Weave Platform — AI-native regulatory automation across the filing lifecycle (IND, CTA, NDA and beyond), with 2026 global-submission capability

The AI-native challenger built for regulatory submissions from a blank sheet. Pitches a single connected source of truth across jurisdictions so dossiers are never rebuilt per market, with AI in every step from data extraction through authoring, review and verification. This is the closest venture-backed analogue to the asset under evaluation.

Strengths

- AI-native architecture with no legacy platform to retrofit — the same structural advantage the asset under evaluation claims
- Cross-jurisdiction single-source-of-truth is a genuinely differentiated wedge; dossier rebuild per market is a real and expensive pain
- Covers the full filing lifecycle (IND/CTA through NDA), broader than a pure authoring tool
- Credible institutional backing (\$36M total) and category recognition, so it will be present in competitive deals
- Serves sponsors, biotechs, CROs and regulatory consultants — no platform lock-in requirement

Weaknesses

- No verified GxP/CSV/Part 11 validation posture in public materials — the hardest gate in this category is unproven
- No named production references at top-20 pharma comparable to Yseop's GSK/Sanofi/Novartis roster
- Submission-pipeline shaped rather than a general conversational agent; agentic autonomy is unverified
- \$36M raised is a fraction of what Dassault/ArisGlobal, IQVIA and Veeva will spend on this category through 2027
- Small-vendor viability and roadmap-continuity risk in a consolidating market

AI shipped today	Shipping: AI infused across data extraction, authoring, review and data verification to produce submission-ready dossiers; widely adopted for preclinical IND preparation. June 15, 2026: announced global submission capabilities establishing a single source of truth across jurisdictions, connecting source data across a program's full arc so one verified reference set feeds every subsequent filing — announced ahead of DIA 2026. Recognized as 'Biotech AI Innovation of the Year'. Whether the platform runs multi-round autonomous agents versus AI-assisted pipeline steps is not verified from public sources.
GxP / validation posture	Not verified. No public CSV/Part 11 validation package, no published Part 11 e-signature or audit-trail architecture was found. For an AI-native vendor selling into RA, this is the most likely procurement blocker and should be diligenced directly.
Pricing signal	Not public. Funding is the available signal: \$20M Series A announced October 2025 led by USVP with Innovation Endeavors, Magnetic Ventures, Character, TMV and Serrado Capital, bringing total raised to ~\$36M (following a \$10M round in 2024). That places it in the same capital band a challenger asset would be benchmarked against.

► Sources

IQVIA — IQVIA.ai — unified agentic AI platform combining conversational AI with an extensible catalog of ready-to-use and configurable agents

The horizontal agentic platform for life-sciences operations, with regulatory as one domain among clinical, commercial and real-world. Sells to the enterprise, not to the RA function specifically — which makes it a top-down threat that can be imposed on RA rather than chosen by it.

Strengths

- Unmatched proprietary data assets — an agent grounded in IQVIA's real-world and clinical data can answer questions no competitor's agent can
- Conversational AI plus a configurable agent catalog is architecturally the closest competitor shape to a general regulatory assistant
- Enterprise reach and existing MSAs mean it can be sold above the RA function's head
- Serious infrastructure backing (NVIDIA stack, AWS as preferred agentic cloud) and the balance sheet to sustain it
- Published, thoughtful governance stance on human oversight in regulatory affairs — this lands well with Quality

Weaknesses

- The regulatory-intelligence agent is explicitly still being built; as of July 2026 there is no shipped regulatory agent to evaluate
- Breadth across clinical/commercial/RWE means regulatory depth is shallow relative to RA-specific vendors
- No system of record for regulatory content — it reasons over data, it does not manage the dossier
- Validation posture for the agent layer is unverified, and a horizontal platform is harder to validate for a specific GxP intended use
- Services-led commercial motion tends to produce long, expensive, consultant-heavy engagements rather than a product a RA team self-serves

AI shipped today	Launched March 16, 2026 at NVIDIA GTC. Combines IQVIA's data assets and Healthcare-grade AI with NVIDIA Nemotron, NeMo Agent Toolkit, Dynamo and LangChain; pairs conversational AI with an extensible agent catalog built around real life-sciences workflows. Initial release targets high-value clinical, commercial and real-world use cases; additional agents expected Q4 2026. IQVIA states it is using IQVIA.ai to build an agentic AI tool for regulatory intelligence — i.e. the regulatory-specific agent is in build, not shipped. December 2025: named AWS preferred agentic cloud provider. Published an April 2026 'Human-at-the-Helm' position on agentic AI for global regulatory affairs. iqvia.com and biospace.com returned HTTP 403 to direct fetch; claims rest on search-result summaries and press coverage.
GxP / validation posture	Stated to operate securely and in alignment with healthcare regulatory, privacy and quality standards, with a published 'human-at-the-helm' governance stance. A discrete GxP/CSV/Part 11 validation package for IQVIA.ai agents is not verified.
Pricing signal	Not public. IQVIA transacts as enterprise platform plus services; agentic deployments in this shape are typically bundled into multi-year technology-and-services agreements rather than priced per seat, but that is inference, not verified.

► Sources

Capability rubric

Our score is cited to `file:line` in this repository. Theirs is cited in the competitor sections above. Scored on what **ships and is reachable**, not what is architected — an unreachable or unvalidated capability scores low regardless of code quality.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Executable tool surface — how many real, backed operations the agent can actually invoke against regulatory data and systems	critical	5 ▲	ArisGlobal NavaX Agents	3	server/services/ana/AnaToolExecutor.ts:213 (registerToolHandler) with 700 registrations in that file and 704 unique handler names repo-wide; 711 unique tool-name literals under server/services/ana/. Real integrations imported at AnaToolExecutor.ts:19-40 (ClinicalTrials.gov, PubMed, CMS coverage, FDA MAUDE, drug labels/approvals, ChEMBL, EUDAMED, EMA EPAR, EU CTIS, preprints, HubSpot, device recalls). server/services/ana-ri/command-executor.ts:3941 COMMAND_REGISTRY carries 76 governed platform commands reachable from chat.
Agentic autonomy — multi-round plan → tool → verify → draft loop rather than single-shot generation	critical	5 ▲	ArisGlobal NavaX Agents	3	server/services/ana/agentic-loop.ts:89 MAX_ROUNDS_BY_EFFORT = fast 4 / balanced 6 / thorough 10, plus agentic-loop.ts:110 ROUND_EXTENSION_BY_EFFORT of 0/2/4 progress-earned rounds; server/routes/ana-ri/stream.ts:1090 wires resolveMaxRounds into the live SSE path, stream.ts:829 emits per-round tool plans, stream.ts:832 runs tools under bounded concurrency; server/services/ana/deep-investigation.ts:263 runs a thorough-tier investigation loop.
Determinism and reproducibility posture — can the vendor tell an inspector which outputs are deterministic vs model-generated	high	5 ▲	Yseop Copilot	2	server/services/ana/tool-pedigree.ts:73 PEDIGREE_LEVELS classifies every tool across five levels (deterministic_registry, deterministic_query, rim_learned, external_api_live, model_assisted) with explicit trust ratings ('high', 'medium', 'requires_verification'); consumed at AnaToolExecutor.ts:63 via getToolPedigree/listDeterministicTools. No competitor publishes an equivalent per-capability determinism taxonomy.
Output grounding and anti-hallucination verification of the agent's own answer	critical	4	Yseop Copilot	4	server/services/ana-ri/evidence-validation.ts:286 validateEvidence performs post-hoc label extraction, claim extraction, grounding check, overclaim detection and contradiction detection; wired at server/routes/ana-ri/chat.ts:755 and server/routes/ana-ri/post-processing.ts:262. Pre-flight guards: server/services/ana-ri/claim-grounding.ts:154 buildClaimGroundingBlock (citation/numeric/probability/precedent/guarantee/deadline) and server/services/ana-ri/scope-guard.ts:68 SCOPE_CHECKS. Not a 5: claim-grounding is a prompt-level directive, not enforcement, and the validator is heuristic and unaudited by any third party.
Model and provider governance — multi-provider routing, data residency, zero-retention, PII screening, prompt-injection defense	high	4 ▲	Veeva AI	3	server/services/ai-gateway/gateway.ts:2043+ buildConfig registers six providers (openai, anthropic, moonshot, bedrock, vertex, azure); gateway.ts:1681 and :1693-1706 treat residency and zero-data-retention as hard constraints that fallback may never cross. Prompt injection is enforced: server/services/ai-gateway/policy.ts:239 blocks on detection with contentFilters defaulting true (policy.ts:99), backed by server/services/ai-gateway/promptInjection.ts severity tiers. Capped at 4 because server/services/ai-gateway/pii-screen.ts:29 defaults AI_PII_ENFORCEMENT to 'audit' — PHI/PII is detected and recorded but not blocked out of the box.
Cross-session memory and context personalization	high	4 ▲	IQVIA.ai	2	server/services/memory-orchestrator.ts:1-27 defines the policy layer over three real layers (working, client, project) with a single cross-layer scoring formula (priorityBoost + similarity-w + confidence-w + verifiedBoost); mechanics in server/services/memory-context-assembler.ts (parallel fetch, pgvector semantic search on client/project layers), persistence in server/services/working-memory.ts, decay in server/services/memory-consolidation-job.ts, acceptance gating in server/services/ana-ri/memory-acceptance.ts. Working memory is recency-only (no embedding yet), which is why this is a 4.
Reachable conversation-first front door — can a user actually get to the agent and run real work	critical	3 ▼	IQVIA.ai	4	Positive: client/src/concept2cure/v2/registryModel.ts:117 puts 'conversation-thread' first in RAIL_PRIMARY (one of only 5 rail entries out of 101 registered surfaces); client/src/concept2cure/v2/surfaceViews.ts:143 mounts it; client/src/concept2cure/v2/surfaces/ConversationThread.tsx:267 calls useAnaChat against the real POST /api/ana-ri/stream with token streaming, extended thinking and grounding sources. Capped at 3 by two shipped gaps: ConversationThread.tsx:279 hardcodes const artifacts: CtArtifact[] = [] so the governed-artifact panel on the primary chat surface is empty, and the surface has no conversation-history list — the richer client with recents (client/src/concept2cure/components/ana/Ana.tsx, 1,189 lines, thread recents via useRecents + document studio) has zero non-test imports and is orphaned.
Part 11 governance of agent-initiated record mutations (reason-for-change + manifested e-signature)	critical	3 ▼	Veeva AI	4	Architecture is real and tiered: server/services/ana-ri/part11-governance.ts:26 PART11_GOVERNED_COMMANDS (11 record-altering commands require reason-for-change), :55 PART11_ESIGN_COMMANDS (6 high-impact commands additionally require re-authentication), :187 loadPart11EnforceStrict fails closed on DB error, and the client sign-off UX shipped (client/src/concept2cure/components/ana/GovernedActionSignoff.tsx, rendered from Shell.tsx and Message.tsx:728). Capped at 3 because part11-governance.ts:196 requires settings.anaPart11Enforce === true — enforcement is per-tenant and defaults OFF, so out of the box an agent-initiated mutation is not Part 11 gated.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Governed artifact production from the conversation (versioned, sealed, exportable)	high	3 ▼	Certara CoAuthor	4	Backend is real: server/services/ana/verifiedSealService.ts implements the Part 11 verified-and-sealed export with a DB approval record (verifiedSealService.ts:317) and signer-authority resolution via server/services/part11/signing-authority.ts; routed at server/routes/ana-ri/seal-verified.ts:27; server/services/ana-ri/artifact-generator.ts exists. But the primary chat surface cannot show them — ConversationThread.tsx:279 pins the artifact list to empty with an honest placeholder, so the chat → governed-artifact loop is not closeable from the shipped front door.
Durable, tamper-evident audit trail of every AI call (model, prompt, tools, tokens, outcome)	high	2 ▼	Veeva AI	5	The persistence code exists but is dead in production. server/services/ai-gateway/audit.ts:49 gates persistence on <code>if (this.pool)</code> ; the pool comes from server/services/ai-gateway/gateway.ts:411 <code>new GatewayAuditLogger(this.config.dbPool)</code> ; buildConfig (gateway.ts:2043+) never populates dbPool and every call site is a bare <code>getGateway()</code> with no config. Result: the ai.gateway_audit_log INSERT at audit.ts:121 never runs, and the Part 11 AI audit trail is an in-memory ring buffer capped at 100 entries (audit.ts:12-13, maxBufferSize=100) that is lost on restart, with log failures swallowed by design (audit.ts:22-23). Turn-level persistence is real (post-processing.ts:25 saveChatMessage, :26 persistProvenance), which is why this is a 2 and not a 0.
GxP/CSV validation package a Quality function can accept (executed IQ/OQ/PQ, approved VSR, intended-use risk assessment)	critical	2 ▼	Yseop Copilot	5	Genuine asset: docs/validation/TM-CORTEX-001-PART11-TRACEABILITY.md (dated 2026-06-08) is a real requirement → design → code → verification matrix where every Part 11 clause row names the implementing module and the automated test or CI gate that verifies it. But the qualification set is unexecuted: docs/validation/VMP-CORTEX-001-VALIDATION_MASTER_PLAN.md, IQ-CORTEX-001, OQ-CORTEX-001, PQ-CORTEX-001 and VSR-CORTEX-001 are all Version 1.0.0-DRAFT, dated 2025-01-24, Approved By: PENDING, and stamped 'REQUIRES VALIDATION REVIEW BEFORE PRODUCTION USE'. No executed qualification records exist. This is a validation-ready package, not a validated system.
System-of-record integration (Veeva Vault RIM / eCTD / existing dossier)	critical	2 ▼	Veeva AI	5	The platform ships its own vault and eCTD stack (server/services/ectdExportService.ts with generateEctdPackage/validateEctdPackage, real leaf PDF rendering via server/services/ectd/leaf-pdf-renderer.ts, and vault tools registered in AnaToolExecutor: list_vault_documents, read_vault_document, get_document_versions, get_tmf_view). What is absent is any connector to a customer's incumbent RIM — no Veeva Vault client, no RIM read/write bridge anywhere under server/services/integrations/. The agent can only act on data already inside this platform, which means displacing the system of record rather than augmenting it.
Production proof — named references, submissions filed with the AI's output, published cycle-time results	critical	0 ▼	Yseop Copilot	5	absent — no customer references, no case studies, no published cycle-time benchmark, and no evidence of a regulatory submission containing this system's output anywhere in the repository. The AnA suites pass (40/40 across tests/ana-single-brain.test.ts and tests/routes/ana-ri-health.test.ts), which is engineering evidence, not market evidence.

Where we stand

Where we win

- Executable tool surface, by roughly 5x the nearest competitor. 704 registered tool handlers (server/services/ana/AnaToolExecutor.ts:213) plus 76 governed platform commands (command-executor.ts:3941), bound to real regulatory sources — ClinicalTrials.gov, PubMed, FDA MAUDE, drug labels and approvals, EMA EPAR, EU CTIS, EUDAMED, ChEMBL, CMS coverage. Every competitor in this set ships a handful of task-shaped agents; none ships a general agent with a tool surface of this breadth.
- Genuine multi-round agentic autonomy. 4/6/10-round ceilings by effort tier with 0/2/4 progress-earned extensions (agentic-loop.ts:89, :110), live on the streaming path with per-round tool planning and bounded-concurrency execution (stream.ts:829, :832, :1090). Veeva's shipped agents are single-purpose; Certara is human-in-the-loop by design; Yseop's agentic tier is partly forward-looking. This is a real architectural lead.
- Determinism pedigree — the strongest and least-appreciated asset in the codebase. tool-pedigree.ts:73 classifies all 704 capabilities across five determinism levels with explicit trust ratings. No competitor publishes anything equivalent, and it answers the exact question a GxP inspector asks: which of these outputs are reproducible and which are model-generated. This is governance IP, not a feature.
- Intent-aware tool governance at scale. tool-selection.ts:116 caps the offered surface at 50 tools per turn, ranked by relevance and reliability, with a platform-command bridge that keeps every dropped capability reachable and a per-tenant deny-list applied first (stream.ts:750-766). Solving 700-tool selection without losing capability is non-trivial engineering that competitors have not had to face.
- Model and provider governance breadth: six providers with residency and zero-data-retention as hard, non-crossable fallback constraints (gateway.ts:1681, :1693), plus enforced prompt-injection blocking (policy.ts:239). Veeva is Bedrock-bound; this gives buyers residency options and commercial leverage no incumbent offers.

- Three-layer memory with a single cross-layer ranking policy (memory-orchestrator.ts) and pgvector semantic retrieval — more architecturally serious than anything publicly described by the six competitors.

Where we reach parity

- Output grounding and anti-hallucination. The post-hoc validator (evidence-validation.ts:286: label extraction, overclaim detection, contradiction detection) plus pre-flight claim-grounding and scope guards is a strong stack, but it is heuristic and unaudited, while Yseop sells verified explainability with FDA/EMA-accepted submissions behind it. Architecturally ahead, evidentially behind — call it even.
- Conversation-first front door. AnA is rail entry #1 of only 5 (registryModel.ts:117) running real SSE streaming — better placement than Veeva's embedded agents, comparable to IQVIA.ai's conversational layer. But the empty artifact panel (ConversationThread.tsx:279) and the missing thread list drag it back to parity rather than a win.
- Regulatory domain knowledge depth. The ana-ri corpora (ich-guideline-corpus.ts, regulatory-pathways-corpus.ts, pharmacopoeia-corpus.ts, deficiency-taxonomy.ts) are substantial, but Certara's regulatory-science bench and IQVIA's proprietary data assets are equally credible from the buyer's chair.

Where we lose

- Production proof — a zero, and the one that decides the deal. Yseop names GSK, Sanofi, Novartis, Lilly, PPD and Pierre Fabre, 300+ trials, FDA- and EMA-approved submissions, and a ~70% CTN cycle-time reduction at GSK. This asset has no named customer, no case study, and no filed submission. No amount of architecture closes that in a procurement.
- Validation package. TM-CORTEX-001 is a real code-linked Part 11 traceability matrix, but VMP/IQ/OQ/PQ/VSR are all 1.0.0-DRAFT, Approved By PENDING, dated 2025-01-24, with no executed qualification records. Quality will not sign. Veeva and ArisGlobal customers already have accepted validation substrates.
- Durable AI audit trail — a P0 GxP defect, not a gap. The gateway audit logger's DB path is unreachable in production because dbPool is never populated (gateway.ts:411 + buildConfig, every call site a bare getGateway()), so the Part 11 AI audit trail is a 100-entry in-memory ring buffer that dies on restart (audit.ts:12-13, :49) with failures swallowed. A single inspection question destroys the sale.
- Part 11 enforcement default. The tiered reason-for-change and e-signature gate is well built and the sign-off UI ships, but part11-governance.ts:196 leaves it OFF unless a tenant opts in. Shipping a regulatory agent with its Part 11 gate default-off is indefensible in front of a Quality reviewer.
- System-of-record integration. No Veeva Vault or RIM connector exists anywhere. The agent can only act on data already inside this platform, so it must displace the system of record instead of augmenting it — the hardest, longest sale in life sciences, and precisely the ground Veeva chose.
- Distribution and capitalization. Dassault is paying ~\$2.0B for ArisGlobal with a \$200M AI revenue earn-out; IQVIA has NVIDIA and AWS behind IQVIA.ai; Veeva sells into an installed base that already owns the dossier. This asset has 704 tools and no route to market.
- Chat UX completeness against a ChatGPT-parity expectation: no conversation-history list on the primary Chats destination, and the 1,189-line Ana.tsx that implements recents, document studio and memory panels has zero non-test imports — the best client-side assistant work in the repository is orphaned.

Is the advantage durable?

Split the advantage into three pieces, because they decay at very different rates.

Perishable within about 6 months — agentic autonomy. The multi-round loop (agentic-loop.ts:89) is excellent engineering but not scarce; it is a known pattern and every competitor has the same model vendors. ArisGlobal already ships multi-agent systems and, post-Dassault, will have \$2B of strategic sponsorship plus a \$200M AI revenue earn-out pointed directly at this. Veeva ships regulatory agents in August 2026. Assume no autonomy lead by Q1 2027.

Perishable within 12–18 months — tool-surface breadth. 704 handlers plus 76 governed commands is roughly 12–18 person-months of grinding integration work, and grinding work is exactly what a well-capitalized incumbent does well. The moat is not the count, it is that Veeva has a structural reason not to build it: agents over Vault-resident data are the whole pitch, so reaching outward to CT.gov, PubMed, MAUDE, EU CTIS and EUDAMED is off-strategy for them. ArisGlobal and IQVIA have no such constraint — IQVIA in particular can substitute proprietary data for public-source breadth and be more valuable while building less. Call it 12–18 months against ArisGlobal, less against IQVIA.

Genuinely durable, 24+ months, and mispriced by this analysis's own scoring — the governance primitives. The five-level determinism pedigree (tool-pedigree.ts:73), the post-hoc evidence validator with overclaim and contradiction detection (evidence-validation.ts:286), the scope guard that distinguishes hand-off from refusal including a hard refusal on data-integrity requests (scope-guard.ts:68), and the code-linked Part 11 traceability matrix (docs/validation/TM-CORTEX-001-PART11-TRACEABILITY.md) together answer the question that actually blocks agentic AI in GxP: which outputs are reproducible, which are model-generated, and how do you prove it to an inspector. Nobody in this set publishes an equivalent. Incumbents are unlikely to copy it quickly not because it is technically hard but because publishing a determinism taxonomy is an admission that some outputs are not deterministic — a disclosure a \$2B platform vendor with an installed base is structurally reluctant to make. That reluctance is the moat, and reluctance decays slowly. Expect 24–36 months before regulatory pressure (FDA/EMA guidance on AI in submissions) forces the category to adopt something like it — at which point being the vendor who published first is worth real money.

Not a moat at all — Part 11 mechanics and audit trail. Veeva and ArisGlobal have had these for a decade. The tiered reason-for-change/e-signature design (part11-governance.ts:26, :55) is good work that reaches parity at best, and today it does not even reach parity because it defaults off and the AI audit trail does not persist.

Net for an acquirer: buy the governance IP and the integration inventory, discount the autonomy lead to near zero in the model, and understand that the clock started on 23 July 2026 when Dassault wrote the check. Roughly 12 months of daylight on the composite technical position, and the durable residual is the determinism-and-grounding stack — which is precisely the part that is worth nothing without an executed validation package to attach it to.

Shortest credible path to parity

1. P0, days, ~10 lines — make the AI audit trail durable. Populate GatewayConfig.dbPool in buildConfig (server/services/ai-gateway/gateway.ts:2043+) so the pool reaches GatewayAuditLogger at gateway.ts:411 and the ai.gateway_audit_log INSERT at audit.ts:121 actually executes; today the guard at audit.ts:49 is never true and the Part 11 AI audit trail is a 100-entry in-memory buffer lost on restart. Then stop swallowing write failures (audit.ts:22-23) — an audit-trail write failure must surface, not console.error. This is the cheapest, highest-severity fix in the entire category and it currently invalidates the Part 11 story on the first inspection question.
2. P0, days — flip Part 11 enforcement on by default. part11-governance.ts:196 requires settings.anaPart11Enforce === true; default it ON for all new organizations and migrate existing tenants on a notice period. The server-side fail-closed gate and the client sign-off UX (GovernedActionSignoff.tsx, rendered from Shell.tsx and Message.tsx:728) both already ship, so this is a default change, not a build. Shipping a regulatory agent with its e-signature gate default-off cannot be defended in a Quality review.
3. P1, 2–4 weeks — close the chat front door. Replace the hardcoded `const artifacts: CtArtifact[] = []` at ConversationThread.tsx:279 with the real governed-artifact stream (verifiedSealService.ts and artifact-generator.ts already produce them), and fold the orphaned recents implementation from Ana.tsx (useRecents → GET /api/chat/threads) into the conversation surface so the primary Chats destination has a thread list. Ana.tsx is 1,189 lines of already-written client work with zero non-test imports — this is harvesting, not building. Without it, every demo dies in the first 30 seconds on 'where are my previous conversations' and 'where did the document go'.
4. P1, 8–12 weeks and the single largest value unlock — execute the validation package. Pin a release, execute IQ-CORTEX-001, OQ-CORTEX-001 and PQ-CORTEX-001 against it, approve VMP-CORTEX-001, and issue VSR-CORTEX-001 at 1.0 approved rather than 1.0.0-DRAFT/PENDING. Add an ICH-E6-aligned intended-use and risk assessment for the agent specifically, and a qualification approach for model non-determinism that leans on the tool-pedigree taxonomy (tool-pedigree.ts:73) — that taxonomy is the answer to the hardest question in agentic CSV and no competitor has one. TM-CORTEX-001 already provides the requirement → code → verification spine, so this is execution and sign-off, not authorship. This converts the strongest technical asset into a sellable artifact.
5. P1, 10–14 weeks — build a Veeva Vault RIM connector (read first, then governed write with Part 11 handoff). No RIM connector exists anywhere under server/services/integrations/. Until one does, the agent can only act on data already inside this platform, which forces a system-of-record displacement sale against the incumbent that owns the dossier. Certara's path is the proof point: it joined the Veeva AI Partner Program in October 2025 rather than fighting Vault. Augmenting Vault converts Veeva from the reason you lose into the reason you are shortlisted.
6. P1, one quarter, non-engineering, and the actual gating item — land 2–3 named design partners and publish one quantified cycle-time result. Yseop wins this category on GSK, Sanofi, Novartis, Lilly, PPD and Pierre Fabre, 300+ trials, FDA- and EMA-accepted submissions, and a ~70% CTN authoring reduction. This asset scores zero on production proof. Pick one narrow, provable workflow — health-authority question response drafting or Module 2.7 assembly — instrument it, and publish the before/after with the customer's name on it. Nothing above matters commercially until this exists.
7. P2, 4–6 weeks — harden the security defaults that a CISO review will flag. Move AI_PII_ENFORCEMENT from its 'audit' default (pii-screen.ts:29) to 'block' for tenants handling real PHI, so PHI can only route to a zero-retention provider. Set AUDIT_HMAC_SECRET as a hard boot requirement rather than a warning fallback, and wire AnA governed actions into the tamper-proof audit chain (lib/tamper-proof-audit.ts), which today has no references from server/routes/ana-ri/, server/services/ana-ri/ or server/services/ana/.
8. P2, 6–8 weeks — turn the determinism pedigree into a customer-visible artifact. Surface per-response pedigree and the evidence verdict (evidence-validation.ts:286) in the chat UI and in every exported document, and publish the taxonomy as a whitepaper. This is the one durable differentiator in the category; leaving it buried in server/services/ana/tool-pedigree.ts means the buyer never sees the thing that should be winning the deal.

Verdict

● **Credible challenger** — The backend is the real asset and it is genuinely ahead of the field. 704 registered tool handlers bound to live regulatory sources, a true multi-round agentic loop (4/6/10 rounds plus progress-earned extensions), intent- and reliability-aware tool selection that solves the 700-tool offering problem, a five-level determinism pedigree no competitor publishes, a post-hoc evidence validator, three-layer memory, and a six-provider gateway with residency and ZDR as hard constraints. On pure agentic architecture this beats Veeva, ArisGlobal, Certara, Yseop, Weave and IQVIA as of July 2026 — and the timing window is real, because Veeva's Regulatory AI Agents are reported for August 2026 and Agentic Authoring for late 2027, while IQVIA's regulatory agent is still in build.

Crucially, and unlike most of this platform's other categories, the reachability problem does not disqualify this one. Only 5 of 101 registered UI surfaces sit in the global rail, but AnA's conversation surface is rail entry #1 and runs the real streaming endpoint. The front door exists.

What disqualifies it from 'leader' is everything downstream of the architecture. Production proof scores zero against Yseop's named top-10 pharma roster and FDA/EMA-accepted submissions. The validation package is entirely draft — VMP, IQ, OQ, PQ and VSR all 1.0.0-DRAFT, Approved By PENDING, dated January 2025, with no executed records — so Quality cannot sign. The Part 11 gate for agent-initiated mutations is well designed and default-OFF. And the AI-call audit trail, the single artifact an inspector will ask for first, does not persist at all in production because the gateway's DB pool is never wired: it is a 100-entry in-memory buffer that is lost on restart, with write failures swallowed by design. That is a P0 defect masquerading as a compliance feature.

Two of those four are cheap to fix (wire the pool, flip the default) and two are not (execute qualification, earn references). There is also no connector to any incumbent RIM, which forces a system-of-record displacement sale against the one competitor that owns the system of record.

For an acquirer the read is clean: this is an engineering asset with a 12-to-18-month architectural lead in agentic tooling and a genuinely novel governance primitive in the determinism pedigree, wrapped in a compliance posture that cannot currently survive a customer audit and a market position that does not yet exist. Buy the engineering and the governance IP, price in a validation program and a RIM connector, and assume the lead compresses fast once Veeva ships in August and Dassault deploys ArisGlobal's \$2B of capital. Do not price it as a market-ready product.

Biostatistics, SAP authoring & statistical programming

Verdict: ● **Not competitive** Weighted capability score — **us 1.6 / 5** vs **best competitor 4.6 / 5** across 11 dimensions.

Full category as scoped: Biostatistics, SAP authoring & statistical programming

Who buys, and what they are actually buying

Head of Biostatistics / VP Biometrics at a sponsor (or the Biometrics lead at a CRO), co-signed by Quality/CSV and Regulatory. The budget line is "biometrics tooling + statistical computing environment." What they are buying is a defensible, auditable path from protocol to locked SAP to submission-ready TLF/ADaM package — with a validation package their QA group can hand an inspector. Their two hard gates are (1) can my statistician actually run a study design and produce a signed SAP in this tool today, and (2) can you show me qualification evidence against SAS/nQuery reference values. Deals are lost on gate 2 more often than on features. Secondary influencer: the statistical programming lead, who cares only about SAS/R execution, double programming, and CDISC conformance on real datasets.

Market structure

STRUCTURE. This is not one market; it is three adjacent ones that no single vendor yet spans, which is why procurements routinely end in two or three purchases:

(1) DESIGN — sample size, power, group-sequential boundaries, adaptive simulation. Owned by Cytel (East/East Horizon/Solara) with nQuery/Statsols as the value alternative (370+ procedures, 1,000+ sample-size and power scenarios, and — notably — published validation documentation comparing results to other statistical software, which is exactly the artifact most vendors will not produce). See <https://cytel.com/east-horizon/> and https://info.statsols.com/hubfs/Resources/_nQuery%20Validation%20Reports/nQuerySampleSizeandPowerCalculationValidationDocumentation.pdf

(2) EXECUTION — the statistical computing environment where SAS/R/Python actually run, with double programming and audit trail. A two-horse incumbent-vs-modernizer race: SAS LSAF (single GxP-validated environment) versus Domino (multi-language, plus SCE QC launched 13 Nov 2025 for automated dual-programmer validation traceable to Part 11). UCB is a public reference for the modernization thesis. See <https://domino.ai/press-releases/sce-qc> and <https://www.ucb.com/newsroom/press-releases/article/ucb-and-domino-data-lab-collaborate-to-modernize-statistical-computing-environment-in-life-sciences>

(3) STANDARDS + NARRATIVE — CDISC conformance, define.xml, and the documents. Certara owns this via Pinnacle 21 Enterprise (SDTM/ADaM/Define-XML/SEND validation rules, real-time error highlighting, clinical metadata repository) plus CoAuthor. Public efficiency claims: validated studies up to 85% faster, define.xml deliverables up to 80% faster. See <https://www.certara.com/pinnacle-21-enterprise-software/validation/> and <https://www.certara.com/pinnacle-21-enterprise-software/demo/>

CONSOLIDATION. Certara has rolled up the standards layer (Pinnacle 21) and stitched it to AI authoring (CoAuthor, next-gen announced June 2024) — the clearest attempt to span (3) into (1)/(2). Cytel has extended from desktop East into cloud East Horizon and downmarket via East On Demand. Nobody has convincingly spanned design → execution → standards, which is the strategic opening — and also the reason a challenger that spans none of them credibly is invisible in an RFP.

THE 2026 AI INFLECTION IS REAL AND IS ABOUT ARCHITECTURE, NOT FEATURES. The industry has converged on a specific question: where is the LLM allowed to sit? Two camps have formed. Cytel's RCACTs puts GPT-4o at the code-generation layer (generating R for the East Horizon engine). Veristat's InStat (launched 13 May 2026) explicitly rejects that, putting AI agents at the specification layer to drive a library of pre-validated statistical engines — marketed verbatim as automation speed "without the risk or regulatory exposure of LLM-generated analysis code," with a 5-weeks-to-5-days readout claim and Clene Nanomedicine as first customer. The specification-layer architecture is winning the credibility argument. Any acquisition thesis in this category must state which camp it is in. See <https://cytel.com/by-topic/artificial-intelligence-and-machine-learning/> and <https://www.businesswire.com/news/home/20260513591002/en/Veristat-Launches-AI-Biostatistics-Platform-Cutting-Clinical-Trial-Data-Readout-Time-from-5-Weeks-to-5-Days-Without-Regulatory-Risks>

ACADEMIC/OPEN PRESSURE ON SAP AUTHORING SPECIFICALLY. SAP drafting is the sub-segment most exposed to commoditization. SAPAI, from King's College London CTU, generates SAPs from protocols and was validated by independent trial statisticians across nine real-world trials: 71 SAPs drafted in 1.0–3.4 minutes each versus a traditional 1–2 days, with SME quality ratings of 3.6–4.2 on a 5-point scale. It is published, peer-reviewed in Clinical Trials, and has a public demo app. A buyer should assume the floor price of "AI drafts a SAP" trends toward zero within 24 months, and that defensibility must come from governance, validation and traceability rather than from generation. See <https://journals.sagepub.com/doi/10.1177/17407745261422365> and <https://www.medrxiv.org/content/10.64898/2026.03.19.26348626v2.full>

CRO/FSP AS THE REAL COMPETITIVE SET. For mid-cap sponsors the alternative to buying software is buying people with proprietary automation: Phastar's REPIT and MAPIT for TFL/SDTM automation, Veramed's CDISC ARM v1.0 metadata-driven generation of standalone SAS programs, Saama BRAIN centralizing statistical programming and generating submission-ready TLFs. Any software-only pitch is priced against an FSP contract that already includes the statistician. See <https://phastar.com/solutions/biostatistical-programming/>, <https://veramed.com/resources/automation-of-safety-tables-for-phase-1-2-biotech-trial/>, <https://www.saama.com/platform/products/biometrics-research-and-analysis-information-network-brain/>

PROCUREMENT PATTERN AND DEAL SIZE. Pricing is uniformly opaque — none of the five publish list prices; Capterra's Cytel listing discloses no starting price. Deals are demo-led and QA-gated, and the gate that kills challengers is not features, it is the validation package: SAS LSAF and nQuery both lead with qualification evidence, and a biometrics QA group will not sign without an IQ/OQ/PQ or a statistical qualification report benchmarking outputs against reference software. Practical implication for this asset: absent that artifact, the product does not reach technical evaluation regardless of engine quality.

The five closest competitors

Cytel — East / East Horizon / Solara (East On Demand)

The incumbent standard for group-sequential and adaptive trial design and simulation. East Horizon launched as a cloud 'collaborative workbench for biostatisticians to create and optimize trials'; Solara is the trial-simulation/design-optimization layer. Sold to sponsor biostatistics groups as the tool of record for sample size, boundaries and operating characteristics.

Strengths

- Decades of regulatory acceptance for East-derived designs; the reference implementation most FDA/EMA statisticians recognize on sight
- East Horizon consolidates East + Solara + open-source analytics into one cloud workflow
- Ships a real AI capability, not a roadmap: RCACTS, an R coding assistant built on GPT-4o and deployed inside Microsoft Azure, that generates R tailored to the East Horizon simulation engine rather than generic standalone scripts
- East On Demand lowers the entry point to smaller biopharma, widening the wedge against challengers
- Partnership credibility (e.g. Solara co-development with GSK)

Weaknesses

- Design-centric: it is not a SAP authoring system and not a statistical computing environment — no ADaM derivation, no TLF production, no CDISC define.xml
- Pricing opacity and historically seat-heavy licensing makes it painful for small sponsors
- RCACTS is an LLM code assistant, so it inherits the reviewability concerns competitors like Veristat explicitly market against
- Collaboration/governance (versioning, e-signature, amendment control) is thin relative to document platforms

AI shipped today	RCACTS (R Coding Assistant for Clinical Trial Simulation) — OpenAI GPT-4o, deployed in Azure, generates R code specifically targeted at the East Horizon simulation engine from plain-English descriptions. Shipping, not roadmap.
GxP / validation posture	Not verified. Cytel does not publish a validation/qualification package on the pages reviewed; East's regulatory standing rests on decades of submission precedent rather than a published CSV artifact.
Pricing signal	Not public. Capterra maintains a Cytel listing but discloses no starting price or free trial; East On Demand is positioned as a lower-commitment entry tier.

► Sources

Certara — Pinnacle 21 Enterprise + CoAuthor

The CDISC conformance and define.xml standard, bundled with a generative-AI regulatory writing tool. P21 Enterprise validates clinical datasets against current CDISC standards and global regulatory rules; CoAuthor puts a life-science GPT plus eCTD structured templates inside Microsoft Word and pulls in analysis datasets, tables, listings and figures. Together they cover the 'metadata + narrative' half of biometrics deliverables.

Strengths

- Pinnacle 21 is the de-facto industry validator: SDTM, ADaM, Define-XML and SEND validation rules, with errors highlighted in real time
- Operates on real submission datasets, not hand-entered metadata — the thing a demo is won or lost on
- Clinical Metadata Repository gives standards governance across a portfolio, which is a genuine enterprise moat

- CoAuthor ships a purpose-built biomedical GPT with client-specific isolation, integrated to P21 validation and the Certara.AI engine, and can import/refresh analysis datasets and TLFs
- Quantified claims sponsors repeat in RFPs: validated studies up to 85% faster, submission deliverables via the Define.xml tool up to 80% faster

Weaknesses

- No trial design or sample-size engine — cedes the front half of the biostatistics workflow entirely to Cytel/nQuery
- No statistical computing environment: does not execute SAS or R, does not derive ADaM
- CoAuthor is a medical-writing tool that consumes SAPs and TLFs; it is not a SAP authoring or estimand system
- Word-centric authoring is a structural constraint for teams wanting API-first pipelines
- Two products, two procurement motions, and the AI value concentrates in CoAuthor rather than in biostatistics proper

AI shipped today	CoAuthor: purpose-built biomedical GPT embedded in Microsoft Word with structured content authoring and eCTD templates, integrated with Pinnacle 21 Enterprise validation and the Certara.AI deep-learning engine; imports and refreshes analysis datasets, tables, listings and figures. Next-generation CoAuthor announced June 2024 and shipping.
GxP / validation posture	Pinnacle 21 Enterprise is built around regulatory conformance rules (CDISC + FDA/PMDA-published validation rules) and is the tool sponsors cite in submissions. Specific 21 CFR Part 11 / CSV documentation for CoAuthor was not verified on the pages reviewed.
Pricing signal	Not public. Certara routes to demo/consultation; no list pricing published for P21 Enterprise or CoAuthor.

► Sources

Domino Data Lab — Domino Statistical Computing Environment (SCE) for Life Sciences + Domino SCE QC

The modern statistical computing environment — the place statistical programming actually happens. Unifies SAS, R and Python in one governed workspace so biometrics teams deliver analyses with full traceability in a 21 CFR Part 11-compliant environment. SCE QC (announced 13 November 2025) extends this into automated, audit-ready quality control for clinical programming.

Strengths

- Owns the execution layer — the single largest capability in this category and the one no design tool touches
- SCE QC embeds QC tracking in the environment: create, assign and approve deliverables inside the SCE, with every dataset, code file and output automatically linked and version-controlled
- Supports dual-programmer validation (double programming) with complete traceability aligned to 21 CFR Part 11 — this is the core compliance workflow of statistical programming
- Multi-language (SAS + R + Python) is a durable advantage over SAS-only incumbents as sponsors migrate to R
- Named enterprise reference: UCB publicly collaborating with Domino to modernize its SCE; SCE QC developed with pharma partners

Weaknesses

- Infrastructure, not domain content: no sample-size engine, no adaptive design, no estimand framework, no SAP authoring
- No CDISC conformance validator or define.xml generator — sponsors still buy Pinnacle 21 alongside
- Substantial implementation and platform-engineering burden; not a tool a lone biostatistician adopts
- AI story is automation and traceability rather than generative assistance to the statistician
- Horizontal-platform DNA means life-sciences depth varies by module

AI shipped today	Automation and traceability rather than generative AI: SCE QC automates QC assignment, approval and lineage capture. Domino is broadly an enterprise AI platform, but the shipping life-sciences differentiator as of 2026 is automated audit-ready QC, not an LLM statistician. Generative-AI features specific to the SCE were not verified.
GxP / validation posture	Strongest of the set on this axis: explicitly positioned as a 21 CFR Part 11-compliant environment supporting submissions, with dual-programmer validation and audit-ready documentation of every step.
Pricing signal	Not public. Enterprise platform licensing; deal sizes are consistent with multi-year six- to seven-figure infrastructure contracts, but no figure is published.

► Sources

SAS Institute — SAS Life Science Analytics Framework (LSAF) / Clinical Acceleration Repository

The default incumbent statistical computing environment for large pharma. Sold as a single GxP-validated environment providing reproducibility, traceability and governance across the clinical development process. The safe choice that no QA group argues with.

Strengths

- Explicitly marketed as a single GxP-validated environment — the validation posture competitors have to argue around
- SAS remains the language of record for the majority of submitted analyses; incumbency in programmer skill base is enormous
- Sustained investment to keep solutions qualified and adherent to new trial types
- Deep integration with the rest of a sponsor's SAS estate; nothing to re-platform
- Governance, reproducibility and traceability are the product, not an add-on

Weaknesses

- SAS-centric in an industry actively migrating to R and Python — the strategic vulnerability Domino targets directly
- No trial design/sample-size engine, no SAP authoring, no estimand framework, no CDISC validator
- Heavy, expensive, slow to deploy; poor fit for small and mid-cap sponsors
- No credible generative-AI biostatistics capability verified as shipping in LSAF as of 2026
- Modernization pressure: the UCB/Domino-style 'modernize the SCE' narrative is explicitly aimed at displacing it

AI shipped today	Not verified. No shipping generative-AI biostatistics or SAP-authoring capability within LSAF was confirmed in the sources reviewed. Treat any AI claim here as unproven.
GxP / validation posture	Strongest published claim in the category: LSAF is described as a single GxP-validated environment delivering reproducibility, traceability and governance, with continuous investment to keep solutions qualified for regulated use.
Pricing signal	Not public. Enterprise licensing, historically among the highest-cost options in the category; no figure published.

► Sources

Veristat — InStat by Veristat

The AI-native challenger, launched 13 May 2026. Marketed as the clinical research industry's first zero-code, fully automated biostatistics solution — compressing database-lock-to-submission-ready TLF from the typical four-to-six weeks to five days or less, with every output backed by validated statistical engines and expert biostatistician review. Delivered as a CRO-attached platform with a sponsor-facing collaboration portal.

Strengths

- Architecturally the sharpest answer to the LLM-in-regulated-analysis problem: AI agents turn a biostatistician's plain description into precise specifications, which then drive a library of validated statistical engines — automation speed without the regulatory exposure of LLM-generated analysis code
- Attacks the metric buyers actually feel: readout cycle time, with a concrete 5-weeks-to-5-days claim
- Transparent collaborative readout review via a secure sponsor portal, working with Veristat in real time to finalize readouts
- System-agnostic — sponsors keep their preferred EDC and their own formatting requirements
- Named reference customer already in a regulatory path: Clene Nanomedicine, NFL biomarker analyses supporting a planned 2026 NDA
- CRO delivery model means the statistician-in-the-loop is included, neutralizing the 'who validates the AI' objection

Weaknesses

- Very new — launched May 2026, one named customer; limited production track record
- Service-attached rather than a licensed product: sponsors wanting to run analyses in-house are not the target
- No published trial-design or sample-size capability; this is a readout/TLF automation play, not a design tool
- No SAP authoring, estimand engine or CDISC validator surfaced in launch materials
- SDTM/ADaM and TFL validation specifics were not verified in the sources reviewed — the 'validated statistical engines' claim is asserted, not evidenced publicly
- Buying InStat generally means buying Veristat as the CRO

AI shipped today	Shipping and architecturally explicit: AI agents convert biostatistician descriptions into precise analysis specifications, which drive a library of pre-validated statistical engines that perform every analytical step. Deliberately excludes LLM-generated analysis code. This is the most credible AI posture in the category because it puts the LLM at the specification layer, not the computation layer.
GxP / validation posture	Claims every output is backed by validated statistical engines plus expert biostatistician review, and markets itself as delivering automation speed 'without regulatory risks.' The underlying validation/CSV package is not published — not verified.
Pricing signal	Not public. Sold as part of Veristat's biometrics/CRO engagement rather than as standalone software, so deal size tracks study-level biometrics service contracts.

► Sources

Capability rubric

Our score is cited to `file:line` in this repository. Theirs is cited in the competitor sections above. Scored on what **ships and is reachable**, not what is architected — an unreachable or unvalidated capability scores low regardless of code quality.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Reachable front door — can a biostatistician find and use the module in a normal session	critical	1 ▼	Cytel	5	shared/constants/ui-surface-registry.ts (biostatistics and biostat-workbench both navTier:'specialist'; only 4 of 47 surfaces are navTier:'global' — projects, apps, artifacts-center, ana-memory); client/src/concept2cure/v2/V2App.tsx:121 (deep-link-only routing via surfaceldFromLocation); client/src/concept2cure/v2/surfaces/BiostatWorkbench.tsx:112 (the single endpoint of 63 with a client caller)
Validation package / CSV / statistical qualification against reference software	critical	0 ▼	SAS Institute (LSAF), matched by nQuery on published qualification evidence	5	absent — no IQ/OQ/PQ, validation summary, qualification report or traceability matrix anywhere in the repo; 249 passing tests across 19 files (server/services/stats/ tests , server/services/cdisc/ tests) are unit tests, not a CSV artifact
Statistical programming execution — SAS/R compute, ADaM derivation, TFL production, double programming	critical	0 ▼	Domino Data Lab (SCE + SCE QC)	5	absent — grep across server/services for proc mixed proc lifetest proc glm .sas generateSasCode rscrip generateRCode returns zero files; TLF exists only as gpt-4o-generated shells at server/services/statistical-continuum-service.ts:334-341, and /continuum has zero client callers
21 CFR Part 11 e-signature integrity on the locked SAP	critical	1 ▼	Domino Data Lab	5	server/services/collaborative-sap-service.ts:388-446 — signVersion writes client-supplied signatureId/signerName/timestamp/method verbatim; the 'Part 11 compliance' check at :415-426 only asserts non-empty fields; no re-authentication, no second ID component, no content hash bound to the signature (violates 11.100(a), 11.200(a)(1)(i), 11.70). Audit-trail route exists at server/routes/biostatPlatform.ts:524
Design & sample-size method breadth incl. group-sequential and adaptive operating characteristics	high	4 ▼	Cytel	5	server/services/stats/group-sequential-oc.ts:1-31 (exact OC by recursive numerical integration, Jennison & Turnbull ch. 19; binding-futility scope stated explicitly at :26-31); multiplicity.ts:56-276 (Bonferroni/Holm/Hochberg/fixed-sequence/graphical + FWER); mmmr-design.ts (280), rmst.ts (183), win-ratio.ts (205), dose-finding-boin.ts (197), assurance.ts (207) — 6,324 LOC total, 249 tests passing
CDISC conformance and define.xml on REAL datasets (XPT / Dataset-JSON ingestion)	high	2 ▼	Certara (Pinnacle 21 Enterprise)	5	server/services/cdisc/ 2,786 LOC of real checkers (sdm-domain 396, send 324, adam-bds 303, adam-adsl 252, adam-occds 244, controlled-terminology 214, define-xml-generator 228) each with tests — but define-xml-generator.ts:22-45 consumes hand-supplied DefineVariable/DefineDataset objects, and no XPT/sas7bdat/Dataset-JSON parser exists anywhere in server/
SAP authoring, versioning, amendment control and collaborative review, reachable end to end	high	2 ▼	Certara (CoAuthor)	4	server/services/collaborative-sap-service.ts:88-340 (drizzle-backed versioning with auto-diff, section edits blocked on lock, threaded comments, formal amendments with rationale) is a genuinely good data model — but grep of client/src for biostat/sap/create returns 0 callers, and all 12 SAP routes (server/routes/biostatPlatform.ts:391-556) are unreachable
ICH E9(R1) estimand framework depth and evidentiary honesty	high	2 ▼	Cytel	3	server/services/estimand-engine-service.ts:229-253 (ICE-level strategy validation against the recognized E9(R1) set) and :372-473 (strategy-to-method map, parallel gatekeeping) are real — but the engine is unreachable (0 client callers for biostat/estimand) and :388 hard-codes an unsourced 'FDA, EMA, and PMDA have accepted this approach' claim into every recommendation
Reproducibility, determinism and computation provenance	high	4 ▼	Domino Data Lab	5	server/services/stats/computation-provenance.ts (buildProvenance attached to results); rng.ts seedFromObject (seeded, reproducible Monte Carlo — verified by 'is reproducible for a fixed seed' tests in tests /monte-carlo.test.ts); compute-cache.ts order-invariant stable keying (tested); group-sequential-oc.ts:11-13 deterministic exact computation, no RNG; define-xml-generator.ts:11-12 byte-identical output
Regulatory judgment layer — telling the statistician what a reviewer will object to	medium	3	Veristat (InStat, biostatistician-in-the-loop review)	3	server/services/biostatistics-judgment/index.ts:55-61 and :73/:123/:155 (runJudgmentPipeline, runPipelineAndGenerateArtifact, runPipelineForRole) over 8 modules ~127 KB — power-adequacy, assumption-fragility, endpoint-method-defensibility, tradeoff-interpreter, risk-classifier, role-aware-interpreter, statistical-artifact-generator; genuinely differentiated content, but unreachable (0 client callers for biostat/judgment)
AI that actually ships in this category, with a defensible regulatory architecture	medium	2 ▼	Veristat (InStat: AI agents at the specification layer)	4	zero LLM in biostatistics-judgment/, biostats-signal-engine/, ana-biostats/, estimand-engine-service.ts, sap-generator-service.ts, collaborative-sap-service.ts (grep-verified) — architecturally the right posture; but the only

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
			driving validated engines)		LLM path is server/services/statistical-continuum-service.ts:230,337,515 (gpt-4o for SAP narrative and TLF shells) and /continuum has 0 client callers, so nothing AI can be demonstrated running

Where we stand

Where we win

- Depth and correctness of the deterministic statistical method library. server/services/stats/ is 6,324 LOC of genuine biostatistics, not wrappers: exact group-sequential operating characteristics computed by recursive numerical integration of the joint distribution of the sequential test statistics (Armitage–McPherson–Rowe; Jennison & Turnbull ch. 19) — deterministic, no RNG, reproducing the closed-form fixed-design result at a single look (server/services/stats/group-sequential-oc.ts:1-30, 586 LOC). Alongside it: multiplicity with Bonferroni/Holm/Hochberg/fixed-sequence/graphical procedures and FWER estimation (multiplicity.ts:56-276), MMRM sample size (280 LOC), RMST (183), win ratio (205), BOIN dose-finding (197), assurance (207), MRM (145), Bayesian device (255), external control (461), enrollment forecast (319). 249 tests across 19 files pass in 2.54s. The source comments state scope limits honestly rather than hiding them — group-sequential-oc.ts:26-31 explicitly flags that futility boundaries are treated as BINDING and tells the user to omit them for the conservative non-binding type-I-error computation. That is the voice of a statistician, and it is rare.
- Intellectual honesty and determinism as an architecture. Zero LLM calls in biostatistics-judgment/, biostats-signal-engine/, ana-biostats/, estimand-engine-service.ts, sap-generator-service.ts and collaborative-sap-service.ts (verified by grep across all six). Computation provenance is a first-class module (server/services/stats/computation-provenance.ts) with seeded RNG (rng.ts, seedFromObject) and an LRU compute cache keyed by order-invariant stable hashing (compute-cache.ts, tested for key-order invariance). Define-XML generation is documented and built as byte-identical for identical metadata (server/services/cdisc/define-xml-generator.ts:11-12). This is precisely the specification-layer/validated-engine architecture Veristat launched in May 2026 — we arrived at it independently and can defend it.
- Breadth of regulatory-judgment content that no competitor ships as software. server/services/biostatistics-judgment/ is eight modules (~127 KB) covering power adequacy, assumption fragility, endpoint-method defensibility, tradeoff interpretation, statistical risk classification, role-aware reporting and artifact generation, exposed through a composed pipeline (biostatistics-judgment/index.ts:73 runJudgmentPipeline, :123 runPipelineAndGenerateArtifact, :155 runPipelineForRole). Cytel computes designs; it does not tell a Head of Biostatistics that an assumption is fragile and why a reviewer will object. This is the most genuinely differentiated asset in the repository.
- CDISC conformance breadth per dollar of engineering. server/services/cdisc/ is 2,786 LOC spanning SDTM domain conformance (396), SEND (324), ADaM ADSL (252) / BDS (303) / OCCDS (244), controlled terminology validation (214), Define-XML 2.1 generation (228) and package readiness (134), each with a matching test file. As a component library this is a real fraction of what Pinnacle 21 does, built small.

Where we reach parity

- SAP versioning and amendment governance as a data model. server/services/collaborative-sap-service.ts (718 LOC) is DB-backed via drizzle — not in-memory — with automatic diffing against the prior version (:88-135), section-level edits that mint a new version and refuse edits to a locked version (:137-207), threaded comments with parent/child resolution (:208-298), formal amendments linking previous to new version with recorded rationale (:299-340), and lock (:449+). Route-level audit trail exists (server/routes/biostatPlatform.ts:524). The model is at parity with Certara CoAuthor's document governance — but see the Part 11 defect under 'lose'.
- ICH E9(R1) estimand structure. server/services/estimand-engine-service.ts (884 LOC) models intercurrent events as first-class objects with per-ICE strategies, and validates that at least one ICE is identified and that every ICE names a strategy against the recognized E9(R1) strategy set (:229-253). Nobody in the comparison set ships a dedicated estimand engine, so structurally this is parity-to-slight-lead on paper — undercut by the reachability and fabrication defects below.
- Method-recommendation coverage relative to a design tool. The strategy-to-method mapping plus multiplicity/gatekeeping design (estimand-engine-service.ts:372-473, including parallel gatekeeping across hypothesis families) covers the analysis-selection conversation Cytel leaves to the statistician.

Where we lose

- THERE IS NO FRONT DOOR. This decides the category. shared/constants/ui-surface-registry.ts registers 47 surfaces with navTier distribution: 4 global, 21 project, 12 specialist, 7 admin. The four global-nav destinations are projects, apps, artifacts-center and ana-memory. Both biostatistics and biostat-workbench are navTier: 'specialist' — in neither global nor project navigation. They are reachable only by typing a deep link, because V2App routes /concept2cure/:surfaceId off the registry (client/src/concept2cure/v2/V2App.tsx:121). registryModel.ts:707 does place 'biostatistics' in a 'Science & intelligence' group for the health segment, but no rendered navigation consumes that group. A biostatistician handed this product cannot find the biostatistics module.
- 62 OF 63 ENDPOINTS ARE DEAD. server/routes/biostatPlatform.ts registers 48 endpoints and server/routes/biostat-design-stats.ts registers 15, both mounted at /api/biostat (server/bootstrap/register-document-routes.ts:404). Grepping client/src for every route family — continuum, design-optimizer, estimand, multiplicity, sap/create, external-control, adaptive, knowledge/query, judgment/analyze — returns zero callers for all nine. Exactly one endpoint has a client caller: /api/biostat/assurance at client/src/concept2cure/v2/surfaces/BiostatWorkbench.tsx:112. The entire SAP authoring, estimand, multiplicity, adaptive/IDMC, external-control and judgment surface area is unreachable code.

- **THE SHIPPED UI DOES NOT USE THE GOOD ENGINES — IT DUPLICATES THEM IN THE BROWSER.** client/src/concept2cure/v2/surfaces/Biostatistics.tsx (672 LOC) re-implements sample size client-side: computeContinuous (:252), computeBinary (:265), computeSurvival (:275), computeDevicePerformance (:283), computeDiagnostic (:289), dispatched at :297-302, with the file's own comment at :523 conceding 'the design/document body is computed in-browser deterministically.' Its only server call is a read of persisted artifacts (:527, /api/ana-biostats/governed-documents). So there are two divergent sample-size implementations, and the one users actually touch is the untested one. Under CSV this is disqualifying: you cannot validate a computation that the UI bypasses.
- **NO STATISTICAL PROGRAMMING WHATSOEVER** — one third of the category name is absent. Grep across server/services for SAS or R code generation and execution (proc mixed, proc lifetest, proc glm, .sas, generateSasCode, rscript, generateRCode) returns zero files. There is no compute environment, no SAS/R execution, no double programming, no ADaM dataset derivation. TLFs exist only as LLM-generated *shells* (server/services/statistical-continuum-service.ts:334-341, gpt-4o) — and /continuum has zero client callers, so even those are unreachable. Against Domino SCE QC and SAS LSAF this is not a gap, it is an absence.
- **CDISC MODULES CANNOT READ A REAL SUBMISSION PACKAGE.** No XPT, sas7bdat or Dataset-JSON parser exists anywhere in server/. The Define-XML generator consumes hand-supplied metadata objects — DefineVariable/DefineDataset TypeScript interfaces at server/services/cdisc/define-xml-generator.ts:22-45. Pinnacle 21 ingests actual datasets and highlights errors in real time. In a side-by-side demo, ours cannot be pointed at the customer's data.
- **THE PART 11 E-SIGNATURE IS NOT PART 11 COMPLIANT.** server/services/collaborative-sap-service.ts:388-446 signVersion accepts client-supplied signatureId, signerName, signerTitle, signerEmail, timestamp and method and writes them verbatim to the row. Its 'Part 11 compliance' check (:415-426) only asserts those fields are non-empty — presence checking, not identity verification. There is no re-authentication at the point of signing, no second distinct identification component, and no cryptographic binding of the signature to the signed content (no hash of the version stored with the signature). 21 CFR 11.100(a), 11.200(a)(1)(i) and 11.70 require exactly those properties. A caller can sign as anyone, at any timestamp. This fails an inspection and it fails a technical due-diligence read.
- **A FABRICATED REGULATORY PRECEDENT CLAIM IS HARD-CODED INTO OUTPUT.** server/services/estimand-engine-service.ts:388 emits, in every method recommendation regardless of indication, strategy or evidence: 'The "\${estimand.strategy}" strategy with \${mapping.primary} is well-established in regulatory submissions. FDA, EMA, and PMDA have accepted this approach in recent approvals for similar indications.' This is an unsourced agency-acceptance assertion generated into a regulatory deliverable. It is a product-liability and credibility exposure, and it must be removed before any demo.
- **NO VALIDATION PACKAGE OF ANY KIND.** No IQ/OQ/PQ, no validation summary, no statistical qualification report benchmarking stats/* against SAS, R, nQuery or PASS reference values, no traceability matrix. 249 passing unit tests are good engineering and are not a CSV artifact. nQuery publishes validation documentation comparing its results to other statistical software; SAS LSAF leads with 'single GxP-validated environment.' This is the gate that stops the deal before features are ever discussed.
- **NO SHIPPING AI IN THE CATEGORY.** The deterministic engines contain no LLM — defensible and correct — but the only LLM path is statistical-continuum-service.ts (gpt-4o at :230, :337, :515) for SAP narrative and TLF shells, and that service has zero client callers. So against Cytel RACTS, Certara CoAuthor and Veristat InStat, there is no AI capability a buyer can be shown running.

Is the advantage durable?

LOW TO MODERATE, AND THE CLOCK IS ALREADY RUNNING WITH NOTHING TO SHOW FOR IT.

Separate the three candidate moats, because they decay at very different rates.

(1) The exact group-sequential OC engine and the broader stats library — NOT A MOAT, roughly 6-9 months to replicate. server/services/stats/group-sequential-oc.ts implements a published algorithm (Armitage–McPherson–Rowe; Jennison & Turnbull ch. 19) that any competent statistician-engineer pair can rebuild from the textbook. It is excellent work and it is not defensible IP. More to the point, Cytel already has a superior, submission-precedented implementation of the same math, so there is nothing here to defend against the one competitor who cares.

(2) The deterministic judgment layer (biostatistics-judgment/, 8 modules, ~127 KB) plus the estimand engine plus SAP governance — THE ONLY REAL CANDIDATE, and it is worth 12-18 months at most. The differentiated asset is not the computation, it is the encoded regulatory judgment: knowing that an assumption is fragile, that an endpoint-method pairing is indefensible, that a reviewer will object. No competitor in the set ships this as software. But two things are closing it fast. Certara already covers roughly 70% of the adjacent ground with CoAuthor's biomedical GPT plus Pinnacle 21's rule engine, and Certara has both the corpus and the regulatory-writing services business to encode the same judgment faster than we can. And Veristat's InStat, launched 13 May 2026, is the same architectural thesis — AI agents at the specification layer driving pre-validated statistical engines, explicitly avoiding LLM-generated analysis code — shipped with a CRO delivery model and biostatistician review behind it, which answers the 'who validates the judgment' objection that we cannot currently answer at all.

(3) The zero-LLM-in-computation architecture — NOT A MOAT, it is now table stakes. This was a genuine insight when it was built. As of May 2026 it is the headline of a competitor's launch press release. The window in which 'we don't let an LLM write the analysis' was a differentiator has closed.

THE COMPOUNDING PROBLEM: a moat requires a product in market to build brand, reference customers and encoded feedback around. We have none, because the module is not in the navigation and 62 of 63 endpoints are dead. Every month in this state is a month of pure decay — the judgment content ages against evolving ICH/agency practice with no customer signal to refresh it, while Certara and Veristat accumulate

deployments. Meanwhile SAP drafting specifically, the piece most likely to be pitched as the AI story, is being actively commoditized from the academic side: SAPAI (King's College London CTU) drafted 71 SAPs in 1.0-3.4 minutes each with independent-statistician validation across nine real trials and SME ratings of 3.6-4.2/5, published in Clinical Trials with a public demo. Assume the floor price of 'AI drafts a SAP' approaches zero within 24 months.

HONEST CONCLUSION FOR AN ACQUIRER: there is no durable category moat here and there is no realistic path to one, because the two structural pillars of the category — a validated computing environment and a published qualification package — are exactly what we lack and are the most expensive things to acquire. What is durable is narrower and real: a tested, deterministic, provenance-carrying statistical component library (6,324 LOC, 249 passing tests) and a CDISC conformance module (2,786 LOC) that would take a competent team 9-12 months and a seven-figure engineering spend to reproduce at this quality. Value the asset as components with a 12-18 month head start, not as a market position. If the thesis is 'buy the category,' walk. If the thesis is 'buy the engines and drop them into a platform that already has navigation, an SCE and a CSV program,' the price should reflect roughly a year of saved engineering — and the fabricated-precedent string at estimand-engine-service.ts:388 and the non-compliant signVersion at collaborative-sap-service.ts:388-446 should be pre-close remediation conditions with holdback attached.

Shortest credible path to parity

1. WEEK 1 — Remove the two liabilities before anyone sees a demo. (a) Delete the hard-coded regulatory assertion at server/services/estimand-engine-service.ts:388 and replace it with either a cited precedent retrieved from the knowledge graph or an explicit 'no regulatory precedent retrieved for this indication/strategy' — one day of work, and it is the difference between a credible product and a discoverable misrepresentation. (b) Add a one-line scope disclaimer to any surface asserting Part 11 compliance until item 3 lands.
2. WEEKS 1-2 — Open the front door. Change biostatistics and biostat-workbench from navTier:'specialist' to 'project' in shared/constants/ui-surface-registry.ts, and render the 'Science & intelligence' group that registryModel.ts:707 already defines. This is a configuration change plus nav wiring, it is the single highest ratio of deal impact to engineering cost in the entire category, and nothing else on this list matters until it is done.
3. WEEKS 2-5 — Kill the duplicate engine. Delete computeContinuous/computeBinary/computeSurvival/computeDevicePerformance/computeDiagnostic from client/src/concept2cure/v2/surfaces/Biostatistics.tsx:252-341 and have the surface call the server engines in server/services/stats/. This removes the dual-implementation defect that would otherwise sink any CSV effort, and it makes the 249 existing tests actually cover what users run. Do this BEFORE the validation package, not after — validating two implementations is wasted money.
4. WEEKS 2-5 (parallel) — Make the e-signature real. Rewrite server/services/collaborative-sap-service.ts:388-446: derive signer identity from the authenticated session rather than the request body, require a re-authentication challenge at the point of signing (second distinct identification component per 11.200(a)(1)(i)), store a SHA-256 hash of the signed version content alongside the signature so it cannot be excised or transferred (11.70), and write an append-only audit record. Roughly 2-3 weeks. This is a hard gate for every GxP buyer — it is not optional and it cannot be deferred to a services engagement.
5. WEEKS 4-12 — Wire the dead endpoints, in deal-impact order. Of the 48 unreachable routes in server/routes/biostatPlatform.ts, connect them in this sequence: SAP lifecycle (:391-556 — create, section edit, comment, amendment, sign, lock, audit trail, versions), then estimand (:276-390), then multiplicity (:318), then adaptive/IDMC (:692-830), then judgment (:950-1010). Six to ten weeks. Skip the external-control and knowledge families until a customer asks — they are not what wins this category.
6. WEEKS 8-20 — Produce the statistical qualification report. This is the highest-value item on the list for revenue, and the one most likely to be under-resourced. Benchmark every procedure in server/services/stats/ against published reference values from SAS, R, nQuery and PASS; document IQ/OQ/PQ; build a traceability matrix from requirement to test to result. nQuery publishes exactly this artifact and SAS leads with 'single GxP-validated environment' — without it the product does not reach technical evaluation no matter how good group-sequential-oc.ts is. Budget a contract statistician plus a CSV consultant; 8-12 weeks.
7. WEEKS 10-16 — Add real dataset ingestion. Implement XPT and CDISC Dataset-JSON readers feeding the existing checkers in server/services/cdisc/, so define-xml-generator.ts stops requiring hand-authored metadata objects (:22-45). Four to six weeks. Until this exists, any CDISC claim collapses the moment a prospect asks to point it at their own study — which Pinnacle 21 does in the first five minutes of its demo.
8. STRATEGIC — Concede statistical programming execution explicitly. Do not build a statistical computing environment. Domino and SAS have a multi-year, multi-hundred-engineer head start on SAS/R compute, double programming and lineage, and SCE QC (Nov 2025) just raised the bar again. Integrate instead: publish the SAP, estimand specification and TLF shells as structured artifacts a Domino or Posit environment consumes, and reposition the product as the design-and-governance intelligence layer that sits upstream of the SCE. This turns the largest 0/5 on the rubric from a losing comparison into a partnership, and it is the only positioning where the genuinely strong assets — the exact OC engine, the judgment layer, the estimand engine — are the point of the product rather than a footnote to it.

Verdict

● **Not competitive** — Scored as a product in this category, this cannot win a deal today — and the reason is not engine quality, it is that no buyer can reach the engines. Weighted against the four critical dimensions the outcome is stark: reachable front door 1/5, validation package 0/5, statistical programming execution 0/5, Part 11 signature integrity 1/5. Losing all four criticals is disqualifying regardless of what the high-weight dimensions say.

The specific, verifiable facts a buyer will find in the first hour of technical diligence: 62 of 63 registered biostatistics endpoints have zero client callers, with only /api/biostat/assurance wired (BiostatWorkbench.tsx:112). Both biostatistics surfaces are navTier:'specialist' in a registry whose global navigation contains four destinations, none of them biostatistics. The one surface that does render re-implements sample size in the browser (Biostatistics.tsx:252-341) instead of calling the tested server engines — two divergent implementations of the same computation, and users touch the unvalidated one. The category's third pillar, statistical programming, is entirely absent: no SAS or R generation or execution anywhere in server/. The CDISC modules cannot ingest a real dataset. signVersion accepts a client-supplied signer name and timestamp with no re-authentication and no content hash, so it fails 11.100(a) and 11.200(a)(1)(i) outright. And estimand-engine-service.ts:388 emits a hard-coded, unsourced claim that FDA, EMA and PMDA have accepted the recommended approach — a fabricated regulatory precedent shipped into a regulatory deliverable.

None of that contradicts the other honest finding: the underlying statistical work is good. The exact group-sequential operating-characteristics engine (586 LOC of recursive numerical integration per Jennison & Turnbull, deterministic, with binding-futility scope stated openly at :26-31) is work a competent trial statistician wrote, not scaffolding. 249 tests pass across 19 files in 2.54s. The 6,324-line stats library, the 2,786-line CDISC module, the 8-module judgment layer and the drizzle-backed SAP amendment model are real components. The zero-LLM-in-computation architecture independently matches the posture Veristat shipped in May 2026 and is the one that is winning the credibility argument.

So the correct read for an acquirer is that this is an engine library misrepresented as a platform. As a product line in Biostatistics/SAP/statistical programming it is not competitive and would not survive a bake-off against Cytel on design, Certara on standards, or Domino on execution. As a set of components to fold into an existing biometrics platform that already has navigation, a compute environment and a validation program, the stats and CDISC modules have genuine value. Price it as the former, diligence it as the latter — and treat the fabricated-precedent string and the e-signature defect as pre-close remediation conditions, not post-close backlog.

Clinical study reporting (CSR) & medical writing automation

Verdict: ● **Not competitive** Weighted capability score — **us 1.5 / 5** vs **best competitor 4.7 / 5** across 10 dimensions.

Full category as scoped: Clinical study reporting (CSR) & medical writing automation — software that turns locked clinical trial data (ADaM/SDTM, TLFs, protocol, SAP) into ICH E3-structured Clinical Study Reports, patient/SAE narratives, and their downstream CTD clinical summaries.

Who buys, and what they are actually buying

Economic buyer is the Head/VP of Clinical & Regulatory Medical Writing inside a sponsor (reporting to Head of Regulatory Affairs or Clinical Development Operations), or the Medical Writing practice lead at a CRO/FSP. Budget is carved out of an existing outsourced-medical-writing line, not new spend. What they are buying is a shorter database-lock-to-final-CSR cycle and a reduction in per-document CRO fees. The reference cost they benchmark against: a CRO delivers a first CSR draft in 4-5 weeks after lock with each revision round adding 5-10 business days, and senior contract regulatory medical writers were advertised in the UK in early 2026 at GBP 50-75/hour before CRO project-management, QC and review overhead (<https://kitsa.ai/blog/ai-medical-writing-vs-cro-outsourcing-clinical-trials>). Technical veto power sits with Clinical Data Standards/Biostatistics (does it read our ADaM and do the numbers in the prose match the TLFs?) and with Computer System Validation/QA (is it a validated GxP system with Part 11 record binding?). Either veto kills the deal regardless of drafting quality.

Market structure

Market size and shape. The global medical writing market was estimated at USD 5.07B in 2025, reaching USD 5.59B in 2026 (<https://www.grandviewresearch.com/industry-analysis/medical-writing-market>). The AI-in-medical-writing slice is USD 1.21B in 2026 growing at 15.1% CAGR (<https://www.globenewswire.com/news-release/2026/07/01/3320868/28124/en/AI-in-Medical-Writing-Market-Trends-Insights-Competitive-Forecast-to-2026.html>). Roughly 59% of pharmaceutical organizations are integrating automation into regulatory and scientific documentation. The market is moderately fragmented — the top 10 players held only about 25% of revenue in 2024 (<https://www.fortunebusinessinsights.com/medical-writing-market-116331>) — which is why five credible AI-native challengers can coexist with Certara.

Critical framing for an acquirer: most of that USD 5.6B is services revenue (IQVIA, ICON, Parexel, Syneos), not software. The software TAM this asset competes for is the USD 1.21B AI slice, and it is being won by displacing per-document CRO fees rather than by adding a new line item. That is a substitution sale, and substitution sales are won on demonstrated cycle-time reduction against a specific study — precisely the demo we cannot run today because the build endpoints have no client caller.

Consolidation is active and running through the services layer. Indegene acquired Trilogy Writing & Consulting GmbH in March 2024 specifically to combine regulatory writing expertise with generative-AI content automation (<https://www.grandviewresearch.com/industry-analysis/medical-writing-market>). Larger CROs and life-science service providers are buying specialized medical writing firms to fold AI tooling into delivery. The strategic implication is that the natural acquirer of a CSR automation asset is a CRO or a services roll-up that wants to arbitrage writer hours — not a platform buyer, and those acquirers underwrite on demonstrated hours saved per document, which requires working software in a customer's hands.

Procurement pattern. Deals in this category are program-level or enterprise, run over 6-12 months, and gated by three independent reviews that occur in this order: (1) enterprise security review, (2) CSV/QA validation review, (3) capability bake-off with the medical writing team on a real locked study. Our asset fails gate 1 outright (four unauthenticated LLM endpoints at server/routes/csr-builder-routes.ts:227,281,309,375 mounted without authenticateToken at server/bootstrap/register-clinical-intel-routes.ts:139-141) and fails gate 2 (unexecuted IQ/OQ/PQ, no audit-chain entry on generation, no e-signature binding). It never reaches gate 3, where its deterministic narrative composer would actually score well.

Pricing signals, ranked by how public they are. Clinion is the only vendor of the five with a disclosed model — flat per-study-per-month, explicitly priced at parity with traditional non-AI systems (<https://www.clinion.com/>). Certara's CoAuthor is not separately priced; third-party aggregator data across all Certara software shows an average near USD 16,000/year and a maximum near USD 41,000, which is best read as a point-purchase floor rather than an enterprise CoAuthor price (<https://www.vendr.com/buyer-guides/certara>). Yseop is a private-offer listing on AWS Marketplace with no published price (<https://aws.amazon.com/marketplace/pp/prodview-wzkfr67cebozi>). AuroraPrime has a 'Create CSR pilot' SKU on the Microsoft commercial marketplace, implying a land-and-expand motion but no published figure (https://marketplace.microsoft.com/en-us/product/web-apps/alphalife_clinical_saas.create_csr_pilot?tab=overview). Narrativa publishes nothing; one vendor-adjacent listing claims a customer displaced roughly USD 500K of CRO patient-narrative spend and accelerated FDA submissions by 60%, which is directional marketing, not verified (<https://healthydata.science/listings/narrativas-medical-writing-ai-agents-how-patient-narrative-automation-replaced-our-500k-cro-spend-and-accelerated-fda-submissions-by-60/>). Net: no public per-seat benchmark exists in this category, so pricing power is set by demonstrated hours displaced, not by feature comparison.

Vendor-claimed ROI benchmarks a buyer will hold us to: Certara at least 30% reduction in initial drafting time; Yseop 50-80% reduction in manual effort; AuroraPrime 90% reduction in first-draft time and 50% overall cycle savings; Clinion up to 70% of the CSR auto-populated from Protocol/SAP/TLFs. Every one of those claims is measured against real study data as input. We cannot produce a comparable number because we do not read study data.

Regulatory backdrop that cuts both ways. As of early 2026 there are no official guidelines specifically addressing the use of AI to write regulatory documents, and vendors including Narrativa explicitly keep the human writer responsible for reviewing and validating output (<https://intuitionlabs.ai/articles/clinical-study-report-automation-ai-risks>). That vacuum is why validation posture is currently a marketing claim across all five competitors rather than a certified fact — none of the five could be independently verified as holding an executed customer-facing GxP validation package. It is the only genuinely open flank in this market, and it is the flank our audit-chain engineering is best positioned to attack.

The five closest competitors

Certara — CoAuthor — CoAuthor (formerly Synchrogenix Writer), launched October 2023, next-generation generative-AI release subsequently; sold alongside Certara.AI, Pinnacle 21 Enterprise and GlobalSubmit

The incumbent regulatory-writing system of record. Sells the whole chain — structured authoring, CDISC data validation, and eCTD publishing — from one vendor, backed by a large in-house regulatory writing services arm that can do the work if the software does not.

Strengths

- Direct incorporation of analysis datasets, CDISC data, and tables/listings/figures inside the report with real-time preview, and results can be refreshed at any point in the cycle (<https://www.certara.com/coauthor/>)
- Word-native structured content authoring with eTemplate libraries that auto-populate content, headings and styles, plus automated formatting, hyperlinking and metadata population (<https://www.certara.com/announcement/certara-launches-coauthor-a-regulatory-and-medical-writing-tool/>)
- Covers protocols, synopses, CSRs and patient narratives in one turnkey system; documented SDTM-to-patient-narrative path (<https://www.certara.com/blog/using-sdtm-data-to-produce-patient-narratives/>)
- Integrates with Pinnacle 21 Enterprise validation and GlobalSubmit to form one workflow from study design to eCTD submission (<https://www.certara.com/pinnacle-21-enterprise-software/>)
- Vendor-reported at least 30% reduction in initial drafting time (<https://www.certara.com/blog/generative-ai-tools-for-regulatory-writing/>)

Weaknesses

- Genuinely enterprise-scale procurement — heavier and slower to land than an AI-native point tool
- AI is positioned as a plugin/assist layer (Certara.AI generative AI plugin) on top of a structured-authoring core rather than an agentic pipeline, so it is arguably behind Narrativa on autonomous section generation
- Public per-seat pricing for CoAuthor is not disclosed; only aggregate Certara software pricing is visible, which makes budget-setting hard for a mid-cap buyer
- Independent (non-vendor) confirmation of a formal GxP/CSV validation package and Part 11 audit-trail architecture for CoAuthor specifically was not verified in this research

AI shipped today	Generative AI is delivered via the Certara.AI plugin for messaging and results-conclusion drafting, layered on a structured-authoring and eTemplate core; Certara.AI deep learning is also used with Pinnacle 21 for data quality and insight generation. Verified as shipping, not roadmap (https://www.certara.com/coauthor/ , https://www.certara.com/certara-ai/real-world-applications/).
GxP / validation posture	Not verified. Certara markets CoAuthor to regulated submission workflows and integrates Pinnacle 21 validation plus GlobalSubmit publishing/validation, but a customer-facing GxP validation package (IQ/OQ/PQ, Part 11 traceability matrix, audit support) was not confirmed from public sources in this research.
Pricing signal	CoAuthor-specific pricing is not public. Third-party aggregator data across all Certara software reports an average around USD 16,000/year and a maximum around USD 41,000 (https://www.vendr.com/buyer-guides/certara) — treat as a floor indicator for a point purchase, not a CoAuthor enterprise price. Certara states clients can engage CoAuthor at program level or across the enterprise.

► Sources

Yseop — Yseop Copilot — Yseop Copilot, an end-to-end enterprise GenAI platform for life-sciences document automation, delivered partly as a Microsoft Word plug-in; roadmap product 'One-Click Dossier'

'Regulatory-Grade AI' — the compliance-first challenger. Sells hybrid symbolic-plus-LLM generation as the answer to the hallucination objection that blocks LLM tools from GxP procurement, and rides the Veeva Vault RIM install base as its distribution channel.

Strengths

- Automates CSRs, clinical narratives, Investigator Brochures, safety/efficacy summaries and preclinical PK/PD/tox reports by transforming structured data tables into first drafts (<https://yseop.com/solutions/life-sciences/clinical/>)
- Deterministic RAG: retrieval logic is fixed at system setup so output is constrained to validated, traceable content sources; symbolic AI is combined with LLMs specifically for determinism and traceability (<https://yseop.com/faqs/>)
- Explicitly markets GxP compliance, data privacy, accuracy and model explainability, with per-use-case testing before deployment and built-in quality monitoring (<https://yseop.com/medical-writing-automation/>)
- Works inside the medical writer's existing tool (Word plug-in) rather than demanding a new authoring environment (<https://yseop.com/automate-medical-regulatory-authoringworkflows/>)
- Veeva AI Partner Program member with Yseop Copilot ↔ Veeva Vault RIM integration, which is the single most valuable distribution position in this category (<https://yseop.com/news-and-press-releases/yseop-joins-veevas-ai-partner-program-to-accelerate-regulatory-document-writing-and-ai-driven-content-automation/>)
- Vendor-claimed 50-80% reduction in manual effort; TIME Best Inventions 2025 (Medical & Healthcare) and 2026 BIG Innovation Award

Weaknesses

- Deterministic RAG requires per-use-case configuration and setup effort — implementation is a project, not a self-serve turn-on, which lengthens time-to-value
- Document coverage is still expanding: Batch Analysis/Stability Reports, Nonclinical Summaries and Nonclinical Overview were 2026 additions, meaning breadth lags Certara
- Smaller company than Certara or Veeva; single-vendor risk and less leverage in an enterprise MSA negotiation
- No public pricing; AWS Marketplace listing exists but the offer is private (<https://aws.amazon.com/marketplace/pp/prodview-wzkfr67cebozi>)

AI shipped today	Hybrid symbolic AI + LLM with deterministic RAG, domain-specific models, structured/validated data inputs and a per-use-case evaluation framework — shipping, not roadmap. 'One-Click Dossier' (fully automated ingestion-to-draft for CSRs, patient narratives and summaries) was announced as a roadmap direction in mid-2025 (https://markets.financialcontent.com/firstheritage/article/gnwcq-2025-6-16-yseop-unveils-roadmap-to-one-click-dossier-accelerating-scalable-compliant-regulatory-writing).
GxP / validation posture	Vendor-claimed GxP compliance with FDA/EMA standards, model explainability, per-use-case pre-deployment testing and built-in quality controls (https://yseop.com/medical-writing-automation/). A customer-executable IQ/OQ/PQ validation package and Part 11 audit-trail specification were not verified from public sources.
Pricing signal	Not public. Listed on AWS Marketplace (private offer / custom pricing) at https://aws.amazon.com/marketplace/pp/prodview-wzkfr67cebozi . Deal size not verified.

► Sources

Narrativa — Clinical Atlas (CSR Atlas) / Navigator — Clinical Atlas within the Narrativa Navigator platform, alongside Narrative Pathway (patient narratives), R-Developer (TLF generation) and Redaction Scout; hosted on AWS

The agentic-AI native. Sells a pipeline of specialized AI agents that carry a study from protocol through TLFs to submission-ready CSR content, with QA agents doing the numeric cross-checking that medical writers currently do by hand.

Strengths

- Specialized AI Agents for dataset creation, TLF generation, table-to-text conversion and QA validation, transforming TLFs into submission-ready CSR content (<https://www.narrativa.com/automation-of-clinical-study-reports/>)
- The QA agent capability is the sharpest differentiator in the category: an agent that generates a CSR efficacy section, checks that numbers in the text match the tables, and links each sentence back to its source (<https://www.narrativa.com/ai-agents-regulatory-life-sciences/>)
- Continuous oversight and rigorous quality-control checks to catch errors early in the process rather than at QC (<https://www.narrativa.com/automation-of-clinical-study-reports/>)
- Covers the full clinical document lifecycle from protocol to final CSR as one AI pipeline (<https://www.narrativa.com/protocol-clinical-trials-automation-with-ai-agents/>)
- Evolved to an agentic architecture in 2025 with 65,000+ regulatory documents generated; President Jennifer Bittinger appointed to the CDISC Board in January 2026 as the first AI-vendor representative — a strong standards-credibility signal (<https://www.narrativa.com/ai-trends-in-pharma-for-2026-what-to-expect/>)
- Owns the TLF-generation step itself (R-Developer), so it is not dependent on the sponsor's biostat programming pipeline being finished

Weaknesses

- Smaller and younger than Certara; no publishing/eCTD arm, so it stops at document content and hands off to another vendor for submission assembly

- Named biopharma customers are largely anonymized in public case studies ('a top biopharmaceutical company'), which weakens reference-selling in a conservative procurement
- Agentic architecture is the newest and least battle-tested pattern in this category — CSV/QA groups will scrutinize non-determinism harder than they scrutinize Yseop's symbolic approach
- No public pricing or deal-size signal found

AI shipped today	Agentic AI in production as of 2026: multiple specialized agents (dataset creation, TLF generation, table-to-text, QA validation) chained into a CSR pipeline on a proprietary generative-AI platform hosted in a secure AWS environment. Narrativa explicitly keeps the human writer responsible for reviewing and validating output (https://intuitionlabs.ai/articles/clinical-study-report-automation-ai-risks).
GxP / validation posture	Not verified. Narrativa markets full compliance in highly regulated environments and keeps the human writer accountable for review/validation, but no public IQ/OQ/PQ package, Part 11 traceability matrix or audit-support commitment was confirmed. Note the broader market fact: as of early 2026 there are no official guidelines specifically addressing the use of AI to write regulatory documents (https://intuitionlabs.ai/articles/clinical-study-report-automation-ai-risks).
Pricing signal	Not public. One third-party listing claims a customer replaced roughly USD 500K of CRO patient-narrative spend using Narrativa's medical writing AI agents and accelerated FDA submissions by 60% — vendor-adjacent marketing content, treat as directional only, not verified (https://healthydata.science/listings/narrativas-medical-writing-ai-agents-how-patient-narrative-automation-replaced-our-500k-cro-spend-and-accelerated-fda-submissions-by-60/).

► Sources

AlphaLife Sciences — AuroraPrime RMA — AuroraPrime RMA (Regulatory and Medical Authoring) Add-In for Microsoft Word 365, part of the AuroraPrime platform (Create / Connect / Build)

The lowest-friction adoption play. Lives inside Word 365 where the medical writer already works, synthesizes upstream documents and data into drafts, and integrates with Veeva RIM so the output lands in the customer's existing system of record.

Strengths

- Word 365 add-in — no new authoring environment for the writer to learn, which materially reduces change-management risk (<https://alphalifesci.com/products/auroraprime-rma/medical-writing>)
- Customizable templates for CSRs and protocols giving a structured, requirement-specific foundation
- Automates content creation by synthesizing upstream documents and data, integrated with Veeva RIM (<https://alphalifesci.com/products/auroraprime-platform>)
- Vendor-claimed 90% reduction in first-draft time and 50% overall time savings across the CSR document cycle — the most aggressive quantitative claim in the category (<https://alphalifesci.com/blog/accelerating-ctd-module-5-clinical-study-reports-csr-with-ai>)
- Listed on the Microsoft commercial marketplace with a CSR pilot SKU, which lowers procurement friction for Azure-committed buyers (https://marketplace.microsoft.com/en-us/product/web-apps/alphalife_clinical_saas.create_csr_pilot?tab=overview)
- Listed in the DIA Global marketplace, giving industry-body visibility (<https://marketplace.diaglobal.org/listing/alphalife-sciences1/products/auroraprime-rmaipowered-medical-writing-solutions>)

Weaknesses

- Least-known brand of the five in US/EU procurement; reference base and Western enterprise footprint are the weakest
- Positioning emphasizes template-driven authoring and upstream-document synthesis rather than direct ADaM/TLF ingestion with numeric traceability — the harder half of the problem
- The 90%/50% savings claims are vendor-reported with no independent validation found
- No public pricing beyond a marketplace pilot listing; validation posture not verified

AI shipped today	AI-assisted authoring shipping inside a Word 365 add-in: template-driven CSR and protocol first-draft generation by synthesizing upstream documents and data, with Veeva RIM integration. Verified as a shipping product via vendor and marketplace listings; specific model/architecture not disclosed.
GxP / validation posture	Not verified. No public information on GxP/CSV validation packages, 21 CFR Part 11 posture, or customer audit support was found for AuroraPrime.
Pricing signal	Not public. A 'Create CSR pilot' SKU is listed on the Microsoft commercial marketplace (https://marketplace.microsoft.com/en-us/product/web-apps/alphalife_clinical_saas.create_csr_pilot?tab=overview) — the existence of a pilot SKU implies a land-and-expand motion with a low entry price, but the figure is not published.

► Sources

Clinion — Clinion CSR Automation — Clinion CSR Automation, a module inside the Clinion AI-native eClinical suite (EDC, RTSM, CTMS, ePRO, eConsent, eSource, eTMF, medical coding)

The bundled AI-native eClinical play, aimed at small and mid-cap sponsors and regional CROs. Sells CSR automation as one more module on a platform that already holds the trial's EDC data, with transparent flat per-study-per-month pricing instead of enterprise negotiation.

Strengths

- Auto-generates ICH E3-compliant CSRs from protocols, SAPs and TLFs using generative AI, auto-populating up to 70% of the document from source data (<https://www.clinion.com/csr-automation/>)
- The only competitor of the five with a published pricing model: flat per-study-per-month, explicitly positioned as AI capabilities at the cost of traditional systems (<https://www.clinion.com/>)
- Owns the upstream data: EDC, eSource, ePRO and AI-powered medical coding sit on the same platform, so the CSR module is not blind to the trial database (<https://www.clinion.com/innovate-clinical-trials-with-aiml-genai/>)
- AI-native architecture rather than AI bolted onto a legacy eClinical stack (<https://www.clinion.com/insight/top-5-reasons-to-choose-clinions-ai-enabled-eclinical-platform-for-your-next-trial/>)
- Named among top clinical trial solution providers in 2026 lists and among the top-5 CSR automation vendors alongside Medidata, Veeva and Oracle (<https://www.dip-ai.com/use-cases/en/the-best-automated-clinical-study-reports>)

Weaknesses

- Bundling is also the weakness: buying CSR automation means adopting or interoperating with the Clinion suite, which is a non-starter for a sponsor standardized on Medidata Rave or Veeva CDB
- 'Up to 70% auto-populated' leaves the hardest 30% (efficacy interpretation, benefit-risk, discussion) fully manual — a narrower claim than Narrativa's or AuroraPrime's
- Weakest brand recognition among large-pharma regulatory writing groups in US/EU; strongest in India and emerging-market CRO channels
- No public GxP validation package, Part 11 documentation or audit-support commitment verified

AI shipped today	Generative AI shipping in production: extracts key study insights from Protocol, SAP and TLFs and auto-populates up to 70% of an ICH E3-structured CSR; separately launched an AI-powered medical coding solution (https://www.clinion.com/news/clinion-launches-revolutionary-ai-powered-medical-coding-solution/).
GxP / validation posture	Not verified. Clinion markets ICH E3 compliance of the generated CSR structure, but no public GxP/CSV validation package, 21 CFR Part 11 documentation or audit-support commitment was found.
Pricing signal	Flat per-study-per-month pricing model, publicly stated as designed for transparency and fairness and priced at the cost of traditional (non-AI) systems (https://www.clinion.com/). Absolute figure not published — this is the only per-unit pricing model disclosed by any of the five.

► Sources

Capability rubric

Our score is cited to `file:line` in this repository. Theirs is cited in the competitor sections above. Scored on what **ships and is reachable**, not what is architected — an unreachable or unvalidated capability scores low regardless of code quality.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Data-driven authoring: generate CSR prose from CDISC ADaM/SDTM datasets and TLFs rather than from a typed-in study description	critical	1 ▼	Narrativa Clinical Atlas	5	server/routes/submission-orchestrator.ts:214-217 — the code's own comment: 'clinicalStudyData has NO loader yet (per PATH_TO_GA §D.3 — needs a real CDISC ADaM extractor)'. The CSR builder's only input is a free-text form: server/services/csr-builder.ts:119-133 (studyInfo = title, protocolNumber, phase, indication, sponsor, design, endpoints as strings). The section prompt at server/services/csr-builder.ts:438 literally instructs the model to 'Include placeholders like [DATA TO BE INSERTED] where actual study data would go', and the template fallbacks emit exactly that at csr-builder.ts:699,701,703,705 for §10.1, §11.4, §12.2 and §12.3. Real table builders exist (server/services/csr-tabulation-builders.ts:151 buildCSRTables) but consume a hand-authored StudyData JSON and are never called by the CSR builder — only by server/routes/submission-orchestrator.ts:672 with a client-supplied body.
Numeric consistency QC: automated verification that every number in the narrative matches the source table, with sentence-to-source linking	critical	0 ▼	Narrativa Clinical Atlas	5	absent — no cross-check exists anywhere in the CSR path. server/services/csr-builder.ts generates prose and server/services/csr-tabulation-builders.ts generates tables from two entirely disjoint inputs that never meet. The provenance envelope at server/services/csr-builder.ts:352-360 carries only an optional deepResearchJobId, no table references and no per-sentence source spans.
Reachable end-to-end CSR workflow in the shipped UI (start a build, watch it, open and edit the draft)	critical	1 ▼	Certara CoAuthor	5	client/src/concept2cure/v2/registryModel.ts:116-122 — the global rail is exactly five destinations (Chats, Projects, Communication Center, Apps, Settings), rendered at client/src/concept2cure/v2/Shell.tsx:185. Both 'csr-workflow' (registryModel.ts:143) and 'safety-narrative' (registryModel.ts:162) are in NAV_HIDDEN, i.e. reachable only by ⌘K or deep link. Worse, the surface that does exist is read-only: client/src/concept2cure/v2/surfaces/BiopharmaProject.tsx:434 fetches GET /api/csr-workflow/board and nothing else; its 'Draft section' button at BiopharmaProject.tsx:496 calls onAsk() into chat. A repo-wide grep for client calls to /api/csr finds only that one board URL — POST /api/csr/jobs (server/routes/csr-jobs.ts:116) and POST /api/csr-builder/build (server/routes/csr-builder-routes.ts:190) have zero client callers. The async build pipeline is curl-only.
Author-in-the-loop environment: Word/DOCX round-trip, structured content reuse, templates, redline and review cycle on the CSR itself	critical	1 ▼	Certara CoAuthor	5	absent for CSR — grep for docx/Packer across server/services/csr*.ts, server/services/csr/.ts and server/routes/csr.ts returns nothing. Output is plain text with headers in CAPS by explicit instruction (server/services/csr-builder.ts:436-437: 'Do NOT use markdown. Write in plain text with section headers in CAPS'). The only template layer is 5 static [PLACEHOLDER] documents at server/services/templates/clinical-csr-templates.ts:40,144,187,233,272. server/routes/csr-workflow-routes.ts:33-40 concedes there is no review/approval state at all: 'The values review/complete/approved are DELIBERATELY never emitted: csr_section_outputs has no review/approval status column'.
GxP/CSV validation package and Part 11 record binding for AI-generated regulatory content	critical	2 ▼	Yseop Copilot	4	Documents exist but are unexecuted and the CSR path itself is outside the controls. docs/validation/ holds IQ-CORTEX-001, OQ-CORTEX-001, PQ-CORTEX-001, VMP, VSR and TM-CORTEX-001-PART11-TRACEABILITY. But grep for audit/signature across server/services/csr/csr-job-runner.ts returns zero hits — no CSR generation event is written to the audit hash chain (server/services/audit/chain.ts). Provenance is structurally hollow: csr_section_outputs has model and token_cost columns (shared/schema.ts:8698-8723) and the runner writes them (csr-job-runner.ts:309-310,319-320), but draftCSRSectionWithProvenance hardcodes model: null and tokenCost: 0 on the AI path (server/services/csr-builder.ts:388-389 and 408-409) — so no record ever says which model wrote which section. The repo's own Part 11 chapter records the binding gap: docs/audit-2026-07/07-compliance-21cfr11.md:121-132 ('no signatureId, no manifestHash, and no electronic_signatures row').
Patient / SAE narrative generation at volume, from the safety database, with MedDRA coding and persisted versions	high	2 ▼	Certara CoAuthor	5	The composer itself is good and genuinely reachable — server/services/ana/safety-narrative.ts:57 composeSafetyNarrative is pure, deterministic ICH E3 §16 prose that never invents clinical detail, wired as an AnA tool at server/services/ana/AnaToolExecutor.ts:3195 and surfaced in the chat composer at client/src/concept2cure/components/ana/Composer.tsx:210 (chat IS in the global rail). But it stops there: the UI at client/src/concept2cure/v2/surfaces/SafetyNarrative.tsx:79 runs the client-side copy of the composer and never calls the AI-backed server service (server/services/safety-narrative-service.ts:358 generateSAENarrative), and the 'Save version' button at SafetyNarrative.tsx:240 fires the literal toast 'Narrative versioning isn't wired to the safety store yet — nothing was saved'. No MedDRA integration exists in the safety path (grep MedDRA across server/services returns only terminology-glossary and study-design files).
Hallucination control and AI governance	high	3 ▼	Yseop Copilot	5	Split. The narrative composer is fully deterministic and non-LLM (server/services/ana/safety-narrative.ts:9-12: 'Pure and deterministic — drafts the prose from the supplied facts only and NEVER invents clinical detail'), which is exactly the

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
defensible to a CSV/QA reviewer					Yseop argument and is a genuine credit. The CSR section drafter is the opposite: an ungrounded LLM call at temperature 0.3 with no retrieval, no citation and no source binding (server/services/csr-builder.ts:472-487), whose prompt tells the model to write submission-ready regulatory prose from a study description alone. That is the single highest-risk thing in this category and a QA reviewer will find it in the first hour.
CSR-to-CTD continuity: generated CSR content flowing into Module 2.5 / 2.7 and on into eCTD assembly without re-keying	high	4	Certara CoAuthor	4	Genuinely built and the strongest thing in this category. server/services/csr/load-csr-inputs-for-project.ts:1-42 is a tenant-scoped reader that turns completed CSR build jobs into orchestrator-shaped CSRSummary/Input[], feeding m2-summary-builders and then server/services/submission-package-orchestrator.ts:1166-1169 (M2.5/M2.7 composition plus CSR tabulation) and on to eCTD export. The file header names the exact gap it closed. Held at 4 rather than 5 only because the upstream CSR content it carries is placeholder-laden.
Cross-study / precedent intelligence over a real CSR corpus (benchmark this study's design and outcome against comparable trials)	medium	1 ▼	Certara CoAuthor	3	Architecturally present, empirically empty. compareWithExistingCSRs at server/services/csr-builder.ts:525-580 runs a tenant-scoped ILIKE over csr_reports and its own comment concedes the outcome column does not exist, so every row returns outcome: 'Unknown' (csr-builder.ts:571) and similarity is a hardcoded 0.95/0.6 string comparison (csr-builder.ts:572). The shipped corpus is data/csr_dataset.csv at 535 rows of thin fields (nct_id, indication, phase, sample_size, ...) with many zeros, and data/processed_csrs/ is empty (0 files), so server/services/csr-search-service.ts:32-50 initializes an empty embedding store.
Security posture of the generation endpoints (an enterprise security review will run this before the capability review)	high	1 ▼	Certara CoAuthor	5	server/bootstrap/register-clinical-intel-routes.ts:139-141 mounts the CSR builder router at /api/csr-builder and /api/csr with NO authenticateToken middleware, unlike its immediate neighbours (citations at register-clinical-intel-routes.ts:130 and the eCTD family at server/bootstrap/register-document-routes.ts:60-77, both auth-gated). Four of the six handlers never call getAuthContext: POST /draft-section (server/routes/csr-builder-routes.ts:227), /safety-signals (:281), /generate-narrative (:309) and /analyze-benefit-risk (:375). All four invoke the LLM. That is unauthenticated, unmetered, unattributed AI invocation on a public path — an abuse and cost vector, and no Part 11 attribution for content that could reach a submission.

Where we stand

Where we win

- CSR-to-CTD continuity inside one codebase. server/services/csr/load-csr-inputs-for-project.ts reads completed CSR build jobs into orchestrator-shaped inputs, m2-summary-builders composes Module 2.5/2.7 from them, and server/services/submission-package-orchestrator.ts:1166-1169 carries that into eCTD assembly and export. Of the five competitors only Certara sells this span, and Certara does it by stitching CoAuthor to GlobalSubmit — two products, two contracts. Narrativa, Yseop, AuroraPrime and Clinion all stop at document content.
- Deterministic, non-LLM patient-narrative generation that is genuinely reachable today. server/services/ana/safety-narrative.ts:57 composes ICH E3 §16 narratives from structured facts only, never invents clinical detail, and reports missingFields so the writer sees the completeness gate before handoff. It ships as an AnA tool (AnaToolExecutor.ts:3195) inside the chat composer (Composer.tsx:210), and chat is one of the five global-rail destinations — so unlike the CSR builder, this one has a real front door. This is the same 'symbolic, traceable, no hallucination' argument Yseop wins GxP procurement with.
- Honest degradation contract in the UI. server/routes/csr-workflow-routes.ts:33-40 refuses to emit review/complete/approved states because no column can source them honestly, and SafetyNarrative.tsx:240 tells the user outright that nothing was saved. That discipline is rare and it is worth real money in a CSV audit — the system does not lie about its own state. It is also, however, the reason the demo looks thin.
- Single-vendor breadth for a small-biotech or regional-CRO buyer: CSR, PV/safety, CMC, device, submissions and eCTD in one platform. None of the five point tools offer that, and it is the only credible go-to-market wedge left in this category.

Where we reach parity

- ICH E3 section taxonomy completeness — all 16 top-level sections with subsections at server/services/csr-builder.ts:38-109, matching what every competitor templates.
- LLM-backed first-draft prose per section (server/services/csr-builder.ts:472-487) with graceful template fallback.
- Async job orchestration with resume semantics, per-section SHA-256 content hashing, quota reservation before enqueue and tenant pinning from the auth principal (server/services/csr/csr-job-runner.ts:222-260, server/routes/csr-jobs.ts:116-160). The engineering here is clean and is genuinely at parity — it is simply attached to the wrong inputs and has no caller.
- ICH E3 §10-12 table builders — disposition, analysis populations, demographics, efficacy, exposure, AE by SOC and PT, deaths/SAEs, lab shifts (server/services/csr-tabulation-builders.ts:171-509). The code is correct and tested; only its input path is missing.
- A 25-node / 120+ field structured CSR intake flow (server/services/ana/intelligence-questions/flows/csr-report.ts) and a 1,036-line CSR auditor, which is a credible substitute for the guided-authoring templates competitors ship.

Where we lose

- No CDISC ingestion in the CSR path at all. This is the deal-loser. Every one of the five competitors generates from ADaM/SDTM or TLFs; we generate from a typed-in study description and emit '[DATA TO BE INSERTED]'. Biostatistics will veto in the first demo.
- No numeric consistency QC between narrative and tables. Narrativa sells exactly this as its headline agent. We have nothing.
- No reachable UI to start, monitor or edit a CSR build. The build endpoints have zero client callers; the one CSR surface is a read-only board and is demoted out of the global rail into NAV_HIDDEN.
- No Word/DOCX authoring or export for CSR, and no review/approval workflow state. Medical writers live in Word; Certara, Yseop and AuroraPrime all meet them there.
- Not a validated system for this module. The IQ/OQ/PQ documents exist but are unexecuted, no CSR generation event reaches the audit hash chain, no e-signature binds an approved section, and the model/token_cost provenance columns are always written null/0 (csr-builder.ts:388-389,408-409).
- The CSR corpus that would justify 'cross-study intelligence' is effectively empty — 535 thin CSV rows and zero processed CSRs — while compareWithExistingCSRs returns hardcoded similarity scores and outcome 'Unknown'.
- Four unauthenticated LLM endpoints on /api/csr-builder. This fails enterprise security review before anyone evaluates drafting quality.

Is the advantage durable?

No durable advantage exists in this category. Take the two real assets in turn. The deterministic ICH E3 §16 narrative composer (server/services/ana/safety-narrative.ts) is roughly 600 lines of rule-based prose assembly with a completeness gate — a competent team reproduces it in two to four weeks, and Yseop already ships the same idea at greater depth as its 'symbolic AI plus deterministic RAG' architecture, which is its central marketing claim. Certara already documents SDTM-to-patient-narrative generation. There is no moat here, only a correct design choice that others made first. The CSR-to-M2.5/2.7-to-eCTD chain is the more valuable asset because it spans a boundary competitors sell across two products, and it carries genuine switching cost once a sponsor has run a submission through it. But Certara already covers the same span with CoAuthor plus GlobalSubmit plus Pinnacle 21 and can close the seam whenever it chooses — and critically, that chain's value is proportional to the quality of the CSR content flowing through it, which today is placeholder-laden. A pipe carrying '[DATA TO BE INSERTED]' has no switching cost. Everything else in our stack — ICH E3 taxonomy, async job runner, table builders, LLM section drafting — is commodity that all five competitors already ship. Meanwhile the gap is widening, not narrowing: Narrativa moved to agentic architecture in 2025 with 65,000+ regulatory documents generated and put its president on the CDISC Board in January 2026 (<https://www.narrativa.com/ai-trends-in-pharma-for-2026-what-to-expect/>); Yseop announced One-Click Dossier in mid-2025 and holds a Veeva AI Partner integration into Vault RIM, which is the distribution position that decides this market (<https://yseop.com/news-and-press-releases/yseop-joins-veevas-ai-partner-program-to-accelerate-regulatory-document-writing-and-ai-driven-content-automation/>). Time for an incumbent to close everything we have: zero to six months, because for the most part they have already closed it. The honest read for an acquirer is that the CSR module should be valued as engineering substrate and as an option on the submission chain, not as a defensible product position. The one window that exists is narrow and time-boxed: no official regulatory guidance yet addresses AI-authored regulatory documents as of early 2026 (<https://intuitionlabs.ai/articles/clinical-study-report-automation-ai-risks>), so a vendor that arrives first with an executed validation package and Part 11-bound AI provenance can define the compliance bar. We currently have the strongest tamper-evidence engineering of anyone in this comparison (hash chain with FOR UPDATE anti-fork locking plus keyed HMAC seal, per docs/audit-2026-07/07-compliance-21cfr11.md) and we do not connect it to the CSR path at all. That is the one asymmetry worth funding, and it expires the moment FDA or EMA publishes guidance and every vendor is forced to the same bar.

Shortest credible path to parity

1. Ship a front door first — it is the cheapest point on the board and nothing else can be demoed without it. Promote 'csr-workflow' out of NAV_HIDDEN (client/src/concept2cure/v2/registryModel.ts:143) or expose it under the Apps destination, then wire the existing surface to POST /api/csr/jobs and poll GET /api/csr/jobs/:jobId — both endpoints already exist and are tested (server/routes/csr-jobs.ts:116,182). Roughly 1-2 weeks of frontend work turns an invisible pipeline into a demoable one. Do this before anything else.
2. Auth-gate and instrument the generation endpoints. Add authenticateToken at server/bootstrap/register-clinical-intel-routes.ts:139-141 and require getAuthContext in the four handlers that skip it (csr-builder-routes.ts:227,281,309,375); populate the model and tokenCost provenance the runner already persists by returning the real values from draftCSRSectionWithProvenance instead of the hardcoded null/0 (csr-builder.ts:388-389,408-409); write an audit-chain entry per generated section via server/services/audit/chain.ts. About 1 week, and it removes the security-review blocker and half the Part 11 objection at once.
3. Build the ADaM/ARD-to-StudyData loader that the code already names as missing (server/routes/submission-orchestrator.ts:214). The target shape is fully specified at server/services/csr-tabulation-builders.ts:25-120 and the CDISC conformance machinery already exists (server/services/cdisc/adam-adsl-conformance-checker.ts, define-xml-generator.ts). Start with ADL, ADAE and one ADaM BDS efficacy dataset — that covers §10.1, §11.1, §11.2, §12.1, §12.2 and §12.3. Estimate 6-10 weeks. This is the single highest-value item and nothing about the category is winnable without it.
4. Wire buildCSRTables into the CSR builder so drafted sections receive real tables instead of '[DATA TO BE INSERTED]', and change the section prompt at csr-builder.ts:436-438 from 'write submission-ready prose about this study' to 'describe this table', passing the generated table as grounded context. This converts the highest-hallucination-risk component in the product into table-to-text, which is what Narrativa and Yseop

actually do. 3-4 weeks once the loader lands.

5. Add a numeric consistency checker: extract every number from generated section prose, match it against the cells of the tables that fed that section, and fail the section on mismatch. This is the cheapest way to neutralize Narrativa's headline QA-agent claim and is ~2-3 weeks on top of the grounded pipeline. Persist the check result on `csr_section_outputs` so it becomes audit evidence.
6. Add DOCX round-trip for CSR — export the assembled ICH E3 report to Word with the section hierarchy, tables and cross-references intact, and re-import writer edits. Without this the product asks medical writers to abandon the tool they have used for twenty years. 4-6 weeks; a Word add-in (the Certara/Yseop/AuroraPrime pattern) is a further quarter and can wait.
7. Add review/approval state to `csr_section_outputs` and bind an `electronic_signatures` row on approval, closing the gap the route currently refuses to fake (`csr-workflow-routes.ts:33-40`) and the gap the repo's own Part 11 chapter documents (`docs/audit-2026-07/07-compliance-21cfr11.md:121-132`). 3-4 weeks.
8. Execute the validation package against the CSR module specifically — the IQ/OQ/PQ/VMP documents in `docs/validation/` are written but not executed, and no OQ script currently exercises the CSR path. This needs a named validation owner and a signed VSR; it is months of mostly non-engineering work, so start it in parallel with step 3, not after step 7.
9. Either populate the CSR corpus properly or stop claiming cross-study intelligence. Today `data/processed_csrs/` is empty and `compareWithExistingCSRs` returns hardcoded similarity with outcome 'Unknown' (`csr-builder.ts:571-572`). Ingesting the Health Canada Clinical Information Portal and EMA clinical-data corpora is a real 4-8 week effort; if it is not funded, remove the claim rather than demo it.
10. Sequencing note for the buyer: steps 1-2 (about 3 weeks) make the asset demoable. Steps 3-5 (about 12-17 weeks) make it competitive on the critical dimension. Steps 6-8 (about 2 quarters, mostly non-engineering) make it sellable into a GxP procurement. Total realistic time to genuine parity: 9-12 months with 3-4 engineers plus a validation owner.

Verdict

● **Not competitive** — In this category the product is not losing on drafting quality — it is losing on the two things that define the category. First, a CSR tool that cannot read ADaM/SDTM or TLFs is not a CSR tool; it is a prose generator that emits '[DATA TO BE INSERTED]' at exactly the four sections (§10.1, §11.4, §12.2, §12.3) that constitute the actual work of writing a CSR. All five competitors ingest study data; the repo's own code comment at `server/routes/submission-orchestrator.ts:214` concedes there is no ADaM extractor. Second, the capability that does exist has no front door: `POST /api/csr/jobs` and `POST /api/csr-builder/build` have zero callers anywhere in the client, and the `csr-workflow` surface is both read-only and explicitly demoted into `NAV_HIDDEN` (`registryModel.ts:143`) behind a five-item global rail. A capability a user cannot reach does not win deals, and in a competitive bake-off it does not even get scored. Layer on top: no Word round-trip, no review/approval state by the route's own admission, an unexecuted validation package with no audit-chain entry or e-signature binding on generated content, an empty CSR corpus behind the 'cross-study intelligence' claim, and four unauthenticated LLM endpoints that will fail security review before the capability review starts. The genuine assets — the deterministic ICH E3 §16 narrative composer and the CSR-to-M2.5/2.7-to-eCTD chain — are real and defensible, but they are one reachable feature and one plumbing advantage, not a product in this category. A buyer running this against CoAuthor, Yseop, Clinical Atlas, AuroraPrime and Clinion would eliminate it in the first round.

eTMF and regulated document management / Vault DMS

Verdict: ● **Not competitive** Weighted capability score — **us 1.7 / 5** vs **best competitor 4.9 / 5** across 13 dimensions.

Full category as scoped: eTMF and regulated document management / Vault DMS

Who buys, and what they are actually buying

Two budget holders, usually jointly. (1) VP/Head of Clinical Operations (or TMF Lead / Head of Clinical Document Management) at a sponsor or CRO — buys "we survive a GCP inspection": a complete, timely, quality-checked TMF filed to the TMF Reference Model, with the missing-document punch list closed before the inspector arrives. (2) Head of Quality / CSV, who holds veto power and buys "the system is validated and the records are Part 11 / Annex 11 defensible": vendor qualification package, IQ/OQ/PQ, tamper-evident audit trail, e-signature manifestation, and a supplier audit the QA group can pass on. Neither buys a dashboard. The outcome purchased is a defensible record set — the actual document bytes, versioned, signed, retrievable years later, and a readiness verdict backed by them. In CRO deals a third voice, the sponsor oversight function, buys TMF exchange/handover: the ability to transfer the TMF to the sponsor's system at study close.

Market structure

Market size and shape. The eTMF systems market is estimated at roughly \$1.55B in 2025 growing to about \$1.73B in 2026 at ~11.8% CAGR, reaching approximately \$2.67B by 2030 (The Business Research Company, via GlobeNewswire, 24 Apr 2026 — <https://www.globenewswire.com/news-release/2026/04/24/3280618/0/en/Electronic-Trial-Master-File-eTMF-Systems-Research-Report-2026-2-67-Bn-Market-Opportunities-Trends-Competitive-Landscape-Strategies-and-Forecasts-2020-2025-2030F-2035F.html>). A second house puts 2026 at ~\$1.76B on ~10.1% CAGR to \$3.16B by 2032. Directionally consistent: a ~\$1.7B market growing low-double-digits, with AI-led document management cited as a named growth driver alongside trial volume and decentralised trials. Note this is a modest TAM for a standalone play — which is exactly why every serious vendor sells eTMF as part of a wider clinical or regulatory suite.

Concentration. Veeva owns the enterprise tier decisively: more than 450 biopharma companies, 18 of the top 20 pharmas, and 4 of the top 6 CROs run Vault eTMF (<https://www.prnewswire.com/news-releases/more-than-450-companies-adopt-veeva-vault-etmf-for-improved-trial-efficiency-and-inspection-readiness-301841812.html>). The remainder splits between TMF specialists (Phlexglobal), document-services-attached platforms (TransPerfect Trial Interactive), Microsoft-estate mid-market (Montrium), site-network players (Florence), and suite vendors attaching eTMF to CTMS/EDC (IQVIA/Wingspan, Ennov, Octalsoft, Cloudbyz). One caveat on secondary sources: at least one widely-syndicated market summary asserts that Veeva acquired Medidata in December 2023 — that is false and should not be relied on; Medidata belongs to Dassault Systèmes.

Ownership churn is a real procurement question in this category. Phlexglobal moved Bridgepoint → Vitruvian, then merged with PharmaLex in January 2022 (<https://www.phlexglobal.com/mergers-and-acquisitions>). Buyers ask about roadmap continuity and will discount accordingly.

Standards. The TMF Reference Model transferred to CDISC stewardship, with v4 published in 2025 (<https://www.cdisc.org/standards/foundational/trial-master-file-reference-model/tmf-reference-model-v4>). v4 renames artifact → Record Group and sub-artifact → Record Type and brings sub-artifacts into the standard. Full artifact counts sit behind CDISC sign-in and are not verified here — but the direction matters for scoring: a vendor still shipping a DIA v3 subset is two model generations behind what a 2026 sponsor QA group expects. Our 41-artifact catalog (server/services/etmf/tmf-completeness.ts:36) sits well below even v3's full scope.

Procurement pattern and deal size. No vendor in this category publishes list pricing; Florence and Montrium both show 'contact us' on G2 and Capterra, and Veeva explicitly never publishes Vault module pricing. Deals are negotiated multi-year with a base-plus-named-user structure. Third-party estimates for Vault put per-user cost at roughly \$50–\$200/user/month (~\$600–\$2,400/user/year) plus a per-application base fee (<https://intuitionlabs.ai/articles/veeva-vault-pricing-2026-cost-breakdown>), with early-stage biotechs reported at tens of thousands per year all-in. Implementation and migration frequently exceed year-one licence. Practically: an eTMF selection is a 3–6 month evaluation with a QA/CSV gate, a security review, a migration scoping exercise, and a reference-call requirement. A vendor with no executed validation package and no inspection precedent does not clear the gate regardless of product quality — which is the structural reason our GAMP 5 kit being 1.0.0-DRAFT with PENDING approvals (docs/validation/OQ-CORTEX-001-OPERATIONAL_QUALIFICATION.md:6-16) matters more than any feature gap.

Where the AI competition actually is. 2026 has split into two AI models. (1) Incumbent-embedded: Veeva TMF Bot (over a million documents classified) plus Vault AI going across all Vault applications in August 2026 and Falcon targeting TMF intake and QC with early-adopter availability in November 2026 (<https://www.prnewswire.com/news-releases/veeva-announces-falcon-an-agentic-platform-and-standard-agents-to-deliver-agentic-labor-in-drug-development-302782537.html>); TI AutoMate; PhlexTMF v21's right-first-time model. (2) Overlay-agentic: Medable's TMF Agent, announced 6 January 2026, which autonomously ingests from shared inboxes and drives, classifies, extracts metadata, holds a human-in-the-loop checkpoint, then one-click submits into Veeva Vault, Wingspan or OpenText, claiming automation of 95% of manual document workflows

(<https://www.medable.com/newsroom/medable-debuts-ai-agent-for-automating-trial-master-file-tmf-processes>). The overlay model is the only lane an AI-first entrant can realistically enter, because it does not require winning a rip-and-replace against a validated system of record — and it is a lane that requires connectors into incumbent eTMFs, of which this codebase has none.

The five closest competitors

Veeva Systems — Veeva Vault eTMF (Vault Clinical / Development Cloud), with Vault AI and the Falcon agentic platform

The default enterprise incumbent and the system every eTMF RFP is benchmarked against. Sells the whole Development Cloud — eTMF, CTMS, Study Startup, RIM, Quality — on one Vault platform so clinical and regulatory documents share a repository and a lifecycle. Land-and-expand: eTMF is frequently the first Vault, RIM/QMS follow.

Strengths

- Installed base and inspection precedent: more than 450 biopharma companies including 18 of the top 20 pharmas and 4 of the top 6 CROs run Vault eTMF (Veeva/PRNewswire). Inspectors have seen it; QA groups do not have to defend the choice.
- Full TMF Reference Model support with maintained taxonomy, plus zone/section/artifact metadata, study-country-site hierarchy, and the completeness/timeliness/quality metric set that the TMF community actually manages to.
- TMF Bot ships production ML classification — Veeva states it has classified more than one million documents; this is shipped automation, not roadmap.
- Native Vault eTMF ↔ Vault RIM connection, so trial documents reused in a submission do not have to be re-filed or re-classified.
- Vault AI is generally available with agents in Safety and Quality, and Veeva has publicly committed Vault AI across all Vault applications in August 2026 with Clinical and Regulatory agents this year. Falcon (announced 27 May 2026) targets TMF document intake and quality control explicitly, with early-adopter availability November 2026.
- Full GxP validation apparatus: qualified multi-tenant cloud, release-cycle validation support, Vault Validation Management as a companion product, and a supplier-audit posture that QA organizations routinely accept.

Weaknesses

- Price and TCO: base-plus-named-user, multi-year, never published. Public estimates put Vault modules at roughly \$50–\$200 per user per month (\$600–\$2,400/user/yr) plus a per-application base fee, with implementation frequently exceeding first-year licence cost. Emerging small-biotech SKUs (Vault Basics) exist precisely because entry cost blocks the low end.
- Configuration and change control overhead; three releases a year each carry a regression-validation burden the customer absorbs.
- Clinical/Regulatory AI agents are the last wave, not the first — Vault AI went GA for Safety and Quality ahead of Clinical, and Falcon's TMF intake agent is early-adopter in November 2026. As of July 2026 the deepest shipped eTMF AI is still TMF Bot classification, not agentic TMF operations.
- Heavier than a 5-person biotech running two Phase I studies needs; the operating model assumes a dedicated TMF function.

AI shipped today	Shipped: TMF Bot ML document classification (Veeva states >1M documents classified). Vault AI agentic capability GA for Safety and Quality; Veeva has stated Vault AI will be delivered across all Vault applications in August 2026, with first Clinical and Regulatory agents later in 2026. Falcon, announced 27 May 2026, is a separate agentic platform whose named initial focus areas include TMF document intake and quality control, health-authority correspondence, and safety case triage — early-adopter availability November 2026, i.e. not yet shipped as of 2026-07-28.
GxP / validation posture	Qualified GxP multi-tenant cloud; 21 CFR Part 11 / EU Annex 11 controls (audit trail, e-signature manifestation, record retention); vendor qualification and supplier-audit material available to customers; Vault Validation Management sold as a companion for customer-side CSV of the three annual releases. Widely accepted by pharma QA and seen in FDA/EMA GCP inspections.
Pricing signal	Not published by Veeva. Third-party estimates: base-plus-named-user model, roughly \$50–\$200 per user per month (~\$600–\$2,400 per user per year) depending on module and volume, plus per-application/environment base subscription; multi-year negotiated contracts; early-stage biotechs reported paying tens of thousands per year. Treat as directional, not verified vendor pricing.

► Sources

Montrium — eTMF Connect (part of Montrium Connect, with Quality Connect eQMS and RIM)

The mid-market and scaling-biotech alternative to Veeva. Built on Microsoft 365 / SharePoint Online and Azure, so it lands inside the customer's existing Microsoft estate rather than as a separate island. Sells speed to go-live and a validation package that removes CSV burden, at a price point a 20–200 person biotech can approve.

Strengths

- Pre-configured TMF structures aligned to the TMF Reference Model, automated workflows and reusable templates — a study can be stood up without a configuration project.
- Validated electronic signature technology for 21 CFR Part 11 and EU Annex 11 compliance, with comprehensive audit trails and role-based access.
- Ships a complete validation and SOP template package and performs testing/qualification on the customer's behalf, explicitly to reduce the customer's validation burden and accelerate go-live — this is the single most effective wedge against Veeva in QA-led evaluations.
- Metadata and in-content search across TMF records; centrally managed tasks for authoring, review and filing.
- Microsoft 365/SharePoint/Azure foundation means familiar UX, existing SSO/identity, and Azure-native security (data isolation, encryption in transit and at rest, SOC 2-aligned monitoring).

Weaknesses

- No publicly verified AI document classification or metadata-extraction product as of 2026 — the marketed differentiators are structure, workflow and validation, not ML. Not verified that any LLM/ML classification ships.
- Smaller installed base and less inspection precedent than Veeva or Phlexglobal; large-pharma procurement often screens it out on scale.
- SharePoint lineage constrains some TMF-specific behaviours (deep artifact hierarchies, high-volume site-level filing) relative to purpose-built eTMFs.
- Pricing is quote-based; no verified public list price.

AI shipped today	Not verified. Public marketing emphasises pre-configured TMF structure, workflow automation, metadata/in-content search and validation acceleration. No shipped AI classification or metadata-extraction capability could be confirmed from public sources as of 2026-07-28.
GxP / validation posture	Strong and explicitly sold: validated e-signature for 21 CFR Part 11 and Annex 11, comprehensive audit trails, and a complete validation + SOP template package with vendor-performed testing/qualification to reduce customer CSV effort. Azure hosting with SOC 2-aligned controls.
Pricing signal	Not public — quote-based across eTMF/eQMS/RIM plans. Third-party summaries describe a scalable per-user model targeted at small-to-mid biotech; no verified list price. Entry-level Connect 365 (SharePoint Online) and Azure-hosted multi-tenant Fast Track are positioned as low-upfront-investment options.

► Sources

TransPerfect Life Sciences — Trial Interactive eTMF (TI), with TI AutoMate

The AI-forward, CRO- and sponsor-services-heavy eTMF. Sells document processing throughput: bulk intake, automated classification and filing, CRA reconciliation, and a live completeness view so the study is continuously inspection-ready. Bundles TransPerfect's translation and document-services muscle, which matters for multi-region trials.

Strengths

- TI AutoMate is shipped AI: it identifies document type, extracts metadata, and auto-files to the correct TMF Index location, eliminating manual classification.
- Vendor-published performance claims of ~40% reduction in document processing time and 98% metadata extraction accuracy (vendor claim, not independently verified).
- Operational TMF features the day-to-day users care about: CRA reconciliation, one-step approvals, bulk uploads, live completeness view.
- Mobile eTMF (myTI) for site and monitor workflows.
- Strong CRO/multi-sponsor fit and TransPerfect's global document/translation services attached to the same contract.

Weaknesses

- Vendor-published accuracy and time-saving figures are not independently verified.
- Smaller enterprise footprint than Veeva; less common as the sponsor-side system of record at top-20 pharma.
- Pricing not published; deal size not publicly verifiable.
- Positioned as a clinical-document platform, not a cross-functional Vault — weaker regulatory/RIM adjacency than Veeva if the buyer wants one repository for eTMF and submissions.

AI shipped today	Shipped. TI AutoMate applies machine learning to auto-classify documents to the TMF Index, extract metadata, and auto-file to the correct folder; scanning/OCR is part of the intake pipeline. Vendor claims ~40% faster document processing and 98% metadata extraction accuracy. First introduced with TI 10.2 and carried forward in later releases.
GxP / validation posture	Marketed as a compliant cloud eTMF with audit trail, e-signature and inspection-readiness tooling. Specific validation-package contents, IQ/OQ/PQ deliverables and supplier-audit terms are not published — not verified.
Pricing signal	Not public. No verified per-user or per-study list price; deals are quoted. No credible public deal-size signal found.

► Sources

Phlexglobal (a PharmaLex company) — PhlexTMF v21 / PhlexEview eTMF, plus TMF services (TMF health checks, remediation, managed TMF)

The TMF specialist. Sells the combination almost nobody else offers — purpose-built eTMF technology plus a large bench of TMF experts who will remediate, migrate and run the TMF as a service. Wins where the buyer's real problem is a legacy TMF in bad shape, not a greenfield study.

Strengths

- AI at the point of upload: PhlexTMF v21 is marketed as the industry's only purpose-built eTMF with next-generation AI making documents 'right-first-time' at the critical upload step, reducing misfiles and metadata errors before they occur.
- The model is pre-trained on millions of documents and embeds the accumulated guidance of hundreds of Phlexglobal TMF experts — a domain-data moat a generic LLM does not have.
- Directly targets the three TMF health metrics inspectors ask about: quality, completeness and timeliness.
- Technology-plus-services is a genuine differentiator for legacy TMF migration and remediation — the hardest, least automatable part of an eTMF displacement.
- Deep TMF-only focus and long enterprise reference base (e.g. a global consolidated eTMF for Bayer).

Weaknesses

- Narrow platform: TMF and clinical documents, not a cross-functional regulated DMS. Buyers wanting eTMF + RIM + QMS on one platform go elsewhere.
- Ownership has changed repeatedly (Bridgepoint → Vitruvian; merged with PharmaLex in January 2022, PharmaLex subsequently within the Cencora orbit) — procurement will ask about roadmap continuity. Current ultimate ownership as of 2026 not independently verified here.
- The services attachment that is a strength for remediation is a cost and lock-in concern for a sponsor that wants to run its own TMF.
- No public pricing; deal size not verifiable.

AI shipped today	Shipped. PhlexTMF v21 embeds pre-trained AI at document upload that reduces misfiles and metadata errors, pre-trained on millions of documents and encoding the cumulative guidance of Phlexglobal's TMF experts. Positioned as prevention (right-first-time at intake) rather than downstream remediation.
GxP / validation posture	Purpose-built regulated eTMF with the inspection-readiness posture expected of a TMF specialist; the services arm supports customers directly through GCP inspections. Specific validation-package contents and supplier-audit terms are not published — not verified.
Pricing signal	Not public. No verified list price or deal-size figure. Services-plus-software bundles are negotiated per engagement.

► Sources

Florence Healthcare — Florence eTMF, Florence eBinders (site eISF), Florence SiteLink

The site-side network that grew into the sponsor side. Owns the investigator site file at scale and sells sponsors the ability to reach into sites' binders directly — collapsing the collect-scan-email-file loop that produces most TMF latency and most misfiles. Wins on the sponsor ↔ site seam rather than on repository depth.

Strengths

- Network scale on the side nobody else owns: publicly claims connections across 65,000 study sites and 600 sponsors worldwide (Oct 2025), with SiteLink cited at 5.2 million remote workflows per month across 18,000 study sites in 52 countries.
- Part 11-compliant e-signatures (stamp or addendum), from individuals or groups, plus role-based permissions, access controls and workflow management.

- Structurally solves TMF timeliness — the metric that fails most often — because documents are captured at the site at the moment of execution rather than reconstructed later.
- Strong fit for sponsors and CROs running decentralised or site-heavy programmes; low friction for site staff, which is the actual adoption constraint.
- Free trial with no credit card, which is unheard of in this category and a real SMB wedge.

Weaknesses

- Sponsor-side eTMF depth (artifact taxonomy governance, complex zone/section configuration, enterprise migration) is generally regarded as thinner than Veeva or Phlexglobal.
- The value proposition depends on site network adoption; in trials where sites already use another eISF the differentiator collapses.
- No verified shipped AI classification product comparable to TMF Bot, AutoMate or PhlexTMF v21 — marketing refers to AI-driven automation reducing manual tasks, but the specific capability is not verified.
- No published pricing on G2 or Capterra; quote-only.

AI shipped today	Partially verified. Florence markets AI-driven automation that reduces manual tasks in eTMF workflows, but no specific shipped classification/metadata-extraction product with published accuracy figures was confirmed. Treat as weaker AI posture than Veeva/TransPerfect/Phlexglobal as of 2026-07-28.
GxP / validation posture	21 CFR Part 11-compliant electronic signatures (stamp and addendum, individual and group), audit trail, role-based permissions and access controls; published security/compliance material covering how clinical research workflows are protected. Detailed IQ/OQ/PQ and supplier-audit deliverables not published — not verified.
Pricing signal	Not published on G2 or Capterra — quote-only for both Florence eTMF and eBinders. A free trial with no credit card is offered for Florence eTMF, which is a meaningful low-end signal even absent a price.

► Sources

Medable — TMF Agent (built on Medable Agent Studio)

The AI-native challenger, and the most important one to understand because it does not try to replace the eTMF — it sits above it. Announced at JPM on 6 January 2026 as an agentic layer that autonomously ingests, classifies and prepares documents, then pushes them into whichever eTMF the customer already owns. This is the attack vector an AI-first entrant can actually execute, and it is the lane a product like ours would be competing in.

Strengths

- System-agnostic by design: writes into Veeva Vault, Wingspan and OpenText, so it does not have to win a rip-and-replace fight.
- Autonomous upstream ingestion from shared inboxes, drives and other sources — it attacks the document-collection problem, not just the filing problem.
- Claims automation of 95% of manual document workflows, and frames the value as recovering the ~33% of a CRA's time consumed by administrative burden (vendor claims, not independently verified).
- Human-in-the-loop checkpoints for validation, QC and audit traceability are architected in, with one-click submission after human review — the right compliance posture for an agentic tool in a GxP setting.
- Agent Studio gives a repeatable path to further agents beyond TMF.

Weaknesses

- Brand-new: announced 6 January 2026, roughly 7 months old at the time of this analysis. No inspection precedent, no published customer evidence, no independent accuracy validation.
- Not a system of record — it does not store, version or retain documents; it depends on an incumbent eTMF underneath. Cannot be the eTMF of record and does not try to be.
- Automation percentages and CRA time figures are vendor-stated.
- No published validation package, GxP qualification detail or pricing — not verified.
- Medable's core identity is decentralised trials, not document management; the TMF Agent is an extension of that platform rather than a TMF-native product.

AI shipped today	Shipped as of January 2026 and genuinely agentic: autonomous document ingestion from shared inboxes and drives, classification, metadata extraction, preparation for human review, then one-click submission into Veeva Vault, Wingspan or OpenText. Human-in-the-loop checkpoints for validation, QC and audit traceability. Vendor claims 95% of manual document workflows automated.
GxP / validation posture	Human-in-the-loop checkpoints and audit traceability are stated design principles, and the agent writes into the customer's already-validated eTMF (which carries the Part 11 record). Medable's own validation package, GAMP 5 categorisation and supplier-audit terms for the TMF Agent are not published — not verified.
Pricing signal	Not public. No verified pricing or deal-size figure disclosed at or since the January 2026 launch.

► Sources

Capability rubric

Our score is cited to `file:line` in this repository. Theirs is cited in the competitor sections above. Scored on what **ships and is reachable**, not what is architected — an unreachable or unvalidated capability scores low regardless of code quality.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Document repository — stores, retains, versions and returns the actual document bytes	critical	1 ▼	Veeva Vault eTMF	5	server/routes/evidence-management.routes.ts:276 (multer temp file is fs.unlink'd in the finally block after text extraction; the DB row written at :218 records file_path = /upload s/{fileId} where nothing was ever written, and the router exposes no download endpoint); shared/schema/vault.ts:5-8 (module header: vaultDocumentChunks and vaultEvidenceCitations INACTIVE — 'no routes/services query this table'; vaultDocuments' only consumer in the whole server tree is server/jobs/retentionCron.ts, a non-auto-registered job); server/services/vaultService.ts:27 (the one real byte store is local filesystem storage/vault , and its only caller is server/routes/ivdr-binder-routes.ts); client/src/concept2cure/v2/surfaces/Vault.tsx:228 (the Vault surface's 'Upload' button calls onAsk() with a chat prompt, not an upload) and :460 ('Download' likewise dispatches a chat message)
Reachability — can a licensed user actually get to the eTMF/Vault in the shipped product	critical	1 ▼	Veeva Vault eTMF	5	client/src/concept2cure/v2/registryModel.ts:116-122 (RAIL_PRIMARY is exactly five entries: Chats, Projects, Communication Center, Apps, Settings) rendered by client/src/concept2cure/v2/Shell.tsx:185, against 100 registered surface views in client/src/concept2cure/v2/surfaceViews.ts (SURFACE_VIEWS) and 96 registry entries in shared/constants/ui-surface-registry.ts + .ui-v2.ts; 'etmf' appears at client/src/concept2cure/v2/surfaceViews.ts:165 and shared/constants/ui-surface-registry.ui-v2.ts:57 but is in neither RAIL_PRIMARY nor even NAV_HIDDEN (registryModel.ts:125-171); the Apps launcher (client/src/concept2cure/v2/surfaces/AdminSurfaces.tsx:1219) renders the module catalog seeded at db/migrations/20260220_user_intelligence_platform.sql:78-107, which contains 20 modules and no eTMF row — and its 'evidence-engine' module id has no matching SURFACE_VIEWS key, so it lands on the KitSurfaceScaffold placeholder (client/src/concept2cure/v2/V2App.tsx:219). eTMF is therefore reachable only by %K substring-matching the surface's notes text (Shell.tsx:983) or by deep link.
TMF Reference Model coverage and taxonomy depth (artifact catalog, study/country/site levels, v4 currency)	critical	2 ▼	Veeva Vault eTMF	5	server/services/etmf/tmf-completeness.ts:36 (TMF_REFERENCE_MODEL = 11 zones, 41 artifacts total, 26 flagged essential — versus the several-hundred-artifact DIA/CDISC model); server/services/etmf/etmf-logic.ts:15-27 (zone list only, 'DIA RM v3'); shared/schema/etmf.ts:29 (tmfModel defaults to 'dia_rm_v3'); shared/schema/tmf-artifacts.ts:24-49 (tmf_artifact_filings is keyed on org+trial+artifactCode with a zoneNumber — there is no country or site dimension, so the study/country/site hierarchy the TMF RM requires cannot be represented). No CDISC TMF RM v4 support anywhere in the tree.
AI document classification and metadata extraction from document content	critical	1 ▼	Phlexglobal PhlexTMF v21 (tie: TransPerfect TI AutoMate, Veeva TMF Bot)	5	server/services/etmf/etmf-logic.ts:35-49 (the entire TMF classifier is 11 regex rules matched against the artifact NAME string, defaulting to Zone 2 when nothing matches — module header states 'Pure, DB-free, LLM-free'); server/services/etmf/etmf-service.ts:56 (addArtifactTx calls that name-based classifier); the platform's real LLM classifier at server/services/ingestion/ingestion-service.ts:164-265 classifies into eCTD/CTD section codes over coauthor_documents HTML and writes submissionLeaves — it never touches TMF zones or artifact codes, and is only reachable from server/routes/ctd-onboarding.ts and server/routes/ectd-documents.ts. server/services/ocr/* exists but its only consumer in the route tree is server/routes/chat/upload.ts.
Validation package / CSV / supplier-audit support covering the eTMF itself	critical	2 ▼	Montrium eTMF Connect (tie: Veeva)	5	server/routes/validation-kit.ts:1-17 + docs/validation/ (a genuine GAMP 5 kit exists — VMP, IQ, OQ, PQ, ISO 14971 RA, Part 11 traceability matrix, cloud vendor qualification, VSR, security assessment — mounted at /api/validation-kit via server/bootstrap/register-inline-routes.ts:1059), BUT docs/validation/OQ-CORTEX-001-OPERATIONAL_QUALIFICATION.md:6-16 shows Version 1.0.0-DRAFT, 'Status: ⚠️ DRAFT - REQUIRES VALIDATION REVIEW BEFORE PRODUCTION USE', Approved By PENDING, dated 2025-01-24; and a case-insensitive grep for 'etmf' or 'trial master' across docs/validation/ returns zero hits — the kit covers the AI platform, not the eTMF. No executed protocols, no approvals, no eTMF test scripts.
Part 11 / Annex 11 e-signature bound to a document record, plus tamper-evident audit trail	critical	3 ▼	Veeva Vault eTMF	5	GENUINE STRENGTH on the audit side: server/services/auditService.ts:230-298 (sha256-chained + HMAC-sealed audit_logs writes) and server/routes/part11-compliance.ts:573,602,791,1192 (signature retrieval, signature manifest, /audit-trail/chain-integrity re-computing a linear SHA-256 hash chain JWT-bound to the caller's org, /audit-trail/seal-integrity), with server/services/part11/{signing-authority.version-binding.resolve-signer-role}.ts. TMF mutations are audited — server/services/etmf/tmf-artifact-persistence.ts:76-85 and :101-110 emit TMF_ARTIFACT_FILED / TMF_ARTIFACT_REMOVED. THE GAP: there is no TMF document record to sign. shared/schema/etmf.ts:50-77 (tmf_artifacts has zone, section, artifactName, status, documentDate — and no document foreign key or file reference at all) and shared/schema/tmf-artifacts.ts:38 (documentRef is a free-text column). Worse, client/src/concept2cure/v2/surfaces/Etmf.tsx:124 and :142 hard-code documentRef = 'vault://' + trialId + '/' + artifactCode, which does not match the one real vault URI scheme in the codebase (server/services/storage/storage-provider.ts:91 emits vault://{orgId}/{projectId}/{filename}) and resolves to nothing.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
TMF health metrics inspectors actually ask for — completeness AND timeliness AND quality	high	2 ▼	Veeva Vault eTMF (tie: Phlexglobal)	5	Completeness is real and well-tested: <code>server/services/etmf/tmf-completeness.ts:36</code> + <code>server/services/etmf/etmf-logic.ts</code> (evaluateCompleteness), with 20 passing unit tests across <code>server/services/etmf/tests/</code> (etmf-logic,tmf-completeness,tmf-inspection-package).test.ts (verified: 3 files, 20 tests passed). Timeliness and quality do not exist — <code>client/src/concept2cure/v2/surfaces/Etmf.tsx:18-27</code> states it explicitly: 'Timeliness and QUALITY (QC) have NO backend on this path: <code>tmf_artifact_filings</code> persists only the artifact CODE and filedAt — there is no document date to compute a filing lag against and no QC status column', and <code>shared/schema/tmf-artifacts.ts:24-44</code> confirms the columns are absent.
Inspection deliverable — exportable, archivable TMF the inspector or sponsor can actually open	high	2 ▼	Veeva Vault eTMF	5	<code>server/services/etmf/tmf-inspection-package.ts:1-20</code> + <code>server/routes/etmf.routes.ts:160</code> (GET <code>/trials/:trialId/inspection-package</code> streams a ZIP with <code>manifest.json</code> , <code>completeness.json</code> , <code>inspection-index.csv</code> , <code>README.txt</code> , SHA-256 in an X-TMF-SHA256 header; deterministic and unit-tested). Its own honesty contract at <code>tmf-inspection-package.ts:13-17</code> is the scoring constraint: 'tmf_artifacts stores metadata only — no document bytes. This package therefore assembles the inspection index and readiness picture... It never fabricates document content it does not hold.' An inspection package with no documents in it is a readiness report, not a TMF export or archive.
Sponsor ↔ CRO ↔ site exchange (TMF exchange, site eISF, handover at study close)	high	0 ▼	Florence Healthcare	5	absent — no site portal, eISF, site binder, or TMF-exchange route or service exists. A grep across <code>server/routes</code> and <code>server/services</code> for 'site portal', 'investigator site file', 'eISF', 'site binder' and 'TMF exchange' returns one hit, <code>server/services/ana/gcpOperationsTools.ts:241,249</code> , which is an AnA advisory tool describing record-retention guidance — not a capability. <code>shared/schema/tmf-artifacts.ts:24-49</code> has no site or country dimension to exchange against.
Semantic / RAG search over the TMF corpus with citations back to source documents	high	2 ▼	Veeva Vault eTMF (Vault AI)	4	<code>pgvector</code> columns are declared widely (<code>shared/schema.ts:1629,5759,11463,11876,13724,15028,15198,15316,16462</code> and <code>shared/schema/vault.ts:142</code>), and provenance modelling is real (<code>server/services/evidence/provenance.ts:103,323</code> — EVIDENCE_SOURCES, buildProvenance, authority tiers, used by <code>server/routes/ana-ri/stream.ts</code>). But the TMF-facing path is not wired: <code>shared/schema/vault.ts:6-8</code> marks <code>vaultDocumentChunks</code> INACTIVE with no querying routes; <code>server/routes/evidence-search.ts:47</code> delegates entirely to an external OpenSearch cluster rather than <code>pgvector</code> ; and the Evidence surface is fixture-first — <code>client/src/concept2cure/v2/surfaces/Evidence.tsx:24-36</code> hard-codes <code>EV_ANSWER/EV_CHUNKS</code> (a canned CGM/K221847 answer) and only replaces them if <code>/api/evidence-asks</code> returns a complete saved shape (:64-86), otherwise rendering the demo behind a SampleTag.
Legacy TMF migration and high-volume bulk ingestion	high	1 ▼	Phlexglobal (technology + TMF remediation services)	5	<code>server/routes/etmf.routes.ts:113</code> provides POST <code>/trials/:trialId/artifacts/bulk</code> , but it files at most 500 artifact CODES per call with no document payload — it is a checklist bulk-tick, not an ingestion path. The only bulk document intake, <code>server/routes/knowledge-base.ts:718-747</code> , re-posts the multipart body to <code>/knowledge/ingest-files</code> on an out-of-repo Python 'shadow service'; the <code>shadow_service/</code> directory in this repo contains only scoring/risk-code files, so that ingestion endpoint does not ship with the deployable and returns 502 'Shadow service unreachable' when absent.
Deployment integrity — does the eTMF schema exist in a deployed environment	high	2 ▼	Veeva Vault eTMF (SaaS — no customer-side schema risk)	5	<code>scripts/db/migration-set.mjs</code> (the curated 25-file out-of-band set that <code>scripts/db/deploy-migrate.mjs</code> applies as the production deploy-time entrypoint) contains no entry for <code>migrations/20260610_etmf.sql</code> or <code>migrations/20260615_tmf_artifact_filings.sql</code> — grep for 'tmf' returns zero hits. <code>scripts/db_migrate.sh:35</code> points at <code>db/migrations/</code> while both eTMF migrations live in the root <code>migrations/</code> tree. Only <code>scripts/db/install-fresh.mjs:65,121-137</code> (the from-scratch provisioning path, which shells out to a devDependency absent from the production image) sweeps the whole <code>migrations/</code> directory. Neither eTMF migration declares RLS. Consequence: on an existing production database the eTMF tables are not created by any automated path, and every <code>/api/etmf</code> endpoint 42P01s — the repo's own 'merged ≠ applied' failure mode, documented at <code>scripts/db/deploy-migrate.mjs:6-14</code> .
eTMF ↔ RIM / eCTD adjacency — trial documents reusable in a submission without re-filing	medium	4 ▼	Veeva Vault eTMF ↔ Vault RIM	5	GENUINE STRENGTH. <code>server/services/ingestion/ingestion-service.ts:164-247</code> classifies a document to a CTD section code and drafts a <code>submissionLeaf</code> into an owned eCTD sequence in one governed, audited transaction; <code>server/routes/etmf.ts:56-79</code> runs every TMF mutation through <code>BEGIN → setTenantContextTx → recordGovernedAction → COMMIT</code> with a mandatory ≥8-character reason string (:52); <code>shared/constants/domain/vault-taxonomy.ts:1-30</code> defines one cross-segment document taxonomy spanning CTD modules, device DHF folders and TMF zones. Scored 4 not 5 because the eTMF side of that bridge holds no documents to reuse.

Where we stand

Where we win

- Governed-mutation discipline. Every eTMF write runs BEGIN → setTenantContextTx → recordGovernedAction → COMMIT with a mandatory reason of at least 8 characters (server/routes/etmf.ts:52,56-79). Competitors log who and when; we force why, at the transaction boundary, and roll back if the ledger write fails. That is a better Part 11 §11.10(e) story than most of this field ships, and it is real code.
- Cryptographically sealed audit ledger. server/services/auditService.ts:230-298 writes sha256-chained, HMAC-sealed rows, and server/routes/part11-compliance.ts:791,1192 exposes JWT-org-bound chain-integrity and seal-integrity verification an auditor can run on demand. Veeva and Montrium assert tamper-evidence; we can demonstrate it with a re-computation endpoint. This is a legitimate technical asset independent of the eTMF.
- Deterministic, byte-stable, unit-tested readiness core. server/services/etmf/tmf-completeness.ts and etmf-logic.ts are pure functions with no IO, covered by 20 passing tests, and the inspection package (tmf-inspection-package.ts) is deterministic given a caller-supplied timestamp so the same TMF state yields the same SHA-256. In a category where AI classification accuracy is the marketing claim, a provably deterministic readiness verdict is defensible in a way an ML confidence score is not.
- Refusal to fabricate. server/services/etmf/tmf-inspection-package.ts:13-17 and client/src/concept2cure/v2/surfaces/Etmf.tsx:18-27 explicitly render 'not yet available' for timeliness and QC rather than synthesising them, and the surface removed its fabricated sample trial. In a GxP demo this honesty engineering survives scrutiny that polished competitors' demos sometimes do not. It is a cultural asset for an acquirer, not a feature.
- eTMF ↔ eCTD adjacency in one governed transaction. server/services/ingestion/ingestion-service.ts:164-247 classifies a document to a CTD section and drafts a submission leaf in one audited step. Only Veeva offers the eTMF ↔ RIM bridge at all, and it is a cross-product integration there rather than a single transaction.

Where we reach parity

- Nothing. There is no dimension in this rubric on which the as-built product reaches parity with the weakest of the five incumbents. The closest is the governed-audit layer, where we exceed several competitors — but audit is a platform capability here, not an eTMF capability, because there is no TMF document record for it to bind to (shared/schema/etmf.ts:50-77 has no document foreign key; shared/schema/tmf-artifacts.ts:38 documentRef is free text that the UI populates with an unresolvable 'vault://trialId/artifactCode' string at client/src/concept2cure/v2/surfaces/Etmf.tsx:124).

Where we lose

- The document repository — the category's definition. We cannot store, version, retrieve or retain a document. Uploaded bytes are read for text extraction and then deleted (server/routes/evidence-management.routes.ts:276) while the DB row claims a file_path that was never written; the S3-backed vault schema has no CRUD routes and only a non-registered retention cron reads it (shared/schema/vault.ts:5-8, server/jobs/retentionCron.ts); the one working byte store is local disk used solely by the IVDR binder (server/services/vaultService.ts:27). The Vault surface's Upload and Download buttons open a chat prompt (client/src/concept2cure/v2/surfaces/Vault.tsx:228,460). A DMS that cannot hold a document is not in this category.
- Reachability. Five of 100 registered surfaces are in the global rail (client/src/concept2cure/v2/registryModel.ts:116-122, Shell.tsx:185); eTMF is in neither the rail nor NAV_HIDDEN, and the Apps launcher's 20-module catalog (db/migrations/20260220_user_intelligence_platform.sql:78-107) has no eTMF entry. A buyer's user cannot find the eTMF without a deep link. A capability nobody can reach loses every deal it is in.
- AI classification. Eleven regexes against the artifact's NAME (server/services/etmf/etmf-logic.ts:35-49, header: 'LLM-free') against TMF Bot's million-plus classified documents, TI AutoMate's claimed 98% metadata accuracy, and PhlexTMF v21's model pre-trained on millions of documents. This is the loudest gap for an 'AI-native' pitch — we ship less AI in eTMF than every incumbent.
- TMF Reference Model depth. 41 artifacts across 11 zones (server/services/etmf/tmf-completeness.ts:36), DIA v3 only, with no country or site level anywhere in the schema (shared/schema/tmf-artifacts.ts:24-49). CDISC published TMF RM v4 in 2025. A TMF assessed against a 41-artifact subset produces a readiness verdict a sponsor's QA cannot rely on.
- Validation. The GAMP 5 kit is real but every document is 1.0.0-DRAFT with approval PENDING (docs/validation/OQ-CORTEX-001-OPERATIONAL_QUALIFICATION.md:6-16) and contains zero references to eTMF or TMF. Montrium wins mid-market eTMF deals specifically on a delivered validation and SOP package. We have templates.
- Timeliness and quality — two of the three TMF health metrics inspectors ask about — do not exist (client/src/concept2cure/v2/surfaces/Etmf.tsx:18-27).
- Sponsor ↔ CRO ↔ site exchange: absent entirely. Florence's 65,000-site network is a structural moat we have no answer to.
- Legacy TMF migration: the only bulk document intake proxies to a Python service that is not in this repo (server/routes/knowledge-base.ts:735-745, shadow_service/ contains only scoring files).
- Deployment integrity: neither eTMF migration is in the production migration set (scripts/db/migration-set.mjs), so on an existing deployed database every /api/etmf endpoint fails on a missing table.

Is the advantage durable?

There is no durable advantage in this category, because there is no advantage in this category — we are not on the board. The honest question is whether anything in the codebase could become a moat if the repository gap were closed, and how long we would have.

What is genuinely differentiated today: the governed-mutation pattern (server/routes/etmf.ts:52,56-79 — mandatory ≥ 8 -character reason at the transaction boundary, ledger write inside the same transaction, rollback on failure) combined with a sha256-chained, HMAC-sealed audit ledger that exposes on-demand chain and seal re-verification (server/services/auditService.ts:230-298, server/routes/part11-compliance.ts:791,1192). No competitor markets customer-runnable cryptographic chain verification. That is a real, defensible technical claim.

Durability: 12–24 months at most, and probably less. This is roughly a one-quarter engineering effort for any incumbent — a hash-chain column, a verification endpoint, a reason field on the mutation API. Nothing about it is patent-shaped or data-shaped. It is a good engineering decision, not a moat. Veeva shipping Vault AI across all applications in August 2026 and Falcon's TMF intake/QC agent in November 2026 both carry audit-traceability requirements that will push exactly this kind of tamper-evidence into the incumbent platforms as a side effect.

The determinism argument — a provably byte-stable readiness verdict rather than an ML confidence score (server/services/etmf/tmf-inspection-package.ts, 20 passing unit tests) — has slightly longer legs because it is a philosophical position an ML-first vendor is structurally reluctant to adopt. But it is worth 6–12 months of differentiation at most, and only against vendors leading with AI accuracy claims. The moment a competitor pairs its classifier with a deterministic rules-based verdict layer, the argument evaporates. Phlexglobal's 'right-first-time at upload' framing is already halfway there.

What we would be attacking, and why it does not yield. The incumbents' moats are the kind that do not erode on an engineering timeline: Veeva's 450+ customers with inspection precedent and QA acceptance (a switching cost measured in validated-migration years, not licence dollars); Phlexglobal's model pre-trained on millions of TMF documents plus a services bench that can remediate a broken legacy TMF (a data-and-labour moat an entrant cannot buy); Florence's 65,000 study sites and 600 sponsors (a two-sided network — the hardest structure in this category to displace). None of these is closable with code.

The one time-boxed opening. The overlay lane Medable opened in January 2026 is the only entry a product like ours could contest, and the window is roughly 18–24 months before the incumbents' own agents (Falcon's TMF intake and QC agent, early-adopter November 2026) close it from above and Medable's Agent Studio compounds from below. Contesting it requires connectors into Veeva Vault, Wingspan and OpenText — of which this codebase has exactly zero — plus a validated, executed CSV package. That is a 12–18 month build against a 18–24 month window. The arithmetic does not work as a standalone bet; it works only as a bolt-on to an acquirer who already has the connectors, the customers, or the validation apparatus.

Shortest credible path to parity

1. STOP FIRST — decide whether to compete at all. Parity with Veeva/Phlexglobal on eTMF is a 3–5 year, tens-of-millions build against a ~\$1.7B TAM that Veeva already holds at the enterprise tier. The recommendation is NOT to pursue eTMF parity. The rest of this list is the shortest credible path if the acquisition thesis nonetheless requires an eTMF story — sequenced so that the earliest steps also pay off if the answer is 'sell the audit substrate, not the eTMF'.
2. P0 / ~1 week — make the front door exist. Add an 'etmf' row to the module catalog (db/migrations/20260220_user_intelligence_platform.sql:78-107) so the surface appears in the Apps launcher, and add 'etmf' plus 'evidence-search' to NAV_HIDDEN (client/src/concept2cure/v2/registryModel.ts:125) so $\mathbb{K}$ resolves them by id rather than by notes-substring luck. Also fix the dead 'evidence-engine' module id, which currently lands on a placeholder scaffold (client/src/concept2cure/v2/V2App.tsx:219). This costs days and converts an invisible capability into a demoable one. It does not win a deal, but every subsequent step is worthless without it.
3. P0 / ~1 week — fix deployment integrity. Add migrations/20260610_etmf.sql and migrations/20260615_tmf_artifact_filings.sql to scripts/db/migration-set.mjs, and add RLS policies to both (neither declares any). Today, on any already-deployed database, every /api/etmf endpoint fails on a missing table. A diligence team that runs the deploy path and hits 42P01 will discount the whole eTMF line to zero — this is the single highest-leverage week in the list.
4. P0 / ~2 weeks — stop the data loss and stop the false pointer. server/routes/evidence-management.routes.ts:276 deletes uploaded bytes while :218 records a file_path that was never written; either persist through server/services/storage/storage-provider.ts or stop claiming a path. Separately, client/src/concept2cure/v2/surfaces/Etmf.tsx:124,142 writes documentRef = 'vault://trialId/artifactCode', which does not match the real scheme at storage-provider.ts:91 and resolves to nothing — either bind it to a real stored object or leave it null. Recording an unresolvable document reference in a regulated filing log is the kind of finding that ends a diligence conversation.
5. P1 / ~2–3 months — build the actual repository, or concede the category. Promote shared/schema/vault.ts's vaultDocuments from schema-with-a-cron to a real service: object storage behind server/services/storage/s3-provider.ts, content-hash on write, immutable version chain (the supersedesId/parentDocumentId columns already exist at shared/schema/vault.ts:104-105), retention enforcement wired to the existing server/jobs/retentionCron.ts, and check-in/check-out. Add an organization_id column — the table is currently scoped only by programId, which is a tenancy defect. Then give tmf_artifacts a foreign key to it (shared/schema/etmf.ts:50-77 has none today). Until this exists nothing else in this list matters, because the category is defined by it.
6. P1 / ~1 month, gated on the repository — bind e-signature to the TMF document record. The Part 11 machinery already works (server/routes/part11-compliance.ts:360,573,602; server/services/part11/version-binding.ts); it simply has no TMF document to sign. Once a versioned document record exists, wiring signature manifestation and version binding to it is small work and converts our strongest existing asset into a category-relevant one.
7. P1 / ~2 months — expand to CDISC TMF RM v4 and add the country/site dimension. Replace the 41-artifact DIA v3 subset (server/services/etmf/tmf-completeness.ts:36) with the full v4 Record Group / Record Type model, and add country and site columns to shared/schema/tmf-artifacts.ts:24-49. Without the three-level hierarchy the completeness verdict cannot be trusted by a sponsor QA group, and

the readiness score is the only thing we currently sell.

8. P2 / ~2 months — content-based classification. Route TMF intake through the existing LLM gateway pattern already proven at `server/services/ingestion/ingestion-service.ts:164-247`, targeting TMF zones/artifacts instead of CTD section codes, with the deterministic regex classifier (`server/services/etmf/etmf-logic.ts:35-49`) retained as a fallback and as an explainability layer. Publish a measured accuracy figure against a held-out set — competitors publish unverified vendor claims; a reproducible number is the differentiated position.
9. P2 / ~1 month — add timeliness and quality. Add `documentDate` and a QC status/outcome column to `tmf_artifact_filings`, then compute filing lag and QC pass rate. This closes the gap the surface itself documents at `client/src/concept2cure/v2/surfaces/Etmf.tsx:18-27` and completes the three TMF health metrics inspectors ask for. Cheap relative to its sales impact.
10. P2 / ~3–4 months and unavoidable — execute the validation package. The GAMP 5 kit at `docs/validation/` is real but every artifact is 1.0.0-DRAFT with approval PENDING and contains zero eTMF coverage. Write eTMF-specific IQ/OQ/PQ protocols, execute them, get them approved by a named quality function, and produce a supplier-audit pack. Montrium wins mid-market deals on precisely this. No amount of product work substitutes for it — this is the QA gate, and it is pass/fail.
11. STRATEGIC ALTERNATIVE, and the one actually worth funding — take the overlay lane instead of the repository lane. Rather than rebuild a system of record, build connectors into Veeva Vault, Wingspan and OpenText and sell the readiness verdict, the governed reason-coded mutation ledger and the sealed audit chain as an inspection-readiness layer over the customer's existing eTMF. This is the Medable TMF Agent model. It needs: P0+P1 connectors (~4–6 months), the content classifier above (~2 months), and the executed validation package (~3–4 months) — call it 9–12 months, versus 3–5 years for repository parity. It plays to the two things we genuinely do better than the field (governed mutations with mandatory reason codes, and customer-verifiable cryptographic audit sealing) and it does not require winning a rip-and-replace against a validated incumbent. The window is roughly 18–24 months before Falcon's TMF intake/QC agent closes it from above.

Verdict

● **Not competitive** — This is a category verdict, not a quality verdict on the code — the eTMF code that exists is clean, deterministic, honestly documented and unit-tested. But a buyer in this category is purchasing a system of record for regulated documents, and the as-built product cannot hold a document.

Three facts decide it, and any one of them is disqualifying on its own.

First, there is no document repository. The evidence upload path reads the file, extracts text, writes a database row whose `file_path` points at a location that was never created, and then deletes the bytes (`server/routes/evidence-management.routes.ts:218,276`) — with no download endpoint anywhere in that router. The S3-backed vault schema that would be the real repository has no CRUD routes at all; its only consumer in the entire server tree is a retention cron that is not auto-registered at boot (`shared/schema/vault.ts:5-8`, `server/jobs/retentionCron.ts`). The single working byte store is a local-filesystem service used exclusively by the IVDR binder routes (`server/services/vaultService.ts:27`) — local disk, which is not a defensible GxP retention substrate on a multi-node deployment regardless. And the Vault surface's Upload and Download buttons dispatch chat prompts to the assistant rather than moving files (`client/src/concept2cure/v2/surfaces/Vault.tsx:228,460`). What is actually built is a TMF completeness checklist: `tmf_artifact_filings` stores an organization, a trial string, a reference-model artifact code, a zone number and a `filedAt` (`shared/schema/tmf-artifacts.ts:24-49`). The richer `tmf_artifacts` table has no document foreign key at all (`shared/schema/etmf.ts:50-77`). The product's own inspection-package module states the constraint plainly: 'tmf_artifacts stores metadata only — no document bytes... It never fabricates document content it does not hold' (`server/services/etmf/tmf-inspection-package.ts:13-17`). That honesty is admirable and it is also the finding.

Second, it is unreachable. The global navigation rail renders exactly five destinations (`client/src/concept2cure/v2/registryModel.ts:116-122`, `Shell.tsx:185`) against 100 registered surface views. The eTMF surface exists and is wired to live endpoints (`client/src/concept2cure/v2/surfaces/Etmf.tsx:105,124,170` → `surfaceViews.ts:165`), but 'etmf' appears in neither `RAIL_PRIMARY` nor `NAV_HIDDEN`, and the Apps launcher renders a 20-module catalog seeded at `db/migrations/20260220_user_intelligence_platform.sql:78-107` that contains no eTMF row. The only routes in are a `⌘K` search that happens to substring-match the surface's notes text, or a deep link someone hands you. This is the pattern the brief flagged, and for this category it is decisive twice over — the same catalog's 'evidence-engine' module id has no matching surface view, so clicking it in Apps lands on a placeholder scaffold (`client/src/concept2cure/v2/V2App.tsx:219`).

Third, even the checklist is not defensible as an inspection instrument. The reference model encodes 41 artifacts across 11 zones with 26 marked essential (`server/services/etmf/tmf-completeness.ts:36`) — a fraction of the DIA/CDISC model, with no country or site level in the schema, and no CDISC TMF RM v4 support. Two of the three TMF health metrics inspectors ask about, timeliness and quality, have no backing columns and are shown as 'not yet available' (`client/src/concept2cure/v2/surfaces/Etmf.tsx:18-27`). Classification is eleven regexes against the artifact's name string in a module whose header says 'LLM-free' (`server/services/etmf/etmf-logic.ts:35-49`) — against Veeva's TMF Bot at over a million documents classified, TransPerfect's claimed 98% metadata accuracy, and PhlexTMF v21 pre-trained on millions of documents. And the filing action in the UI writes a `documentRef` of `'vault://' + trialId + '/' + artifactCode` (`Etmf.tsx:124,142`) that does not match the one real vault URI scheme in the codebase (`server/services/storage/storage-provider.ts:91`) and resolves to nothing — so the checklist's pointer back to the source document is a dead string.

There is a fourth issue an acquirer's technical diligence will find: neither `migrations/20260610_etmf.sql` nor `migrations/20260615_tmf_artifact_filings.sql` appears in `scripts/db/migration-set.mjs`, the curated 25-file set that `scripts/db/deploy-migrate.mjs` applies at production deploy time. Only the from-scratch install path sweeps the whole `migrations/` tree (`scripts/db/install-fresh.mjs:65`). On an already-deployed database, every `/api/etmf` endpoint returns a missing-table error. The repo documents this exact failure mode as 'merged ≠ applied' at `scripts/db/deploy-migrate.mjs:6-14` — it has simply not been closed for eTMF.

What is genuinely valuable here is orthogonal to the category: a sha256-chained, HMAC-sealed audit ledger with on-demand chain and seal verification (server/services/auditService.ts:230-298, server/routes/part11-compliance.ts:791,1192), and a governed-mutation pattern that forces a reason string at the transaction boundary and rolls back if the ledger write fails (server/routes/etmf.ts:52,56-79). That is a better Part 11 §11.10(e) story than most of this field ships. It is an asset — for a platform, or bolted onto an acquirer's existing DMS. It is not an eTMF.

Verdict for an acquirer: do not value this line as eTMF/DMS revenue capability. Value it as (a) a governed-audit and provenance substrate, and (b) an eCTD/submission adjacency that happens to include a TMF gap-checker. If the thesis requires an eTMF, this is a build, not a buy.

EU MDR / IVDR clinical evaluation (CER / PER) software

Verdict: ● **Not competitive** Weighted capability score — **us 1.8 / 5** vs **best competitor 4.3 / 5** across 13 dimensions.

Full category as scoped: EU MDR / IVDR clinical evaluation (CER / PER) software

Who buys, and what they are actually buying

VP/Director of Regulatory Affairs or Head of Clinical Evidence at a Class IIa–III device or Class B–D IVD manufacturer (or the RA consultancy/CRO writing on their behalf). They are not buying "documents" — they are buying a defensible, audit-survivable clinical evidence chain that clears a Notified Body technical documentation review under MDR 2017/745 Annex XIV / IVDR 2017/746 Annex XIII on the first or second cycle, and that can be re-run annually for PMS/PMCF/PSUR updates without re-doing the literature work. The purchase is justified against a hard alternative: outsourcing the CER to a consultancy at roughly EUR 150k–1M+ per Class IIb/III device over 8–24 months (qmedify.com), against a total MDR certification cost of roughly EUR 200k–600k per device (SNITEM data via meddeviceguide.com). Budget sits in RA/Clinical, not IT. Procurement gates on three things in order: (1) does the literature search-and-appraisal survive an auditor, (2) is the system validated (Part 11 / Annex 11 / CSV package + vendor audit), (3) does it reduce medical-writer hours. Feature novelty is a distant fourth.

Market structure

Market structure. This category has an unusual shape: the dominant incumbent is not a software vendor at all, it is the consultancy. Manufacturers are highly likely to outsource CER development to specialist consultants given the cost and time involved, so every software deal is displacing a services line item rather than another tool. That sets the value anchor high and the switching bar high at the same time — the buyer is comparing your platform against a firm that will simply hand them a finished, signed CER.

Deal size and pricing. Class IIb/III CERs typically cost EUR 150k–1M+ and take 8–24 months (qmedify.com). Total MDR certification per device runs roughly EUR 200k–600k on SNITEM data, with a range from about EUR 8k for a simple Class I device to over EUR 600k for a Class III requiring clinical investigations (meddeviceguide.com, medenvoyglobal.com). Where MDD accepted literature reviews, MDR frequently demands clinical investigations or PMCF studies, adding USD 36k–120k or more. Four of the five competitors publish no pricing at all — only CiteMed exposes a public pricing page with usage-based billing and no per-user charge on Freelancer tiers (citemed.io/pricing). Practical read: platform ACVs in this category are anchored somewhere between a single outsourced CER and a fraction of it, sold per-product-family or per-seat, with the compelling pitch being amortisation across the annual PMS/PMCF/PSUR re-issue cycle rather than one-time report cost.

Segmentation. The five split cleanly into three groups, and a real RFP usually contains one from each. (1) Document suites — Celegence CAPTIS, CiteMed — sell the whole EU documentation family (CER, PER, PMS, PSUR, SSCP) and typically attach services. (2) Evidence infrastructure — DistillerSR, Nested Knowledge — sell the validated, auditable literature spine and leave authoring to someone else; DistillerSR claims use by more than 80% of the largest pharma and medical device companies. (3) AI-native whole-document challengers — Vespper — sell the integrated outcome but are the least publicly verifiable on viability, validation and AI governance. Concept2Cure.RI is architecturally in group 3 while its shipped literature capability is below group 2's floor.

What actually decides the deal. MDCG 2020-13 is the template Notified Bodies use to assess a CER, and it defines expectations for clinical evidence sufficiency, benefit-risk conclusions and PMCF integration; MDCG 2020-6 governs sufficient clinical evidence for legacy devices. Vendors are increasingly evaluated on whether their output survives that specific template. The pain is real and quantified: roughly 40% of medium-risk and 45% of high-risk device manufacturers report inconsistencies in the amount of clinical data accepted by notified bodies (PMC10276779). That inconsistency is precisely the gap a Notified Body simulator addresses — which is why our cer-auditor.ts is strategically well-aimed even though the surrounding product is not ready.

Consolidation. Clarivate is actively rolling up adjacent regulatory and literature assets — Dialog Solutions in Aug 2023 (MDR literature review search, PV literature monitoring) and Global QMS in Apr 2024 (automated regulatory reporting and compliance management). Note carefully: no acquisition of DistillerSR by Clarivate was found in public sources — DistillerSR appears to remain independent, and any claim otherwise is not verified. Rimsys is consolidating the adjacent MedTech RIM layer, claiming 6 of the top 12 global MedTech manufacturers, a KPMG partnership from Mar 2025, and a Spring 2026 release embedding submission authoring and AI-powered regulatory monitoring — a credible future entrant into clinical evaluation from the RIM side, and the most likely acquirer-or-competitor to watch. The strategic implication for a buyer of this asset: the CER category is being pulled into larger regulatory platforms from two directions (evidence infrastructure and RIM), so a point CER tool with no literature engine and no validation package has a narrowing window to matter on its own.

Sources: qmedify.com/articles/clinical-evaluation-report-for-medical-devices; meddeviceguide.com/blog/ce-marking-cost-medical-devices-guide; medenvoyglobal.com/blog/whats-the-cost-of-medical-device-approval-in-europe; citemed.io/pricing; distillersr.com/industries/medical-devices; mdxcro.com/mdcg-2020-13-for-medical-device-manufacturers; pmc.ncbi.nlm.nih.gov/articles/PMC10276779; clarivate.com/news/clarivate-acquires-

The five closest competitors

Celegence — CAPTIS / CAPTIS Copilot — CAPTIS (cloud MDR/IVDR compliance and medical-writing platform) with the CAPTIS Copilot GenAI layer, sold both as software and bundled with Celegence's own medical-writing service

The purpose-built MDR/IVDR document factory. Positions as end-to-end CER/PER/PMS/PSUR/SSCP authoring with integrated literature search, structured extraction and an embedded citation manager, backed by in-house SMEs (physicians, PhDs, engineers). Public claim of MDR-compliant CER delivery in as few as 6 weeks. This is the vendor a buyer most often names in the same sentence as a CER RFP.

Strengths

- Scope covers the whole EU device documentation family (CER, PER, PMS, PSUR, safety reports, SSP/SSCP), not just literature — the closest thing in the market to a single-vendor answer
- Copilot is a shipped enterprise product (announced Aug 2023), built on pre-trained LLMs plus RLHF specifically for the device/diagnostic industry, not a generic wrapper
- Integrated literature module with automated retrieval and screening against PubMed and Google Scholar plus embedded citation management — auditability is preserved through the citation chain
- Software-plus-services model de-risks the buy: the customer can start as a writing engagement and convert to platform, which is how most CER budgets are actually released
- Celegence dogfoods it — their own medical-writing team runs PMS documentation on Copilot, which is a credible proof point in NB conversations

Weaknesses

- Pricing is entirely opaque; no public list price, no per-seat or per-report figure — every deal is a negotiated enterprise contract, which slows procurement
- No public 21 CFR Part 11, SOC 2, or ISO 27001 attestation found in searchable sources — not verified either way, which means the buyer's CSV team has to run a full vendor audit
- The services attachment is a strength commercially and a weakness architecturally: heavy reliance on human SMEs caps the automation ceiling and keeps marginal cost per CER high
- Literature source coverage as publicly described leans on PubMed and Google Scholar; Embase/Cochrane coverage depth is not verified, and NB assessors probe database justification hard
- No published quantitative validation of the AI (recall/precision on screening) comparable to what the SLR-native vendors disclose

AI shipped today	Shipping. CAPTIS Copilot is an enterprise cloud platform using pre-trained LLMs with Reinforcement Learning from Human Feedback, targeted at device and diagnostic manufacturers. Publicly claimed average saving of 13 hours 16 minutes via the AI-powered systematic literature review module with automated data extraction. Applied to scientific literature summaries, clinical evaluations, safety reports and summary-of-safety-and-performance documents.
GxP / validation posture	Not verified. Marketing uses 'audit-ready' and 'MDR/IVDR compliance' language and describes audit-trail/traceability intent, but no public 21 CFR Part 11, EU Annex 11, SOC 2 or ISO 27001 certification statement was found. A buyer must assume a full vendor qualification and CSV effort.
Pricing signal	Not public. Enterprise negotiated. The adjacent service anchor is the outsourced-CER market: EUR 150k–1M+ per Class IIb/III CER.

► Sources

DistillerSR — DistillerSR literature review platform + DistillerSR AI (Smart Evidence Extraction / SEE) + DistillerSR Agentic AI

The incumbent system-of-record for the literature spine of a CER. Does not claim to be a CER authoring tool end-to-end; claims to be the auditable, validated evidence layer that CERs, State-of-the-Art reports, 510(k) summaries, PSURs and PMCF plans are built on. Public claim: used by more than 80% of the world's largest pharmaceutical and medical device companies. This is the vendor that wins on the auditor's question, not the writer's question.

Strengths

- Explicit public compliance posture: 21 CFR Part 11, EU Annex 11, and NIST AI standards — the only one of the five with a clearly stated regulated-systems claim, which collapses the buyer's CSV risk
- Provenance to the cell level: the platform tracks all review activity so the origin of every extracted data point is inspectable — precisely what a Notified Body assessor asks for under MDCG 2020-13
- Deep installed base in medtech RA (>80% of the largest device companies) means reference calls are easy and the tool is already in the auditor's mental model
- Published outcome data: a case study claiming 30% reduction in CER time, and up to 70% reduction in screening time supporting timely PSUR/PMCF delivery
- AI is current and shipping in layers, not roadmap: Agentic AI launched Sep 2025, and new fully automated Smart Evidence Extraction capabilities launched 8 Apr 2026 — this vendor is not standing still
- SEE keeps human governance over AI-generated output while offering a fully automated mode, which is the exact human-in-the-loop shape MDCG/NB reviewers expect

Weaknesses

- It is a literature/evidence-synthesis platform, not a CER document generator — the buyer still needs a writing layer, so DistillerSR is frequently bought alongside a consultancy or a second tool, raising total cost
- No GSPR (Annex I) conformity matrix, no equivalence assessment framework, no PMS/PMCF/PSUR lifecycle object — the regulatory scaffolding around the literature is out of scope
- Priced and sold as an enterprise research platform; pricing is not public and seat-based licensing can be awkward for small RA teams doing 2–5 CERs a year
- Generic across pharma and medtech; the EU-MDR-specific opinionation (MEDDEV 2.7/1 rev 4 appraisal weighting, Annex XIV section order) is thinner than the device-only specialists
- No vigilance/postmarket database integration (EUDAMED, MAUDE) as part of the core evidence pipeline

AI shipped today	Shipping and the most advanced of the five. DistillerSR AI combines traditional AI and GenAI. Smart Evidence Extraction finds, suggests, explains, extracts and links supporting evidence within a reference, in both human-in-the-loop and fully automated workflows, with full auditability. Agentic AI (launched Sep 2025) exposes a validated organization-wide evidence source to agents. April 2026 release added fully automated SEE. GenAI drafting of device safety-profile comparisons against equivalent devices is claimed to cut manual writing burden by up to 70%.
GxP / validation posture	Strongest publicly stated of the five. Maintains compliance with FDA 21 CFR Part 11, EU Annex 11, and NIST AI standards; built-in automation and validation tools; full activity tracking so the provenance of every cell of extracted data is viewable. Specific IQ/OQ/PQ package contents and SOC 2 status not verified from public sources.
Pricing signal	Not public. Enterprise subscription. Value anchor is the published 30% CER cycle-time reduction and up to 70% screening-time reduction.

► Sources

CiteMed — CiteMed clinical evidence and literature review platform, plus CER/PMS writing services and a PMCF survey module

The medtech-only specialist. Narrower than Celegence, more opinionated than DistillerSR: evidence management purpose-built for EU MDR, IVDR and FDA device submissions, covering CER, PMS, PMCF, PSUR and vigilance reports. Sells a hybrid — software for teams that write in-house, and an end-to-end owned service (literature review, writing, revisions, final deliverable) for teams that do not.

Strengths

- Only vendor of the five with a public, self-serve pricing page and a usage-based model — 'pay when you use the software to review', no charge for additional users on Freelancer tiers — which is a real procurement advantage for small and mid-cap manufacturers
- Device-regulation-native scope end to end: CER, PMS, PMCF, PSUR and vigilance in one place, aligned to MDR/IVDR/FDA rather than to generic systematic review
- Full audit trail: every interaction is captured and logged, giving the documented evidence trail MDR/IVDR inspections require
- Concrete SLR mechanics that survive audit: automatic duplicate detection by DOI, PMID and title with optional manual validation; centralized source repository with tags, statuses and selection history
- PMCF survey creation, distribution, scheduling and automated reminders is a genuinely differentiated module — most competitors stop at literature and leave PMCF data collection to a separate tool
- MEDDEV 2.7/1 rev 4 compliant automated literature search is explicitly claimed, which is the methodology NB assessors actually cite

Weaknesses

- Smallest vendor of the five; concentration/continuity risk is a live procurement objection for a Class III manufacturer with a 10-year technical-documentation retention obligation
- No public 21 CFR Part 11 certification, no CSV/IQ-OQ-PQ package, no SOC 2 or ISO 27001 statement found — not verified
- AI capability is the least specified of the five: automation and screening are described, but no named GenAI product, no published recall/precision, no AI-disclosure documentation
- The services arm competes with the software arm — a buyer wanting pure tooling may find the roadmap biased toward the managed-service motion
- No GSPR conformity matrix or MDR equivalence framework; the regulatory scaffolding beyond literature and PMCF is thin
- Pricing transparency is partial: tiers are described but per-report cost is still gated behind a sales conversation

AI shipped today	Automation-heavy rather than demonstrably GenAI-heavy as of 2026. Automated literature search and retrieval, automatic deduplication by DOI/PMID/title, screening workflow and status tracking. No named large-language-model product, no published model validation, and no AI transparency documentation found. Treat AI depth as not verified relative to DistillerSR or Celegence.
GxP / validation posture	Partial and self-asserted. Full audit trail with every interaction logged, decision-process tracking, and inspection-readiness framing for clinical evaluation, PMS and PMCF. No public Part 11 / Annex 11 certification, no validation package, no security attestation verified.
Pricing signal	Most transparent of the five. Public pricing page at citemed.io/pricing with usage-based billing ('only pay when you use the software to review') and no per-user charges on Freelancer tiers. Exact per-report figures still require contact.

► Sources

Nested Knowledge — AutoLit — AutoLit evidence-synthesis SaaS with Smart Search and Robot Screener AI modules; published CER demonstration nests

The AI-native evidence-synthesis challenger with the most scientifically honest AI posture in the category. Compresses search, screening, tagging, extraction and critical appraisal into one connected workflow. Not marketed as an MDR compliance suite, but explicitly demonstrated on device CER work — they publish a 'Clinical Evaluation Report: Aspiration Catheter' demo nest.

Strengths

- Publishes quantitative AI validation studies — Smart Search, an LLM chain-of-thought reasoning agent that builds Boolean strings, validated at over 75% recall against Cochrane and in-system SLRs; Robot Screener, an ML second-reviewer replacement in dual screening, at up to 97% recall in internal studies. No other vendor in this set publishes numbers a Notified Body can interrogate
- Publishes formal AI disclosure and AI-systems documentation — directly addresses the EU AI Act and MDCG expectations around responsible AI use in clinical evaluation, and pre-empts the NB question 'how do you know your AI did not miss studies'
- Robot Screener replacing the second human reviewer in dual screening is the single highest-leverage cost reduction in a CER literature workflow, and it is defensible because the recall is measured
- Critical appraisal is inside the workflow, not bolted on — matches MEDDEV 2.7/1 rev 4 appraisal expectations better than pure screening tools
- Genuinely modern architecture and a fast release cadence; strong fit for a buyer who wants an AI-forward tool without vendor hand-waving

Weaknesses

- Not a CER product. No CER document generation, no GSPR matrix, no equivalence assessment, no PMS/PMCF/PSUR lifecycle, no vigilance integration — the buyer gets a superb literature engine and nothing else
- 21 CFR Part 11 compliance, audit-trail-for-regulated-records posture, and validation package contents are not publicly documented and could not be verified — a serious gap for a GxP buyer, and the exact dimension where DistillerSR beats them
- Positioned across academic/clinical evidence synthesis broadly; medtech regulatory affairs is a segment, not the whole company, so MDR-specific opinionation is shallow
- Pricing not public; sales-gated via sales@nested-knowledge.com
- Smaller commercial footprint in device RA than DistillerSR; fewer NB-facing reference customers

AI shipped today	Shipping, and the most transparently validated. Smart Search is a human-in-the-loop LLM reasoning agent generating Boolean search strategies (>75% recall vs Cochrane and in-system SLRs). Robot Screener is an ML classifier that replaces the second reviewer in dual screening (up to 97% recall, internal studies). Both are accompanied by published validation-study and AI-disclosure documentation.
GxP / validation posture	Not verified for GxP. Strong scientific/AI validation documentation, but no public 21 CFR Part 11 statement, no CSV/IQ-OQ-PQ package, no audit-trail-for-electronic-records attestation found. This is the inverse of most competitors: model validated, system not demonstrably validated.
Pricing signal	Not public. Subscription; pricing page directs to sales@nested-knowledge.com .

► Sources

Vespper — AI Clinical Evaluation Report Generator (medtech/biotech use case)

The closest structural analogue to what Concept2Cure.RI is attempting: an AI-native platform that connects clinical data, literature and post-market surveillance records into structured, traceable, EU MDR-compliant CERs. Sells the whole-document outcome rather than the literature substrate. This is the competitor that most directly contests our intended wedge.

Strengths

- Whole-CER framing — connects three evidence streams (clinical data, literature, PMS records) into one traceable report, which is exactly the integration story buyers want and which DistillerSR and Nested Knowledge explicitly do not sell
- Traceability is the headline claim, not an afterthought — aligns with the MDCG 2020-13 assessment posture where NB reviewers follow evidence from conclusion back to source
- Correctly frames the regulatory context in its own materials: EU MDR 2017/745 clinical evaluation is mandatory for every class from I to III, and the CER is required technical documentation under Annex II — indicating real domain grounding rather than generic AI marketing
- AI-native architecture with no legacy services business to protect, so automation ceiling is higher than Celegence's or CiteMed's
- Smallest switching friction for a greenfield buyer who has never bought a CER tool

Weaknesses

- Almost nothing about the company is publicly verifiable — funding, headcount, customer count, and pricing all returned nothing in search. For a system holding technical documentation subject to a 10-year retention obligation, unverifiable vendor viability is a hard procurement blocker
- No 21 CFR Part 11, Annex 11, SOC 2, ISO 27001, or CSV/validation-package evidence found — not verified
- No published AI validation: no recall/precision on screening, no AI disclosure documentation, no model governance statement. Against Nested Knowledge's published numbers this is a losing position in a technical evaluation
- No evidence of GSPR conformity matrix, MDR equivalence assessment (Art 61(4) / Annex XIV Part A §3), or PMS/PMCF/PSUR lifecycle objects
- No named Notified Body reference or case study found — in a category where NB acceptance is the whole point, absence of NB-facing proof is telling

AI shipped today	Shipping per its own product page — an AI CER generator that connects clinical data, literature and PMS records into structured traceable CERs for EU MDR. Model family, provider, human-in-the-loop design, and any validation are all not verified from public sources.
GxP / validation posture	Not verified. No public GxP, Part 11, CSV, or security posture statement located.
Pricing signal	Not public. No funding or deal-size signal located.

► Sources

Capability rubric

Our score is cited to `file:line` in this repository. Theirs is cited in the competitor sections above. Scored on what **ships and is reachable**, not what is architected — an unreachable or unvalidated capability scores low regardless of code quality.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Systematic literature review engine wired into CER (query build → multi-database search → dedup → dual screening → PRISMA counts)	critical	1 ▼	DistillerSR	5	server/services/cerGenerationService.ts:545-552 — literatureReview is a hardcoded shell {searchStrategy:'Systematic literature search conducted', databases: ['PubMed','EMBASE','Cochrane'], results:[]}; no search is executed. server/routes/cerv2-ai-routes.ts:164-167 — the 'dataset'/search_strategy' CER section is a template string containing literal '[DATE RANGE]' and '[N] articles' placeholders. No literature-search service is imported by any CER route; server/services/research-intelligence/runLiteratureSearch.ts is referenced only by routeEvidenceRequest.ts:2 and never by CER code.
Literature appraisal and evidence weighting per MEDDEV 2.7/1 rev 4 Appendix A5/A6 (scientific validity, relevance, methodological quality, contribution weighting)	critical	1 ▼	DistillerSR	5	server/routes/cerv2-ai-routes.ts:169-172 — the entire appraisal capability is one boilerplate sentence ('Each identified study was appraised per MEDDEV 2.7/1 rev. 4 criteria: scientific validity, relevance to the device, and methodological quality.'). No appraisal data model, no per-study scoring, no weighting algorithm, no appraisal table generator anywhere in server/services/cer/ or server/routes/cer-routes.ts.
GSPR (Annex I) conformity matrix with per-requirement status, applicability, and evidence linkage	critical	2 ▼	Celegence CAPTIS	4	Split verdict. IVDR side is real: server/routes/ivdr-routes.ts:1027 defines all 23 IVDR Annex I GSPRs across Chapters I–III; :1060-1105 creates the assessment with per-requirement status/evidenceLinks/notes; :1151 updates a single requirement; :1213-1279 returns a chapter-grouped compliance matrix with rollups and an overall compliance percentage. MDR side is fabricated: server/services/cerGenerationService.ts:566-613 (generateGeneralRequirements / generateDesignRequirements / generateInformationRequirements / generateClinicalRequirements) emits five hardcoded items numbered 'ER 1/2/3/13/14' — the superseded MDD 93/42/EEC Essential Requirements vocabulary, not MDR Annex I GSPRs — each with conformity hardcoded to 'Conforms' and evidence hardcoded to a generic string, regardless of input. client/src/concept2cure/mdx/data/cer.ts:81-110 holds a correct 23-row MDR GSPR array but it has zero consumers (verified: no file outside data/cer.ts imports CER_GSPR).
Equivalence assessment framework (MDR Art. 61(4) / Annex XIV Part A §3 — technical, biological, clinical characteristics with data-access justification)	critical	1 ▼	Celegence CAPTIS	4	client/src/concept2cure/mdx/data/cer.ts:136-172 defines CER_EQUIV_MATRIX across Technical/Biological/Clinical dimensions — correct MDR shape, but it is a hardcoded fixture for a fictional device and has zero consumers. The only live equivalence endpoint, server/routes/cerv2-ai-routes.ts:354 POST /equivalence, implements FDA 510(k) substantial equivalence to a predicate (template at :114-117 reads '[DEVICE NAME]' is substantially equivalent to [PREDICATE DEVICE] ([PREDICATE K]))', which is a different legal test from MDR equivalence and cannot be used for an Annex XIV Part A §3 claim.
Postmarket / vigilance data integration for devices (EUDAMED, MAUDE, national competent-authority databases, complaint handling)	critical	1 ▼	CiteMed	4	server/routes/cer-routes.ts:103 — the CER module's only live vigilance integration queries https://api.fda.gov/drug/event.json (FAERS, the FDA drug adverse-event database) keyed by NDC code. FAERS/NDC is a pharmaceutical pharmacovigilance source and is the wrong database for a medical-device CER; the correct source is MAUDE plus EU vigilance. A working MAUDE client exists in the codebase (server/services/ana/AnaToolExecutor.ts:18 imports fda_maude_client, executor at :1424-1459) but is never imported by any file under server/routes/cer*.ts or server/services/cer*. No EUDAMED integration exists; client/src/concept2cure/mdx/data/cer.ts:36-44 shows 'Eudamed' as a signal source only in fixture data.
PMS / PMCF / PSUR lifecycle linkage (MDR Arts. 83–86, Annex XIV Part B) — plans, surveys, trend reporting, periodic re-issue	high	1 ▼	CiteMed	5	server/routes/cerv2-ai-routes.ts:177-180 — PMS is one boilerplate sentence asserting that plans 'have been established'. client/src/concept2cure/mdx/data/cer.ts:176-234 defines CER_PMS_KPIS, CER_PMS_COMPLAINTS, CER_PMCF_STUDIES and CER_PMS_TIMELINE with correct regulatory shape (including an Article 88 trend-report row), but all four are hardcoded fixtures with zero consumers. No PMS/PMCF data model, no survey capability, no PSUR generator, no periodicity scheduler in the CER module.
Reachable, task-complete CER workspace — a front door a regulatory writer can find and finish a CER in	critical	1 ▼	Celegence CAPTIS	5	client/src/concept2cure/v2/registryModel.ts:116-122 — RAIL_PRIMARY, the global navigation, contains exactly 5 entries (Chats, Projects, Communication Center, Apps, Settings) against 100 surfaces registered in client/src/concept2cure/v2/surfaceViews.ts. registryModel.ts:140 places 'device-cer' in NAV_HIDDEN, demoted from the rail in the HEAD commit itself (3276b878, 2026-07-28); it is reachable only via %K or deep link. The surface it lands on, client/src/concept2cure/mdx/surfaces/CerSurface.tsx, is 374 lines rendering three panels (signals, literature buckets, export checklist); its own header comment at :5-7 states the 7-tab CerWorkbench (Equivalence / GSPR / Lit corpus / Signals / PMS / Generator) 'is not present in this kit drop' — verified: no CerWorkbench file exists anywhere in client/. The 'Apps' rail entry is a module-subscription catalog (client/src/concept2cure/v2/surfaces/AdminSurfaces.tsx via surfaceViews.ts:127), not a

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					surface launcher. Decisively: zero frontend files call <code>/api/cer/*</code> — the entire CER backend (POST <code>/api/cer/mdr/generate</code> , GET <code>/api/cer/mdr/:id/validate</code> , <code>/api/cer/reports</code> , <code>/api/cer/faers/*</code>) has no UI caller. The registry's own note at <code>shared/constants/ui-surface-registry.ts:362</code> admits 'Dashboard only today.'
GxP / CSV / 21 CFR Part 11 validation posture (audit trail, e-signature manifestation, IQ/OQ/PQ package, vendor-audit readiness)	critical	2 ▼	DistillerSR	5	Real but incomplete. Audit trail is genuine: <code>server/services/cerGenerationService.ts:35</code> imports <code>auditService</code> , with <code>logAction</code> calls at <code>:210-215</code> , <code>:346</code> , <code>:427</code> . Governed export is genuine and better than most AI-native rivals: <code>server/routes/cerv2-export-routes.ts:118-167</code> implements a human-review gate (403 <code>HUMAN_REVIEW_REQUIRED</code> , enforced by default in production per <code>:129-134</code>) plus AI-generated / reviewer / review-timestamp response headers; <code>server/routes/cerv2-sections.ts:538</code> records a Part 11 trail on accept-ana-draft. Missing: no 21 CFR Part 11 §11.50/§11.70 electronic-signature manifestation anywhere in the CER path; no IQ/OQ/PQ protocols or CSV package for the CER module (the only validation artifact in the repo is <code>docs/validation/VMP-CORTEX-001-VALIDATION_MASTER_PLAN.md</code> , which does not cover CER); no SOC 2 or ISO 27001 evidence.
AI that ships for CER drafting, with provenance and human-in-the-loop governance	high	3 ▼	DistillerSR	5	Genuinely working and the second-best thing we have. <code>server/routes/cerv2-ai-routes.ts:186-265</code> (<code>generateWithRAG</code>) performs tenant-scoped RAG retrieval via <code>ragRouter</code> against the <code>rag_chunks</code> corpus with reranking, then routes to the AI gateway with Claude primary (<code>taskType</code> 'document_drafting', temperature 0.3), returning <code>ragSources</code> for provenance and degrading to a template only on failure. Section-level accept-with-audit exists at <code>server/routes/cerv2-sections.ts:547</code> . Endpoints: <code>/suggest</code> , <code>/equivalence</code> , <code>/benefit-risk</code> , <code>/analyze-section</code> , rate-limited at <code>:41-42</code> . Ceiling: the fallback templates it degrades to (<code>:155-183</code>) are unfillable boilerplate containing literal '[N]' and '[DATE RANGE]' tokens, and no AI validation (recall/precision) is published.
Notified Body review simulation / deficiency prediction against MDCG 2020-13 CEAR expectations	high	4 ▲	Celegence CAPTIS	1	Our single clear win, and it is reachable. <code>server/services/ana/intelligence-questions/war-game/auditors/cer-auditor.ts</code> is 875 lines implementing 25 audit rules (verified count of 'id:rid(' occurrences), each phrased as a question a Notified Body assessor would ask under EU MDR 2017/745 and citing the specific provision — e.g. the device-identification rule at <code>:46-60</code> cites Annex XIV Part A Section 1 and returns severity 'critical'. Registered at <code>war-game/auditors/index.ts:12</code> (<code>createCerAuditor</code>), executed via <code>server/services/ana/AnaToolExecutor.ts</code> , and rendered in the UI at <code>client/src/concept2cure/components/ana/ChatView.tsx:236-241</code> (<code>warGameReport</code>) — reachable from 'Chats', which is <code>RAIL_PRIMARY</code> entry #1. Supporting depth: <code>server/services/ana/intelligence-questions/flows/cer-report.ts</code> is 2058 lines. Capped at 4 because it audits interview answers, not the actual CER artifact.
Deterministic conformance / completeness validation of the produced CER	medium	3	Celegence CAPTIS	3	<code>server/services/cer/cerConformanceValidator.ts:69-160</code> runs 10 checks (9 mandatory, 1 recommended) against actual stored report content, correctly branching MDR Annex XIV Part A vs IVDR Annex XIII references at <code>:72-74</code> and <code>:112-137</code> , and fails closed. Its own docstring at <code>:12-16</code> honestly scopes itself as structural completeness only, explicitly not scientific adequacy. Backed by passing tests — 25/25 green across <code>server/services/cer/tests/unified-cer-service.failclosed.test.ts</code> and the IVDR PER suite. Capped at 3 because 10 presence checks is a section-existence test, not conformance: a CER can pass all 10 with fabricated content.
IVDR Performance Evaluation (Annex XIII: scientific validity / analytical performance / clinical performance) and IVDR technical-file assembly	high	3 ▼	Celegence CAPTIS	4	Our deepest real asset, and mostly unreachable. <code>server/routes/ivdr-routes.ts</code> is 1610 lines: Annex VIII classification (<code>:175</code>), analytical validations with parameter history (<code>:380-596</code>), clinical evidence with results and history (<code>:597-811</code>), CDx workflows (<code>:812-968</code>), the 23-GSPR checklist and matrix (<code>:1060-1279</code>), submission-package build (<code>:1307</code>) and EUDAMED export (<code>:1451</code>). <code>server/routes/ivdr-binder-routes.ts</code> adds 1016 lines of claim → evidence → approve/revoke governance with pack readiness, build jobs and artifact hashing, plus a background worker started at <code>server/bootstrap/register-regulatory-routes.ts:199</code> . Reachability is the cap: only the classification/validation/clinical-evidence/GSPR-matrix slice has a UI (<code>client/src/concept2cure/mdx/surfaces/lvdSurface.tsx:63-65</code> via <code>hooks/useIvd.ts</code>), and that surface sits behind 'device-diagnostics', also in <code>NAV_HIDDEN</code> (<code>registryModel.ts:141</code>). The binder and pack builder have zero frontend consumers (verified: no client file references <code>/api/ivdr/binder</code> or <code>/packs</code>). The Annex XIII PER pillar scorer, <code>server/services/regulatory/ivdr-performance-evaluation.ts</code> , is 70 lines scoring 10 boolean flags and is called only from <code>server/routes/udi-ivdr.ts:81</code> and a demo script.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Output fidelity — MDCG 2020-13 / Annex XIV section order, PRISMA flow diagram, appraisal tables, GSPR traceability annex in the delivered document	high	2 ▼	Celegence CAPTIS	5	server/routes/cerv2-export-routes.ts:268-331 (PDF) and :334+ (DOCX) render whatever the ProseMirror editor holds through renderCombinedPdf, then persist a governed artifact with CTD placement resolved at :168-172 (CER → m5.0). The CER style pack, server/export/stylePacks/cer_mdr_v1.html, is 19 lines — a header/footer carrying the string 'Annex XIV • MEDDEV 2.7/1 rev. 4', not a section-structure template. There is no PRISMA flow-diagram generator, no literature appraisal table generator, and no GSPR traceability annex in the export path. The governed-artifact chain and the human-review gate are real strengths here; the regulatory document structure is not.

Where we stand

Where we win

- Notified Body review simulation. server/services/ana/intelligence-questions/war-game/auditors/cer-auditor.ts ships 25 rules written as Annex XIV-cited assessor questions with severity grading, registered in the auditor index and rendered in the ANA chat UI (ChatView.tsx:236-241) — which is the #1 entry in the 5-item global nav. None of the five competitors ships anything comparable; they all optimize the writing side and leave the reviewer's side to consultants. This is the only capability in the category where we are ahead and reachable at the same time.
- Export governance chain. cerv2-export-routes.ts:118-167 enforces a human-review gate that returns 403 HUMAN_REVIEW_REQUIRED by default in production, stamps AI-generated / reviewer / review-timestamp headers, and persists a governed artifact with CTD placement. Against the AI-native challengers (Vespper, and Nested Knowledge on the GxP axis) this is a stronger shipped answer to 'how do you stop an AI-drafted CER reaching a Notified Body unreviewed' than anything they publish.
- IVDR technical-file depth. 2,626 lines across ivdr-routes.ts and ivdr-binder-routes.ts deliver Annex VIII classification, analytical/clinical performance records with history, CDx workflows, a complete and correct 23-requirement Annex I GSPR checklist with per-requirement evidence linkage and a chapter-rolled compliance matrix, plus a claim → evidence → approve/revoke evidence binder with pack building, artifact hashing and a background worker. No competitor in this set sells an IVDR technical-file assembly product — they all sell literature. This is a real, differentiated asset that is currently 90% invisible.
- Honest fail-closed engineering. cerConformanceValidator.ts scopes itself accurately in its own docstring, refuses to auto-certify, and is covered by 25 passing tests; UnifiedCERService.generateReport returns status 'failed' with the reason rather than fabricating a report. In a category where every competitor's marketing says 'audit-ready', a codebase that documents its own limits is a diligence asset.

Where we reach parity

- AI drafting mechanics. The RAG-plus-Claude pipeline at cerv2-ai-routes.ts:186-265 with tenant-scoped retrieval, reranking and provenance return is architecturally on par with what Celegence and Vespper describe. We are behind DistillerSR's Smart Evidence Extraction on evidence-level extraction and behind Nested Knowledge on published validation, but the plumbing is not the gap.
- Audit trail for electronic records. auditService logging at cerGenerationService.ts:210/:346/:427 plus section-level Part 11 trails at cerv2-sections.ts:538 reaches roughly CiteMed's stated level ('every interaction captured and logged'). It does not reach DistillerSR's stated Part 11 / Annex 11 / cell-level provenance posture.
- Deterministic completeness checking. Ten mandatory-element checks with correct MDR-vs-IVDR reference branching is a credible parity feature against the structural checks the document-suite vendors ship.

Where we lose

- Literature. This is the category's centre of gravity and we have no engine at all — cerGenerationService.ts:545-552 emits an empty results array and cerv2-ai-routes.ts:164 emits a '[N] articles' placeholder. DistillerSR publishes 30% CER cycle-time reduction and up to 70% screening-time reduction; Nested Knowledge publishes >75% search recall and up to 97% screener recall. We publish nothing because there is nothing running. A CER tool without a defensible literature search is not a CER tool.
- Appraisal and evidence weighting. One boilerplate sentence (cerv2-ai-routes.ts:169-172) against four competitors with real screening/extraction/appraisal workflows.
- MDR GSPR conformity. cerGenerationService.ts:566-613 emits obsolete MDD-era 'ER 1/2/3/13/14' items with conformity hardcoded to 'Conforms' and generic evidence strings — a fabricated conformity assertion, and the single most damaging artifact in this module for a diligence reviewer. Compounding it, generateRiskBenefitConclusion at :637-640 always appends 'The clinical benefits outweigh the residual risks when the device is used as intended.' even when calculateBenefitRiskRatio returned 'Needs review', re-fabricating the exact conclusion that :620 was explicitly patched to prevent.
- Vigilance data. cer-routes.ts:103 queries the FDA *drug* event API by NDC code for a *medical device* CER. This is a category error a regulatory buyer will spot in the first demo, and it is worse than having no integration. A working MAUDE client already exists at AnaToolExecutor.ts:18 and is simply not wired in.

- Equivalence. No MDR Art. 61(4) / Annex XIV Part A §3 capability; the only live equivalence endpoint implements FDA substantial equivalence to a predicate, which is a different legal test.
- PMS/PMCF/PSUR. Fixtures with zero consumers against CiteMed's shipped PMCF survey creation, distribution and automated reminders.
- Reachability. 'device-cer' sits in NAV_HIDDEN (registryModel.ts:140) with 5 of 100 surfaces in the global rail; the surface it reaches is a 3-panel dashboard whose own comment says the 7-tab workbench does not exist; and no frontend file calls /api/cer/* at all. Every competitor has a front door. A capability a user cannot reach does not win deals, and here even the reachable door opens onto a room with no GSPR, no equivalence, no appraisal and no generator.
- Validation package. No Part 11 e-signature manifestation, no IQ/OQ/PQ, no CSV documentation for the CER module, no SOC 2 / ISO 27001. DistillerSR states Part 11, EU Annex 11 and NIST AI compliance outright. In a GxP procurement this alone can end the evaluation before capability is discussed.

Is the advantage durable?

No durable advantage exists here, and the honest window is short.

Our one clear win, the Notified Body auditor (cer-auditor.ts, 25 Annex XIV-cited rules), is a corpus-plus-prompt asset. Celegence or DistillerSR could ship an equivalent in two to three quarters: both already hold the regulatory corpus and the customer relationships, MDCG 2020-13 is a public template that defines exactly what an assessor checks, and DistillerSR has shipped three distinct AI capability waves in eighteen months (Nov 2024 purpose-built GenAI, Sep 2025 Agentic AI, Apr 2026 fully automated Smart Evidence Extraction) — a cadence that says a deficiency-simulator feature is a release, not a research programme. There is no data moat: the rules encode published regulation, not proprietary NB outcomes. If we had a corpus of real NB deficiency letters mapped to CER content, that would be defensible; we do not.

The IVDR technical-file machinery (2,626 lines of classification, GSPR matrix, evidence binder with approve/revoke and pack hashing) is the more durable asset — perhaps three to four quarters for a competitor to replicate, because it is genuine domain modelling and workflow rather than a prompt. But durability is irrelevant while it is unreachable: no frontend calls the binder or pack endpoints at all, and the one IVDR surface that exists sits behind 'device-diagnostics' in NAV_HIDDEN. An advantage no user can reach cannot be defended, only lost. Worse, the IVDR clock is running independently of us — IVDR transition deadlines are pulling every device-regulation vendor toward PER and Annex XIII coverage, so the window in which 'nobody else sells IVDR technical-file assembly' stays true is narrowing on its own.

Meanwhile the deficits are getting harder to close, not easier. Literature is where the compounding happens: DistillerSR's advantage is not its algorithms but the curated, reusable, provenance-tracked evidence base its customers have accumulated inside it, plus a stated Part 11 / Annex 11 / NIST AI posture that took years and audits to establish. Nested Knowledge's published recall figures (>75% search, up to 97% screening) are a validation asset we cannot match by shipping code — we would have to run and publish comparable studies. Every quarter we do not have a literature engine, the gap widens by whatever the incumbents' customers extracted that quarter.

Net: assume roughly two to three quarters before an incumbent could neutralise the NB-auditor differentiator if it were visible enough to provoke a response — and it currently is not. The realistic strategy is not to defend a moat but to convert the IVDR asset into a reachable, sellable product fast, using the NB auditor as the demo hook, and to buy rather than build the literature layer. Betting on defensibility here would be a mistake; betting on speed to a reachable IVDR offering is the only credible play.

Shortest credible path to parity

1. Fix the two fabrication defects before anything else — this is a one-day change and it is a diligence gate, not a feature. Delete generateGeneralRequirements / generateDesignRequirements / generateInformationRequirements / generateClinicalRequirements (cerGenerationService.ts:566-613), which assert 'Conforms' against obsolete MDD 'ER' numbering with no evidence, and rewrite generateRiskBenefitConclusion (:637-640) so it stops appending 'The clinical benefits outweigh the residual risks' when calculateBenefitRiskRatio returned 'Needs review'. Until this ships, every other investment is building on a generator that fabricates conformity claims.
2. Repoint vigilance at the right database — days, not weeks, because the client already exists. Replace the api.fda.gov/drug/event.json NDC lookup at cer-routes.ts:103 with the fda_maude_client already imported at AnaToolExecutor.ts:18 (device/event.json by product code), and retain FAERS only for drug-device combination products. Add EUDAMED and national competent-authority vigilance behind the same interface. This closes a demo-killing category error at near-zero cost.
3. Clone the working IVDR GSPR implementation onto the MDR side — the hardest part is already built and tested. ivdr-routes.ts:1027-1279 is a complete 23-requirement Annex I checklist with per-requirement status, applicability, evidence links, notes, update history and a chapter-rolled compliance matrix. Re-point it at MDR Annex I (the correct 23-row MDR requirement text already sits unused at client/src/concept2cure/mdx/data/cer.ts:81-110) and reuse the existing matrix endpoint and IvdSurface rendering pattern. Estimated 2-4 weeks; moves a critical dimension from 1 to 4.
4. Build the literature engine. This is the long pole and the one that decides whether the product exists: PubMed E-utilities plus a licensed Embase/Cochrane connector, protocol-driven query construction with a saved and re-runnable search strategy, deduplication by DOI/PMID/title (the pattern CiteMed publishes), dual screening with reviewer assignment and conflict resolution, MEDDEV 2.7/1 rev 4 Appendix A5/A6 appraisal scoring per study, and PRISMA counts emitted as structured data rather than the '[N]' articles' placeholder at cerv2-ai-routes.ts:164.

Estimated one to two quarters. Consider buying rather than building the screening layer — reselling or OEM-ing an existing validated screener would let the wedge be the Notified Body auditor plus the IVDR binder rather than a from-scratch race against a vendor with published recall figures.

5. Give the offering a front door and finish the workspace. Build the CerWorkbench that CerSurface.tsx:5-7 says is missing — the fixtures at `mdx/data/cer.ts` already define every tab's data shape (GSPR at :81, equivalence at :136, PMS/PMCF at :176-234), so the contracts are settled and only the live wiring and components are missing. Surface it through the `Projects → project → CER` module route, which `approvedRoutePolicy.ts` already allows ('cer' is in `APPROVED_PROJECT_MODULES`), so no navigation-constitution fight is required. Also fix the broken affordance where the diagnostics segment's 'IVDR GSPR checklist' chip (`registryModel.ts:993`) routes to a surface that has no GSPR tab.
6. Ship a CSV package and Part 11 electronic signatures. IQ/OQ/PQ protocols, a requirements traceability matrix, and \$11.50/\$11.70 signature manifestation on CER approval and export. DistillerSR clears this bar publicly and it is frequently a pass/fail gate before capability is even discussed. The audit trail (`cerGenerationService.ts:210/:346/:427`) and the human-review export gate (`cerv2-export-routes.ts:118-167`) already exist, so this is documentation and a signature workflow rather than new architecture — one quarter with a CSV consultant.
7. Restructure the export to the document a Notified Body expects. `cer_mdr_v1.html` is 19 lines of header/footer; replace it with an MDCG 2020-13 / Annex XIV Part A section-ordered template that emits a PRISMA flow diagram, MEDDEV A5/A6 appraisal tables, and a GSPR traceability annex from structured data rather than rendering whatever the editor happens to hold.
8. Sell the wedge while the gaps close. Package the 25-rule Notified Body auditor as a standalone pre-submission CER readiness review and the IVDR binder as an IVDR technical-file product. Both are real, both are differentiated, and both can carry revenue and reference customers during the two-to-three quarters the literature engine takes — provided step 5 gives them a front door.

Verdict

● **Not competitive** — Scored on the thirteen dimensions that actually decide CER/PER deals, we average roughly 1.9 out of 5, and the failures are concentrated exactly where the money is: all six critical-weighted dimensions score 1 or 2. The three questions a Notified-Body-facing buyer asks first — how does your literature search hold up, how do you demonstrate GSPR conformity, and is the system validated — return, respectively, an empty results array (`cerGenerationService.ts:545-552`), five obsolete MDD-era requirements hardcoded to 'Conforms' (`cerGenerationService.ts:566-613`), and no CSV package or Part 11 signature capability at all. Against that, DistillerSR states 21 CFR Part 11 / EU Annex 11 / NIST AI compliance publicly and publishes a 30% CER cycle-time reduction, and Nested Knowledge publishes measured screener recall of up to 97%. We cannot enter that comparison.

The reachability finding is what converts a weak position into a non-position. The premise held: HEAD commit 3276b878 (2026-07-28) leaves exactly 5 of 100 registered surfaces in the global rail (`registryModel.ts:116-122`), and that same commit demoted 'device-cer' into `NAV_HIDDEN` (`registryModel.ts:140`). But the deeper problem is not the missing rail entry — it is that the door leads nowhere. `CerSurface.tsx` is a three-panel dashboard whose own header comment (:5-7) states that the 7-tab CerWorkbench containing Equivalence, GSPR, Lit corpus, PMS and Generator does not exist, and no such file exists anywhere in client/. The MDR GSPR matrix, the equivalence matrix and the full PMS/PMCF dataset all exist as correctly-shaped fixtures in `mdx/data/cer.ts` (lines 81, 136, 176) with zero consumers. And no frontend file anywhere calls `/api/cer/*` — the CER backend has no UI caller at all. This is not a navigation regression; it is an offering that was never assembled.

Two findings go beyond 'incomplete' into affirmative liability, and a buyer should price them as such. First, `cer-routes.ts:103` queries the FDA drug adverse-event database (FAERS, by NDC code) to build the postmarket section of a medical-device CER — the wrong regulatory database for the wrong product class, while a working MAUDE client sits unused at `AnaToolExecutor.ts:18`. Second, `cerGenerationService.ts:637-640` appends 'The clinical benefits outweigh the residual risks when the device is used as intended' to every benefit-risk conclusion, including when the adjacent function returned 'Needs review' — silently re-fabricating the precise conformity claim that line 620 was explicitly patched to stop fabricating. A generator that asserts GSPR conformity and a favourable benefit-risk determination with no supporting evidence is not a partially-built product; it manufactures the exact defect a Notified Body assessor is trained to find.

The asset that survives diligence is not the CER module. It is the 875-line Notified Body auditor (25 Annex XIV-cited assessor rules, reachable today through the ANA chat, which is rail entry #1) and the 2,626 lines of IVDR technical-file machinery — a complete and correct 23-requirement Annex I GSPR checklist with evidence linkage and a compliance matrix, plus a claim → evidence → approve/revoke binder with pack hashing and a live worker. No competitor in this set sells IVDR technical-file assembly; they all sell literature. That is a genuine differentiated wedge, and it is roughly 90% invisible: the binder and pack builder have no frontend at all, and the one IVDR surface that does exist sits behind 'device-diagnostics', also in `NAV_HIDDEN`. The verdict is not-competitive for MDR CER as a standalone purchase. It is not a verdict on the engineering, which in the IVDR module and the audit/governance chain is materially better than the CER module's marketing would suggest — it is a verdict on what a buyer can actually take to a Notified Body this quarter.

Labeling, SPL and artwork management

Verdict: ● **Not competitive** Weighted capability score — **us 1.4 / 5** vs **best competitor 4.7 / 5** across 12 dimensions.

Full category as scoped: Labeling, SPL and artwork management

Who buys, and what they are actually buying

Head of Global Regulatory Labeling (or VP Reg Ops) with a dotted line to Packaging/Artwork Ops and Quality/CSV. They buy one outcome: every market's approved label content, its translations, and the printed carton/insert artwork stay provably in sync with the approved core label — with a 21 CFR Part 11 signed approval act and a validation package that survives an FDA/EMA inspection. Budget typically sits in Reg Ops for the labeling-content half and in Packaging/Supply Chain for the artwork half; deals close only when both halves are covered or explicitly OEM'd. Secondary buyer for the SPL slice is the US Reg Ops publishing lead who must transmit SPL R4 through the FDA ESG.

Market structure

Market size and growth: the pharma labeling-and-artwork management segment was ~\$2.1B in 2025 projected to \$4.8B by 2034 at ~9.6% CAGR (<https://dataintelo.com/report/labeling-artwork-management-for-pharma-market>). The top ten vendors hold roughly 58-63% of global revenue, so this is a consolidated, incumbent-defended category, not a green field (<https://dataintelo.com/report/labeling-artwork-management-for-pharma-market>).

Consolidation is heavy and continuing: Esko acquired Blue Software (2018); Lofware merged with NiceLabel (2021), acquired PRISYM ID (2022) and BL.INK (April 2025), and raised a \$50M round in 2025 for cloud expansion; Danaher spun Esko into Veralto (September 2023); Kallik has been PE-owned by FPE Capital since 2022 (<https://dataintelo.com/report/labeling-artwork-management-for-pharma-market>, <https://intuitionlabs.ai/articles/pharma-artwork-management-comparison>). For an acquirer this matters twice: it means an exit path exists, and it means the incumbents have capital to close feature gaps fast.

Procurement pattern. Labeling deals are almost never single-vendor. The dominant shape is a content-of-label system (Veeva RIM, ArisGlobal, Freyr LABEL 360) plus a separate artwork/packaging system (Lofware Smartflow, Esko WebCenter, Kallik Veraciti) plus a proofreading point tool (GlobalVision Verify, Schlafender Hase TVT) — with integration between them being a named RFP requirement. Kallik is the notable exception, positioning as one workflow across label text/IFU and packaging graphics (<https://www.kallik.com/industries/medical-devices>). GlobalVision explicitly ships an Esko WebCenter integration, which tells you how the market actually composes (<https://www.globalvision.co/blog/the-verify-x-esko-webcenter-integration-automates-proofreading-for-packaging-artwork>).

Deal size. Veeva does not publish list pricing and sells base-application-plus-named-user subscriptions negotiated on multi-year terms; third-party estimates put Vault modules at roughly \$50-200 per user per month (~\$600-2,400/user/year), with onboarding \$10K-50K and professional services commonly 30-60% of first-year license fees. Note a Vault user needing both RIM and QMS consumes two separate named-user licenses (<https://intuitionlabs.ai/articles/veeva-vault-pricing-2026-cost-breakdown>, <https://www.itqlick.com/veeva-vault/pricing>). Lofware, Kallik, Esko, ArisGlobal, Karomi and Freyr all publish no list pricing — all quote-only. A global top-20 pharma labeling program typically lands in the high six to low seven figures annually across the content+artwork+proofing stack.

Validation is a gate, not a feature. Regulated buyers require the artwork/labeling system itself to be validated with IQ/OQ/PQ evidence (<https://www.esko.com/en/products/webcenter-enterprise/validation>). Lofware sells this as a productized Validation Acceleration Pack (<https://www.loftware.com/products/labeling/loftware-cloud/compliance>). A vendor arriving without validation deliverables does not reach shortlist regardless of capability.

AI in this category shipped in 2025-2026 and is now table stakes rather than differentiation: Esko launched Comply, an AI packaging/label compliance validator, and added AI proofing to WebCenter (April 2026); GlobalVision shipped AI-driven OCR in Verify; Karomi ships AI proofing with image compare, barcode check and color/layer inspection; ArisGlobal's NavaX GenAI engine is live across LifeSphere. Veeva's RIM-specific AI Agents are the laggard, slated August 2026, with Agentic Authoring not expected until late 2027 (<https://intuitionlabs.ai/articles/pharma-artwork-management-comparison>, <https://www.pffc-online.com/news/18022-globalvision-launches-groundbreaking-ocr-feature-a-leap-into-ai-for-pharma-regulatory-and-proofreading-teams>, <https://www.clinicaltrialvanguard.com/conference-coverage/veeva-unveils-falcon-ai-platform-and-agentic-authoring-at-2026-summit/>).

The one structural gap in the incumbent field: nobody enforces linguistic quality as a hard, deterministic gate. Competitors treat translation as a workflow state and proofreading as a probabilistic AI check. That is the only seam this codebase's translation engine could exploit — and it currently has no user interface.

The five closest competitors

Kallik — Veraciti (cloud label and artwork management)

The closest single-vendor analogue to what this platform attempts: one workflow spanning label text, IFUs and packaging graphics, with deep medical-device and pharma specialization. Sold as end-to-end LAM to global device manufacturers and pharma. PE-owned (FPE Capital, 2022).

Strengths

- Manages label text, IFUs AND graphics/packaging design in a single workflow — the exact seam most competitors leave to integration (<https://www.kallik.com/industries/medical-devices>)
- Explicit compliance coverage for EU MDR, EU IVDR, FDA UDI, 21 CFR 820, 21 CFR Part 11 and EU GMP Annex 11 (<https://www.kallik.com/industries/medical-devices>)
- 'Cascade' plugin auto-populates templates and generates multilanguage inserts — directly competes with the translation-coverage workflow, from an artwork-native starting point (<https://www.kallik.com/industries/medical-devices>)
- Rules and AI check font sizes, barcode validity and legal text inside the approval flow (<https://www.kallik.com/industries/medical-devices>)
- 20+ years of device labeling references; PE backing means capital to close gaps

Weaknesses

- Not an SPL publishing system — no FDA ESG SPL transmission story surfaced in public materials (not verified either way)
- Smaller than Veeva/Loftware; less leverage in enterprise IT standardization decisions
- AI is rules-plus-checks rather than generative authoring; no public agentic authoring capability as of 2026 (not verified)

AI shipped today	AI and rules-based checks on font size, barcode validity and legal text within the approval workflow, plus template auto-population and multilanguage insert generation via the Cascade plugin. No public generative/agentic authoring product as of 2026 (https://www.kallik.com/industries/medical-devices).
GxP / validation posture	Publicly claims support for FDA 21 CFR Part 11 and EU GMP Annex 11, plus 21 CFR 820, EU MDR/IVDR and FDA UDI (https://www.kallik.com/industries/medical-devices). Specific IQ/OQ/PQ deliverable contents not public — not verified.
Pricing signal	not public — quote only

► Sources

Veeva Systems — Vault RIM (Registrations, Submissions, Submissions Archive) used as the labeling content backbone

The default incumbent and the vendor most large pharma standardizes on. Positioned as single source of truth for labeling content and changes with end-to-end tracking of label updates; labeling rides on top of the RIM suite rather than being a standalone artwork product.

Strengths

- Widely regarded as market leader among large pharma; the safe institutional choice (<https://dataintel.com/report/labeling-artwork-management-for-pharma-market>)
- Vault Registrations handles global registrations, health-authority interactions, country-specific data, lifecycle (renewals/variations) and e-label metadata per market — the CCDS/core-to-local spine (<https://intuitionlabs.ai/articles/veeva-vault-rim-guide-2>)
- Records structured IDMP data (substance codes) and can auto-generate an IDMP submission package — material with EU IDMP deadlines in 2026 (<https://intuitionlabs.ai/articles/veeva-vault-rim-guide-2>)
- Creates PDF viewable renditions for SPL submissions uploaded as ZIP (<https://regulatory.veevavault.help/en/gr/36690/>)
- Adjacency: same vendor already owns QualityDocs/PromoMats/Safety at most accounts, so labeling is an expansion sale not a new procurement

Weaknesses

- No packaging artwork/prepress system — customers pair Vault with Loftware, Esko or Kallik
- SPL support is rendition-oriented (viewable PDF from an uploaded SPL ZIP), not native SPL authoring/generation (<https://regulatory.veevavault.help/en/gr/36690/>)
- RIM-specific AI Agents are the last in the rollout order — Clinical/Regulatory/Medical agents slated August 2026, after CRM (Dec 2025) and Safety/Quality (Apr 2026); Agentic Authoring not expected until late 2027 (<https://www.clinicaltrialvanguard.com/conference-coverage/veeva-unveils-falcon-ai-platform-and-agentic-authoring-at-2026-summit/>)

- Expensive and rigid: separate named-user license per Vault application, no perpetual licensing, services 30-60% of first-year license (<https://intuitionlabs.ai/articles/veeva-vault-pricing-2026-cost-breakdown>)

AI shipped today	Vault AI Agents announced October 2025 on a phased rollout built on Anthropic and Amazon models via Amazon Bedrock; Regulatory/RIM agents slated August 2026 with expected capabilities including auto-tagging, regulatory-intelligence extraction, labeling paragraph analysis, missing-content detection and HAQ response drafting. Agentic Authoring (proactive drafting of submissible documents, native to Vault RIM and Microsoft Word) expected late 2027. As of mid-2026, RIM-specific AI is largely not yet shipped (https://intuitionlabs.ai/articles/veeva-vault-rim-ai-submission-planning-correspondence , https://www.clinicaltrials.vanguard.com/conference-coverage/veeva-unveils-falcon-ai-platform-and-agentic-authoring-at-2026-summit/).
GxP / validation posture	Vault is sold as a validated GxP cloud platform with vendor-supplied qualification evidence and managed release qualification across three annual releases. Specific per-module IQ/OQ/PQ contents are contract-bound and not public — not verified in detail.
Pricing signal	Never published; base-application-plus-named-user subscription, multi-year negotiated. Third-party estimates \$50-200/user/month (\$600-2,400/user/year), onboarding \$10K-50K, services 30-60% of first-year license (https://intuitionlabs.ai/articles/veeva-vault-pricing-2026-cost-breakdown , https://www.itqlick.com/veeva-vault/pricing)

► Sources

Software — Smartflow (packaging artwork management) + Software Cloud (enterprise labeling/print)

The artwork-workflow leader for regulated industries. Built around approval choreography for complex packaging artwork; replaces spreadsheet-and-email routing with a configurable workflow framework. Pairs with Software Cloud for label print/execution — covering the content-to-carton-to-printer span most content systems stop short of.

Strengths

- Purpose-built approval choreography for complex packaging artwork in pharma/device/regulated sectors (<https://www.loftware.com/resources/blog/2025/how-loftware-smartflow-transformed-a-global-pharmaceutical-companys-artwork-management>)
- eSignature on artwork approvals explicitly for 21 CFR Part 11 compliance — the exact approval act this platform cannot sign (<https://www.loftware.com/products/artwork-management/smartflow/quality-management-and-control>)
- Productized validation: Software Cloud Compliance is validation-ready with an optional Validation Acceleration Pack (VAP), turning CSV from a services project into a SKU (<https://www.loftware.com/products/labeling/loftware-cloud/compliance>)
- 21 CFR Part 11, EU MDR and GHS modules out of the box plus defensible audit trails (<https://creativemanager.net/best-label-and-artwork-management-software/>)
- Consolidated scale: NiceLabel (2021), PRISYM ID (2022), BL.INK (April 2025), \$50M raise in 2025; SAP S/4HANA integration expanded February 2026 (<https://dataintel.com/report/labeling-artwork-management-for-pharma-market>)

Weaknesses

- Not a regulatory content-of-label system — no CCDS authoring, no USPI/SmPC section model, no SPL generation
- No IDMP/structured-product-data story
- AI capability is thinner than Esko's Comply or GlobalVision's Verify; positioning leads with workflow and print, not intelligence (not verified as absent, but not publicly marketed)
- Breadth from serial acquisition creates integration seams across Smartflow / NiceLabel / PRISYM lineages

AI shipped today	No prominent shipping generative-AI labeling capability surfaced in 2026 public materials; the 2026 announcements lead with cloud platform and SAP S/4HANA integration rather than AI. AI posture: not verified as shipped (https://dataintel.com/report/labeling-artwork-management-for-pharma-market).
GxP / validation posture	Strongest productized posture in the set. Software Cloud Compliance is sold as validation-ready with an optional Validation Acceleration Pack; Part 11 eSignature on artwork approvals; Part 11 / EU MDR / GHS modules shipped out of the box with audit trails (https://www.loftware.com/products/labeling/loftware-cloud/compliance , https://www.loftware.com/products/artwork-management/smartflow/quality-management-and-control).
Pricing signal	not public — quote only. Company-level signal: \$50M raise in 2025 for cloud expansion (https://dataintel.com/report/labeling-artwork-management-for-pharma-market)

► Sources

ArisGlobal — LifeSphere Labeling Management (within LifeSphere Regulatory, powered by NavaX)

The AI-native challenger to Veeva on the regulatory-content half. Sells an AI-driven global labeling engine for automated compliant label variants — structured authoring in multiple languages and formats with SPL, IDMP and regional standards compliance and automated variant generation. Directly overlaps the USPI/SmPC structural intelligence this platform has built, but ships it inside a reachable, validated product.

Strengths

- Structured authoring of labels in multiple languages and formats with automated variant generation — the core-to-local engine (<https://lifesphere.arisglobal.com/platform/regulatory/labeling-management/>)
- Explicit SPL and IDMP compliance in the labeling engine, plus a Products Compliance module for IDMP-conformant product-data submission across submission/post-submission/post-approval (<https://www.arisglobal.com/lifesphere/regulatory/>)
- NavaX GenAI/LLM engine is shipping and at scale — 700,000 cases annually, scaling to 2.5M by mid-2026; customers report >50% regulatory-operations efficiency gains (<https://www.arisglobal.com/media/press-release/newest-version-of-lifesphere-regulatory-platform-allows-organizations-to-leverage-latest-genai-technology/>)
- Handles unstructured documents and structured data in one platform — the right architecture for the IDMP transition (<https://intuitionlabs.ai/articles/evaluating-rim-systems>)
- Commercial momentum: ~120% YoY LifeSphere bookings growth reported Q1 2026 (<https://www.arisglobal.com/media/press-release/arisglobal-reports-strong-q1-2026-momentum-with-accelerating-enterprise-ai-transformation/>)

Weaknesses

- No packaging artwork lifecycle — same gap as Veeva; requires an Esko/Loftware/Kallik pairing
- Smaller install base than Veeva in top-20 pharma; more common in mid-cap and as a Veeva alternative
- Vendor-published efficiency claims (>50%, >70% claim-error reduction) are marketing-sourced and not independently verified
- Historical reputation for heavy implementation effort on the Safety side — not verified for the labeling module

AI shipped today	Shipping, not roadmap. LifeSphere NavaX is a GenAI/LLM cognitive engine live across the platform supporting content ingestion, generation and insight extraction; the labeling engine is marketed as AI-driven for automated compliant label variant generation. Processing volume disclosed at 700K cases/year scaling to 2.5M by mid-2026 (https://www.arisglobal.com/media/press-release/newest-version-of-lifesphere-regulatory-platform-allows-organizations-to-leverage-latest-genai-technology/ , https://lifesphere.arisglobal.com/platform/regulatory/labeling-management/).
GxP / validation posture	Sold as a GxP cloud platform for regulated regulatory operations with IDMP-compliant submission handling; specific IQ/OQ/PQ deliverable contents not public — not verified.
Pricing signal	not public — quote only. Company signal: ~120% YoY LifeSphere bookings growth in Q1 2026 (https://www.arisglobal.com/media/press-release/arisglobal-reports-strong-q1-2026-momentum-with-accelerating-enterprise-ai-transformation/)

► Sources

Freyr — Freyr LABEL 360 (regulatory labeling platform) + Freyr SPL/SPM (structured product labeling software and publishing services)

The SPL specialist and the realistic alternative for mid-cap sponsors who need SPL transmitted, not architected. Sells software plus a regulatory services arm, so the buyer can outsource the publishing act entirely. This is the vendor that most directly beats the SPL claim in this platform.

Strengths

- Dedicated SPL/SPM software for labeling management and submission in SPL/SPM format to US FDA and Health Canada, with automated SPL publishing — the complete submission act, not a skeleton generator (<https://www.freyrdigital.com/products/labeling-management/spl-spm>, <https://www.freyrsplspm.com/structured-product-labeling-spl-software>)
- LABEL 360 covers content-to-carton: global and regional labeling, CCDS creation and update, and core-to-local label alignment (<https://www.freyrsolutions.com/pharmaceutical-labeling-software>)
- Process-integrated tracking module receives and triages proposed variations and tracks implementation upstream and downstream, giving end-to-end traceability from label content to carton — the change-impact spine (<https://www.freyrlabel.com/freyr-label360>)
- Explicitly bridges labeling information from core label change through artwork, supply chain and printing phases (<https://www.freyrlabel.com/freyr-label360>)
- Software-plus-services model de-risks adoption for sponsors without in-house SPL publishing skill

Weaknesses

- Not a packaging artwork authoring/DAM system — bridges to artwork rather than owning it

- Services-led revenue mix means outcomes depend on Freyr staffing, which some buyers treat as an outsourcing dependency rather than a platform
- Less prominent AI story than ArisGlobal or Esko as of 2026 — not verified as shipping generative labeling AI
- Smaller platform footprint; rarely the enterprise IT standard at top-20 pharma

AI shipped today	Freyr markets technology integration into labeling management but no specific shipping generative-AI labeling capability was verified in 2026 public materials — not verified (https://www.freyrsolutions.com/blog/integrating-technology-into-labeling-management-tools-and-solutions).
GxP / validation posture	Sells into FDA and Health Canada SPL submission workflows via a regulatory services organization; specific IQ/OQ/PQ validation deliverables for the software not public — not verified.
Pricing signal	not public — quote only; software-plus-services engagements

► Sources

Esko (Veralto) — WebCenter Enterprise (artwork management, DAM, review/approval, validation) + Comply (AI packaging compliance validator)

The packaging-artwork platform incumbent, spun out of Danaher into Veralto in September 2023. Owns the prepress-adjacent half of the category — DAM, workflow automation, review/image approval, and a formal validation module. Shipped AI proofing in April 2026, making it the AI pace-setter on the artwork side.

Strengths

- WebCenter Enterprise is the flagship for workflow, DAM and review at enterprise scale, with distinct modules for project/workflow automation, review/image approval, and validation (<https://intuitionlabs.ai/articles/pharma-artwork-management-comparison>)
- Comply is a shipping AI validator that checks labels and packaging against customizable rules for missing allergens, incorrect barcodes and FDA formatting violations (<https://intuitionlabs.ai/articles/pharma-artwork-management-comparison>)
- Expanded WebCenter with AI-powered proofing in April 2026 — real-time text and barcode validation against compliance rules (<https://intuitionlabs.ai/articles/pharma-artwork-management-comparison>)
- Explicit IQ/OQ/PQ validation product for regulated pharma and device buyers (<https://www.esko.com/en/products/webcenter-enterprise/validation>)
- Deep prepress/print lineage no software-first vendor can replicate; integrates with GlobalVision Verify for proofreading (<https://www.globalvision.co/blog/the-verify-x-esko-webcenter-integration-automates-proofreading-for-packaging-artwork>)
- Launched WebCenter Go in 2026 as a lighter tier — signals downmarket expansion (<https://www.esko.com/en/company/news/esko-launches-new-webcenter-go-to-help-emerging-brands-streamline-packaging-artwork-and-ensure-compliance>)

Weaknesses

- No regulatory content-of-label capability — no CCDS, no USPI/SmPC section model, no SPL, no IDMP
- Packaging/CPG heritage means regulatory-affairs buyers rarely own the relationship; the sale sits in packaging ops
- Enterprise WebCenter is heavy to implement and configure; WebCenter Go exists precisely because of that
- Comply is rules-plus-AI over artwork, not label content authoring

AI shipped today	Shipping. Comply is a live AI-powered packaging/promotional-material compliance validator using customizable rules to catch missing allergens, wrong barcodes and FDA formatting violations; WebCenter added AI-enabled artwork and packaging management with real-time text and barcode validation in April 2026 (https://intuitionlabs.ai/articles/pharma-artwork-management-comparison).
GxP / validation posture	Explicit validation product line. Esko documents that heavily regulated pharma and medical-device buyers require the artwork management system to be validated, and sells IQ/OQ/PQ verification of every aspect of implementation (https://www.esko.com/en/products/webcenter-enterprise/validation).
Pricing signal	not public — quote only. WebCenter Go launched 2026 as a lower-cost tier for emerging brands, implying enterprise WebCenter carries a substantial floor (https://www.esko.com/en/company/news/esko-launches-new-webcenter-go-to-help-emerging-brands-streamline-packaging-artwork-and-ensure-compliance)

► Sources

GlobalVision / Schlafender Hase — GlobalVision Verify (AI proofreading and inspection) and Schlafender Hase TVT, the Text Verification Tool

The proofreading/verification point solutions that appear in essentially every labeling RFP as a required capability or a named integration. Not full LAM platforms, but they own the one dimension this platform scores zero on and they are how competitors satisfy the 'prove the carton matches the approved source' requirement.

Strengths

- TVT is configured to compare XML documents in the exact formats specified by FDA (Structured Product Labeling) and EMA (Product Information Management) — direct SPL-diffing capability this platform has no analogue for (<https://www.schlafenderhase.com/pharma-proofreading-software>)
- TVT matches and compares Unicode values character by character across Word, RTF, PDF and TXT, and verifies text, spelling, artwork and barcodes (<https://schlafenderhase.com/tvt/>)
- TVT is used by 9 of the top 10 global pharma companies and by regulatory agencies — near-universal incumbency (<https://schlafenderhase.com/publications/leader-in-intelligent-automated-proofreading-solutions/>)
- GlobalVision Verify runs character-for-character text inspection across digital packaging assets and labels with AI-driven OCR shipping today (<https://www.globalvision.co/verify>, <https://www.pffc-online.com/news/18022-globalvision-launches-groundbreaking-ocr-feature-a-leap-into-ai-for-pharma-regulatory-and-proofreading-teams>)
- Verify ships a Part 11 audit trail tracking parameter changes and logins, with version history and ALCOA+-aligned traceability (<https://www.globalvision.co/blog/10-reasons-top-pharma-companies-automate-proofreading-with-globalvisions-verify-platform>)
- Pre-built Esko WebCenter integration — the reference pattern for how proofing plugs into LAM (<https://www.globalvision.co/blog/the-verify-x-esko-webcenter-integration-automates-proofreading-for-packaging-artwork>)

Weaknesses

- Point tools, not platforms — no workflow, no DAM, no CCDS, no SPL generation, no registration tracking
- Cannot win a labeling-platform RFP alone; always a component of a larger stack
- Two vendors competing head-to-head in a narrow niche, which caps pricing power
- Deployment often on-prem/desktop-oriented in the TVT lineage — not verified for current cloud posture

AI shipped today	Shipping. GlobalVision Verify uses AI-driven OCR for regulatory documentation inspection, launched as a named AI feature for pharma regulatory and proofreading teams. Schlafender Hase markets TVT as intelligent automated proofreading; the comparison engine is deterministic character-level Unicode matching rather than generative AI (https://www.pffc-online.com/news/18022-globalvision-launches-groundbreaking-ocr-feature-a-leap-into-ai-for-pharma-regulatory-and-proofreading-teams , https://schlafenderhase.com/tvt/).
GxP / validation posture	GlobalVision Verify ships a 21 CFR Part 11 audit trail with attributable logging, version history and ALCOA+-aligned traceability for every inspection (https://www.globalvision.co/blog/10-reasons-top-pharma-companies-automate-proofreading-with-globalvisions-verify-platform). TVT is deployed at 9 of the top 10 pharma and at regulatory agencies, implying a mature validation package — specific IQ/OQ/PQ contents not public, not verified.
Pricing signal	not public — quote only; typically seat-based and materially cheaper than a full LAM platform

► Sources

Capability rubric

Our score is cited to `file:line` in this repository. Theirs is cited in the competitor sections above. Scored on what **ships and is reachable**, not what is architected — an unreachable or unvalidated capability scores low regardless of code quality.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Reachable end-to-end labeling workflow (a front door a labeling manager can find and use)	critical	1 ▼	Kallik Veraciti	5	client/src/concept2cure/v2/registryModel.ts:116 (RAIL_PRIMARY = exactly 5 destinations: conversation-thread, projects, communication-center, apps, setup); :164 ('labeling' demoted into NAV_HIDDEN); :169 ('labeling-pi' demoted). The 14-file domain shell client/src/concept2cure/labeling/App.tsx:41 exports LabelingApp with zero importers anywhere outside its own directory. Only the v2 device-labeling board at client/src/concept2cure/v2/surfaces/Labeling.tsx:122 is reachable, and only by typing 'label' into the %K palette (client/src/concept2cure/v2/Shell.tsx:982). The repo's own registry rates it shared/constants/ui-surface-registry.ts:678 readiness:'kit-only'.
FDA-submittable SPL R4 generation, validation and ESG transmission	critical	1 ▼	Freyr SPL/SPM	5	server/services/labeling/spl-generator.ts:163-186 — generateSpl emits // with narrative elements ONLY. No , no , no NDC/package codes, no marketing category, no DEA schedule, no establishment/labeler DUNS, no . Section text is passed through xmlEscape (:69-76), so SPL's required XHTML subset (, ,) is structurally impossible to emit. server/services/labeling/spl-generation-service.ts:16-22 hardcodes 5 LOINC section codes against the ~50+ real SPL sections. The module's own docstring (spl-generator.ts:9-11) admits it does not run FDA's schematron. No

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					ESG submission path exists.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Packaging artwork lifecycle — DAM, versioning, prepress, print-ready release					Loftware Smartflow / Esko WebCenter 5 absent — grep for artwork proofing dieline prepress Pantone across server/, client/src/ and shared/ returns only unrelated hits (workflow-service names, a Ghostscript PDF quality enum, and two taxonomy strings at shared/constants/domain/vault-taxonomy.ts:73,97 that merely mention the word 'artwork' in a document-type description). Zero implementation.
Automated proofreading — character-level text, barcode and artwork verification against approved source					Schlafen Hase TVT / GlobalVision Verify 5 absent for artwork/PDF. The nearest capability is verify_docx_against_source driven by required_strings derived from server/services/ana/labeling-authoring.ts:52-100 — a substring-presence check on section headers, not a character-by-character Unicode comparison, and it never sees a rendered carton or barcode. No barcode decode/verify anywhere in the labeling path (the only barcode code is a mock in server/src/routes/stability.router.ts:40-42 for sample labels).
CCDS / core-to-local label alignment, change control and downstream impact tracking					Freyr LAB EL 360 5 server/api/labeling/routes.ts:225-412 implements label change recording, impact simulation via labeling.calculate_impact_score, and version comparison via labeling.compare_documents — but this router is NEVER MOUNTED. grep for app.use('/api/labeling' across the whole server tree returns nothing; the only importer of any file named labeling/routes is server/api/gcc/index.ts:21, which is itself not mounted in server/bootstrap/register-inline-routes.ts. There is no CCDS object model, no core-vs-local diff, and no market-implementation tracking anywhere.
21 CFR Part 11 e-signed approval act + immutable audit trail on the label record					Loftware Smartflow 5 server/routes/mdx-labeling.ts:82-360 — 11 endpoints, zero references to esign, electronic_signature or audit. server/routes/labeling-pi.routes.ts:29 is a single read-only GET with no write path at all. server/routes/labeling-smpc.routes.ts exposes only a section-status POST. The platform DOES have Part 11 infrastructure (server/routes/esignature.ts, server/routes/part11-compliance.ts, server/services/part11/, server/services/part11ComplianceService.ts) — none of it is wired to any labeling route. Scores 1 not 0 only because the infrastructure exists to wire.
Validation / CSV deliverables — IQ/OQ/PQ package, traceability					Loftware Validation Acceleration Pack / Esko Web 5 absent — no IQ/OQ/PQ artifacts, no validation protocol, no requirements traceability matrix and no vendor audit pack exist anywhere in the repository. Test coverage for the labeling path totals 57 assertions across 8 files (spl-generation-service 15, labeling-authoring 13, smpc-qrd-catalog 6, labeling-smpc-read 6, spl-generator 5, labeling-structure 5, labeling-pi-read 4, labeling-translations-shape 3) — respectable unit coverage, but unit tests are not a validation package and no regulated buyer will accept them as one.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					bility matrix, vendor audit support Cent er Valid ation
			USPI (PLR) EU SmPC (QRD) structu red section model with US ↔ E U cross-mappin g	hi g h 4 ▼ Aris Glob al LifeS pher e Labe ling 5	server/services/ana/labeling-structure.ts:35-95 — full USPI section table with per-section content-routing cues and explicit crossMap to SmPC section numbers (Indications 1 ↔ 4.1, Dosage 2 ↔ 4.2, Contraindications 4 ↔ 4.3, Warnings 5 ↔ 4.4, Adverse Reactions 6 ↔ 4.8, Interactions 7 ↔ 4.5, Populations 8 ↔ 4.6, Overdosage 10 ↔ 4.9, Clin Pharm 12 ↔ 5.1, Nonclinical Tox 13 ↔ 5.3). server/services/ana/labeling-authoring.ts:52-100 encodes the 21 CFR 201.57(c) mandatory PLR headers as a verbatim section guard. server/services/labeling/labeling-intelligence-knowledge.ts (2,418 lines) carries Highlights/FPI descriptors, SPL LOINC codes, boxed-warning categories, REMS models and ETASU elements, safety-labeling-change steps, PLLR former-pregnancy-category mappings, SmPC section structure, FDA-vs-EMA differences and OTC Drug Facts. server/services/labeling/smpc-qrd-catalog.ts adds QRD readiness rollout. This is the genuine asset. Docked one point because it is advisory knowledge with no authoring persistence and is reachable only through chat.
			Regula ted multilin gual label translat ion with enforc ed linguist ic QA and back-translat ion	hi g h 3 ▼ Kalli k Vera citi (Cas cade multil angu age inser ts) 4	server/services/translation/hybrid-workflow.ts:28-44 — a pure state machine that makes it structurally impossible for a machine-translated segment to reach 'approved': requires method ∈ {human, mt_postedited}, an existing back-translation verified above threshold, and a NAMED human reviewer of record distinct from the post-editor. 11 QA checks across server/services/translation/qa/ (numeric: number/unit consistency, length sanity; structural: DNT preservation, placeholder/markup, untranslated, control characters; semantic: glossary adherence, back-translation divergence at a 0.5 overlap threshold). Seven terminology domains (oncology, clinical-safety-pv, cmc-quality-analytical, regulatory-ctd, biostatistics-design, pharmacology-pk-adme, immuno-inflammation-vaccines) plus translation memory. Nine REST endpoints live at server/routes/translation.routes.ts:596-1072, mounted at server/bootstrap/register-inline-routes.ts:402-403. Scored 3 not 5 because client/src/concept2cure/translation/ (Projects, SegmentWorkspace, GlossaryPanel, QaFindingsPanel) has ZERO importers — the engine has no user interface. Backend alone would score 5.
			Shippi ng AI a labelin g team can actual ly invoke in-produc t	hi g h 2 ▼ Esko Com ply / Glob alVis ion Verif y / Aris Glob al Nava X 4	server/services/ana/AnaToolDefinitions.ts:2150 registers LABELING_INTELLIGENCE_TOOLS — six tools from server/services/ana/labelingIntelligenceTools.ts (assess_plr_structure:38, assess_boxed_warning:91, design_rems:151, assess_pregnancy_lactation_labeling:216, structure_smpc:279, assess_otc_labeling:327) — plus generateSplXML and validateSplStructure (server/services/ana/AnaToolExecutor.ts:15864,15871), build_from_template (:6210) and review_label_currency (:12339). Genuinely wired server-side. But the UI that renders these — LabelingAuthoringPane and LabelCurrencyPanel — lives only in client/src/concept2cure/components/ana/Ana.tsx:1135, and Ana is exported from client/src/concept2cure/components/ana/index.ts:1 with no importer anywhere in the tree. The shipped chat surface (client/src/concept2cure/v2/surfaces/ConversationThread.ts x, 378 lines) contains zero labeling references. AI exists; the labeling-specific rendering of it does not ship.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Deterministic, rule-cited compliance gates (verdicts a labeling team can defend, not model output)	hi	4	Esko Comply	3	server/services/ana/labeling-authoring.ts:1-20 — the currency gate (evaluateLabelCurrency / review_label_currency) is explicitly documented and implemented as NEVER an AI guess; server/services/ana/AnaToolExecutor.ts:2359 hard-codes the orchestration note 'Currency verdict is deterministic — never inferred.' client/src/concept2cure/components/ana/LabelCurrencyPanel.tsx:1-13 renders findings verbatim with their regulatory basis. server/services/labeling/spl-generator.ts:86-131 returns typed error/warning issues with JSON paths rather than prose. server/services/translation/hybrid-workflow.ts:38-44 rejects illegal transitions with a typed WorkflowTransitionError. This is the one dimension where the design is genuinely better than the field: competitors' AI checks (Esko Comply, GlobalVision OCR) are probabilistic and their gates are workflow-state, not rule-cited. Docked one point solely because the verdicts are unreachable — the shipped UI.
Device labeling specifics — UDI/G UDID, ISO 15223-1 symbol governance, IFU translation coverage	me	3	Kallik Vera	5	server/routes/mdx-labeling.ts:303-360 — live symbol CRUD (labeling_symbols) and a translation-coverage endpoint, backed by migrations/20260511_qms_and_labeling.sql:163. server/services/ivd-knowledge/regulatory/labeling-rules.ts:51-54 encodes UDI DI/PI structure, plain-text plus AIDC placement, and GUDID submission obligations under 21 CFR 830 / 801 subpart B with GS1/HIBCC/ICCBBA issuing agencies. server/services/market-specs/device-labeling.ts adds market specs. Real and working — but there is no GUDID submission path, no symbol image library, and no EU MDR Annex I labeling checklist enforcement, and the surface that renders it is ÆK-only.

Where we stand

Where we win

- Deterministic, citable compliance gating. The label-currency verdict is a rule-derived finding set with regulatory basis attached, not model output (server/services/ana/labeling-authoring.ts:1-20; AnaToolExecutor.ts:2359 'Currency verdict is deterministic — never inferred'). Every competitor's AI check in this category is probabilistic. In a Part 11 world a defensible verdict beats a confident one, and no incumbent has architected for that distinction.
- Regulated translation guardrails as a state machine rather than a policy document. server/services/translation/hybrid-workflow.ts:28-44 makes it structurally impossible for machine translation to reach 'approved' — it requires an approvable method, a back-translation verified above threshold, and a named human reviewer of record who is distinct from the post-editor. Kallik generates multilanguage inserts; Freyr tracks translations; none of them enforce translator provenance as a type-level invariant. This is genuinely novel work.
- Depth of USPI/SmPC structural intelligence per dollar of engineering. 2,418 lines of labeling knowledge (server/services/labeling/labeling-intelligence-knowledge.ts) covering PLR Highlights/FPI descriptors, SPL LOINC codes, boxed-warning categories, REMS models and ETASU elements, PLLR former-category mappings, SmPC structure, FDA-vs-EMA differences and OTC Drug Facts — plus a bidirectional USPI ↔ SmPC section cross-map (labeling-structure.ts:35-95). Competitors sell this as consulting; here it is executable and unit-tested.
- Linguistic QA breadth. 11 automated checks spanning numeric consistency, unit consistency, length sanity, DNT preservation, placeholder/markup integrity, untranslated detection, control characters, glossary adherence and back-translation divergence, across seven regulatory terminology domains. No competitor in this set ships comparable content-level translation QA — they treat translation as a workflow state.

Where we reach parity

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					- Device labeling data model. Live symbol CRUD, translation records with method and back-translation-verified flags, and coverage rollup (server/routes/mdx-labeling.ts:303-360) are functionally comparable to what a mid-tier LAM tool exposes — reachable, org-scoped, with real writes. Kallik is deeper; most others are not. - SPL structural validation as a linting function. server/services/labeling/spl-generator.ts:86-131 returns typed errors and warnings with JSON paths for LOINC format, set-id GUID, integer version, organization and per-section code/title/text. That is a real, honest validator — it is simply validating a document that is not yet submittable. - UDI/GUDID regulatory knowledge. server/services/ivd-knowledge/regulatory/labeling-rules.ts:51-54 correctly encodes DI/PI structure, plain-text plus AIDC placement and issuing-agency requirements. Knowledge parity with the field; execution (actual GUDID submission) is absent.

Where we lose

- Artwork management — score 0 against a category whose name contains the word. Zero implementation. Loftware, Esko and Kallik each have 15-25 years of prepress, DAM and print-release engineering here. This is not closable by building.
- Automated proofreading — score 0. Schlafender Hase TVT compares Unicode character-by-character and is deployed at 9 of the top 10 global pharma; it even diffs FDA SPL and EMA PIM XML natively. The nearest thing here is a substring-presence check on section headers.
- FDA-submittable SPL — score 1. The generator produces a narrative-only skeleton with no product data elements and XML-escaped section text, which forecloses SPL's XHTML subset entirely. Freyr transmits SPL to FDA and Health Canada as a product. This artifact would not clear schematron.
- Part 11 e-signed approval act — score 1. No labeling route touches e-signature or audit. Loftware sells eSignature on artwork approvals specifically for Part 11. Without a signed approval act there is no GxP labeling deal at any price.
- Validation/CSV deliverables — score 0. Loftware productizes this as a Validation Acceleration Pack; Esko sells IQ/OQ/PQ verification. Nothing here. This alone disqualifies from shortlist at every regulated buyer.
- CCDS and core-to-local change propagation — score 1. The impact-simulation and change-tracking code exists (server/api/labeling/routes.ts:225-412) and is never mounted. There is no CCDS object model at all.
- Reachability — score 1, and it multiplies everything else. RAIL_PRIMARY has five destinations and labeling is not among them (registryModel.ts:116, :164). The 14-file labeling shell, the entire translation workspace UI, and the Ana pane that renders the labeling authoring and currency gates all have zero importers. A buyer's technical evaluator will find this in an afternoon, and it converts every 'we built that' claim into a demo risk.

Is the advantage durable?

There is exactly one durable advantage and it is narrower than it looks. The regulated-translation guardrail design — machine translation structurally barred from 'approved', back-translation verified above threshold, named human reviewer of record distinct from the post-editor, enforced as a pure state machine rather than a workflow configuration (server/services/translation/hybrid-workflow.ts:28-44) — is a real architectural insight that no competitor in this set has made. Kallik generates multilanguage inserts, Freyr tracks translation status, Veeva stores translated documents; none of them enforce translator provenance as a type-level invariant that cannot be configured away. Combined with 11 content-level QA checks and seven regulatory terminology domains, that is roughly 12-18 months of lead on the linguistic-QA dimension specifically, and it is defensible because it requires a regulatory insight, not just engineering. Nothing else here is durable. The USPI/SmPC structural knowledge is impressive engineering but it encodes public regulation — 21 CFR 201.56/201.57 and the EMA QRD template are freely available, and any competent team plus a current LLM can reproduce the section model and cross-map in 4-8 weeks. ArisGlobal already ships it. The deterministic-gate philosophy is a design choice an incumbent can adopt in one release cycle once a customer asks for it. The SPL generator is a weekend of work behind Freyr, not a moat. And the clock is running fast: Veeva's RIM AI Agents land August 2026 with labeling paragraph analysis and missing-content detection explicitly in scope; Esko shipped Comply and AI proofing into WebCenter in April 2026; GlobalVision shipped AI OCR; ArisGlobal's NavaX is processing 700K cases a year scaling to 2.5M by mid-2026. Every incumbent is closing the intelligence gap in this exact category right now, and they are closing it from a position that already has artwork, Part 11 signatures and a validation package. The decisive point for a buyer: a moat behind a door nobody can open is worth zero at closing. The translation engine's 12-18 month lead only starts counting from the day it has a user interface — and today it has none (client/src/concept2cure/translation/ has zero importers). If that UI ships within one quarter, the lead is real and monetizable as a layer product. If it does not, the lead expires unexercised, because the incumbents will have shipped adequate translation QA into products that already win every other row on the RFP. Value the asset accordingly: this is a component acquisition priced on the translation engine and the labeling knowledge base, not a platform acquisition priced on category position.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
-----------	--------	----	--------------------	----------------	--------------

Shortest credible path to parity

1. Week 1 — open the front door. Remove 'labeling' from NAV_HIDDEN (client/src/concept2cure/v2/registryModel.ts:164) and either add it to RAIL_PRIMARY (:116) or expose a surface launcher, since the current Apps surface is a module-subscription toggle catalog (client/src/concept2cure/v2/surfaces/AdminSurfaces.tsx:1104-1120), not a launcher. Add registry entries for 'labeling-pi' and 'labeling-smpc' in shared/constants/ui-surface-registry.ts — they exist in surfaceViews (101 entries) but not in UI_SURFACES (49 entries), so they are invisible to $\mathbb{K}$ and reachable only by hand-typed URL. Cost: ~2 days. This does not add capability; it stops the demo from failing.
2. Week 1-2 — mount the code that already exists. Add app.use('/api/labeling', authMiddleware, ...) for server/api/labeling/routes.ts in server/bootstrap/register-inline-routes.ts, verify the labeling.* schema installs (db/migrations/070_gcc_rls_extended_ga.sql:175 already carries RLS policies for labeling.spl_documents), and confirm the labeling.calculate_impact_score and labeling.compare_documents functions exist. This recovers change tracking, impact scoring and version diff for roughly two days of work — the single cheapest capability gain available.
3. Month 1-2 — ship the translation workspace. Register client/src/concept2cure/translation/surfaces (Projects, SegmentWorkspace, GlossaryPanel, QaFindingsPanel) into surfaceViews.ts and UI_SURFACES, bound to the nine already-mounted endpoints at /api/translation. This is the highest-ROI move in the entire category: the backend is genuinely differentiated, no competitor has an equivalent, and the UI is already written. Estimated 3-6 weeks including QA-finding rendering and reviewer-assignment flows.
4. Month 2-3 — wire Part 11 into every labeling state transition. Connect server/routes/esignature.ts and server/services/part11/ to every status change in server/routes/mdx-labeling.ts, server/routes/labeling-smpc.routes.ts and the newly-mounted /api/labeling change endpoints, and add a write path to labeling-pi (currently GET-only, server/routes/labeling-pi.routes.ts:29). The infrastructure exists; this is integration, not invention. Non-negotiable — no regulated labeling deal closes without a signed approval act.
5. Month 3-6 — produce the validation package. IQ/OQ/PQ protocols, requirements traceability matrix, and a vendor audit pack for the labeling and translation modules. This is documentation-and-process work, not engineering, and it can run in parallel with the above. Until it exists the product cannot be shortlisted, regardless of capability.
6. Month 4-9 — complete SPL or stop claiming it. Real parity requires with ingredient/strength/NDC package codes, marketing category and application number, DEA schedule, labeler and establishment registration with DUNS, , the full LOINC section set rather than the 5 hardcoded in spl-generation-service.ts:16-22, XHTML-subset section content (which means removing the blanket xmlEscape at spl-generator.ts:69-76 and building a proper content model), and a schematron pass plus ESG transmission. Estimate 4-6 engineer-months minimum. The alternative — and the better commercial answer — is to OEM SPL publishing from Freyr or Reed Tech and integrate, which converts a 6-month build into a 6-week integration.
7. Do not build artwork. Partner or OEM. Esko WebCenter and GlobalVision Verify both expose integration surfaces and already integrate with each other (<https://www.globalvision.co/blog/the-verify-x-esko-webcenter-integration-automates-proofreading-for-packaging-artwork>). Building DAM, prepress, proofing and print-ready release from zero is a 2-3 year program at 20+ engineers against incumbents with two decades of head start. An API partnership closes the RFP row in one quarter; a build never catches up.
8. Reposition while the above lands. The honest, winnable pitch today is not 'labeling platform' — it is 'labeling intelligence and regulated translation QA layer that sits on top of your Veeva/Loftware/Kallik stack.' That framing turns the artwork and SPL gaps from disqualifiers into scope boundaries, and it is the framing under which the translation engine and the PLR/QRD knowledge base are genuinely best-in-class.

Verdict

● **Not competitive** — This category has six must-have rows on every RFP: (1) a reachable end-to-end labeling workflow, (2) FDA-submittable SPL, (3) packaging artwork lifecycle, (4) automated proofreading against source, (5) Part 11 e-signed approval with audit trail, (6) an IQ/OQ/PQ validation package. As of HEAD the platform scores 0-1 on five of the six. Artwork management — literally half the category name — has zero code: grep for artwork/proofing/dieline/prepress/Pantone across server/, client/src/ and shared/ returns nothing labeling-related. There is no IQ/OQ/PQ package, no traceability matrix, no vendor audit pack anywhere in the repo. No labeling route touches the e-signature or Part 11 services that DO exist elsewhere (server/routes/esignature.ts, server/services/part11/) — server/routes/labeling-pi.routes.ts is a single read-only GET. The SPL generator emits narrative sections wrapped in a bare HL7 v3 envelope with no , no ingredient/NDC/marketing-category/establishment data elements, and XML-escapes section text so SPL's required XHTML subset (, ,) is structurally impossible; the higher-level service hardcodes 5 LOINC section codes. That artifact will not clear FDA schematron, let alone the ESG. And the reachability finding holds and is decisive:

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					RAIL_PRIMARY (client/src/concept2cure/v2/registryModel.ts:116) has exactly five destinations — Chats, Projects, Communication Center, Apps, Settings — and 'labeling' and 'labeling-pi' are both explicitly demoted into NAV_HIDDEN (lines 164, 169). The 14-file labeling domain shell at client/src/concept2cure/labeling/ has no importer anywhere in the tree. The entire translation workspace UI at client/src/concept2cure/translation/ has no importer. The Ana chat component that renders LabelingAuthoringPane and LabelCurrencyPanel is exported from components/ana/index.ts:1 and imported by nobody. Two genuine assets survive that scrutiny — the USPI/SmPC structural intelligence (a 2,418-line knowledge base plus deterministic PLR/QRD section guards and US-EU cross-mapping) and a genuinely best-in-class regulated translation engine whose state machine makes it structurally impossible for machine translation to reach 'approved' without a verified back-translation and a named human reviewer distinct from the post-editor. Neither is a product. One is reachable only by typing into a command palette; the other is reachable not at all. In a head-to-head against Kallik, Veeva, Loftware, ArisGlobal, Freyr or Esko, this loses every must-have row. It is an acqui-tech component — specifically a labeling-intelligence and translation-QA engine worth bolting onto a platform that already owns the workflow — not a competitor in this category.

Medical device & IVD regulatory (510(k), De Novo, PMA) and ...

Verdict: ● **Not competitive** Weighted capability score — **us 2.1 / 5** vs **best competitor 4.2 / 5** across 14 dimensions.

Full category as scoped: Medical device & IVD regulatory (510(k), De Novo, PMA) and device QMS

Who buys, and what they are actually buying

Two budget holders, usually buying together in medtech/IVD companies of 50–2,000 people. (1) VP/Director of Regulatory Affairs owns the submission budget and buys one outcome: a submittable, defensible FDA package — an official eSTAR for 510(k)/De Novo, a PMA module set, an EU MDR/IVDR technical file — produced faster and with fewer AI/Not-Substantially-Equivalent and Additional Information (AI/NSE) letters. Their proof point is a clearance, not a feature list. (2) VP/Director of Quality (RA/QA combined below ~300 headcount) owns the QMS budget and buys audit survivability under 21 CFR 820 QMSR (effective 2026-02-02, incorporating ISO 13485:2016 by reference — <https://www.fda.gov/medical-devices/postmarket-requirements-devices/quality-management-system-regulation-qmsr>) and notified-body surveillance. Their non-negotiable is a vendor validation package they can hand an FDA investigator, plus Part 11 audit trail and e-signature. In practice one of these two signs and the other holds veto. Deals die on three questions: "does it produce the actual eSTAR", "is it validated out of the box", and "can my RA associate find it without training". Typical deal size \$25K–\$60K/yr mid-market, \$150K–\$1M+ enterprise.

Market structure

Structure. The category is not one market, it is three adjacent budgets that buyers assemble: (a) device eQMS — Greenlight Guru at the emerging/mid tier, MasterControl and Veeva QualityOne at enterprise; (b) medtech RIM — Rimsys effectively uncontested, Veeva RIM at the very top; (c) engineering-side compliance/ALM — Ketryx, Matrix Requirements, Jama. Almost no company buys one vendor for all three. That is the strategic opening this product was designed for and the reason its unified backend has real acquisition value even though it does not currently ship as a product.

Regulatory forcing functions in play right now, both of which reprice the category. QMSR took effect 2026-02-02, amending 21 CFR 820 to incorporate ISO 13485:2016 by reference, and FDA retired QSIT in favor of the updated Inspection of Medical Device Manufacturers Compliance Program 7382.850 on the same date (<https://www.fda.gov/medical-devices/postmarket-requirements-devices/quality-management-system-regulation-qmsr>). Every device company is re-examining its QMS in 2026 — an unusually large number of evaluations are open. Separately, electronic submission via eSTAR is mandatory for Traditional, Special and Abbreviated 510(k)s; paper/PDF compilation is no longer accepted (<https://www.fda.gov/medical-devices/how-study-and-market-your-device/estar-program>). A widely repeated secondary claim is that eSTAR 7.0 becomes the only accepted template for new applications from 2026-08-03 (<https://crux.ai/pages/subpages/regulatory/510k/resources/fda-estar-templates.html>) — five days after this analysis; that specific date and version were NOT verified against an FDA primary source and should be confirmed in diligence. Either way, eSTAR output is a gating requirement, not a nice-to-have.

Deal size and procurement pattern. Mid-market device eQMS clusters at \$25K–\$60K/yr: Greenlight Guru's median observed contract is \$43,989/yr with a \$20,975–\$54,739 range and \$2K–\$5K mandatory onboarding (<https://checkthat.ai/brands/greenlight-guru/pricing>). MasterControl entry is cited near \$25K/yr scaling past \$100K/yr (<https://checkthat.ai/brands/mastercontrol>). Rimsys, Ketryx and Veeva are all quote-only; Veeva and Rimsys are enterprise-weighted. Sales cycles run 3–9 months mid-market and 9–18 months enterprise, and the technical evaluation is dominated by two artifacts, not features: the vendor validation package and a live demo producing a real submission output. Services-attached AI-native entrants are compressing the floor — Pure Global launched flat-fee full-service market access starting at USD \$2,000 per market in February 2026, citing >50% reduction in dossier compilation time from in-house AI tooling (<https://www.pureglobal.com/> , <https://www.pureglobal.ai/>).

Consolidation. Rimsys' KPMG partnership (March 2025) and its Spring 2026 move into embedded submission authoring signal RIM expanding into authoring; Veeva's production Accumulus connectivity signals the submission-transmission layer commoditizing at the top. Greenlight Guru's January 2026 package-separation repricing (reported up to +100% with no new features —

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					https://openregulatory.com/articles/greenlight-guru-price) is generating churn evaluations in the exact mid-market segment a challenger would target. Capital is flowing to AI-native compliance: Ketryx's \$39M Series B (September 2025, >\$55M total) is the reference round (https://www.rdworlonline.com/ketryx-raises-39-million-in-series-b-funding-to-expand-ai-compliance-tools-for-life-sciences/). The window for an AI-native entrant to take mid-market share is open but closing as Greenlight Guru AI reaches GA in Q2 2026 and Veeva's regulatory agents land in August 2026.

The five closest competitors

Greenlight Guru — Greenlight Guru Quality (eQMS), Product Development, Software Development, Quality Events; Greenlight Guru AI

The default medical-device-only eQMS for the emerging-to-mid-market. Positions as 'the #1 QMS for medical devices' — purpose-built for 21 CFR 820/QMSR and ISO 13485 rather than a horizontal QMS configured for devices. Wins the RA/QA-combined buyer who wants design controls, risk, and QMS in one validated system and does not want to run a validation project.

Strengths

- Validated-out-of-the-box IQ/OQ/PQ package with per-release revalidation — removes a 6–12 week customer validation project
- Device-only data model: design controls, DHF traceability, ISO 14971 risk, CAPA, complaints, supplier, training in one system under QMSR
- Enormous mid-market install base and auditor familiarity; notified bodies and FDA investigators have seen the system before
- Published QMSR transition resources and a product already mapped to ISO 13485:2016 clause structure
- Fast time-to-value: an RA associate can find and use every module from the primary navigation on day one

Weaknesses

- Weak global RIM: no serious multi-country registration lifecycle, no Universal UDI framework, no EUDAMED M2M — companies selling in 30+ markets buy Rimsys alongside it
- AI is GA-targeted Q2 2026 and beta-gated; no validated AI agents, no predicate/substantial-equivalence reasoning engine
- No IVD-specific analytical performance engine (no IVDR Annex VIII rule engine, no cutoff/hook-effect/carryover/recovery calculators)
- Aggressive Jan-2026 repricing is creating active churn evaluations in the installed base — a real wedge for a challenger
- Not verified that it emits a filled official FDA eSTAR PDF; it manages the content that goes into one

AI shipped today	Greenlight Guru AI is targeted for GA in Q2 2026 with beta customers getting early access; it is grounded on the customer's own QMS records and traceability rather than a general corpus. Shipped/beta capabilities described: generate device-specific design-control and risk starters, chat over QMS data, and search across the QMS with linked source references. As of mid-2026 this is the newest and least-proven part of their stack — treat AI as a tie-breaker, not a differentiator, in a 2026 bake-off.
GxP / validation posture	Strongest in the set for the mid-market. Ships validated out of the box with a 21 CFR Part 11-compliant IQ protocol plus completed OQ and PQ reports, and re-validates each release — so the customer inherits the validation rather than executing it. This is the single most common reason a 200-person device company picks them over a cheaper tool.
Pricing signal	Not listed publicly; sales-quoted. Third-party aggregation puts the median contract at \$43,989/yr with observed deals from \$20,975 to \$54,739/yr, and \$25K–\$35K/yr for small teams rising to \$50K–\$60K+/yr with multiple modules. A January 2026 'package separation' restructuring is reported to raise prices materially (up to ~+100%) without added features. Budget \$2,000–\$5,000 one-time mandatory onboarding.

► Sources

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					Rimsys — Rimsys MedTech RIM platform — Registrations, Submissions, Standards, Essential Principles, UDI (Universal UDI), Rimsys Intelligence, Rimsys Connect; Spring 2026 'Regulatory Execution Engine' release The category-defining Regulatory Information Management system built only for medtech — the system of record for 'what am I registered to sell, where, and what expires when'. Sells to enterprise RA operations leaders, not to quality. Explicitly complements rather than replaces an eQMS, which is why it co-exists with Greenlight Guru and MasterControl in the same account. Strengths - Only true medtech RIM at scale: registrations, submissions, standards, essential principles and UDI in one model across 100+ markets - Universal UDI framework with bulk UDI submission and EUDAMED / M2M transmission compliance — a hard, expensive problem nobody else solves well - Regulatory intelligence across 90+ countries with AI triage scoped to the customer's actual product/market matrix - Enterprise credibility: trusted by 6 of the top 12 global MedTech manufacturers; KPMG partnership (March 2025) for transformation pull-through - Spring 2026 added embedded submission authoring with reusable content — moving upstream into the authoring territory this product occupies Weaknesses - Not a QMS: no design controls, no DHF, no CAPA/complaints/NC, no training or supplier management — the quality buyer's veto is unaddressed - No predicate/substantial-equivalence intelligence and no US 510(k)-specific reasoning; it manages the submission record, it does not argue SE - No IVD analytical-performance or IVDR Annex VIII classification engine - Enterprise sales motion and price point make it inaccessible to the 50–300 person device company that is the volume of the market - Public validation posture unverified — a gap for a QMSR-era quality buyer
AI shipped today					Spring 2026 release embeds submission authoring, reusable submission content, and configurable impact workflows in the RIM platform, plus Rimsys Intelligence — regulations, guidance documents, safety alerts and legislation across 90+ countries with AI triage and prioritization scoped to each customer's products and markets. Described by the company as the first step toward its AI vision, i.e. AI-assisted regulatory monitoring and authoring shipping now, agentic execution still ahead.
GxP / validation posture					Not verified. No public IQ/OQ/PQ package, validation-package SKU, or Part 11 attestation was found in the sources reviewed. Enterprise customers of this size typically run their own CSV/CSA against the vendor's qualification evidence; absence of a public package is not evidence of absence.
Pricing signal					Not public. Five pricing editions, subscription-based, scaled by modules/users/scope; quote-only via vendor. Enterprise-weighted given the customer profile (6 of the top 12 global medtech manufacturers), so expect six-figure annual contracts at that tier — the specific figures are not verified.

► Sources

Ketryx — Ketryx FDA Software Compliance Platform / ALM — IEC 62304, ISO 13485, ISO 14971, 21 CFR 820 & Part 11; Ketryx AI Agents (Change Impact, Requirements, Traceability, Complaint)

The AI-native challenger, and the closest philosophical competitor to this product. Overlays existing engineering tools (Jira, GitHub, etc.) rather than replacing them, and continuously generates the DHF/technical file as a by-product of development. Sells to VP Engineering and Head of SaMD/Software Quality first, then pulls in RA — a different entry point that bypasses the incumbent eQMS incumbency.

- Strengths**
- Validated AI agents shipped and referenced — the single hardest claim to make in this category and the one that neutralizes the 'AI is not auditable' objection
 - Continuous DHF/technical-file generation from live engineering artifacts — no separate documentation project

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					4 of the top 5 Fortune 500 medtech companies on the platform; products reaching >100M patients — reference power that beats any feature demo - Strongest SaMD/AI-ML device fit: IEC 62304, SBOM, AI/ML model compliance — exactly where 510(k) volume is growing - Well capitalized (\$55M+) and moving fast; published eSTAR-program workflow content tying its output to the 510(k) submission Weaknesses - Not a full eQMS: thin on non-software quality processes (supplier, training-at-scale, management review, manufacturing NC) — a hardware-heavy device company still needs a second system - No global registration/UDI lifecycle — loses to Rimsys on 'where can I sell' - No IVD analytical-performance or IVDR Annex VIII depth - No predicate/substantial-equivalence intelligence engine - Engineering-led entry point means longer path to the RA budget holder in RA-dominant organizations
AI shipped today					The strongest verifiable AI posture in the set: launched what it describes as the industry's first validated AI Agents for regulated industries — Change Impact, Requirements, Traceability and Complaint agents — operating in a validated, human-in-the-loop framework aligned to IEC 62304, ISO 13485, ISO 14971 and 21 CFR Part 11, claimed to cut manual compliance work ~90%. This is shipped and customer-referenced, not roadmap.
GxP / validation posture					Differentiated: markets the AI agents themselves as validated, which is the specific objection every regulated buyer raises about LLM features. Compliance framework spans IEC 62304, ISO 13485, ISO 14971, 21 CFR 820/11 and GMP. The exact contents of the customer-facing validation package (executed IQ/OQ/PQ vs. qualification evidence) are not verified from public sources.
Pricing signal					Not public. Funding is the proxy: \$39M Series B led by Transformation Capital (September 2025), >\$55M total. Customer mix (4 of top 5 Fortune 500 medtech, HeartFlow, Flo Health, Meta Reality Labs, DeepHealth, Beacon Biosignals, Aignostics) implies enterprise six-figure ACVs at the top with a land-and-expand engineering-team entry below.

► Sources

Veeva MedTech (Vault RIM / RegulatoryOne / QualityOne) — Veeva Vault RIM and RegulatoryOne for registrations, submissions, publishing and archival; Vault QualityOne/QMS; Vault 26R1; Veeva Falcon AI platform and Regulatory/Medical AI Agents

The enterprise platform play: one Vault for regulatory, quality, clinical and medical, sold on consolidation rather than best-of-breed. Wins when the acquirer is a large diversified manufacturer already standardized on Veeva for pharma and wants medtech on the same backbone. Rarely competes below ~\$500M revenue.

Strengths

- Single-vendor consolidation across RIM, quality, clinical and medical — the CIO's preferred answer
- Production Accumulus connectivity for multi-authority packaging/routing without republishing — genuinely ahead on submission transmission
- Enterprise GxP credibility and auditor familiarity at the largest manufacturers
- Falcon AI agents built on frontier models inside the Vault security/compliance boundary — solves the data-residency objection
- Deep pockets and release cadence (26R1 April 2026) that will close feature gaps mechanically

Weaknesses

- Regulatory/Medical AI Agents slated for August 2026 — not shippable evidence in a mid-2026 evaluation
- Heavy, slow and expensive to implement; effectively unavailable to the 50–500 person device company where 510(k) volume lives
- Device-specific depth (predicate/SE argumentation, IVDR Annex VIII, analytical performance) is thin relative to its RIM/QMS breadth

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					- Configuration-heavy: 'medtech' is largely a configuration of a pharma-shaped platform - Pricing and SI dependency make it a poor comparator for an emerging-growth acquirer's ICP
AI ship ped tod ay					Falcon AI platform with agentic authoring announced at the 2026 Summit. Clinical, Regulatory and Medical AI Agents are slated for August 2026 — i.e. arriving, not yet proven in the field as of this analysis. Expected regulatory capabilities: document auto-tagging, regulatory-intelligence extraction, predictive submission-timeline insight, labeling paragraph analysis, missing-content detection, and drafting health-authority question responses, running on Anthropic and Amazon models via Bedrock inside the Vault boundary. Vault RIM ↔ Accumulus connectivity went to production in 2026, enabling packaging and routing to participating authorities (FDA, Health Canada, Swissmedic, Saudi FDA pilot) without republishing — the most concrete multi-agency 'push-button filing' in the market.
Gx P / vali dati on pos ture					Mature enterprise GxP posture: Vault is deployed as the regulated system of record across pharma and medtech with established qualification documentation and per-release validation support, and Part 11 controls are table stakes in the platform. Specific medtech validation-package contents were not verified from public sources.
Pric ing sign al					Not public. Enterprise subscription; Veeva reported 1,552 total customers in FY2026 (ended January 2026), 1,196 in R&D/Quality. Deals in this category are consistently six to seven figures annually with multi-quarter implementations and a systems integrator attached.

► Sources

MasterControl — MasterControl Quality Excellence (document management, CAPA, training, change control, complaints, audit management); Validation Excellence Tool and patented Validation on Demand

The 30-year enterprise document-centric compliance incumbent. Sells audit survivability and process control to Quality, and shows up in every device QMS shortlist above ~300 employees. Competes on completeness and inspection history, not on speed or user experience.

Strengths

- Broadest connected eQMS process coverage: document control, CAPA, complaints, change control, training, audit — all cross-linked
- Validation on Demand materially collapses customer validation cost and time, and it is patented
- 1,000+ customers across pharma, biotech and device; deep FDA inspection track record and auditor familiarity
- QMSR-ready positioning with published guidance as 21 CFR 820 moved to ISO 13485 incorporation in February 2026
- Enterprise procurement, security and support posture already cleared at most large manufacturers

Weaknesses

- Not a submissions platform: no 510(k)/De Novo/PMA authoring, no predicate/SE intelligence, no eSTAR production
- No global registration/UDI RIM — needs Rimsys or Veeva alongside
- Widely characterized as complex and heavy for smaller, faster device teams; usability is its recurring loss reason
- AI posture is incremental document/workflow assistance, not validated agents
- Document-centric architecture makes structured device data (DHF traceability, risk matrices, IVD performance) a bolt-on rather than native

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE	
					AI shipped today	Life-sciences-specialized AI applied to routine work — automated workflow routing and intelligent document summarization — explicitly framed as efficiency under human oversight rather than autonomous agents. Materially less ambitious than Ketryx and less specific than Veeva's agent roadmap; do not expect AI to be the reason a buyer picks MasterControl in 2026.
					GxP / validation postulate	A genuine commercial strength: patented Validation on Demand automates validation against the customer's configured workflows at the click of a button, with the Validation Excellence Tool supporting CSA-style approaches; the company cites medical device customers reaching a validated state in under 45 minutes on average, with built-in templates for 21 CFR Part 11, ISO 13485 and international standards. This directly attacks the largest hidden cost of a QMS purchase.
					Pricing signal	Not listed publicly. Third-party aggregation puts entry around ~\$25K/yr scaling quickly to \$100K+/yr; enterprise deployments run well above that with services attached.
► Sources						

Capability rubric

Our score is cited to `file:line` in this repository. Theirs is cited in the competitor sections above. Scored on what **ships and is reachable**, not what is architected — an unreachable or unvalidated capability scores low regardless of code quality.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Produces the official FDA eSTAR PDF (submittable 510(k)/De Novo output)	critical	1 ▼	Ketryx	3	server/services/pathway-engines/estar/estar-field-map.ts:33-38 (all four descriptor maps empty); server/routes/510k-estar-routes.ts:228 (officialEstarPdf: false); assets/estar-templates/ contains only README.md; POST /official returns 422 ESTAR_NOT_PRODUCIBLE
Reachable device/IVD workspace — can an RA associate find and use it unaided	critical	1 ▼	Greenlight Guru	5	client/src/concept2cure/v2/registryModel.ts:116-123 (RAIL_PRIMARY = 5 non-device destinations); registryModel.ts:139-141,164-168 (device-510k, device-cer, device-diagnostics, design-controls, human-factors, quality, risk in NAV_HIDDEN); registryModel.ts:446-500 (SEGMENT_MODULES referenced only by its own test)
eQMS process breadth under QMSR/ISO 13485 — doc control, CAPA, complaints, NC, training, supplier, audit, management review	critical	1 ▼	Master Control	5	server/routes/qms.ts:66-222 (17 endpoints over server/services/qms/qms.service.ts, 275 lines) with zero client references to /api/qms; client/src/concept2cure/v2/surfaces/QualityModule.tsx (20-line adapter, SOP register + change control only)
Vendor validation package — executed IQ/OQ/PQ, per-release revalidation, auditor-ready evidence	critical	1 ▼	Greenlight Guru	5	docs/validation/VSR-CORTEX-001-VALIDATION_SUMMARY_REPORT.md:9,17 (1.0.0-DRAFT, 2025-01-24, approver PENDING, 'REQUIRES VALIDATION REVIEW BEFORE PRODUCTION USE'); all 10 documents in docs/validation/ are DRAFT and describe a differently-named 'Cortex Prime AI System'
Asset completeness and transferability — does the acquired repo contain the demonstrated capability	critical	1 ▼	Veeva MedTech	5	server/routes/predicate-intelligence.ts:62,248 (proxy to SHADOW_SERVICE_URL, 502 on absence); shadow_service/ contains 2 files and fails to import (ModuleNotFoundError: shadow_service.shadow_service.models_predicate, verified by execution); server/routes/se-matrix.ts:29 and server/routes/docx-factory.ts:34 same dependency
Part 11 audit trail and electronic signature integrity	critical	4 ▼	Master Control	5	server/routes/audit-trail-ledger.routes.ts:4-21 (per-org SHA-256 hash chain, record_hash/previous_hash/sequence_number via BEFORE INSERT trigger, untruncated hashes); db/migrations/20260222_audit_events_hash_chain.sql; server/services/audit/tests/chain.test.ts and chainIntegrityMonitor.test.ts
Predicate device selection and substantial-equivalence argumentation	critical	2	Rimsys	2	Real: server/routes/fda510k-routes.ts:1022,1167 (live openFDA 510(k) search) — but zero client callers. Shipping path: client/src/concept2cure/mdx/hooks/useK510.ts:13,22 ('degrade to fixture on 502', 'falls back to fixtures') against server/routes/predicate-intelligence.ts:248
Design controls, DHF and ISO 14971 risk file	critical	3 ▼	Greenlight	5	server/routes/design-risk.ts:78-302 (20 endpoints: inputs, outputs, verifications, validations, reviews, changes, design plan, DHF assessment, RMF + risk items + controls +

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
with end-to-end traceability			Guru		summary) — but the shipping UI wires only the thin route at client/src/concept2cure/v2/surfaces/DesignControls.tsx:146 → server/routes/design-controls.routes.ts
IVD/IVDR-specific depth — Annex VIII classification, analytical performance, performance evaluation, CDx/CLIA	high	4 ▲	Veeva MedTech	2	server/routes/ivd-lifecycle.ts:156-452 (~30 calculators: stability, carryover, hook effect, recovery, cutoff, traceability, Monte Carlo accuracy, EVPI/EMV, drift, calibration backtest); server/services/regulatory/tests/ivdr-classification.test.ts (13 assertions pass, 7 Annex VIII rules + 10-row rule trace); ivd-platform.openapi.json (34 paths). Deduction: zero client references to /api/ivd-lifecycle
AI/ML device lifecycle — PCCP, 524B cybersecurity/SBOM, IEC 62304	high	3 ▼	Ketryx	4	server/services/ai-ml-pccp/pccp.service.ts:129,184 (approve/supersede lifecycle) + pccp-validator.service.ts:322 + server/routes/pccp.ts:81-254; server/services/regulatory/cybersecurity-524b.ts (SBOM scoring, tests pass). Deduction: 1 client reference each; client/src/concept2cure/v2/surfaces/DeviceSubmission.tsx:457 notes they 'stay flagged, not half-wired'
Post-market: complaints, MDR/vigilance reportability triage, MAUDE/recall surveillance	high	4	Master Control	4	server/services/capa-mdr/ (1,574 lines: triageEngine.ts, clockCalculator.ts, stateMachine.ts, capaMdr.service.ts) with deterministic 21 CFR 803 / EU MDR Art 87 / 21 CFR 806 classification per server/services/ana/capaMdrTools.ts:32-38; server/routes/capa-mdr.ts mounted at register-document-routes.ts:281; 8 client references; server/services/postmarket/openfda-surveillance.ts
Global registration lifecycle, UDI/EUDAMED and market-access RIM	high	1 ▼	Rimsys	5	server/routes/registrations-standards.ts:35 — one endpoint (GET /data-standards); server/routes/mdx-udi.ts exists but no multi-country registration lifecycle, no EUDAMED M2M, no bulk UDI submission
Shipped, grounded, governed AI (not roadmap) for device regulatory work	high	3 ▼	Ketryx	4	server/services/ana/AnaToolExecutor.ts:4036 (live openFDA tool call), server/services/ana/capaMdrTools.ts (5 tools), governed export consequence + e-signature on mutations at server/routes/510k-estar-routes.ts:214-231. Deduction: server/services/ana/predicateIntelligenceTools.ts:10 — the 4 predicate tools call the absent shadow service
Human factors / IEC 62366-1 use-related risk analysis	medium	3 ▼	Greenlight Guru	4	server/routes/human-factors.ts:32-136 (4 endpoints) over server/services/regulatory/human-factors.ts (assessHfeCompleteness, analyzeUseRelatedRisk — 5 assertions pass); client/src/concept2cure/v2/surfaces/HumanFactors.tsx:159 persists real scenarios but falls back to sample at :185

Where we stand

Where we win

- IVD/IVDR technical depth no competitor in this set ships. `server/services/regulatory/ivdr-classification` is a real Annex VIII rule engine — seven classification rules, highest-applicable-class resolution, a complete 10-row rule trace on every call, and every knowledge reference resolving to a corpus entry; all 13 assertions pass (`server/services/regulatory/tests/ivdr-classification.test.ts`, verified by running `vitest`). `server/routes/ivdr-lifecycle.ts` exposes ~30 analytical-performance and decision calculators — real-time and accelerated stability, carryover, hook effect, recovery, cutoff determination, metrological traceability, scientific validity, Monte Carlo diagnostic accuracy, EVPI/EMV decision analysis, calibration backtest, drift detection (`server/routes/ivdr-lifecycle.ts:156-452`), documented in `ivd-platform.openapi.json` (34 paths). Rimsys, Greenlight Guru, Ketryx, Veeva and MasterControl have no equivalent — this is genuine, defensible IP.
- Deterministic post-market safety triage. `server/services/capa-mdr/` is 1,574 lines across a triage engine, an RFC-style clock calculator and a state machine, computing FDA MDR reportability under 21 CFR 803, EU MDR Article 87 vigilance, and 21 CFR 806 correction/removal triggers with jurisdiction, report type, severity, clock and rationale — explicitly deterministic, not LLM-generated (`server/services/ana/capaMdrTools.ts:32-38`). It is the one deep device backend that is actually wired to the UI (8 client references to `/api/capa-mdr`). Competitors provide complaint workflow; they do not compute the regulatory trigger.
- Part 11 audit integrity implemented at the database, not the application. The audit ledger is a per-organization SHA-256 hash chain (`record_hash` / `previous_hash` / `sequence_number`) populated by a BEFORE INSERT trigger with a backfill migration, serving full untruncated hashes so the chain the UI verifies is real and contiguous (`server/routes/audit-trail-ledger.routes.ts:4-21`, `db/migrations/20260222_audit_events_hash_chain.sql`). This is stronger tamper evidence than an application-layer audit log and is supported by a dedicated test suite (`chain.test.ts`, `chainIntegrityMonitor.test.ts`, `audit-integrity-pglite.integration.test.ts`, `auditChainIntegritySweep.test.ts`).
- AI/ML device lifecycle coverage that is early to a real 2026 requirement. A working PCCP module with plan/modification CRUD, a validator, and a full governed lifecycle including approve and supersede (`server/services/ai-ml-pccp/pccp.service.ts:129,184`; `server/routes/pccp.ts:81-254`), plus 524B cybersecurity SBOM completeness scoring and readiness assessment (`server/services/regulatory/cybersecurity-524b.ts`, tests passing). Only Ketryx is credibly in this space, and it approaches it from IEC 62304 rather than from the PCCP artifact itself.
- Honest fail-closed engineering — a real diligence asset. The eSTAR path refuses to fabricate a submittable artifact: the ZIP export self-labels `officialEstarPdf`: false with an inline comment explaining it is not the PDF CDRH ingests (`server/routes/510k-estar-routes.ts:221-228`), POST `/official` returns 422 `ESTAR_NOT_PRODUCIBLE` with named blockers, and GET `/readiness` exists purely so the UI can disable the button with a reason (`server/routes/510k-estar-routes.ts:468`). Tests assert the fail-closed behavior explicitly (`estar-fill.test.ts:67,80`). A buyer inheriting this codebase inherits an unusually low risk of discovering fabricated compliance claims post-close.

Where we reach parity

- Design controls and risk management data model. `server/routes/design-risk.ts:78-302` implements 20 endpoints covering the full 21 CFR 820.30 chain — design inputs, outputs, verifications, validations, reviews, changes, design plan, DHF assessment — plus an ISO 14971 Risk Management File with risk items, risk controls and an RMF summary. On data model this is at parity with Greenlight Guru. It is not at parity in the product, because the shipping UI wires only the thin `/api/design-controls` GET/POST design-inputs route, not this one (`client/src/concept2cure/v2/surfaces/DesignControls.tsx:146` vs `server/routes/design-controls.routes.ts`).
- Live FDA source data. Real openFDA integration against the 510(k) and PMA endpoints with `device_class` and `regulation_number` extraction, `accessdata.fda.gov` deep links, host throttling and caching (`server/routes/fda510k-routes.ts:264,1022,1167,1380,1474`; `server/services/integrations/host-throttle.ts:52`). Also openFDA post-market surveillance and device recalls (`server/services/postmarket/openfda-surveillance.ts`). Equal to or better than what competitors expose; undermined only by the fact that zero client code calls `/api/fda510k`.
- AI substrate. `AnaToolExecutor` is a genuine tool-calling agent with device-specific tool families for predicate intelligence and CAPA/MDR, governed export consequences, e-signature and audit wired into the mutation path. As raw capability this is at parity with Ketryx's agents and ahead of Greenlight Guru's Q2-2026 GA — but see the losses, because the device tools that matter most depend on a service that is not in this repository.

Where we lose

- The product has no front door. `RAIL_PRIMARY` contains exactly five destinations — Chats, Projects, Communication Center, Apps, Settings (`client/src/concept2cure/v2/registryModel.ts:116-123`) — and a test locks it at five

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					(client/src/concept2cure/v2/tests/registryModel.test.ts:35). Every device and IVD surface is demoted into NAV_HIDDEN: device-510k, device-cer, device-diagnostics, design-controls, human-factors, quality, risk (registryModel.ts:139-141,164-168). The comment calls them 'reachable via %K and deep-link', and they are, but SEGMENT_MODULES — the object literally documented as 'complete capability inventory on the segment home', listing every medtech and diagnostics module (registryModel.ts:446-500) — is referenced by nothing except its own unit test. A regulatory affairs associate opening this product sees a chat window and cannot find the 510(k) workbench. Greenlight Guru scores 5 here without trying. • Cannot produce an official FDA eSTAR. All four descriptor field maps are empty — '510k-device', '510k-ivd', 'de_novo-device', 'de_novo-ivd' (server/services/pathway-engines/estar/estar-field-map.ts:33-38) — and assets/estar-templates/ contains only a README, no vendored FDA template. POST /api/510k/estar/official therefore always returns 422 • ESTAR_NOT_PRODUCIBLE, and /build emits a ZIP of six section PDFs explicitly marked officialEstarPdf: false (510k-estar-routes.ts:228). eSTAR is mandatory for Traditional, Special and Abbreviated 510(k)s. This is a category-gating failure: the product cannot deliver the artifact the RA buyer is purchasing. • The flagship differentiator is not in the repository. Predicate intelligence, SE-matrix generation and the DOCX factory are 100% HTTP proxies to an out-of-repo Python service at SHADOW_SERVICE_URL (server/routes/predicate-intelligence.ts:62; server/routes/se-matrix.ts:29; server/routes/docx-factory.ts:34). Every one of the ~12 proxy routes returns 502 'Shadow service unavailable' when it is absent (predicate-intelligence.ts:248,264,275,286,308,325,341,352,368). The shadow_service/ directory in this repo holds two files, and shadow_service/scoring/risk_code_map.py fails to import — ModuleNotFoundError: No module named 'shadow_service.shadow_service.models.predicate' (verified by execution). The 510(k) UI hooks are written to expect this and 'degrade to fixture on 502' so the surface 'falls back to fixtures so nothing renders empty' (client/src/concept2cure/mdx/hooks/useK510.ts:13,22). Net effect: the predicate and SE panels a buyer sees in a demo are demo data, and the real openFDA integration that does exist at /api/fda510k has zero client callers. • No shippable eQMS. server/routes/qms.ts:66-222 exposes 17 endpoints — document control with state transitions, training and training-compliance, suppliers and supplier approval, internal audits, management reviews, nonconformances with disposition, and a compliance summary — over a 275-line service. Client references to /api/qms: zero. The 'quality' surface renders a 20-line adapter into a separate module whose tabs are SOP register and change control only (client/src/concept2cure/v2/surfaces/QualityModule.tsx). There is no CAPA UI, no complaint-handling UI, no NC UI. Against QMSR effective February 2026, the quality buyer's veto is absolute. • No vendor validation package. docs/validation/ contains ten documents — VMP, IQ, OQ, PQ, VSR, ISO 14971 risk analysis, Part 11 traceability matrix, cloud vendor qualification, security assessment — totalling 4,525 lines, and every one is version 1.0.0-DRAFT dated 2025-01-24 with approver PENDING and a banner reading 'DRAFT - REQUIRES VALIDATION REVIEW BEFORE PRODUCTION USE' (docs/validation/VSR-CORTEX-001-VALIDATION_SUMMARY_REPORT.md:9,17). They also describe a differently-named system, the 'Cortex Prime AI System'. Nothing is executed. Greenlight Guru ships a completed IQ/OQ/PQ and revalidates every release; MasterControl reaches a validated state in under 45 minutes via Validation on Demand. This alone loses mid-market deals. • No global registration or UDI lifecycle. server/routes/registrations-standards.ts contains a single endpoint, GET /data-standards. Rimsys manages registrations across 100+ markets with a Universal UDI framework, bulk UDI submission and EUDAMED M2M. Any customer selling outside the US and EU buys Rimsys regardless of what else they buy. • Asset transferability. For an acquirer this is the finding that changes the price, not just the score: the demonstrable IP includes a service whose source is not being conveyed, and the repo's own inventory documents are stale (FEATURE_INVENTORY.md names an app entry point that no longer exists). Reps and warranties must cover the shadow service explicitly.

Is the advantage durable?

No durable moat exists today, but one narrow, real moat is buildable and defensible for roughly 18–30 months.

What is not a moat. Every capability the platform currently shows a buyer is either absent from the repo (predicate intelligence, SE matrix), unreachable (IVD calculators, QMS, DHF/RMF), or commodity (openFDA queries — public API, any competitor can add it in a sprint). The AI substrate is good engineering, but Ketryx already ships validated AI agents, Veeva's regulatory agents land August 2026 on frontier models inside the Vault boundary, and Greenlight Guru AI reaches GA in Q2 2026 grounded on customer QMS data. The AI window is closed within two quarters.

What is a moat, and for how long. The IVD/IVDR analytical and classification depth is the only genuinely defensible position. It is not a UI feature; it is encoded domain knowledge — Annex VIII rule interactions with highest-applicable-class resolution and a full audit trace, plus roughly 30

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					analytical-performance and decision calculators (cutoff determination, hook effect, carryover, metrological traceability, Monte Carlo diagnostic accuracy, EVPI). Building that requires an IVD-experienced regulatory scientist working alongside engineers for 12–18 months; it is not a scraping or LLM problem, and it is not something a product manager can spec. None of the five competitors has it, and — critically — none of them is trying. Rimsys is expanding into submission authoring, not IVD science; Greenlight Guru is expanding into AI over its own QMS records; Ketryx is going deeper on IEC 62304 and SaMD; Veeva and MasterControl are horizontal platforms for whom IVD analytics is a rounding error. Their roadmaps point away from this. That is what makes 18–30 months a defensible estimate rather than a hopeful one. The deterministic MDR/vigilance triage engine (21 CFR 803 / EU MDR Art 87 / 21 CFR 806 with clocks and jurisdiction) is a secondary, weaker moat — roughly 12 months, because the rules are public and a determined competitor can encode them, though few have bothered to make them computable rather than a workflow form. Time-to-close on everything else. An incumbent closes the eSTAR gap in one release cycle (they already manage the content). Design controls and DHF are already at parity or better in Greenlight Guru and Ketryx today. Global registrations and UDI would take a non-Rimsys competitor 2–3 years, but that gap runs against us, not for us. The honest conclusion on durability: the moat is real but perishable, and it is currently invisible because no user can reach it. Every month the IVD calculators stay unwired is a month of moat decay with no offsetting revenue or reference customers. If this asset is acquired, the IVD depth must be exposed and marketed within two quarters or the advantage expires unmonetized — the domain knowledge does not depreciate, but the first-mover window and the ability to sign reference IVD customers ahead of the field does.

Shortest credible path to parity

- Weeks 1–2 — Put the device workstream in the navigation. Add a medtech/diagnostics destination to RAIL_PRIMARY (client/src/concept2cure/v2/registryModel.ts:116-123) or render SEGMENT_MODULES (registryModel.ts:446-500) as a segment home, and remove device-510k, device-cer, device-diagnostics, design-controls, human-factors, quality and risk from NAV_HIDDEN (registryModel.ts:139-168). Update the five-destination assertion at client/src/concept2cure/v2/**tests**/registryModel.test.ts:35. This is a configuration change against an existing, working router and it moves the single most damaging score in the rubric from 1 to 4. Nothing else on this list matters until a user can find the product.
- Weeks 2–6 — Vendor the official FDA eSTAR templates and populate the field maps. The fill machinery is already built and proven: `estar-fill.test.ts:43-64` shows a real AcroForm being filled and read back. Drop the official FDA eSTAR PDFs into `assets/estar-templates/`, run `listAcroFields` (`server/services/forms/fill-official-pdf`) to enumerate real field names, populate the four descriptor maps at `server/services/pathway-engines/estar/estar-field-map.ts:33-38`, and pin template versions in `ESTAR_TEMPLATE_MANIFEST`. This is a version-pinned data change, not new code — the file's own header says so. Confirm the eSTAR 7.0 template/date question first (widely reported as 2026-08-03 but unverified against FDA primary sources). Moves the top critical dimension from 1 to 4 and makes the product sellable to the RA buyer.
- Weeks 2–8 (parallel, and the highest-leverage commercial move) — Wire the IVD calculators to a UI. `/api/ivd-lifecycle` exposes ~30 calculators (`server/routes/ivd-lifecycle.ts:156-452`) with a published OpenAPI contract (`ivd-platform.openapi.json`) and zero client callers. Build one IVD performance workbench surface over the existing `IvdSurface` shell that drives cutoff, stability, carryover, hook effect, recovery and traceability, and expose the Annex VIII classifier with its 10-row rule trace as the classification entry point. This does not reach parity — it reaches differentiation, in the only dimension where the competitive set scores 2 and this platform scores 4.
- Weeks 4–10 — Resolve or replace the shadow service. Two branches, and diligence should force the choice before close. If the Python service is owned and conveyable, bring the source into the repository, add it to `docker-compose` and CI, and make the 502-to-fixture fallback (`client/src/concept2cure/mdx/hooks/useK510.ts:13,22`) fail loudly instead of silently rendering demo data. If it is not conveyable, delete the proxy layer and rebuild predicate search on the openFDA integration that already exists and is already tested but has zero callers (`server/routes/fda510k-routes.ts:1022,1167`) — a 3–4 week rebuild that yields a real, if less sophisticated, predicate capability with no external dependency. Either way, the demo must stop showing fixtures.
- Weeks 6–14 — Ship an eQMS front end over the QMS backend that already exists. `server/routes/qms.ts:66-222` provides document control with state transitions, training and compliance rollup, suppliers with approval, internal audits, management reviews and nonconformances with disposition; `server/services/capa-mdr/` provides CAPA and complaints with deterministic reportability. Building UI over these two closes the quality buyer's veto. Scope this to the QMSR-relevant subset — do not attempt MasterControl's full breadth. Moves eQMS from 1 to 3, which is enough to stop losing on veto without pretending to be a QMS leader.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					6. Weeks 8–20 — Execute a real validation package. Retire the ten DRAFT 'Cortex Prime' documents (docs/validation/, all 1.0.0-DRAFT dated 2025-01-24, approver PENDING) and produce an executed, approved, correctly-named IQ/OQ/PQ with a Part 11 traceability matrix tied to the actual audit-chain implementation (server/routes/audit-trail-ledger.routes.ts:4-21, which is genuinely strong evidence), plus a per-release revalidation commitment. This is the deliverable Greenlight Guru and MasterControl lead with; without it the mid-market close rate stays near zero regardless of features. Budget for an external CSV/CSA consultant — this is not an engineering task. 7. Explicitly do not pursue — global registrations and UDI RIM. Reaching Rimsys parity means 100+ market registration lifecycles, Universal UDI and EUDAMED M2M: a multi-year build against an entrenched leader that 6 of the top 12 global manufacturers already run. Partner or integrate. Every engineering week spent here is a week not spent on the IVD moat, which is the only place this asset can actually win.

Verdict

● **Not competitive** — Not competitive as a product today; genuinely valuable as an IP acquisition. Those are different findings and a buyer must not conflate them.

The product case. Six dimensions in this category are critical, and the platform scores 1 out of 5 on five of them: it cannot produce an official FDA eSTAR (the mandatory artifact for every Traditional, Special and Abbreviated 510(k)); it has no navigational front door for any device or IVD surface; it has no eQMS user interface at all under a QMSR regime that took effect five months ago; it has no executed vendor validation package; and its most demonstrable differentiator is not contained in the repository. Put a regulatory affairs director and a quality director in a room with this product and Greenlight Guru and every one of their three gating questions — "does it produce the eSTAR", "is it validated out of the box", "can my associate find it" — is answered no, no, and no. There is no configuration of this product that wins a competitive mid-market device deal in 2026. Scoring what ships rather than what is architected, this is not-competitive, and the verdict would not change even if every backend gap were closed, because the navigation and validation gaps alone are disqualifying.

The asset case, which is the one that matters for an acquisition. The backend is not vaporware. The IVDR Annex VIII classifier is a real seven-rule engine with a complete audit trace and passing tests. The ~30 IVD analytical-performance and decision calculators at server/routes/ivd-lifecycle.ts:156-452 are capability that Greenlight Guru, Rimsys, Ketryx, Veeva and MasterControl collectively do not have. The CAPA/MDR triage engine computes reportability deterministically under three regulatory regimes rather than routing a form. The audit ledger enforces tamper evidence with a database-level hash chain, which is architecturally stronger than the application-layer logging most of this field ships. The PCCP module is early to a requirement the market has barely started building for. And the codebase is unusually honest — the eSTAR path returns 422 with named blockers rather than emitting a plausible-looking PDF, and the tests assert that fail-closed behavior. An acquirer inheriting this inherits low latent-liability risk, which is rare.

The distance between those two paragraphs is almost entirely wiring and one missing repository. Five of the seven capability losses are "backend exists, no UI reaches it" — /api/qms has 17 endpoints and zero client callers, /api/ivd-lifecycle has ~30 calculators and zero, /api/design-risk has 20 endpoints while the UI calls a thinner route, /api/fda510k has live openFDA integration while the shipping predicate panel renders fixtures from a 502. That is engineering work measured in weeks, not a rebuild.

Two findings should move price rather than score. First, the shadow service: predicate intelligence, SE-matrix generation and the DOCX factory are entirely HTTP proxies to an out-of-repo Python service, and shadow_service/ in this repository is two files that will not import. Whatever was demonstrated in a sales process was produced by code not being conveyed. Confirm ownership and secure explicit reps, warranties and source delivery, or discount the valuation to zero for the entire predicate/SE capability. Second, the validation package is ten DRAFT documents dated 2025-01-24 for a differently-named system — there is no validation asset here, only a template.

Recommendation: value this as regulatory-logic IP and an engineering team, not as a revenue-ready platform. Do not underwrite a 2026 competitive-deal pipeline.

Pharmacovigilance & drug safety (safety database of record,...

Verdict: ● **Not competitive** Weighted capability score — us 1.1 / 5 vs best competitor 5.0 / 5 across 15 dimensions.

Full category as scoped: Pharmacovigilance & drug safety (safety database of record, ICSR/E2B(R3) submission, signal detection & management, aggregate safety reporting)

Who buys, and what they are actually buying

Head of Pharmacovigilance / QPPV (EU) or Drug Safety Officer, usually co-signed by Head of Quality/CSV and IT. They hold a PV operations budget and buy one thing: a validated system of record that provably gets ICSRs to FAERS/EudraVigilance/PMDA inside the 7- and 15-day clocks, survives an EMA/FDA PV inspection, and produces the DSUR/PBRER on the EURD date. Failure mode they are buying insurance against is a GVP non-compliance finding or a Form 483 — not efficiency. Secondary buyer at small biotech (<10 marketed products) is the VP RA/Clinical who wants PV bundled rather than a separate six-figure Argus program, which is the only door this platform could realistically enter through.

Market structure

SIZE AND SHAPE. Estimates diverge sharply by scope definition and a buyer should not anchor on any single one. Narrow PV software: USD 234.73M in 2026 rising to USD 309.03M by 2031 at 5.65% CAGR (Mordor Intelligence); a competing estimate puts 2026 at USD 228.57M from USD 215.84M in 2025 (Global Growth Insights). Broad PV and drug-safety software including services-adjacent tooling: USD 2.53B in 2025 to USD 2.86B in 2026 at 12.8% CAGR. Total PV market including outsourced services: roughly USD 10.5B in 2026 growing toward USD 31.6B by 2034 at ~15%. The gap between the ~USD 235M software number and the ~USD 10.5B total is the single most important structural fact in this category: PV is overwhelmingly a SERVICES market, and most small and mid-size biotechs solve pharmacovigilance by hiring IQVIA or a specialist CRO, not by buying software. Any PV revenue model for this platform is competing against outsourcing, not just against Argus. Sources: <https://www.mordorintelligence.com/industry-reports/pharmacovigilance-and-drug-safety-software-market> ; <https://www.globalgrowthinsights.com/market-reports/pharmacovigilance-software-market-108058> ; <https://www.fortunebusinessinsights.com/pharmacovigilance-pv-market-102746>

SEGMENT MIX AND DEPLOYMENT. Pharma and biotech held 54.10% of PV software spend in 2025, while business process outsourcing firms are the fastest-growing buyer at 17.2% CAGR — confirming the services-led shape above. Cloud/SaaS is now 66.55% of revenue and growing at 21.3% CAGR, so on-premise is no longer a competitive position. Source: <https://www.mordorintelligence.com/industry-reports/pharmacovigilance-and-drug-safety-software-market>

STRUCTURE AND CONSOLIDATION. The category is concentrated around Oracle, ArisGlobal, IQVIA and Veeva at enterprise scale, with RxLogix named alongside them in 2026 vendor coverage, and a long tail of SME/multivigilance specialists (AB Cube, Ennov, EXTEDO, Sarjen). Consolidation is active: in early 2026 AB Cube brought Marvin, asthenis and SafetyEasy together under the AB Cube Group to form an integrated real-world and clinical-trial safety suite, and EXTEDO distributes SafetyEasy under its own brand — meaning the SME tier this platform would enter is itself consolidating and gaining distribution reach while we have no product to sell into it. Sources: <https://www.globenewswire.com/news-release/2026/04/30/3285101/0/en/pharmacovigilance-and-drug-safety-software-market-report-2026-featuring-profiles-of-iqvia-oracle-corporation-arisglobal-and-rxlogix.html> ; <https://www.ab-cube.com/vigilance/> ; <https://extedo.com/products/pharmacovigilance-and-drug-safety/safetyeasy>

PROCUREMENT PATTERN AND DEAL SIZE. Pricing is almost universally undisclosed across every vendor examined — enterprise subscription with modules, users and case volume as the meters. The one usable public benchmark for the segment: small SaaS PV solutions start at roughly USD 10,000-20,000 per year, while large enterprise systems run hundreds of thousands in licence plus millions in implementation and validation. Veeva Vault Safety is estimated in secondary analysis at hundreds to low thousands per user per year plus fixed platform cost, and Veeva has said AI usage will be metered and usage-priced. AB Cube competes explicitly on 'most cost-effective,' 'full price transparency,' 'no hidden costs.' The decisive procurement mechanic is that the software line item is frequently the smaller half of the cost — the implementation, data migration and computer system

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					validation program dominates. That is exactly why Veeva's vendor-executed IQ/OQ three times a year with a customer validation package, and customer-reported validation cycle times up to 80% shorter than legacy on-premise, is the sharpest commercial weapon in the category, and why our zero-page PV validation posture is not a documentation gap but a pricing disadvantage. Sources: https://intuitionlabs.ai/articles/veeva-vault-pricing-2026-cost-breakdown/ ; https://www.veeva.com/resources/veeva-vault-validation-product-brief/ ; https://www.veeva.com/wp-content/uploads/2022/03/Veeva-Vault-Validation-Datasheet.pdf ; https://en.ennov.com/pharmacovigilance-full-features/ TECHNICAL GATE. E2B(R3) is an XML model derived from HL7 version 3; individual and batch ICSRs use the HL7 batch message wrapper with message interaction identifier MCCI_IN200100UV01, and EMA publishes the schema at http://eudravigilance.ema.europa.eu/XSD/multicacheschemas/MCCI_IN200100UV01.xsd. EU legislation requires MAHs to submit ICSRs to EudraVigilance in E2B(R3), and FDA publishes a Regional Implementation Guide. This is a hard, externally-verified conformance boundary — not a spec a vendor can approximate — which is why AB Cube publicises passing China NMPA E2B(R3) testing as a differentiator, and why our bespoke <element id="C.1.1"> projection is a category-exclusion rather than a feature gap. Sources: https://www.fda.gov/media/98536/download ; https://www.ema.europa.eu/en/documents/scientific-guideline/international-conference-harmonisation-technical-requirements-registration-pharmaceuticals-human-use-guideline-e2b-r3-electronic-transmission-individual-case-safety-reports-icsrs-data-elements_en.pdf ; https://database.ich.org/sites/default/files/ICH_E2B-R3_QA_v2_4_Step4_2022_1202.pdf ; https://www.pharmiweb.com/press-release/2023-07-26/ab-cube-s-safetysuite-cloud-based-multivigilance-software-successfully-passes-china-ich-e2b-r3-testing WHAT THE CATEGORY IS NOW COMPETING ON. Not features — measured automation. ArisGlobal publishes >1M cases processed on NavaX at >95% accuracy and >30% efficiency gain, heading to 2.5M by mid-2026, with seven global life-sciences companies publicly selected. IQVIA publishes up to 80% fewer false positives from GenAI in Vigilance Detect. Veeva ships Safety.AI MedDRA pre-coding, multilingual coding and duplicate detection today with metered AI agents phasing in from April 2026. AB Cube claims up to 70% faster intake from CasEasy AI and OCR. A new entrant with no shipped case-processing automation, no intake surface and no validation package has no credible answer to the first question in any 2026 PV bake-off. Sources: https://www.arisglobal.com/lifesphere/safety/ ; https://www.prnewswire.com/news-releases/arisglobal-announces-xdi-navax-data-intelligence-three-new-agents-and-navax-translation-302684836.html ; https://www.iqvia.com/library/fact-sheets/iqvia-vigilance-detect-transforming-pharmacovigilance-with-measurable-outcomes ; https://safety.veevavault.help/en/gr/753121/ ; https://www.ab-cube.com/vigilance/ UNVERIFIED CLAIMS FLAGGED. A secondary source attributes Oracle a 24% enterprise-segment share and Argus a 9.4/10 data-integrity rating; neither is traceable to a primary or audited source and both should be treated as marketing-adjacent. Vault Safety-specific customer counts are not disclosed (Veeva reported 1,552 cumulative customers across all Vault products at FY2026). All vendor automation and accuracy metrics cited above are vendor-published and none are independently audited.

The five closest competitors

Oracle Argus Safety (Oracle Life Sciences "Safety One") — Argus Safety / Argus Cloud Service (releases 8.4.x and 2026.1.x), with Argus Insight, Argus Mart, Empirica Signal, and Axway-based E2B e-submission gateway

The default incumbent and de-facto reference safety database. Sold to large pharma, established biotech, CROs and PV service providers that need a validated, globally familiar safety database with regulatory reporting continuity. Argus is the system most PV staff have already been trained on, which makes it the risk-free choice in a procurement.

Strengths

- Widest installed base and deepest regulatory reporting rule library across FDA/EMA/PMDA/NMPA/Health Canada — the reporting rules engine is the actual product
- Empirica Signal brings MGPS/EBGM disproportionality with a full database-wide fit, not a single-cell approximation
- Trained-labor market: PV staff and CRO partners already know Argus, which collapses change-management risk in a deal
- Proven E2B gateway path (Axway) with ACK reconciliation and submission tracking at scale
- Inspection track record — Argus case files have survived thousands of FDA/EMA PV inspections

Weaknesses

- Heaviest and most expensive to implement and validate; long time-to-first-case

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					• UX is dated relative to Veeva/ArisGlobal and drives per-case processing cost • AI story is the weakest of the top three incumbents as of 2026; Oracle is defending, not leading • Configuration depth becomes a validation liability — every change is a CSV event • Poor fit below ~mid-size biotech; effectively unsellable to a 5-person safety group
AI shipped today					Oracle markets the Life Sciences PV solution as "cloud-enabled automation and advanced analytics, built on OCI and leveraging AI to streamline intake, case management, signal detection, and regulatory workflows." Specific shipped, GA AI case-processing agents in Argus as of mid-2026 are not verified from Oracle primary sources; Oracle's AI messaging is materially less concrete than ArisGlobal's or Veeva's. Empirica Signal (MGPS/EBGM data mining) is long-standing statistical, not LLM, capability.
GxP / validation posture					Long-established GxP/21 CFR Part 11 posture; Oracle publishes Argus Cloud Service administration and qualification documentation. Historically the customer carries a heavier CSV burden than on Veeva because Argus is more configurable and, in on-prem/hybrid form, customer-qualified. Exact current Oracle-supplied validation package contents not verified.
Pricing signal					Not public. Enterprise subscription, licensed by usage, modules and user count; requires Oracle Sales engagement (secondary source: rxalmanac vendor profile). Real-world programs are commonly multi-hundred-thousand-dollar annual license plus a separate implementation/validation project — not independently verified.

► Sources

ArisGlobal LifeSphere Safety (NavaX) — LifeSphere Safety with LifeSphere NavaX (GenAI case processing), MedDRA Coding Agent, NavaX Translation, and XDI data intelligence cortex

The AI-native incumbent. Positions explicitly as "AI Pharmacovigilance Software for Drug Safety & Case Processing" and is winning displacement deals on case-processing cost per case rather than on database features. This is the vendor most likely to define what "AI PV" means in a 2026 procurement.

Strengths

- The only vendor with a public, large-N production metric for AI case processing (>1M cases, >95% accuracy, >30% efficiency)
- Full PV suite — intake, case processing, coding, submissions, signal, aggregate reporting — not a point tool
- Named-logo momentum: seven global pharma selections publicly announced for NavaX alone
- NavaX Translation removes the multilingual intake bottleneck that historically forced regional PV vendors
- XDI positions them to arbitrage safety data against regulatory, clinical and quality — a platform play the point vendors cannot match

Weaknesses

- Validation of probabilistic AI components under GAMP 5 is an unsettled area; conservative QA groups will resist
- Smaller installed base than Oracle; less PV labor-market familiarity
- Enterprise-only commercial motion — very poor fit for small biotech
- Efficiency claims are vendor-published and not independently audited
- Migration off Argus is still a multi-quarter data-migration and revalidation project

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
AI ship ped toda y					Shipped and in production, not roadmap: ArisGlobal states NavaX is processing more than 1 million safety cases with data accuracy greater than 95% and efficiency gains greater than 30%, with volumes projected to reach 2.5 million cases by mid-2026. At Breakthrough 2026 it announced XDI (data intelligence cortex), three new AI agents, and NavaX Translation — the latter GA to LifeSphere Safety customers from July 2026, bringing pharma-grade multilingual case intake. A dedicated MedDRA Coding Agent is part of the shipped agent set. Seven named global life-sciences companies have publicly selected NavaX for GenAI-driven case processing.
GxP / valid atio n post ure					GxP-validated enterprise PV platform sold to top-20 pharma; ArisGlobal supplies validation documentation as part of the cloud service. Specific IQ/OQ package contents and the validation approach for the GenAI agents (how a >95%-accuracy probabilistic component is qualified under GAMP 5) are not verified from primary sources — this is the single best question to ask them in diligence.
Prici ng sign al					Not public. Enterprise subscription; NavaX is sold as an add-on/uplift to LifeSphere Safety. No published per-case or per-user rate.

► Sources

Veeva Vault Safety (with Vault Safety.AI and Veeva Safety Signal) — Vault Safety, Vault Safety.AI, Veeva Safety Signal, Vault SafetyDocs; part of the Vault platform and the new Falcon AI platform

The cloud-native modern challenger, and the strongest displacement threat because the buyer often already owns Vault for RIM/Clinical/Quality. Sells on unified data across safety, clinical and regulatory plus the lowest validation burden in the category.

Strengths

- Best-in-category validation economics — vendor-performed IQ/OQ per release plus a customer validation package
- Signal module ingests EVDAS and literature alongside internal PV data — genuinely multi-source signal detection
- Multilingual MedDRA coding and duplicate detection are shipped, not roadmap
- Platform gravity: if the buyer runs Vault RIM/Clinical/QualityDocs, safety data joins the same object model with no integration project
- 3x/year release cadence means feature gaps close fast

Weaknesses

- Newest of the big three in safety; less deep regulatory reporting rule coverage in long-tail markets than Argus
- Agentic safety capability is April-2026-to-late-2026 phased, so "agents" are partly forward-looking in a 2026 procurement
- Platform lock-in and per-user pricing scale badly for a CRO/service model with many low-usage users
- Vault Safety-specific reference count is not publicly disclosed, so segment proof is thinner than Argus
- Requires buying into the Vault platform to get the full benefit

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					AI shipped: Safety.AI auto-extracts event terms from narratives and pre-codes them with MedDRA suggestions; Vault Safety includes intelligent duplicate detection and follow-up; a multilingual MedDRA browser maps Japanese/Spanish reported terms to MedDRA codes; Veeva codes events using the latest published MedDRA version with manual coding fallback. Veeva Safety Signal runs scheduled and ad-hoc signal detection over PV data from Veeva Safety, literature data from SafetyDocs, and external health-authority sources including EMA EVDAS. Agentic: Veeva stated Safety and Quality AI agents were slated for April 2026 release, with usage-metered pricing; Falcon safety case intake and processing agents target late 2026 for early adopters — treat the agents as emerging, and Safety.AI/Signal as the shipped baseline.
			Gx P / validation position		Strongest published position in the category. Veeva validates every release itself (IQ and OQ) three times a year and supplies customers a validation package; customers report validation cycle times up to 80% shorter than legacy on-premise; a comprehensive revalidation of all functionality is performed every two years. This is a decisive advantage in front of a QA buyer.
			Pricing signal		Not public for Safety specifically. Secondary analysis puts Vault Safety on the order of hundreds to low thousands per user per year plus fixed platform cost, with Safety historically sold to large enterprises; Veeva has stated AI usage will be metered and usage-priced. Veeva reported 1,552 cumulative customers at FY2026 (Jan 2026) across all Vault products; a Vault Safety-specific customer count is not verified.

► Sources

IQVIA Vigilance Platform — IQVIA Vigilance Platform — modules: Vigilance Intake, Vigilance Collect, Vigilance Case, Vigilance Detect, Vigilance Signal (formerly the Safety Suite lineage)

True-SaaS PV platform sold alongside IQVIA's PV outsourcing services. Wins where the buyer wants to outsource the safety function rather than staff it — the most common answer for small and mid-size biotech, and therefore a direct substitute for buying any PV software at all.

Strengths

- Substitutes for the whole PV function, not just the database — beats software-only vendors at small biotech
- Quantified GenAI outcome claim (up to 80% fewer false positives in Detect) tied to case studies
- End-to-end module coverage from reporter portal through signal, all on one SaaS
- Deep literature and RWD assets to feed signal detection
- Buyer offloads inspection risk onto IQVIA, which is the real thing being purchased

Weaknesses

- Service-led model means less buyer control and higher long-run cost per case at scale
- Software is less frequently bought standalone, so standalone references are thinner
- Vendor lock-in extends to the operating model, not just the data
- Efficiency claims are client-case-study based, not independently audited
- Conflicted where the buyer also uses IQVIA as CRO — concentration risk

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
AI ship ped toda y					Shipped: Vigilance Detect is GenAI-powered for automated drug safety event detection and extraction, with client case studies reporting up to 80% fewer false positives and notable reductions in manual review. Vigilance Intake uses AI/ML/NLP to capture adverse events from external and internal sources. Vigilance Collect provides web/mobile reporter portals that store submissions in E2B+ format, auto-validate each submission and auto-create the case in the safety database. IQVIA has also announced custom-built AI agents using NVIDIA technology for life-sciences workflows.
GxP / valid ation post ure					Delivered as a validated SaaS within IQVIA's regulated services organisation; IQVIA carries the inspection exposure when the service is bundled. Specific customer-facing validation package contents not verified.
Prici ng sign al					Not public as software. Commercially usually bundled into a PV services contract; the effective procurement unit is a per-case processing fee plus an annual PV service retainer rather than a license. Specific rates not verified.

► Sources

AB Cube SafetyEasy Suite (also distributed by EXTEDO) — SafetyEasy Suite — unified multivigilance database (pharmacovigilance, materiovigilance/device, cosmetovigilance, nutrividigilance) with the AB Cube Galaxy AI modules: CasEasy AI (NLP case creation) and Converter (OCR form extraction)

THE realistic head-to-head competitor for this product. Explicitly targets pharmacovigilance for small-to-mid-sized companies and CROs managing multiple clients, marketed as the cost-effective, compliant, easy-to-use multi-vigilance platform for SMEs. A SaaS vigilance pioneer since 2006; in early 2026 AB Cube consolidated Marvin, asthenis and SafetyEasy under the AB Cube Group.

Strengths

- Occupies exactly the SME/CRO segment this platform must enter, at a price a small biotech will actually pay
- Third-party-proven E2B(R3) conformance including China NMPA testing
- Multivigilance in one database (drug + device + cosmetic + nutritional) — combination-product cases handled in one application
- Explicit GAMP 5 / Part 11 posture with vendor-managed regulatory updates
- Real shipped intake AI (NLP + OCR) with a ~70% intake acceleration claim

Weaknesses

- Weakest brand and smallest reference base of the five — loses large-pharma deals on perceived risk
- Signal detection and analytics are thinner than Empirica/Veeva Signal
- Less capital behind AI than ArisGlobal, IQVIA or Veeva; risk of falling behind on agentic case processing
- Intake acceleration and cost claims are vendor-published, not independently audited
- Recent portfolio consolidation (Marvin/asthenis/SafetyEasy) creates roadmap and rationalisation uncertainty

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					AI shipped today Shipped: CasEasy AI applies NLP to case creation and Converter applies OCR to extract data from reporting forms; AB Cube claims case intake acceleration of up to 70%. This is narrower than NavaX/Safety.AI (intake and extraction, not end-to-end autonomous case processing) but it is real, GA, and priced for the segment this platform would sell into.
					GxP / validation posture States full compliance with ICH E2B(R3), FDA 21 CFR Part 11 and GAMP 5, with automatic system updates to stay current with regulations. Independently demonstrated E2B(R3) gateway competence: SafetyEasy Suite passed China NMPA ICH E2B(R3) testing, which is a genuine third-party conformance proof point rather than a marketing claim.
					Pricing signal Enterprise subscription, not publicly disclosed, but the company markets on "most cost-effective," "full price transparency" and "no hidden costs" — i.e. it competes on published-ish, SME-scale pricing. Broader category benchmark: small SaaS PV solutions start around \$10,000–\$20,000/year while large enterprise systems run hundreds of thousands in license plus millions in implementation and validation.

► Sources

Capability rubric

Our score is cited to `file:line` in this repository. Theirs is cited in the competitor sections above. Scored on what **ships and is reachable**, not what is architected — an unreachable or unvalidated capability scores low regardless of code quality.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Case intake — can a safety officer actually enter a case in the product	critical	0 ▼	IQVIA Vigilance Collect / ArisGlobal NavaX	5	absent — POST /api/pharmacovigilance/adverse-events exists and is Zod-validated at server/routes/pharmacovigilance-routes.ts:271-319, but a grep of the entire client/src tree returns ZERO references to that endpoint. The only PV endpoints any UI calls are overview, compliance-matrix, signals/screen and calculate-deadline (client/src/concept2cure/v2/surfaces/PvCockpit.tsx:87-90,102,117) plus /api/pharmacovigilance/board and /api/safety-narratives/cases. There is no case-intake form, no case worklist with create, and no inbound E2B import anywhere in the repo. Every KPI, signal and compliance number in the UI is therefore structurally empty for any real customer.
E2B(R3) ICSR generation conformant to the HL7 v3 ICH schema	critical	1 ▼	AB Cube SafetyEasy (passed China NMPA E2B(R3) conformance testing) / Oracle Argus	5	server/services/ind-lifecycle/e2b-icsr-composer.ts:276-290 — serializeE2bXml emits containing generic value tags. That is a bespoke key-value projection, not the HL7 v3 MCCI_IN200100UV01 message EMA and FDA require; the file admits this at :12-17. Two further blockers: pharmacovigilanceService.ts:972-977 hardcodes the C.1.8.1 worldwide unique case id prefix to 'XX-C2CRI-' ('XX' is not an ISO 3166 country code, so every case fails agency validation), and pharmacovigilanceService.ts:959-965 mints the C.1.1 sender's unique identifier from Math.random() despite crypto.randomUUID being imported at :27 and used at :1264. Separately, the PV module's own endpoint POST /api/pharmacovigilance/icsr/generate never calls the composer at all — pharmacovigilanceService.ts:563-630 returns a metadata row with a hardcoded e2bVersion:'R3' string and no XML.
Agency gateway transmission and ACK reconciliation (FDA ESG/FADERS, EudraVigilance, PMDA, NMPA)	critical	0 ▼	Oracle Argus (Axway E2B gateway)	5	server/services/ind-lifecycle/icsr-gateway-transport.ts:189-201 — when a gateway IS configured, transmitIcsr() unconditionally throws 'ICSR gateway transport client is not implemented ... Refusing to fabricate a gateway acknowledgement.' With no gateway configured it throws in production (:204-212) or returns an explicitly simulated:true receipt outside production (:216-227). There is no AS2, no SFTP, no ESG client anywhere in the repo. Zero ICSRs can be transmitted, in any environment, ever. The ACK parser at e2b-icsr-message.ts:143-162 is well built but has no ACK to parse.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
MedDRA / WHODrug dictionary management, auto-coding and version upgrade	critical	1 ▼	Veeva Vault Safety (multilingual MedDRA browser, coded to latest published MedDRA version)	5	server/services/compliance/pharmacovigilanceService.ts:1136-1165 — searchMeddraTerms queries meddra_term_reference and returns [] on 42P01/42703. The migration never creates that table: migrations/20260603_pv_operational.sql:165-167 only adds an index IF to_regclass('public.meddra_term_reference') IS NOT NULL. There is no MedDRA loader, no seed, no version-upgrade path, and no WHODrug support anywhere in scripts/ or ingestion/. Auto-coding does not exist; the field is free text (adverseEventSchema reactionPt/reactionPtCode are optional strings, pharmacovigilance-routes.ts:76-79).
Quantitative signal detection math (disproportionality)	high	4 ▼	Veeva Safety Signal (multi-source: internal PV + literature + EMA EVDAS, scheduled and ad-hoc) / Oracle Empirica	5	server/services/compliance/pv-signal-detection.ts:95-152 — genuine, literature-cited PRR, ROR with log-method 95% CI, Yates-corrected chi-squared, and Gamma-Poisson EBGM/EB05, with total (non-throwing) zero-cell handling and Acklam/Wilson-Hilferty numerics at :254-329. server/routes/pharmacovigilance-board.routes.ts:133-187 automatically cross-tabulates the org's own adverse_events by (suspect_product × reaction_pt) into 2x2 tables with an n>=3 floor and runs the screen. A BCPNN IC + EBGM multi-method consolidator is exposed as an ANA tool (server/services/ana/statisticalDesignTools.ts:239). The file honestly self-declares the single-Gamma (alpha0=beta0=0.5) approximation vs a full database-wide MGPS fit at :155-179. Deducted one point for that approximation and for the UI exposing only a hand-typed 2x2 (PvCockpit.tsx:150-172).
Signal management workflow (GVP Module IX: validation, prioritisation, assessment, closure, ownership)	high	1 ▼	Veeva Safety Signal / Oracle Empirica Signal	5	server/services/compliance/pharmacovigilanceService.ts:192-208 — SafetySignal is a flat row with no owner, no assignee, no due date, no evidence links, no state-transition history and no closure record; evaluationStatus is a free enum with no workflow enforcing it. server/routes/pharmacovigilance-board.routes.ts:66,182 explicitly returns owner:null with the comment 'GAP: no signal owner/assignee exists in adverse_events or safety_signals'. reportSignal (pharmacovigilanceService.ts:745-786) is a bare INSERT with no route that ever transitions a signal.
Aggregate safety reporting (DSUR / PBRER / PSUR / PADER) authoring	high	2 ▼	Oracle Argus / ArisGlobal LifeSphere Safety	5	server/services/compliance/pv-periodic-scheduler.ts (234 lines) computes upcoming deadlines from data-lock points and is exposed at POST /api/pharmacovigilance/periodic-reports/schedule (pharmacovigilance-routes.ts:423-443); server/services/ana/pharmacovigilance.ts:29-70+ encodes DSUR/PBRER section structure and pitfalls for AI advisory. But PeriodicSafetyReport (pharmacovigilanceService.ts:171-183) is metadata only — reportType, dates, status, dueDate. There is no document authoring, no summary tabulations, no

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
g and line listings					line listings, no cumulative exposure computation, and no UI. Scheduling and knowledge without generation.
Literature monitoring (GVP Module VI/VIIa — mandatory PV activity)	high	0 ▼	Veeva (SafetyDocs literature feeding Safety Signal) / IQVIA	5	absent — 'literature' appears in this codebase only as a signalSource enum value (server/services/compliance/pharmacovigilanceService.ts:196 and server/routes/pharmacovigilance-routes.ts:105). No Embase/Medline ingestion, no abstract screening, no ICSR-from-literature triage, no EMA Medical Literature Monitoring reconciliation exists anywhere in server/.
Expedited reporting clock and regulatory compliance tracking	critical	3 ▼	Oracle Argus reporting rules engine	5	server/services/compliance/pharmacovigilanceService.ts:284-336 computes 7/15-day deadlines across FDA/EMA/PMDA/NMPA/Health Canada with cited legal bases; :1093-1115 computeReportingClock is a pure, unit-tested day-6-of-15 escalation function; server/routes/safety-narrative.ts:60-80 recomputes the 21 CFR 312.32(c) clock LIVE from awareness_date and fails closed to null rather than displaying a stale stored value. This is the strongest thing in our PV module. Deductions: calendar-day arithmetic only (no business-day or holiday handling), the PMDA 72-hour first-notice obligation is deferred to a 'workflow layer' that does not exist (:313-315), and the compliance matrix hardcodes a 7-country map so any other country silently vanishes from the matrix (pharmacovigilance-routes.ts:638-641,647-650).
21 CFR Part 11 audit trail and electronic signature on safety records	critical	1 ▼	Oracle Argus / Veeva Vault Safety	5	server/services/compliance/pharmacovigilanceService.ts:1233-1278 — writePvAudit is documented as 'best-effort', swallows every error and returns false (:1271-1274); submitCaseToTriage calls it with .catch(() => false) at :1216, so a case can transition state with no audit record and the API still returns success:true with auditWritten:false. A Part 11 audit trail that can silently fail is not a Part 11 audit trail. There is also no electronic signature anywhere in PV — grep for 'signature' in server/routes/pharmacovigilance-routes.ts returns nothing, so no case submission, ICSR release or signal closure is e-signed.
GxP/CSV validation package and inspection readiness for the PV module	critical	0 ▼	Veeva Vault Safety (vendor IQ/OQ every release, 3x/yr, customer validation package, biennial full	5	absent — docs/validation/VMP-CORTEX-001-VALIDATION_MASTER_PLAN.md is 408 lines and contains ZERO occurrences of 'pharmacovigilance', 'adverse event', 'ICSR' or 'E2B' (verified by case-insensitive grep). There is no PV validation plan, no IQ/OQ/PQ, no requirements-to-test traceability against ICH E2B(R3), 21 CFR 312.32/314.80 or Part 11, and no supplier audit pack. Unit tests exist for the pure math (server/services/compliance/tests/pv-signal-detection.test.ts, pv-signal-screen.test.ts, pv-periodic-scheduler.test.ts, pharmacovigilance-clock.test.ts) but unit tests are not qualification evidence.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
			revalidation)		
Reachability — is the capability in the product a user navigates	critical	1 ▼	All five	5	client/src/concept2cure/v2/registryModel.ts:116-122 — RAIL_PRIMARY contains exactly five destinations (conversation-thread, projects, communication-center, apps, setup). No PV entry. pv-cockpit and safety-narrative are in shared/constants/ui-surface-registry.ts:622,638 so they surface in the ÆK palette (Shell.tsx:982-984), which is the only front door. Worse, client/src/concept2cure/v2/surfaces/PvSignal.tsx:187 exports PvSignalPanel that is imported by nothing — it is absent from surfaceViews.ts (which registers only pv-cockpit at :196, safety-narrative at :211 and pharmacovigilance at :195) and BiopharmaSpecialty.tsx:893 carries the comment 'PvSignalPanel placeholder -- not yet ported as a standalone component'. 288 lines of dead signal UI.
Production AI shipped for PV case work (not advisory chat)	high	1 ▼	ArisGlobal NavaX (>1M cases processed, >95% accuracy, >30% efficiency, in production)	5	server/services/ana/pharmacovigilance.ts and server/services/pharmacovigilance/pharmacovigilance-knowledge.ts (87KB) are advisory knowledge bases; the H.1 narrative is produced by a deterministic template composer (e2b-icsr-composer.ts:210-224 calling composeSafetyNarrative, which by design 'never invents clinical detail'). There is no AI intake, no OCR, no NLP extraction from source documents, no MedDRA auto-coding, no duplicate detection, no case triage model. The deterministic-narrative choice is defensible for audit but it is not the automation competitors are selling against.
Single case store of record / data integrity	high	1 ▼	All five	5	The module has two disjoint, unreconciled case tables. adverse_events (migrations/20260603_pv_operational.sql:16, TEXT ids) backs /api/pharmacovigilance and the signal board; c2c_sae_cases (db/migrations/20260717_sae_cases_store.sql:8) backs /api/safety-narratives/cases (server/routes/safety-narrative.ts:48-56) and the SafetyNarrative surface. Nothing writes one from the other. A case entered via the API appears in the cockpit KPIs but never in the narrative worklist, and vice versa. The PV migration header itself documents that before 2026-06 the service silently degraded to in-memory because the tables it queried did not exist.
External safety data integration (FAERS / MAUDE / EVDAS)	medium	2 ▼	Veeva Safety Signal (EVDAS + literature + internal PV as first-class signal sources)	5	server/fda_faers_client.js:88-182 is a real openFDA drug/event client with 24h caching, and server/fda_maude_client.js (364 lines) covers device MAUDE. But server/fda_faers_client.js:274 sets total_reports from apiResponse.results.length — the returned page size (default limit 100), not meta.results.total, which is read separately at :202 and then not used for the count. Every FAERS total surfaced to a user is silently truncated to the page size. No EVDAS integration exists.

Where we stand

Where we win

- Transparent, citable, deterministic disproportionality statistics. `server/services/compliance/pv-signal-detection.ts:1-42` cites Evans 2001 (PRR), Rothman 2004 (ROR) and DuMouchel 1999 (GPS) inline, documents the exact formulas, and explicitly declares at `:155-179` that EBGM uses a single-Gamma $\alpha=0.5$ prior rather than a full database-wide MGPS fit. Every incumbent's signal math is a black box behind a UI. For a methods-literate QPPV or a statistical reviewer this is a real, if narrow, differentiator — and it is the only dimension where we score 4.
- Fail-closed transmission and audit honesty as an engineering culture artifact. `server/services/ind-lifecycle/icsr-gateway-transport.ts:11-19` refuses to fabricate an agency acknowledgement and states why ('the most dangerous lie a pharmacovigilance platform can tell'); non-production receipts are hard-flagged `simulated:true`. `server/routes/pharmacovigilance-board.routes.ts:66,79-83` returns documented nulls for owner/author/reviewers rather than inventing them. This is a diligence positive about the team, not a product advantage — but it is unusual and it will read well to a technical acquirer.
- Multi-region expedited-reporting deadline logic as a pure, tested function across FDA/EMA/PMDA/NMPA/Health Canada with statutory citations (`pharmacovigilanceService.ts:258-336`), plus a live-recomputed 21 CFR 312.32(c) clock that fails closed rather than showing a stale stored value (`server/routes/safety-narrative.ts:60-80`). Cleaner and more testable than the equivalent buried inside a commercial rules engine.
- Zero marginal price if PV rides along with the platform's regulatory/CMC/submission modules. Against AB Cube's SME positioning this is the only commercially credible wedge — and only if the intake gap is closed first.

Where we reach parity

- Single drug-event-pair disproportionality computation on demand — matches the out-of-the-box signal math in Ennov and AB Cube, though not Empirica or Veeva Safety Signal.
- Automatic 2x2 cross-tabulation of the org's own case data into a ranked signal board (`pharmacovigilance-board.routes.ts:133-187`) with a defensible $n \geq 3$ floor — parity with basic mid-market signal data mining, conditional on cases existing.
- Periodic report deadline scheduling from data-lock points across DSUR/PSUR/PBRER/PADER (`pv-periodic-scheduler.ts`) — parity with the calendar function of mid-market tools.
- ICH domain knowledge content (`E2A/E2B(R3)/E2C(R2)/E2D/E2E/E2F` encoded in `server/services/ana/pharmacovigilance.ts` and the 87KB `pharmacovigilance-knowledge.ts`) — parity with vendor help systems as reference content, not as product.

Where we lose

- Case intake. There is no way for a user to enter a case. Zero client references to `POST /api/pharmacovigilance/adverse-events`. This alone is disqualifying: a safety database you cannot put a case into is not a safety database, and every downstream number in the UI is structurally zero.
- E2B(R3) conformance. The XML is a bespoke projection, not HL7 v3 MCCI_IN200100UV01 (`e2b-icsr-composer.ts:276-290`); the worldwide unique case id is hardcoded to an invalid 'XX-' country prefix (`pharmacovigilanceService.ts:972-977`); case ids come from `Math.random()` (`:959-965`). Nothing we emit would pass EudraVigilance or FDA ESG validation.
- Gateway transmission. `transmitIcsr` throws in every configured path (`icsr-gateway-transport.ts:189-201`). No AS2, no SFTP, no ESG client exists. We cannot submit a single ICSR to any regulator.
- MedDRA and WHODrug. No dictionary is shipped, no loader exists, the reference table is never even created (`migrations/20260603_pv_operational.sql:165-167` only conditionally indexes it), and there is no auto-coding. PV is not practicable without a licensed, versioned MedDRA.
- Part 11. The audit write is best-effort and silently returns false on failure (`pharmacovigilanceService.ts:1271-1274`, called with `.catch(()=>false)` at `:1216`); there is no electronic signature on any PV action. Fails an inspection question on day one.
- CSV/validation. The Validation Master Plan contains zero mentions of pharmacovigilance, ICSR or E2B. Veeva ships a customer validation package with vendor-executed IQ/OQ three times a year; we ship nothing.
- Literature monitoring (GVP VI/VIIa) — entirely absent. This is a mandatory PV activity, not a nice-to-have.
- Duplicate case detection — absent. Veeva ships it; every serious safety database has it.
- Signal management workflow — `SafetySignal` has no owner, no dates, no evidence links, no transitions (`pharmacovigilance-board.routes.ts:66` documents the gap in code).
- Aggregate report generation — scheduling and section knowledge exist; DSUR/PBRER authoring, line listings, summary tabulations and cumulative exposure do not.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					- Production AI for case work — competitors ship it at scale (NavaX >1M cases at >95% accuracy; IQVIA Detect up to 80% fewer false positives; Veeva Safety.AI MedDRA pre-coding and duplicate detection). We ship advisory chat and a deterministic narrative template. - Discoverability — PV is not among the five global nav destinations (registryModel.ts:116-122); it is �K-only, and PvSignal.tsx is 288 lines of orphaned dead code.

Is the advantage durable?

No durable advantage exists in this category — and critically, the one place we score well is the easiest thing on the board for an incumbent to neutralise, because they have already shipped it. Taking the two candidate moats in turn. (1) Transparent disproportionality mathematics: PRR, ROR with CI, Yates chi-squared and EBGM are thirty-year-old published methods (Evans 2001, Rothman 2004, DuMouchel 1999, all cited in pv-signal-detection.ts:20-29). Oracle has shipped Empirica Signal with a full database-wide MGPS fit for two decades — strictly better than our single-Gamma alpha0=beta0=0.5 approximation, a limitation the file honestly declares at :155-179 — and Veeva Safety Signal already runs scheduled and ad-hoc detection across internal PV data, SafetyDocs literature and EMA EVDAS. Our differentiator is not the math, it is that the math is legible; any vendor could publish a methods appendix in one release cycle. Time to close: effectively zero, since it is already closed on capability and the transparency gap is a documentation exercise measured in weeks. (2) Fail-closed transmission and audit honesty (icsr-gateway-transport.ts:11-19): admirable engineering discipline, but it is a property of a module that cannot transmit. It is a positive signal about the team in diligence, not a defensible market position — you cannot sell 'refuses to lie about submissions it cannot make.' Now invert the question, which is the one that matters for an acquisition: how long before WE could close the gap the incumbents hold over US? That is the real clock, and it runs 12-18 months minimum, gated by things money and headcount only partially accelerate — a MedDRA MSSO and WHODrug UMC licence, an FDA ESG and EudraVigilance gateway registration and conformance-test cycle (AB Cube publicises passing China NMPA E2B(R3) testing precisely because it is a hurdle), and a full CSV package that must be authored, executed and defended. Meanwhile the frontier keeps moving away: ArisGlobal projects NavaX from 1M to 2.5M cases by mid-2026 and shipped NavaX Translation to Safety customers in July 2026, Veeva's Safety agents began landing April 2026 with Falcon safety case intake and processing agents targeting late 2026, and IQVIA is building custom AI agents on NVIDIA. The competitive gap in this category is widening faster than it can be closed from a standing start. Underwrite zero PV moat and zero PV revenue; value the signal-statistics and reporting-clock engines as reusable analytics components inside the regulatory platform, not as a pharmacovigilance business.

Shortest credible path to parity

- WEEKS 1-4 — Make it reachable and usable, or nothing else counts. Build the case-intake form and case worklist against the already-validated POST /api/pharmacovigilance/adverse-events (server/routes/pharmacovigilance-routes.ts:271-319), and add Pharmacovigilance to RAIL_PRIMARY (client/src/concept2cure/v2/registryModel.ts:116-122) or accept that no evaluator will ever find it. Delete or wire client/src/concept2cure/v2/surfaces/PvSignal.tsx — 288 orphaned lines is a diligence finding by itself. This is the highest-leverage work in the category: it converts an entire backend from structurally-zero to demonstrable.
- WEEKS 1-4 — Collapse the two case stores. adverse_events (migrations/20260603_pv_operational.sql:16) and c2c_sae_cases (db/migrations/20260717_sae_cases_store.sql:8) are disjoint and unreconciled; pick one as the record of record and migrate the other, or the cockpit and the narrative worklist will permanently disagree about how many cases exist.
- WEEKS 2-6 — Fix the three identifier defects that make every ICSR invalid regardless of schema: replace the Math.random() UUID generator (pharmacovigilanceService.ts:959-965) with the crypto.randomUUID already imported at :27; make the C.1.8.1 worldwide unique case id a real {ISO country}-{registered sender id}-{case no} instead of the hardcoded 'XX-C2CRI-' (:972-977); and wire POST /api/pharmacovigilance/icsr/generate to composeE2bR3Icsr so the PV module's own ICSR endpoint returns XML rather than a metadata row (:563-630).
- MONTHS 2-4 — Replace the bespoke projection with real E2B(R3). Generate HL7 v3 MCCI_IN200100UV01 and validate against the published EMA XSD (http://eudravigilance.ema.europa.eu/XSD/multicacheschemas/MCCI_IN200100UV01.xsd) plus the FDA Regional Implementation Guide. Keep the existing gap/completeness gate (e2b-icsr-composer.ts:234-249) — it is good — but make what it gates schema-valid.
- MONTHS 3-6 — Buy or build a gateway. Either implement FDA ESG AS2 and the EudraVigilance gateway behind the existing transmitIcsr seam (icsr-gateway-transport.ts:160-236, which currently throws at :196-200) or OEM Axway, then wire the already-written parseIcsrAcknowledgment (e2b-icsr-message.ts:143-162) to real ACKs and build submission tracking. Budget an agency gateway registration and conformance-test cycle; AB Cube's China NMPA E2B(R3) test pass is the proof point buyers will ask you to match.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					6. MONTHS 3-6 — License MedDRA (MSSO) and WHODrug (UMC), ship an ingest pipeline into meddra_term_reference (which no migration currently creates), and build the twice-yearly version-upgrade and re-coding path. Then add auto-coding on the intake form. This is a hard dependency for every other PV capability and it carries recurring licence cost that must go into the model. 7. MONTHS 4-7 — Make Part 11 real. Convert writePvAudit from best-effort (pharmacovigilanceService.ts:1233-1278, silently returning false at :1271-1274 and swallowed by .catch(()=>false) at :1216) into a transactional write in the same commit as the state change, and add e-signature gating on case submit, ICSR release and signal closure. Reuse the existing recordGovernedAction path the file itself points at (:1229-1231) rather than the PV-local shortcut. 8. MONTHS 5-9 — Produce a PV-scoped validation package: validation plan, URS, functional and design specs, IQ/OQ/PQ protocols and a requirements-to-test traceability matrix against ICH E2B(R3), ICH E2A/E2C(R2)/E2F, 21 CFR 312.32, 21 CFR 314.80 and 21 CFR Part 11. docs/validation/VMP-CORTEX-001-VALIDATION_MASTER_PLAN.md currently mentions none of these. Without this you cannot answer a vendor qualification questionnaire, and Veeva's vendor-executed IQ/OQ-per-release with a customer validation package is the benchmark you are measured against. 9. MONTHS 6-12 — Close the two mandatory functional gaps: literature monitoring (Embase/Medline ingestion, abstract screening, ICSR triage, EMA MLM reconciliation) per GVP Modules VI/VIIa, and probabilistic duplicate case detection. Both are table stakes, not differentiators. Then complete signal management workflow — owner, dates, evidence links, validation/assessment/closure transitions — against the gap the code already documents at pharmacovigilance-board.routes.ts:66. 10. QUICK WIN, DAYS — Fix server/fda_faers_client.js:274, which reports total_reports as the returned page length (default limit 100) instead of meta.results.total read at :202. Every FAERS count shown to a user today is silently truncated. One line, and it removes a demo-killing wrong number. 11. STRATEGIC ALTERNATIVE — recommended. Do not chase parity. Twelve to eighteen months plus MedDRA/WHODrug licences and a gateway certification cycle buys entry to a category where ArisGlobal, Veeva and IQVIA are competing on measured automation at 1M-case scale. Reposition instead: keep the signal-statistics engine and the reporting-clock engine as differentiated analytics that sit ON TOP of the customer's existing Argus or Vault Safety via E2B import, and sell the platform on regulatory submissions where it is actually strong. That preserves the genuinely good code, removes the Part 11/validation exposure, and converts a losing category into an integration.

Verdict

● **Not competitive** — Score the four things that actually gate a PV purchase and we register 0, 1, 0, 0: no case intake UI, non-conformant E2B(R3) XML, a gateway transport that throws by construction, and a validation master plan with zero PV coverage. A safety database that cannot accept a case, cannot emit schema-valid ICSR XML, cannot transmit to any agency, has no MedDRA dictionary, and has a Part 11 audit trail that silently returns false on failure is not a product a QPPV can buy — it would not survive the first fifteen minutes of a vendor qualification questionnaire, let alone an EMA PV inspection. The signal-detection mathematics is genuinely good (PRR/ROR+CI/Yates chi-squared/EBGM/EB05 with cited literature and an honestly declared approximation, plus real automatic 2x2 cross-tabulation over org data at pharmacovigilance-board.routes.ts:133-187), and the expedited-reporting clock is clean and live-computed — but both compute over a case store nothing can populate. Reachability compounds it: PV is absent from the five-destination global rail (registryModel.ts:116-122), accessible only by ÆK, and one of the three named surfaces (PvSignal.tsx) is imported by nothing at all. Meanwhile the field has moved decisively past feature parity into measured automation — ArisGlobal NavaX is in production on >1M cases at >95% accuracy, IQVIA Detect claims up to 80% fewer false positives, Veeva ships multilingual MedDRA coding plus duplicate detection and validates every release itself three times a year — so even a fully-built version of what is here would be arriving two product generations late. The correct read for an acquirer is that this is a competent PV statistics library and reporting-clock engine wearing the label of a PV platform. Do not underwrite any PV revenue in the model, and do not let the presence of pharmacovigilanceService.ts, an E2B composer and an ICSR gateway module in the file tree be mistaken for a shipping safety system — they are, respectively, a CRUD layer, a non-conformant XML serializer, and a module whose only runtime behaviour is to throw.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
APPENDIX B · COMPETITIVE					

QMS: SOP / document control, CAPA, change control, deviatio...

Verdict:


Not competitive

Weighted capability score — us 1.6 / 5 vs best competitor 4.9 / 5 across 13 dimensions.

Full category as scoped: QMS: SOP / document control, CAPA, change control, deviations & nonconformance, GxP training

Who buys, and what they are actually buying

The VP/Head of Quality (or Quality Systems Manager) at a 50–1,000-person biotech, medtech or CDMO, with the CFO co-signing and IT/CSV validating. They hold a \$25K–\$250K/yr line item and they are buying one outcome: surviving an FDA/Notified Body inspection without a 483 observation on document control, CAPA closure, or training records. Concretely they buy (a) a system of record that is itself validated (vendor IQ/OQ/PQ package + release-by-release validation docs), (b) 21 CFR Part 11 e-signatures on every quality approval, (c) a defensible training matrix showing every employee is current on every effective SOP, and (d) an auditor-ready export in the room during an inspection. Secondary buyer in medtech is the RA lead who wants QMS and submission evidence in one place. AI is a tiebreaker in 2026, never the reason for the purchase — no Head of Quality has ever been fired for slow root-cause narratives, but plenty have for an unvalidated system.

Market structure

MARKET SIZE AND SHAPE. The pharmaceutical QMS software market is projected to grow from USD 1.59B (2025) to USD 2.98B (2030) at 13.3% CAGR; the broader QMS software market is forecast at \$20.43B by 2031. Pharma firms accounted for >57.29% of life-sciences QMS revenue in 2024, so a device-first product addresses well under half the money. Veeva and MasterControl are named the leading players in pharmaceutical QMS; the rest of the field — Dassault, IQVIA (Pilgrim), AmpleLogic, Qualio, QT9, Sparta/TrackWise (Honeywell), AssurX, ETQ (Hexagon), Qualityze, Ideagen — sits behind them. The category is consolidating: high M&A activity as players buy technical capability and share (Honeywell/Sparta, Hexagon/ETQ are the completed examples).

PROCUREMENT PATTERN. This is a replacement sale, not a greenfield sale. The buyer already has SOPs somewhere — SharePoint, paper, or a legacy eQMS — and is migrating under audit pressure or investor pressure. Two distinct motions: (1) Emerging-company motion (\$12K–\$60K/yr, 4–12 week cycle): Qualio, Dot Compliance Xpress, Greenlight Guru. Decided on time-to-value and the pre-validation package. Qualio's "deploys in weeks, pre-validation package used by 99% of customers" is the canonical winning line. Vendr median for Greenlight Guru is \$43,989/yr with observed deals \$20,975–\$54,739 — that is the real mid-market band. (2) Enterprise motion (\$100K–\$1M+/yr, 6–18 month cycle): Veeva Vault Quality, MasterControl. Base-plus-named-user (Veeva ~\$50–\$200/user/month) or \$25K entry scaling past \$100K (MasterControl). Decided by a formal RFP with a CSV/validation workstream, a security review, and a supplier-audit of the vendor's own quality system.

THE GATING QUESTION IN EVERY DEAL. Before any feature is discussed, the buyer asks: "Send me your validation package and your Part 11 statement." Veeva answers with built-in validation documentation supplied with each release plus a Part 11/Annex 11 compliance statement on QualityDocs. Qualio answers with a pre-validation package and documented IQ/OQ/PQ. MasterControl answers with Part 11 + Annex 11 compliance and an ISO 42001-certified AI management system. Dot answers with "pre-built and pre-validated." A vendor without an answer does not reach the demo. This is not a scoring dimension among many — it is the qualifying gate.

WHERE AI ACTUALLY SITS IN 2026. The market has moved past copilots. Industry commentary is explicit that successful quality organisations are no longer running standalone tools or copilots outside the QMS; they are embedding AI directly into existing validated workflows at the points that rely on manual review, free text and institutional memory — which is precisely deviation investigation, root-cause narrative, and CAPA drafting. Two vendors shipped agentic capability in April 2026 in the same month: Veeva's AI Agents for Quality (GA April 2026, Anthropic + Amazon models on Bedrock, with the Deviation Agent generating investigation and CAPA-plan narratives) and Dot Compliance's Dottie AI 5.0 Personas (GA 21 April 2026). MasterControl differentiates on AI governance rather than agent count, holding ISO 42001 certification since July 2025 and marketing Assist AI as "validated and ready to use." The implication for a challenger: the AI-native window in eQMS effectively closed in April 2026. AI is now a feature comparison inside validated systems, not a wedge against them.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
-----------	--------	----	--------------------	----------------	--------------

The five closest competitors

Veeva Systems — Vault Quality (Vault QMS + QualityDocs + Training + Station Manager + Validation Management) — Vault QMS with the surrounding Vault Quality application family on the single Vault platform

The enterprise default for pharma/biopharma and increasingly medtech. Sold as 'one platform for quality, clinical and regulatory' — the QMS shares the Vault object model with Vault RIM, so quality events and submission content live in one system. Land is usually QualityDocs + QMS; Training, Station Manager, LIMS, Batch Release and Validation Management are the expansion path.

Strengths

- Complete process coverage on one platform: deviations, CAPA, change control, audits, complaints, plus QualityDocs for controlled SOP content and Training for GxP curricula tied to those SOPs
- QualityDocs is stated as FDA 21 CFR Part 11 compliant with electronic records, e-signatures and audit trails, EU Annex 11 compliant, and ships built-in validation documentation with each release — this is the single biggest procurement unlock
- Training application creates curricula from QualityDocs SOPs/policies, assigns by role, and tracks completion and re-certification — the exact artifact a 483 turns on
- Ships a real, in-product AI agent: the Deviation Agent generates narrative summaries of the investigation or CAPA plan for a Deviation, pulling from related Investigation and Root Cause records, and answers questions about the deviation via Vault AI Chat
- AI Agents for Quality reached general availability April 2026, running on LLMs from Anthropic and Amazon via Bedrock — this is shipped, not roadmap
- Station Manager puts controlled documents on the manufacturing floor on approved tablets — closes the paper-on-the-line gap most cloud eQMS vendors leave open

Weaknesses

- Most expensive option; base-plus-named-user model means costs scale badly for large operator populations
- Implementation is a consulting engagement, typically multi-quarter, and configuration debt is real
- Deviation Agent as shipped is summarization/Q&A over existing records — it does not classify a GMP deviation against 21 CFR 211.192 thresholds or derive Field Alert / recall evaluation triggers
- Pricing is never published; every deal is a negotiated multi-year contract, which slows small-buyer procurement
- Overkill for a sub-200-person biotech; frequently loses those deals to Qualio/Dot on time-to-value

AI ship ped today	Shipped as of 2026: Deviation Agent in Vaults licensed for Vault AI for Quality — generates investigation/CAPA-plan narrative summaries from related records and answers deviation questions in Vault AI Chat. Veeva AI Agents for Quality (and PV) became generally available April 2026, powered by Anthropic and Amazon models on Amazon Bedrock, targeting quality-event summarization, investigation narrative generation, translation and APQR drafting. Customers can build their own agents. Human review remains required — the agent drafts, the quality unit approves.
GxP / validation post ure	Strongest in the set. QualityDocs stated FDA 21 CFR Part 11 compliant (e-records, e-signatures, audit trails), EU Annex 11 compliant, with built-in validation documentation supplied with each release. A separate Vault Validation Management application manages IQ/OQ/PQ protocols and execution for the customer's own systems.
Pricing sign al	Not public. Industry analysis of 2026 deals reports a base-plus-named-user model — an annual base subscription per application/environment plus per-user licences, with standard Vault fees roughly \$50–\$200 per user per month (low hundreds to low thousands of dollars per user per year). AI agent pricing not disclosed.

► Sources

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
			MasterControl — Quality Excellence — MasterControl Quality Excellence (document management, CAPA, deviations, change control, training, audits, complaints) on the ADAPT platform, with MasterControl Assist AI		
			The manufacturing-heavy incumbent. Positions as 'AI-first quality' for regulated manufacturers, with the strongest story where quality meets the shop floor (eDHR / electronic batch records feeding deviations). Deepest install base in pharma manufacturing and long-tenured medtech.		
			Strengths		
			- Centralises CAPA, deviations, change control, training, document control and audit management in one integrated environment at enterprise scale - Stated 21 CFR Part 11 and EU Annex 11 compliant — the procurement checkbox is answered out of the box - ISO 42001 certification (July 2025) for its AI management system, explicitly covering layered security, validation and compliance oversight of its AI tools for life sciences — this is the most defensible AI-governance credential in the category and directly answers the CSV lead's 'how do I validate your AI' question - MasterControl Assist AI is marketed as validated and ready to use for content generation and quality trend monitoring — validated AI, not beta AI - eDHR captures live shop-floor data, flags deviations and links them to batch records — closes the manufacturing-to-quality loop that pure cloud eQMS vendors cannot - March 2026 expansion of the AI-first quality platform including support for secure AI adoption inside regulated quality processes		
			Weaknesses		
			- Legacy UX; long-standing user complaints about configuration complexity and admin burden - Priced and scoped for mid-to-large manufacturers — the \$25K entry plan is thin and real deployments land far higher - Implementation and validation effort is substantial; not a weeks-to-value product - Weaker than Veeva on unifying quality with regulatory submission content		
			AI shipped today		Shipped: MasterControl Assist AI for content generation and quality trend monitoring, described as validated and ready to use. The ADAPT platform is built in alignment with ISO 42001 to provide a compliant foundation for AI services with regulatory and manufacturing context. Company reports the AI tooling saves customers 1,000+ hours/year. No publicly documented autonomous deviation-classification agent.
			GxP / validation posture		Stated 21 CFR Part 11 and Annex 11 compliant; ISO 42001 certified AI management system (July 2025) covering validation and compliance oversight of AI tools. Vendor validation packages and validation services are part of the standard commercial motion.
			Pricing signal		Quality Excellence starts at ~\$25,000/year for the Basic plan (analytics, document management, BI, change control) and commonly scales past \$100K/year. SaaS subscription with per-user licences (full-access and basic/read-only tiers). No public tiered pricing on mastercontrol.com — quote-based.
			► Sources		
			Dot Compliance — eQMS (QMS Xpress / Compliance Xpand / Enterprise Xact) with Dottie AI — Salesforce-native pre-validated eQMS with the Dottie AI assistant and, from 2026, Dottie AI 5.0 agentic personas		
			The AI-native challenger with an incumbent-grade compliance story. Sells 'ready-to-deploy and pre-validated' against Veeva's implementation timeline and MasterControl's admin burden. Salesforce platform gives enterprise IT a familiar security and integration surface.		
			Strengths		
			- Pre-built and pre-validated out of the box with life-sciences best-practice workflows — the shortest credible path from signature to a defensible QMS - Broadest process list in the set: document management, change management, audit management, training, CAPA, complaints, quality events, risk, equipment, electronic batch records and supplier quality		

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					- Dottie AI 5.0 with Dottie Personas — a class of agentic AI specialists intended to operate as members of a hybrid workforce, announced generally available April 2026. This is the most aggressive agentic positioning of any established eQMS vendor - Embedded assistant lets users query quality data conversationally and surfaces proactive compliance insights — the same conversational-QMS thesis Concept2Cure is chasing, already in market inside a validated system - Three-tier packaging (Xpress → Xpand → Xact) lets a 30-person biotech start small and grow without replatforming - Salesforce foundation means SSO, org security model and integration tooling are enterprise-grade on day one Weaknesses - Salesforce dependency adds a platform layer and a second vendor relationship to the risk register - Smaller install base and reference pool than Veeva/MasterControl in large pharma - Agentic personas are new (April 2026) — limited public evidence of inspection-tested outcomes as of mid-2026 - No public per-user pricing; deal shape must be discovered through sales
AI shipped today					Shipped: Dottie, an AI assistant trained on quality and compliance workflows, embedded across the eQMS for querying quality data and surfacing proactive compliance insights. Dottie AI 5.0 with Dottie Personas — agentic AI specialists designed to operate as trusted members of hybrid workforces — announced generally available 21 April 2026. Specific per-process autonomy boundaries and human-review gates are not verified from public sources.
GxP / validation posture					Ships pre-built and pre-validated with industry best practices and key workflows incorporated out of the box — this is the core commercial claim. Detailed contents of the validation package (IQ/OQ/PQ scope, release-by-release regression evidence) not verified from public sources.
Pricing signal					Not public. Independent comparison places it alongside Greenlight Guru and Qualio at roughly \$20K–\$60K/year with a typical one-to-three-year minimum commitment. No per-user rate published on Capterra, GetApp or G2.

► Sources

Qualio — Qualio cloud eQMS (Foundation / Growth / Scale)

The emerging-company default. Explicitly built for life-sciences companies moving off paper or hybrid systems, and the most common first eQMS for a Series A–C biotech or a small medtech. Competes on time-to-value and pre-validation, not on depth.

Strengths

- Deploys in weeks using pre-built life-sciences workflows and a pre-validation package used by 99% of customers — the single most quoted line in this segment's procurement
- Covers document control, training, CAPA, audit management, risk, design controls and pharmacovigilance in one subscription
- Supports FDA 21 CFR Part 11, ISO 13485, EU MDR, MDSAP, GxP and ICH Q10 in one validated system, with Part 11-compliant electronic signatures and documented IQ/OQ/PQ protocols for GxP environments
- Pricing is the most transparent in the category via third-party data — a buyer can budget before the first call
- Tiering by edit-user count with unlimited free basic (read/train) users is exactly right for training compliance economics: you pay for authors, not for the 400 people who must read-and-understand
- Ships AI for predictive quality-issue identification, automated root-cause and CAPA-monitoring analysis, anomaly detection, AI-assisted document review, predictive risk analysis and AI-powered search

Weaknesses

- Depth ceiling: enterprise pharma manufacturing processes (batch records, shop-floor deviation intake, complex multi-site change control) outgrow it
- Less configurable than MasterControl/Veeva; opinionated workflows are a virtue at 50 people and a constraint at 500

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					- AI features are analytics-and-assist rather than agentic action inside the governed workflow - Per-user cost is high relative to the base fee, so growth is expensive
AI shipped today					Shipped: AI-powered predictive analytics for identifying quality issues, automated data analysis for root-cause investigation and CAPA monitoring, AI-driven anomaly detection, AI-assisted document review, predictive risk analysis using machine learning, and AI-powered search/knowledge management. No publicly documented autonomous write-agent that transitions quality records.
GxP / validation posture					Strong for the segment. Pre-validation package used by 99% of customers; 21 CFR Part 11-compliant electronic signatures; documented IQ/OQ/PQ protocols for GxP deployments; single validated system spanning Part 11, ISO 13485, EU MDR, MDSAP, GxP and ICH Q10.
Pricing signal					Base platform fee starts around \$12,000/year plus approximately \$3,000 per (edit) user — e.g. ~\$36,000/year for 10 users. Three tiers: Foundation (5 edit + 10 basic users), Growth (10 + 20), Scale (20 + 50); basic users unlimited at no extra cost. Small-team estimates of \$5K–\$15K/year appear in third-party analyses. Qualio's own /pricing page is quote-request only.

► Sources

Greenlight Guru — Quality Management System (with Greenlight Guru AI) — Greenlight Guru QMS — medical-device-only eQMS covering document control, CAPA, design controls, risk, complaints, training and traceability

The medtech-only specialist and the most likely head-to-head for Concept2Cure's device segment. Sells depth-in-one-vertical: design controls, ISO 14971 risk and traceability wired to the QMS, rather than a horizontal quality platform configured for devices.

Strengths

- Only eQMS in this set built exclusively for medical device companies; 1,100+ medtech customers with pre-configured workflows aligned to ISO 13485, FDA 21 CFR Part 820/QMSR, ISO 14971 and EU MDR
- Differentiator that actually decides medtech deals: design controls, risk management and traceability linking user needs → design inputs → outputs → V&V → approvals inside the same eQMS as CAPA and document control
- Core Part 11 machinery present — document control, audit trails, electronic signatures, CAPA workflows
- Greenlight Guru AI works from the customer's own QMS data (documents, records, traceability) and keeps outputs inside the governed system — the correct architecture for regulated AI
- Strong brand and reference density in medtech; often shortlisted by default

Weaknesses

- Medtech-only — irrelevant for a pharma/biotech buyer, which halves its addressable overlap with a multi-vertical platform
- Pricing rose sharply: reports of an increase starting January 2026 potentially approaching +100% without new features, plus a mandatory \$2,000–\$5,000 one-time onboarding fee — this is actively creating switching intent in the installed base
- AI GA is targeted for Q2 2026 with beta customers ahead of broad release, so as of mid-2026 the AI story is newer and thinner than Veeva's or Dot's
- No manufacturing/batch-record depth; weak for combination products and drug-side quality

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					AI shipped today Greenlight Guru AI is grounded in the customer's own QMS documents, records and traceability, with outputs staying inside the governing system. GA targeted for Q2 2026, with beta customers getting early access and shaping features before broad release. The specific per-feature GA set as of July 2026 is not verified from public sources.
					GxP / validation posture Pre-configured workflows aligned to ISO 13485, FDA 21 CFR Part 820/QMSR, ISO 14971 and EU MDR; ships document control, audit trails and electronic signatures. Vendor validation-package specifics not verified from public sources.
					Pricing signal Not published by the vendor. Verified third-party data: annual cost ranges \$25,000–\$35,000 for small teams to \$50,000–\$60,000+ for larger multi-module deployments; Vendr procurement median \$43,989/year with observed deals \$20,975–\$54,739. Alternative reported structure ~\$500/month for a single user scaling to ~\$10,000/month at 100 users. Price increase from 01/2026 reported as potentially +100%; budget \$2,000–\$5,000 mandatory one-time onboarding.
► Sources					

Capability rubric

Our score is cited to `file:line` in this repository. Theirs is cited in the competitor sections above. Scored on what **ships and is reachable**, not what is architected — an unreachable or unvalidated capability scores low regardless of code quality.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Vendor validation package + Part 11/Annex 11 compliance statement (the qualifying gate — no package, no evaluation)	critical	1 ▼	Veeva Vault QualityDocs — Part 11 e-signatures/audit trails, EU Annex 11, built-in validation documentation with each release	5	docs/validation/VMP-CORTEX-001-VALIDATION_MASTER_PLAN.md:1-20 (scoped to 'Cortex Prime AI System', v1.0.0-DRAFT, 'REQUIRES VALIDATION REVIEW BEFORE PRODUCTION USE', Approved By: PENDING — no QMS-module coverage); server/routes/part11-compliance.ts:1132-1149 (every §11.10 section returned as 'not_assessed', overallStatus 'not_assessed', readinessScore null, disclaimer 'Self-assessment only'), rendered by client/src/concept2cure/v2/surfaces/Part11Console.tsx:7-13
21 CFR Part 11 electronic signature on quality approvals — §11.200 two identification components + §11.50 signature manifestation on SOP approval, change approval, CAPA closure	critical	1 ▼	Veeva Vault QualityDocs / MasterControl / Qualio (all three at parity)	5	server/routes/c2c/actions.ts:74 (HIGH_RISK_COMMANDS = {'sign','lock','revoke-signature','transmittal_rollback'}) vs server/services/ana/AnaToolExecutor.ts:13239 (SOP approval records command:'transition' — not high-risk, so the re-auth at actions.ts:225-236 never fires); AnaToolExecutor.ts:13426-13453 (change transition bypasses the ledger entirely, calling auditService.logAction); server/services/part11ComplianceService.ts:546 (working bcrypt second-factor exists) with zero QMS callers — only server/services/510kComplianceTracker.ts:16 imports it
Reachability — can the target user find and operate the QMS from the product's own navigation	critical	1 ▼	Qualio / Veeva / MasterControl / Dot / Greenlight Guru (the QMS is the product)	5	client/src/concept2cure/v2/registryModel.ts:116-122 (RAIL_PRIMARY = 5 destinations, none is Quality) and :170 ('quality' in NAV_HIDDEN); db/migrations/20260220_user_intelligence_platform.sql:78 (available_modules seed = 18 modules, no Quality/QMS row, so the Apps catalog cannot surface it); registryModel.ts:467/493/551/634 (SEGMENT_MODULES lists quality but is imported only by client/src/concept2cure/v2/tests/registryModel.test.ts:20); reachable only via %K (Shell.tsx:982, which does not filter NAV_HIDDEN) or the URL /concept2cure/quality
GxP training management — role-based curricula, assignment, due/overdue per	critical	1 ▼	Veeva Vault Training — curricula built from QualityDocs SOPs, assigned by role, completion and re-	5	migrations/20260511_qms_and_labeling.sql:51-70 (qms_training_records has user_id/document_version/quiz_score/expires_at but no curriculum, assignment, role or due-date table); server/routes/mdx-qms.ts (training endpoints are list, expiring, compliance, ack only); client/src/concept2cure/quality/hooks.ts:105-118 (compliance = distinct current acknowledgements over org roster); no

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
person, retraining cycle, effectiveness check, inspection-ready training matrix			certification tracked		assignment engine, scheduler, notification or matrix export anywhere
Deviation / nonconformance management — intake, classification, investigation, product impact and batch disposition, closure	critical	1 ▼	Veeva Vault QMS (deviations native, with Deviation Agent narrative generation) / MasterControl (eDHR shop-floor deviation capture linked to batch records)	5	shared/schema.ts:9737 (deviations table fully specified, zero routes/services/UI — grep finds no reads or writes); server/routes/qc.routes.ts:41-47 and server/storage.ts:1524,1528 (QC deviations and OOS investigations return HTTP 501 NOT_IMPLEMENTED); qms_nonconforming_products has endpoints in mdx-qms.ts but no client consumer; only GCP protocol deviations are built (server/services/protocol-deviations/, 301 lines)
Controlled document control — lifecycle, periodic review, versioning, rendered document viewing, controlled copy, redline	critical	2 ▼	Veeva Vault QualityDocs + Station Manager (controlled content, floor-level tablet access)	5	server/routes/mdx-qms.ts:79-115 (8 doc types, 5-state lifecycle, review dates, template-seeded sections, nextMajorVersion bump) and 35 endpoints total — the model is real; but client/src/concept2cure/quality/SopRegister.tsx:10-15 is explicitly read-only ('No mutation is performed directly here'), there is no document viewer, no redline, no controlled-copy print, and no approval inbox anywhere in client/src/concept2cure/quality/
Data integrity / ALCOA+ — no synthetic records presented as real, immutable audit trail	critical	2 ▼	Veeva / MasterControl / Qualio (validated systems never render fixtures)	5	Strong substrate: server/services/auditService.ts:251-302 (SHA-256 hash chain, HMAC seal, immutability triggers). Fatally undercut by client/src/concept2cure/quality/SopRegister.tsx:80,86 (reg.docs ?? FIXTURE_DOCS , trainComp.rows ?? FIXTURE_TRAINING) and ChangeControl.tsx:73-74 — on error or unprovisioned tenant the register renders 8 invented SOPs (data.ts:146-155, e.g. 'SOP-820-100 CAPA v5.0 effective 2026-03-30') and '47 of 47' training compliance with no badge or state marker; contrast client/src/concept2cure/v2/surfaces/Training.tsx:29-33 which is fixture-free with honest EmptyState
CAPA lifecycle — root cause, action plan,	critical	2 ▼	Veeva Vault QMS (CAPA native with agentic CAPA-plan	5	Backend is genuinely strong: server/services/capa-mdr/stateMachine.ts:87-88 (action_implemented → effectiveness_check → closed_effective closed_not_effective escalated),

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
effectiveness verification, closure gating, and a working front end			narrative) / Qualio (CAPA with pre-validated workflow)		capaMdr.service.ts (1,022 lines, org-scoped, audited), shared/schema/capa-mdr.ts:398-399 (effectivenessCheckCriteria/Result), clockCalculator.ts + triageEngine.ts for 21 CFR 803 / EU MDR Art. 87 reportability. But the only CAPA UI is client/src/concept2cure/v2/surfaces/DeviceSubmission.tsx:285-287, which no file imports; the second is PostmarketSurface.tsx routed at mdx/App.tsx:240 under nav id 'postmarket', absent from mdx/data/nav.ts:31-49. Device postmarket CAPA only — no general pharma CAPA record exists
Change control — impact assessment, segregation of duties, implementation, effectiveness verification, cross-record linkage (ICH Q10 §3.2.3 / Annex 15)	high	3 ▼	Veeva Vault QMS (change control native, object-graph linked to deviations/CAPA/docs, e-signed)	5	server/services/qms/changeControl.service.ts:46-55 (explicit 8-state machine, illegal transitions throw), :203-205 (SegregationOfDutiesError — approver must differ from proposer, enforced in code), :31-36 (typed links to deviation/capa/validation/document/sop/supplier/risk with 5 relationship kinds); tested at server/services/qms/tests/changeControl.pglite.integration.test.ts; real read UI at client/src/concept2cure/quality/ChangeControl.tsx (375 lines) + ChangeFlow.tsx lifecycle chart. Capped at 3: no e-signature on approval, no impact-assessment form in the UI, all writes are chat-only, and links are free-text refs because no deviation register exists to link to
AI that acts inside the governed quality workflow — classify, draft, transition — with human-in-loop and audit trail	high	4	Veeva Deviation Agent + AI Agents for Quality (GA April 2026, Anthropic/A mazon on Bedrock) — narrower in scope but inside a validated, e-signed system; Dot Compliance Dottie 5.0 Personas (GA 21 April 2026) comparable	4	server/services/gmp-quality-systems/gmp-quality-systems-knowledge.ts:1554 classifyGMPDeviation (critical/major/minor with per-rule rationale, 24/48/72h response clock, 21 CFR 211.192 30-day investigation target, batch disposition, and automatic 21 CFR 314.81(b)(1) Field Alert + Part 7 recall evaluation triggers) and :1308 designCAPA (ICH Q9(R1) §5.2 proportionate formality, cited root-cause method selection, ICH Q10 §3.2.2 correction/corrective/preventive split, effectiveness checks with acceptance criteria and 3/6-month timing); 6 tools exposed via gmpQualitySystemsTools.ts:33-458, registered at AnaToolDefinitions.ts:2174; 11 QMS write tools at qms-labeling-analytics-tool-defs.ts:18-186 with real handlers at AnaToolExecutor.ts:13152/13205/13353/13393/13426 — tenant-scoped, transactional, audited, reason-for-change enforced (13432), SoD surfaced to the user (13449)
Supplier quality, internal audit and management review	medium	1 ▼	Dot Compliance (supplier quality, audit management, equipment, eBR in one	5	migrations/20260511_qms_and_labeling.sql:72 ,95,121 (qms_suppliers, qms_internal_audits, qms_management_reviews) and endpoints in server/routes/mdx-qms.ts — zero client consumers; a second unused router at server/routes/qms.ts (227 lines, mounted via server/bootstrap/register-document-

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
			pre-validated suite)		routes.ts:292) covers the same ground with no UI either
Time to a defensible, validated go-live (preconfigured GxP workflows + procedure library)	high	1 ▼	Qualio — deploys in weeks on pre-built life-sciences workflows with a pre-validation package used by 99% of customers	5	server/services/qms/sopTemplates.ts (199 lines, 7 generic templates sharing one STANDARD_SECTION skeleton — client/src/concept2cure/quality/data.ts:135-143); no ISO 13485 / 21 CFR 820 / QMSR procedure library, no preconfigured validated workflow pack, no migration tooling, no customer validation deliverables
Inspection readiness and quality analytics (483 response clock, readiness scoring, management-review metrics)	high	2 ▼	MasterControl (quality trend monitoring + AI-assisted audit readiness) / Veeva (audit readiness summarisation agents)	4	server/services/inspection/inspection-service.ts + server/services/inspection/inspection-logic.ts (Form 483 responses default to 15 business days from inspection end; per-area readiness scoring), mounted at server/bootstrap/register-inline-routes.ts:688; server/routes/mdx-qms.ts:160-275 (cross-domain readiness aggregate with honest available:false degradation). Scored 2 because the only inspection UI is the unreferenced DeviceSubmission.tsx:333, and useQmsReadiness is consumed only by client/src/concept2cure/mdx/projectHome/ProjectHome.tsx:202, itself inside the “K-only MDX app

Where we stand

Where we win

- Deterministic, citation-bearing GMP quality reasoning that no competitor ships. server/services/gmp-quality-systems/gmp-quality-systems-knowledge.ts is 2,558 lines of real regulatory logic: classifyGMPDeviation (line 1554) takes area, patient-safety impact, OOS status, sterility and recurrence and returns a critical/major/minor classification with per-rule rationale, a 24/48/72-hour initial-response clock, a 30-day investigation target anchored to 21 CFR 211.192, a product-impact and batch-disposition recommendation, and — the part nobody else has — automatic Field Alert Report evaluation against 21 CFR 314.81(b)(1) with the 3-working-day clock, and a recall/health-hazard evaluation trigger against 21 CFR Part 7. designCAPA (line 1308) applies ICH Q9(R1) §5.2 QRM-proportionate formality, selects a root-cause method with citations, separates correction/corrective/preventive per ICH Q10 §3.2.2, and emits effectiveness checks with acceptance criteria and 3/6-month review timing. Veeva’s Deviation Agent summarises records; this reasons to a regulatory conclusion.
- Write-capable AI inside the governed workflow, not a read-only assistant. 11 QMS write tools are registered in the model’s live tool registry (server/services/ana/qms-labeling-analytics-tool-defs.ts lines 18–186: create/approve/revise/retire_qms_document, ack_training, register_supplier, log_nonconforming_product, qms_change_create/transition/link) plus 6 GMP reasoning tools (gmpQualitySystemsTools.ts, registered at AnaToolDefinitions.ts:2174). Handlers are real, tenant-scoped, transactional and audited — qms_change_transition (AnaToolExecutor.ts:13426) refuses to execute without a reason-for-change of ≥3 characters and surfaces the segregation-of-duties error verbatim to the user. A quality engineer can raise, assess, approve and link a change control in conversation. Neither Veeva’s Deviation Agent nor Qualio’s assist layer transitions records.
- Change control that is architecturally correct and provably tested. server/services/qms/changeControl.service.ts implements the ICH Q10 §3.2.3 / EU GMP Annex 15 lifecycle as an explicit state machine (lines 46–55: proposed → under_assessment →

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					approved/rejected → in_implementation → verification → closed, with cancel from any live state and rejected/closed/cancelled terminal), enforces segregation of duties in code (lines 203–205: the approver must differ from the proposer), and carries a typed cross-reference table linking a change to deviations, CAPAs, validation records, SOPs, suppliers and risks with relationship semantics (triggered_by/addresses/requires/impacts/references). It has a PGLite integration test (server/services/qms/tests/changeControl.pglite.integration.test.ts) and a client component test. This is the one dimension where the design is genuinely competitive with Veeva. - Quality-system readiness as an aggregate that crosses domains. GET /api/mdx/qms/readiness (server/routes/mdx-qms.ts:160) computes effective/overdue-review document counts, unapproved-critical-supplier and overdue-supplier-audit counts, training currency, open audit findings and nonconformance counts in one org-scoped block — and does it honestly, degrading each block independently on a missing table to available:false rather than reporting a misleading zero (documented at lines 154–159: 'a zero from an absent system reads as an all-clear'). That engineering judgment is better than most incumbents' dashboards. - Tamper-evident audit trail with real cryptography. server/services/auditService.ts delegates to a hash-chain log with SHA-256 chaining, HMAC seals and database immutability triggers (lines 251–302), and the platform ships a Part 11 console reading /api/part11/audit-trail/chain-integrity. The substrate for an inspection-grade audit trail exists and is stronger than a plain append-only table. - Adjacent regulatory depth an eQMS vendor cannot match. Inspection readiness with the Form 483 15-business-day response clock and per-area readiness scoring (server/services/inspection/inspection-service.ts, mounted at /api/inspections), and a complete device postmarket chain — complaint → MDR reportability triage → CAPA with an effectiveness_check state that closes to closed_effective / closed_not_effective / escalated (server/services/capa-mdr/stateMachine.ts:87–88, capaMdr.service.ts, 1,022 lines) with FDA 21 CFR 803 / EU MDR Art. 87 / 21 CFR 806 clock calculation. For a medtech buyer this is Greenlight Guru's territory, built.

Where we reach parity

- Controlled-document data model and lifecycle. qms_documents supports 8 document types, the full draft → in_review → effective → superseded → retired lifecycle, periodic review dates with overdue derivation, artifact linkage, template-seeded section skeletons and automatic major-version bump on revision. 35 REST endpoints across mdx-qms.ts cover documents, training, suppliers, internal audits, management reviews, nonconforming products and change control. Structurally this is at parity with Qualio's data model — the gap is everything above the data model.
- Cross-record traceability. The qms_change_links table gives a change control typed references to deviations, CAPAs, validation records and SOPs with relationship semantics — comparable in ambition to Veeva's object-graph linkage, though it links by free-text ref rather than by enforced foreign key to a live deviation record (because no deviation register exists to link to).
- Tenant isolation and governed-action ledger. Every QMS read and write is organization-scoped from the JWT, mutations run BEGIN → setTenantContextTx → recordGovernedAction → COMMIT, and cross-tenant IDOR was explicitly hardened at the compile boundary. Multi-tenant security posture is at or above the mid-market field.

Where we lose

- THE MODULE HAS NO FRONT DOOR. As of HEAD the global rail contains exactly five destinations — Chats, Projects, Communication Center, Apps, Settings (client/src/concept2cure/v2/registryModel.ts:116–122) — and 'quality' was demoted into NAV_HIDDEN (line 170). The fallback discovery surface is the Apps catalog, which renders from /api/module-subscriptions/catalog, seeded from available_modules in db/migrations/20260220_user_intelligence_platform.sql:78 — 18 modules, none of which is Quality/QMS. SEGMENT_MODULES, the registry map that does list 'quality' under 'Review & govern' (registryModel.ts:467, 493, 551, 634), is imported only by a test file and renders nowhere. Net: a Head of Quality can reach the QMS only by typing 'quality' into %K or by knowing the URL /concept2cure/quality. In a competitive bake-off the evaluator never finds it.
- NO ELECTRONIC SIGNATURE ON ANY QUALITY APPROVAL. This is the disqualifying gap. A working Part 11 §11.200 implementation exists — part11ComplianceService.verifyUserCredentials (line 546) does bcrypt password re-authentication for the second identification component, and the governed-action ledger has a re-auth gate — but HIGH_RISK_COMMANDS in server/routes/c2c/actions.ts:74 is exactly {'sign','lock','revoke-signature','transmittal_rollback'}. SOP approval (AnaToolExecutor.ts:13205) records command:'transition', which is not in that set, so no re-auth fires. qms_change_transition bypasses the ledger entirely, calling auditService.logAction directly. Result: an SOP goes effective and a change control gets approved on a session cookie, with no signature manifestation (§11.50: printed name, date/time, meaning), no re-authentication, no signature record. Grep confirms no QMS code path imports part11ComplianceService at all.
- NO VENDOR VALIDATION PACKAGE — AND THE PRODUCT SAYS SO. docs/validation/ contains IQ/OQ/PQ/VMP/traceability documents, but they are scoped to the 'Cortex Prime AI System', versioned 1.0.0-DRAFT, dated 2025-01-24, marked 'REQUIRES VALIDATION REVIEW

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					BEFORE PRODUCTION USE' with Approved By: PENDING. Nothing covers the QMS module. Worse, the shipping product self-reports the answer: GET /api/part11/compliance-status returns overallStatus 'not_assessed' with every §11.10 section 'not_assessed', readinessScore null and the disclaimer 'Self-assessment only' (server/routes/part11-compliance.ts:1132–1149) — and Part11Console renders it. A buyer clicking the compliance console in the demo sees the vendor state it has not assessed its own Part 11 compliance. Against Veeva shipping validation documentation with every release and Qualio's pre-validation package used by 99% of customers, this ends the evaluation. • THE QUALITY SURFACE FABRICATES QUALITY RECORDS. SopRegister.tsx:80 does <code>const docs = reg.docs ?? FIXTURE_DOCS</code> and line 86 <code>const training = trainComp.rows ?? FIXTURE_TRAINING</code>; ChangeControl.tsx:73–74 does the same for changes and KPIs. On an unauthenticated session, an unprovisioned tenant, or any fetch error, the register renders eight invented SOPs with invented numbers, versions and effective dates (QM-001 v4.0, SOP-820-100 CAPA v5.0 effective 2026-03-30, VP-7 sterilizer OQ/PQ) and a training board reading '47 of 47' — with no badge, watermark or state distinguishing them from real records. In a GxP system of record this is an ALCOA+ attributability and accuracy defect, and it is the specific thing a diligence QA lead will screenshot. The rest of the platform already does this correctly — Training.tsx uses fixture-free live reads with honest EmptyState components, and Apps.tsx is explicitly 'fixture-free' — so the QMS surface is the outlier, not the house style. • NO DEVIATION REGISTER. The category name includes 'deviations' and there is no place to record one. The <code>deviations</code> table in shared/schema.ts:9737 (deviation_number, severity, investigation_status, root_cause, batch_disposition, regulatory_reporting_required) has no route, service or UI — <code>grep</code> finds zero reads or writes. QC deviations and OOS investigations route to server/routes/qc.routes.ts, whose storage layer throws NOT_IMPLEMENTED and returns an honest HTTP 501 (qc.routes.ts:41–47; server/storage.ts:1524 createQcDeviation, 1528 updateQcDeviation). qms_nonconforming_products has endpoints but no UI. Only protocol deviations (GCP, a different regulation) are actually built. classifyGMPDeviation therefore produces an excellent classification with a Field Alert trigger that has nowhere to be written down. • TRAINING IS AN ACKNOWLEDGEMENT COUNTER, NOT A TRAINING SYSTEM. qms_training_records (migrations/20260511_qms_and_labeling.sql:51) has user_id, document_id, document_version, acknowledged_at, method, trainer_id, quiz_score and expires_at — good columns. What is missing is the system: no curriculum table, no role-to-curriculum assignment, no assignment engine, no due/overdue computation per person, no retraining scheduler, no notification, no quiz delivery, no training matrix export. 'curriculum' exists only as a document type string. The compliance endpoint divides distinct current acknowledgements by the org roster. Veeva Training builds curricula from QualityDocs SOPs, assigns by role and tracks re-certification; Qualio ships training with unlimited free read-and-understand users. On the single artifact an inspector asks for first — 'show me this person's training record against every effective SOP' — we cannot produce it. • THE UI CANNOT MUTATE ANYTHING. SopRegister.tsx documents the decision at lines 10–15: 'No mutation is performed directly here; AnA runs the governed action.' Every button on both quality surfaces calls onAsk(promptString). There is no create-document form, no approval queue, no review-and-approve inbox, no reject-with-reason, no impact-assessment form, no training-acknowledgement action. A quality organisation running 200 change controls a quarter will not conduct them by typing prompts, and an inspector will not accept a chat transcript as the approval record. • THE CAPA AND INSPECTION UIs ARE UNREACHABLE CODE. client/src/concept2cure/v2/surfaces/DeviceSubmission.tsx holds the only complaint/MDR/CAPA panels (lines 285–287) and the only inspection-readiness panel (line 333) — and nothing imports it. Grep across client/src returns exactly one hit, a comment in EditorCanvas.tsx. The 'device-submission' registry id aliases to DeviceWorkstream, not to this file. The second CAPA UI, PostmarketSurface.tsx, is routed inside mdx/App.tsx:240 under the nav id 'postmarket' — which does not appear in that app's NAV_ITEMS (client/src/concept2cure/mdx/data/nav.ts:31–49). So the 1,022-line CAPA service is behind a hash deep-link, inside an app that is itself only reachable by <code>⌘K</code>. Three complete backends, zero doors. • SUPPLIER QUALITY, INTERNAL AUDITS AND MANAGEMENT REVIEW HAVE NO UI AT ALL. Tables and endpoints exist in mdx-qms.ts; no client code consumes them. A second full QMS router, server/routes/qms.ts (227 lines, mounted at /api/qms via register-document-routes.ts:292), has zero client consumers — two parallel QMS APIs, one entirely unused. • NO DOCUMENT CONTENT. The register is metadata. There is no rendered SOP body, no PDF/Word viewer, no watermarked controlled-copy print, no read-and-understand reading pane, no redline between versions, no shop-floor access. Veeva ships QualityDocs plus Station Manager for tablets on the manufacturing floor. A document-control system that cannot display the document is not a document-control system. • NO PRECONFIGURED QMS CONTENT. Seven generic SOP templates with a shared section skeleton (server/services/qms/sopTemplates.ts, 199 lines). Competitors ship complete ISO 13485 / 21 CFR 820 / QMSR procedure libraries and pre-built validated workflows that let a customer go live in weeks. Time-to-value is the whole basis of the emerging-company purchase and we have no answer.

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
-----------	--------	----	--------------------	----------------	--------------

Is the advantage durable?

NOT DURABLE, AND THE WINDOW IS ALREADY MOSTLY CLOSED.

The one real advantage is the deterministic, citation-bearing GMP reasoning layer — classifyGMPDeviation deriving a 21 CFR 211.192 classification, a 24/48/72-hour response clock, a batch disposition, and automatic Field Alert (21 CFR 314.81(b)(1), 3 working days) and Part 7 recall evaluation triggers; designCAPA applying ICH Q9(R1) §5.2 proportionate formality with cited root-cause method selection and effectiveness criteria. That is 2,558 lines of encoded regulatory judgment, and it is not a weekend of prompt engineering — call it 6–12 months of domain-expert-plus-engineer time to reproduce with equivalent citation fidelity.

But three things make it non-durable in this category:

FIRST, THE INCUMBENTS ALREADY SHIPPED THE CATEGORY-DEFINING VERSION. April 2026 was the month the window closed. Veeva's AI Agents for Quality reached GA in April 2026 on Anthropic and Amazon models via Bedrock, with the Deviation Agent generating investigation and CAPA-plan narratives from related records and answering deviation questions in Vault AI Chat. Dot Compliance made Dottie AI 5.0 with agentic Personas generally available on 21 April 2026. MasterControl markets Assist AI as validated and ready to use and has held ISO 42001 certification for its AI management system since July 2025. Industry commentary is explicit that the market has moved past standalone copilots to AI embedded in existing validated workflows. Our depth advantage is real but narrow — reasoning-to-a-regulatory-conclusion versus summarisation — and it sits on the wrong side of the validation line.

SECOND, THE MOAT IS UNREACHABLE AND THEREFORE UNMONETISABLE. An advantage a buyer cannot see in a demo generates no pricing power and no reference customers. Today the quality module is not in the rail, not in the Apps catalog, and reachable only by \$6K or a memorised URL; the CAPA UI is imported by zero files. You cannot defend a position you have never occupied. Every month this stays true, the incumbents accumulate the thing that actually compounds in this market — inspection-tested reference accounts — while we accumulate nothing.

THIRD, THE ASYMMETRY RUNS AGAINST US. Veeva or Qualio adding deviation-classification logic to an already-validated, already-e-signed, already-deployed QMS is a feature release: they have the record to write into, the signature to bind it with, and the validation evidence to ship it under. We adding validation, e-signatures, a deviation register and a training system is a rebuild of the product's foundation. They are 2–4 quarters from our differentiation; we are 3–5 quarters from their table stakes. Realistically the reasoning advantage is defensible for about 12 months and is not defensible at all inside this category — where validation and reachability, not reasoning quality, decide deals.

FOR THE ACQUIRER: do not underwrite this as an eQMS. Underwrite the gmp-quality-systems knowledge engines, the 17 governed write-tools with segregation-of-duties enforced in code, and the hash-chained audit substrate as an AI/regulatory-intelligence asset — most valuable embedded into a validated eQMS (whether an acquirer's own or a partner's), least valuable as a standalone challenger to Qualio at \$36K/year. Price the QMS category at option value, not at revenue.

Shortest credible path to parity

- WEEK 1 — Stop the two findings that end diligence, both one-day changes. (a) Delete 'quality' from NAV_HIDDEN (client/src/concept2cure/v2/registryModel.ts:170) or, better, add a 'quality-management' row to the available_modules seed (db/migrations/20260220_user_intelligence_platform.sql:78) with path /concept2cure/quality so the module appears in the Apps catalog the shell already renders — the design constitution's five-destination rule is satisfied by Apps, so no rule is broken. (b) Remove the fixture fallbacks: SopRegister.tsx:80,86 and ChangeControl.tsx:73-74 become honest empty/error states using the EmptyState component already used in Training.tsx:52-57 and the pendingStore meta flag mdx-qms.ts:1010 already returns. A QMS that invents SOP records will not survive a QA diligence read, and the correct pattern is already in the codebase.
- WEEKS 2–4 — Turn on the e-signature that already exists. Add 'transition' and 'approve' to HIGH_RISK_COMMANDS (server/routes/c2c/actions.ts:74), route qms_change_transition through recordGovernedAction instead of auditService.logAction (AnaToolExecutor.ts:13440), and persist a signature record — printed name, UTC timestamp, signature meaning — via part11ComplianceService.createElectronicSignature on SOP approval, change approval and CAPA closure. Build the one modal the product lacks: re-enter password + select meaning + reason for change, rendered on the record. Everything needed exists (bcrypt verification at part11ComplianceService.ts:546, the re-auth gate at actions.ts:225-236); this is wiring, not invention, and it converts the single most disqualifying gap into a checkbox.
- WEEKS 4–10 — Build the deviation register, then point the AI at it. Promote the orphaned deviations table (shared/schema.ts:9737) into a real service + router modelled on changeControl.service.ts, with a state machine (open → investigation → root_cause → impact_assessed → closed) and a UI. Then wire classifyGMPDeviation's output — classification,

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					response clock, product-impact and disposition, Field Alert and recall evaluation triggers — to write into that record as an AI-proposed draft the quality unit confirms and e-signs. This is the highest-leverage work in the plan: it converts the strongest existing asset from a chat answer into the demo that no competitor can match, and it fills the largest hole in the category name simultaneously. Link the register to qms_change_links so change control finally references live deviation IDs instead of free text. 4. WEEKS 6–14 (parallel) — Make training a training system. Add qms_curricula, qms_curriculum_items and qms_training_assignments; an assignment engine that fans a curriculum out to a role and computes per-person due/overdue; a retraining scheduler driven by the expires_at column that already exists; and one export the buyer will ask for in the demo — 'every employee × every effective SOP, current or overdue, as of today.' Auto-assign on document approval so the training obligation is created by the same transaction that makes the SOP effective. Without this the product cannot answer an inspector's first question. 5. WEEKS 6–12 (parallel) — Give the existing backends doors. Register DeviceSubmission.tsx (or port its CAPA/complaint/MDR and inspection panels into the Quality shell as tabs) so the 1,022-line capaMdr service becomes reachable; add 'postmarket' to client/src/concept2cure/mdx/data/nav.ts:31-49; build minimal supplier, internal-audit and management-review tabs over the endpoints already in mdx-qms.ts; and retire the duplicate unused /api/qms router (server/routes/qms.ts) so there is one QMS API. Add real forms — create document, approve, revise, raise change, complete impact assessment — alongside the AnA path rather than replacing it. Keeping chat as the only write path is a differentiator; keeping it as the only write path is a deal-loser. 6. QUARTER 2 — Produce a QMS validation package and stop self-reporting 'not_assessed'. A VMP, IQ/OQ/PQ protocols and a Part 11 traceability matrix scoped to the QMS module (not Cortex Prime), executed against a release, plus release-by-release regression evidence and a customer-facing Part 11 / Annex 11 compliance statement. Replace the 'not_assessed' payload at part11-compliance.ts:1132-1149 with real assessed status once evidence exists — until then it is honest, and honest is disqualifying. Add a GxP procedure library (ISO 13485 / 21 CFR 820 / QMSR mapped SOP set) so time-to-value can be quoted in weeks. This needs a QA/CSV lead on payroll, not an engineer; it is the difference between shipping software and shipping a regulated system of record. 7. STRATEGIC ALTERNATIVE, worth pricing before committing to the above. Two-to-three quarters of a dedicated squad plus a QA/CSV hire buys parity in a category where the incumbent price floor is \$12K–\$36K/year (Qualio) and the differentiated asset is the reasoning engine, not the register. The higher-return path may be to package gmp-quality-systems-knowledge.ts and the 17 governed tools as an embeddable quality-intelligence layer — Veeva, Qualio and Dot all now sell AI inside their QMS and none of them derives a Field Alert Report trigger from a deviation's facts. Sell the reasoning into their validated systems rather than rebuilding their validated systems around the reasoning.

Verdict

● **Not competitive** — Weighted against the eight critical dimensions, this scores 11/40 (27%) versus a best-competitor 40/40. Across all thirteen dimensions it is 22/65 (34%) versus 58/65 (89%). It wins one dimension outright — deterministic GMP quality reasoning — ties on agentic AI, and loses or is heavily capped on everything a Head of Quality actually signs for.

Three findings independently disqualify it from this category, and any one of them ends a real procurement before the demo:

1. There is no vendor validation package, and the product says so out loud. The only IQ/OQ/PQ/VMP documents in the repo are scoped to a different subsystem, versioned 1.0.0-DRAFT, dated January 2025, and stamped "Approved By: PENDING." Meanwhile /api/part11/compliance-status returns every §11.10 section as "not_assessed" with the disclaimer "Self-assessment only" — and the shipping Part11Console renders it. Every competitor in this set answers the validation question in their first email: Veeva ships validation documentation with each release, Qualio's pre-validation package is used by 99% of customers, MasterControl holds ISO 42001 certification for AI governance on top of Part 11/Annex 11, Dot Compliance sells "pre-built and pre-validated" as the product.
2. There is no electronic signature on any quality approval. The Part 11 machinery exists and works — bcrypt second-factor re-authentication at part11ComplianceService.ts:546, a re-auth gate in the governed-action ledger — but the gate fires only for HIGH_RISK_COMMANDS = {sign, lock, revoke-signature, transmittal_rollback}, and SOP approval records command:'transition' while change-control approval bypasses the ledger entirely. An SOP goes effective on a session cookie. For a QMS this is not a gap, it is the absence of the product's defining control.
3. The category name says "SOP, CAPA, change control, deviations, training," and three of those five have no working front door. Deviations do not exist as a record type at all: the deviations table has zero routes, QC deviations and OOS return HTTP 501 NOT_IMPLEMENTED, and only GCP protocol deviations are built — so classifyGMPDeviation produces an excellent 21 CFR

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					211.192 classification with a Field Alert trigger that has nowhere to be written. Training is an acknowledgement counter with no curriculum, no role assignment, no due dates and no matrix export. CAPA is a 1,022-line service whose only UI file, DeviceSubmission.tsx, is imported by nothing. The reachability problem compounds rather than causes this. The five-destination nav collapse put 'quality' in NAV_HIDDEN, the Apps catalog seed contains no QMS module, and SEGMENT_MODULES — the map that would have listed it — is imported only by a test. But even if the module were pinned to the rail tomorrow, the evaluator would land on a read-only register that renders eight fabricated SOPs and "47 of 47" training compliance whenever the store is empty, with no visual distinction from real records. In a GxP system of record, synthetic quality data indistinguishable from real quality data is the finding, not a polish item — and it is inconsistent with the platform's own house style, since Training.tsx and Apps.tsx are explicitly fixture-free with honest empty states. What is genuinely here is not a QMS. It is a quality-reasoning engine — 2,558 lines of cited GMP logic that derives regulatory conclusions no competitor's AI derives, plus 17 tenant-scoped, audited, write-capable tools that let a model raise and transition change controls with segregation of duties enforced in code. Veeva's Deviation Agent summarises records; classifyGMPDeviation decides whether you owe FDA a Field Alert Report in three working days. That is real, defensible IP. It should be valued as an AI/knowledge asset and a candidate integration into someone else's validated eQMS — not underwritten as an eQMS that will win a competitive deal against Qualio at \$36K/year.

Regulatory document authoring & AI CO

Verdict: ● **Not competitive** Weighted capability score — **us 1.9 / 5** vs **best competitor 4.7 / 5** across 12 dimensions.

Full category as scoped: Regulatory document authoring & AI co-authoring (eCTD/CTD module, CSR, IB, protocol, narrative drafting with LLM assistance, under GxP/Part 11 governance)

Who buys, and what they are actually buying

Global Head of Medical Writing or VP Regulatory Affairs (with Reg Ops as co-signer and QA/CSV as gatekeeper). The budget is the medical-writing outsourcing line — CRO/FSP writer hours per submission, typically \$300K–\$3M/yr for a mid-cap. What they buy is: a defensible first draft of a CSR/Module 2.x/IB produced in days instead of weeks, in Word, with every claim traceable to a source, that QA will let them file. They do not buy an editor; they buy fewer contracted writer hours plus an audit story that survives an FDA inspection. The QA/CSV gate is a hard veto: no validation package, no purchase, regardless of demo quality.

Market structure

STRUCTURE — a barbell, and we sit in the empty middle. One end is the system of record: Veeva Vault RIM already holds the customer's regulatory content, workflows and validated Part 11 environment. The other end is a well-funded AI-native challenger tier: Peer AI (\$12.1M, Oct 2025, Flare Capital + SignalFire), Weave Bio (\$36M Series A, Oct 2025, USVP, following \$10M in May 2024, 59 employees as of 2026-06-30), and Ritivel (Y Combinator W26, agents drafting CTDs/CSRs/INDs/BLAs directly in Microsoft Word, sourcing from SharePoint and Veeva, founders ex-Microsoft Research AI copilots). In between sit the specialist AI writing vendors — Certara CoAuthor, Yseop Copilot, Narrativa Navigator. A platform with neither the content estate nor the capital nor a Word-native editor has no natural position on this barbell.

CONSOLIDATION VIA PARTNERSHIP, NOT M&A — the defining market dynamic. Veeva converted its two most credible competitors into channel: Yseop joined the Veeva AI Partner Program in September 2024 (Copilot ↔ Vault RIM integration for visibility, data quality and agility), and Certara joined to connect CoAuthor's generative AI to content stored in Vault RIM. The strategic consequence is that "best AI writer" is no longer a standalone category — it is a plug-in slot on Veeva's platform. Any vendor without a Vault connector is competing for a slot that has already been filled twice.

THE 2026–2027 WINDOW. Veeva's own roadmap defines the timing. Clinical/Regulatory/Medical AI Agents are slated for August 2026 and are intelligence-extraction and QC features — auto-tagging, regulatory intelligence extraction, submission-timeline prediction, labeling paragraph analysis, missing-content detection, drafting HA question responses — not full document generation. Agentic Authoring, the application that proactively drafts submittable documents natively into Vault RIM and Word when incoming data meets conditions, is expected late 2027. That leaves roughly 18 months in which the incumbent cannot demo native AI first-draft generation. Every challenger in this analysis is sprinting into that window right now.

PRICING AND DEAL SIZE. Only Veeva has usable public signal: Vault RIM baselines around \$500–\$1,000 per user per year at small scale; Veeva prices per enterprise deal with no public rate card; the "enterprise redline" is estimated near \$500K/yr of combined Vault spend, with large pharma at \$1–5M+ annually and reduced per-user rates under those deals; implementation runs \$10K–\$50K for SMB covering consulting, configuration, migration and training. Certara, Yseop, Narrativa, Peer AI and Weave Bio all publish no pricing and require a demo to obtain cost. Yseop is listed on AWS Marketplace but the listing returned 403 to automated fetch, so its terms are not verified. One third-party customer account claims Narrativa's patient-narrative automation displaced roughly \$500K of CRO spend — a proxy for the pain being displaced, not a license price, and not independently verified. Practical read: AI-native challenger ACVs are low-to-mid six figures; the specialist vendors ride existing service relationships; Veeva is the only seven-figure motion.

HOW THE DEAL IS ACTUALLY WON. Three published proof points dominate evaluations: Yseop's less-than-7%-requiring-re-authoring on a GSK CSR; Narrativa's 65,000 regulatory documents delivered with agentic AI in 2025; Peer AI's customer-reported 55–94% drafting acceleration with claimed Top 20 pharma adoption. Buyers now open conversations by asking for the number. There is no equivalent number for Concept2Cure.RI — no named customer, no measured acceptance rate, no third-party award. In a market where every vendor's demo looks similar, the published metric is the differentiator, and acquiring one is cheaper than building most of the missing features.

PROCUREMENT PATTERN. Three gates in sequence. (1) The writer gate: does it work in Word, and does it round-trip tracked changes — this is why Certara, Yseop and Ritivel all deliver through Word rather than a browser canvas. (2) The QA/CSV gate: a hard veto, where Veeva's

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					validated platform is the reference standard and the AI-natives are conspicuously silent — none of Peer AI, Weave Bio or Ritivel publishes a CSV package or Part 11 attestation, which is the one place a challenger can genuinely differentiate. (3) The IT gate: does it read from where our content already lives (Vault, SharePoint), because content migration for an unproven vendor is a non-starter. A product that fails gate 1 never reaches gates 2 and 3 — which is precisely our position, since our strength sits entirely in gate 2.
The five closest competitors					
Certara — CoAuthor (Certara.AI platform)					
The incumbent AI regulatory-writing product for medical writers — 'human-at-the-helm' drafting inside Microsoft Word, sold by the company that also sells the regulatory writing services, so it lands with existing CRO relationships.					
Strengths - Native Microsoft Word integration — writers stay in the tool they already validate, train on, and template against; zero editor-migration risk - Comprehensive eCTD writing templates spanning Modules 1–5, not a single document type - Sold alongside Certara's regulatory writing services, so the buyer can start as a service engagement and convert to software — the lowest-friction procurement path in this category - Veeva AI Partner Program integration means it reads from where the customer's content already lives rather than demanding migration - Brand trust with regulatory affairs buyers built over a decade of submission consulting					
Weaknesses - Word-bound: no strong structured/component single-source story compared to purpose-built structured content management - Client-specific GPT means per-customer tuning cost and slower time-to-value than a general agentic product - Public validation/Part 11 documentation is thin — ISO 27001 and Part 11 compliance are documented for certain modules but not explicitly confirmed for all modules on public pages (not verified) - No public pricing or self-serve motion makes it slow to evaluate for emerging biotech - Perceived as a services company selling software, which invites the 'are we buying a tool or a retainer' objection					
AI shipped today					Ships today: a life-science-specialized, client-specific GPT combined with structured content authoring and eCTD regulatory writing templates covering Modules 1–5. Marketed as AI-assisted drafting with the writer retaining control, not autonomous generation. Joined the Veeva AI Partner Program to flow content between Vault RIM and CoAuthor.
GxP / validation posture					ISO 27001 certification and 21 CFR Part 11 compliance are documented for certain modules; explicit confirmation for all modules is not on public pages. Full GxP validation documentation requires direct contact with Certara. Treat as: credible but not publicly verified end-to-end.
Pricing signal					Not public. No rate card, no per-seat or per-submission figure, no free trial or self-serve onboarding — evaluation requires a sales demo. Certara reports a 'Regulatory and Medical Writing' segment in its IR supplemental disclosures, so deal size is bundled with services engagements.
► Sources					
Yseop — Yseop Copilot (incl. 'One-Click Dossier')					
The deepest data-to-document automation in the category — starts from clinical datasets and TLFs, not from a blank page. Positions on measured re-authoring rate rather than on editor experience.					
Strengths The only competitor with a published, customer-attributed quality metric: less than 7% of generated content required re-authoring on a GSK CSR — this single number wins evaluations					

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					• True structured-data-to-narrative: table-to-text and data integration, which is where the actual writer hours are spent • Word plug-in preserves the writer's existing workflow and validated toolchain • Explicit GxP compliance, data privacy and model explainability posture aimed directly at the QA/CSV gatekeeper • Joined Veeva's AI Partner Program (Sept 2024), integrating Copilot with Vault RIM for visibility and data quality • External validation signals: 2026 BIG Innovation Award for regulatory writing with generative AI; TIME Best Inventions 2025 (Medical & Healthcare) Weaknesses • Narrow document set — heavily clinical (CSR/narrative/summary/IB/ICF); much weaker on CMC Module 3, device 510(k)/CER, and administrative Module 1 • Requires clean, standardized source data (ADaM/SDTM/TLF) to hit the headline numbers; messy sponsors get far worse results • Deployment is heavyweight — data pipeline integration, not a login • No independent third-party verification of the <7% figure; it is a single vendor-published customer case • Word plug-in means it inherits Word's weak multi-user co-authoring and governance, pushing control back to the customer's DMS
AI shipped today					Ships today: automated generation of CSR, Clinical Trial Narrative (CTN), Summary of Clinical Safety (SCS), Summary of Clinical Efficacy (SCE), Investigator's Brochure (IB) and Informed Consent Form (ICF). Generates a complete CSR first draft combining data-driven sections with reuse from approved templates. Delivered through a Microsoft Word plug-in. 'One-Click Dossier' automates data ingestion through draft creation end to end. Explicit emphasis on AI model explainability alongside accuracy and reliability.
GxP / validation posture					Publicly claims GxP compliance, data privacy controls, accuracy/reliability and AI model explainability as core product properties, and states output is validated against regulatory rules and templates. Specific IQ/OQ/PQ or CSV package contents are not public (not verified).
Pricing signal					Not public. Listed on AWS Marketplace (private-offer style listing; no public rate card retrievable — listing page returned 403 to automated fetch, so terms are not verified). Enterprise contract motion; contact-sales only.

► Sources

Veeva Systems — Vault RIM Suite + Veeva AI (Regulatory AI Agents) + Agentic Authoring

Not the best authoring tool — the tool that owns the content. Veeva already holds the customer's regulatory documents, workflows, and validated Part 11 environment, so authoring becomes a feature of the system of record rather than a separate purchase.

Strengths

- Owns the system of record — displacing Veeva means a content migration nobody wants to sponsor
- Validated, inspected, Part 11 GxP platform with a decade of customer audit history; QA sign-off is effectively pre-granted
- Incumbency in RIM, QualityDocs, eTMF and submissions publishing means one vendor, one validation, one audit trail
- Partner program converts would-be competitors (Certara, Yseop) into features, neutralizing point solutions
- Gartner Peer Insights presence and enterprise procurement familiarity shorten the buying cycle

Weaknesses

- Agentic Authoring is a late-2027 expectation, not a 2026 product — there is a real ~18-month window where Veeva cannot demo native AI first-draft generation
- AI Agents (Aug 2026) are intelligence and QC features (tagging, gap-spotting, HA response drafting), not full document generation

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
					• Cost: \$500K–\$5M+/yr enterprise deals price out emerging biotech entirely • Configuration-heavy and slow to change; every customization re-triggers validation • Partner-dependency for the highest-value capability means the customer buys two contracts and owns the integration seam
AI shipped today					Shipping/near-term: Clinical, Regulatory and Medical AI Agents slated for August 2026 — auto-tagging documents, extracting regulatory intelligence, predictive insights such as submission-timeline estimation, labeling paragraph analysis, spotting missing content, and drafting responses to health authority questions. Agentic Authoring — an application that proactively drafts submittible documents, integrates natively with Vault RIM and Microsoft Word, monitors incoming data and initiates drafting when conditions are met — is expected late 2027, i.e. NOT shipping as of 2026-07. Today the AI-authoring gap is filled by partners (Certara CoAuthor, Yseop) via the Veeva AI Partner Program.
GxP / validation posture					Strongest in the category. Vault is a validated GxP/Part 11 platform with vendor-supplied qualification documentation, release-by-release validation support (e.g. 26R2 cycle), and an extensive record of customer and regulator audits. This is the reference standard other vendors are measured against.
Pricing signal					Vault RIM baselines around \$500–\$1,000 per user per year at small scale. Veeva prices on enterprise-deal basis with no public rate card; the 'enterprise redline' is estimated around \$500K/yr combined Vault spend, and large pharma pay \$1–5M+ annually with reduced per-user rates. Implementation typically \$10K–\$50K for SMB, covering consulting, configuration, migration and training.

► Sources

Narrativa — Narrativa Navigator (Clinical Atlas · Narrative Pathway · TLF Voyager · Redaction Scout)

Agentic AI at production volume — sells throughput and traceability rather than editor experience. Aimed at teams drowning in patient narratives and TLF-to-text work.

Strengths

- Published production volume (65,000 documents in 2025) is the strongest throughput evidence in the category
- Agent decomposition (dataset → TLF → table-to-text → QA) maps to how CSR work is actually staffed, so the ROI story is legible to a writing lead
- Broadest ancillary coverage: redaction (Redaction Scout) and TLF generation are adjacent budgets other vendors ignore
- Publishes explicit guidance on validating AI-generated regulatory content — meets the QA gatekeeper on their own terms
- Expanding into adjacent verticals (veterinary regulatory with VMD Sciences), indicating a repeatable agent architecture

Weaknesses

- Weaker brand recognition with large-pharma regulatory affairs buyers than Certara or Veeva
- No published quality metric comparable to Yseop's <7% re-authoring figure
- No public pricing and no self-serve evaluation
- Positioning spread across many sub-products risks a 'suite of demos' impression versus one deep capability
- Depends on structured clinical data quality; same ceiling as Yseop without the marquee customer proof point

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
AI ship ped toda y					Ships today: specialized AI agents across the regulatory documentation lifecycle that analyze data, apply regulatory rules, generate compliant narratives and validate outputs with full traceability. Clinical Atlas automates CSR and protocol generation via agents for dataset creation, TLF generation, table-to-text conversion and QA validation. Also covers patient narratives, eCTD document generation/transformation/maintenance, redaction, and collaborative authoring. Published a delivery figure of 65,000 regulatory documents produced with agentic AI in 2025.
GxP / valid ation post ure					Publishes a public position on how to validate AI-generated regulatory content (demonstrating outputs are reliable, consistent and fit for intended use) and markets full traceability on agent outputs. A formal vendor CSV/IQ-OQ-PQ package is not public (not verified).
Prici ng sign al					Not public. One third-party customer account claims patient-narrative automation replaced roughly \$500K of CRO spend — a deal-size proxy for the pain being displaced, not a license price (single-source, not independently verified).

► Sources

Peer AI — Peer AI regulatory platform (agentic authoring + submission orchestration + query prediction)

The funded AI-native challenger — unified agentic platform spanning authoring, orchestration and regulatory-query prediction, with medical writers kept in the oversight seat. This is the company most likely to be in the same competitive bake-off as Concept2Cure.RI.

Strengths

- Customer-reported drafting acceleration of 55–94%, with claimed adoption by Top 20 pharma and emerging biotech — the most specific efficiency range published by an AI-native entrant
- Unified scope (author + orchestrate submission + predict HA queries) matches the workflow, not just the document
- Query prediction is genuinely differentiated — it moves the value from drafting speed to approval risk, which is a bigger budget
- Venture-funded and expanding fast (Oct 2025 raise, Apr 2026 platform expansion), so feature velocity outpaces incumbents
- Explicit human-oversight framing defuses the QA objection early

Weaknesses

- \$12.1M total funding is small — enterprise procurement will run vendor-viability diligence and may require escrow or a parent guarantee
- No public GxP/CSV validation package or Part 11 attestation (not verified)
- No public pricing; early-stage commercial motion means inconsistent implementation quality
- Efficiency claims are vendor-published and customer-anonymized; 55–94% is a very wide band that implies high variance
- Competing head-on with Weave Bio (\$36M Series A) for the same AI-native budget, with more capital on the other side

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
AI shipped today					Ships today: specialized AI agents automating document creation across protocols, CSRs, patient narratives, INDs, Investigator's Brochures and plain-language summaries, with writers retaining oversight and control. April 2026 expansion added real-time visibility and control across every document plus predictive intelligence that aligns submissions with regulator expectations before filing. Single unified platform for authoring, submission orchestration and query anticipation.
GxP / validation posture					Not verified. No public CSV/IQ-OQ-PQ package, Part 11 attestation or audit history located. Markets human-in-the-loop oversight and compliance maintenance as the control story rather than a formal validation deliverable.
Pricing signal					Not public. \$12.1M total funding announced October 2025, led by Flare Capital Partners and SignalFire — implies startup-scale ACVs (low six figures) and a land-and-expand motion, not enterprise-suite pricing.

► Sources

Weave Bio — Weave Bio platform / AutoIND

AI-native regulatory automation organized around the filing, not the document — single source of truth across jurisdictions, from IND/CTA through NDA. The best-capitalized AI-native challenger.

Strengths

- Best-capitalized AI-native competitor (\$36M Series A, USVP) — survives vendor-viability diligence better than peers
- eCTD-native output formatting from the start, so the draft lands in a publishable shape rather than needing reformatting
- Cross-jurisdiction single-source-of-truth architecture directly attacks the most expensive problem in global filings (reusing one dossier across FDA/EMA/PMDA)
- Covers the full arc — authoring, review, publishing, response management — rather than drafting alone
- AutoIND gives it a sharp, demonstrable wedge product for emerging biotech's first filing

Weaknesses

- Small team (59 as of mid-2026) for the breadth of scope claimed; execution risk across authoring + publishing + response management
- No public GxP/CSV validation package or Part 11 attestation located (not verified)
- No public pricing and demo-gated evaluation slows emerging-biotech adoption, its natural market
- IND-first heritage means less depth on CSR/narrative volume work where Yseop and Narrativa are strongest
- Competes with Veeva on publishing/submission management — a fight against an incumbent with a validated platform

AI shipped today					Ships today: AutoIND takes source data (study reports, lab results, prior submissions) and generates draft regulatory documents — narratives, tables, figures — formatted to eCTD standards using eCTD-formatted templates, covering authoring, review, publishing and response management. June 2026: global submission capability giving one connected platform for every filing across a program's lifecycle from a single source of truth.
GxP / validation posture					Not verified. No public CSV package, IQ/OQ/PQ documentation or Part 11 attestation located. Positions on eCTD-standard output conformance rather than on system validation.
Pricing signal					Not public; demo required to obtain cost. \$36M Series A October 2025 led by USVP (plus a prior \$10M in May 2024). 59 employees as of 2026-06-30 — implies a focused mid-market/biotech ACV, likely low-to-mid six figures.

► Sources

DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Capability rubric					
Our score is cited to <code>file:line</code> in this repository. Theirs is cited in the competitor sections above. Scored on what ships and is reachable , not what is architected — an unreachable or unvalidated capability scores low regardless of code quality.					
DIMENSION	WEIGHT	US	BEST COMPETITOR	THEIR SCORE	OUR EVIDENCE
Editor fidelity & Word round-trip (styles, tables, TOC, cross-refs, tracked changes, .docx in/out)	critical	1 ▼	Certara Co Author	5	client/src/concept2cure/v2/surfaces/DocumentAuthoring.tsx:636 — the shipped authoring canvas is a plain holding plain text (no rich text, no